

Resultados de Auditoría en Madurez TI

Auditoria al Sistema Informático Programa de Resultados Electorales Preliminares-PREP

Centro de Investigación en Matemáticas A.C.
Jalisco S/N, Col. Valenciana CP: 36240 Guanajuato, Gto,
México, Apartado Postal 402, CP 36000

T + 52 473 732 7155 / 735 0800 F +52 473 732 5749 W cimat.mx

Tabla de contenido

Información General 10

Roles de la auditoría 11

Introducción 13

Características del instrumento 14

Dominios críticos del instrumento 16

Resultados del instrumento de madurez de TI 18

Resultados de la Situación Actual – Políticas y Estrategias 19

Resultados de la Situación Actual – Organización 29

Resultados de la Situación Actual – Personas 34

Resultados de la Situación Actual – Procesos 42

Resultados de la Situación Actual – Tecnología 68

Resultados de la Situación Actual – Instalaciones 76

Resultados de la percepción del sentido de urgencia – Políticas y Estrategias 79

Resultados de la percepción del sentido de urgencia – Organización 89

Resultados de la percepción del sentido de urgencia – Personas 94

Resultados de la percepción del sentido de urgencia – Procesos 102

Resultados de la percepción del sentido de urgencia – Tecnología 128

Resultados de la percepción del sentido de urgencia – Instalaciones 136

Resultado de auditoría en sitio 142

Estrategias y Políticas 145

Organización 163

Procesos 185

Tecnologia 237

Instalaciones 251

Control de versiones 255

Aprobaciones 256

Lista de Cuadros

Cuadro 1. Clasificación de las preguntas en el instrumento 14
Cuadro 2. Escala de la percepción de la situación actual 15
Cuadro 3. Escala del sentido de urgencia 15
Cuadro 4. Plan de seguridad en TI 20
Cuadro 5. Gestión de políticas TI 21
Cuadro 6. Modelo de arquitectura de información empresarial 22
Cuadro 7. Esquema de clasificación de datos 23
Cuadro 8. Regulaciones y tendencias futuras 24
Cuadro 9. Estándares tecnológicos 25
Cuadro 10. Marco de trabajo de administración de riesgos 26
Cuadro 11. Evaluación de riesgos de TI 27
Cuadro 12. Mantenimiento y monitoreo de un plan de acción de riesgos 28
Cuadro 13. Responsabilidad sobre el riesgo, la seguridad y el cumplimiento 30
Cuadro 14. Administración de seguridad de la información 31
Cuadro 15. Propiedad de datos y sistemas 32
Cuadro 16. Segregación de funciones 33
Cuadro 17. Reclutamiento y retención del personal 35
Cuadro 18. Competencias del personal 36
Cuadro 19. Dependencia sobre los individuos 37
Cuadro 20. Procedimientos de investigación del personal 38
Cuadro 21. Cambios y terminación de trabajo 39
Cuadro 22. Transferencia de conocimiento a usuarios finales 40
Cuadro 23. Transferencia de conocimiento al personal de operaciones y soporte 41
Cuadro 24. Estándares y procedimientos para cambios 43
Cuadro 25. Evaluación de impacto, priorización y autorización 44
Cuadro 26. Ambiente de prueba 45
Cuadro 27. Pruebas de cambios 46
Cuadro 28. Promoción a producción 47
Cuadro 29. Planes de continuidad de TI 48
Cuadro 30. Pruebas del plan de continuidad de TI 49
Cuadro 31. Almacenamiento de respaldos fuera de las instalaciones 50
Cuadro 32. Respaldo y restauración 51
Cuadro 33. Acuerdos de almacenamiento y conservación 52
Cuadro 34. Requerimientos de seguridad para la administración de datos 53
Cuadro 35. Disposición 54
Cuadro 36. Repositorio y línea base de configuración 55
Cuadro 37. Identificación y mantenimiento de elementos de configuración 56
Cuadro 38. Monitoreo y reporte del cumplimento de los niveles de servicio 57
Cuadro 39. Administración de riesgos del proveedor 58

Cuadro 40. Definición de incidente de seguridad 59
Cuadro 41. Escalamiento de incidentes 60
Cuadro 42. Pruebas, vigilancia y monitoreo de la seguridad 61
Cuadro 43. Monitoreo del marco de trabajo de control interno 62
Cuadro 44. Control interno para terceros 63
Cuadro 45. Evaluación del cumplimiento con requerimientos externos 64
Cuadro 46. Aseguramiento independiente 65
Cuadro 47. Administración de identidad 66
Cuadro 48. Administración de cuentas del usuario 67
Cuadro 49. Protección y disponibilidad del recurso de infraestructura 69
Cuadro 50. Mantenimiento de la infraestructura 70
Cuadro 51. Administración de llaves criptográficas 71
Cuadro 52. Seguridad de la red 72
Cuadro 53. Intercambio de datos sensitivos 73
Cuadro 54. Prevención, detección y corrección de software malicioso 74
Cuadro 55. Protección de la tecnología de seguridad 75
Cuadro 56. Medidas de seguridad física 77
Cuadro 57. Acceso físico 78
Cuadro 58. Plan de seguridad en TI 80
Cuadro 59. Gestión de políticas TI 81
Cuadro 60. Modelo de arquitectura de información empresarial 82
Cuadro 61. Esquema de clasificación de datos 83
Cuadro 62. Regulaciones y tendencias futuras 84
Cuadro 63. Estándares tecnológicos 85
Cuadro 64. Marco de trabajo de administración de riesgos 86
Cuadro 65. Evaluación de riesgos de TI 87
Cuadro 66. Mantenimiento y monitoreo de un plan de acción de riesgos 88
Cuadro 67. Responsabilidad sobre el riesgo, la seguridad y el cumplimiento 90
Cuadro 68. Administración de seguridad de la información 91
Cuadro 69. Propiedad de datos y sistemas 92
Cuadro 70. Segregación de funciones 93
Cuadro 71. Reclutamiento y retención del personal 95
Cuadro 72. Competencias del personal 96
Cuadro 73. Dependencia sobre los individuos 97
Cuadro 74. Procedimientos de investigación del personal 98
Cuadro 75. Cambios y terminación de trabajo 99
Cuadro 76. Transferencia de conocimiento a usuarios finales 100
Cuadro 77. Transferencia de conocimiento al personal de operaciones y soporte 101
Cuadro 78. Estándares y procedimientos para cambios 103
Cuadro 79. Evaluación de impacto, priorización y autorización 104
Cuadro 80. Ambiente de prueba 105
Cuadro 81. Pruebas de cambios 106

Cuadro 82. Promoción a producción 107
Cuadro 83. Planes de continuidad de TI 108
Cuadro 84. Pruebas del plan de continuidad de TI 109
Cuadro 85. Almacenamiento de respaldos fuera de las instalaciones 110
Cuadro 86. Respaldo y restauración 111
Cuadro 87. Acuerdos de almacenamiento y conservación 112
Cuadro 88. Requerimientos de seguridad para la administración de datos 113
Cuadro 89. Disposición 114
Cuadro 90. Repositorio y línea base de configuración 115
Cuadro 91. Identificación y mantenimiento de elementos de configuración 116
Cuadro 92. Monitoreo y reporte del cumplimento de los niveles de servicio 117
Cuadro 93. Administración de riesgos del proveedor 118
Cuadro 94. Definición de incidente de seguridad 119
Cuadro 95. Escalamiento de incidentes 120
Cuadro 96. Pruebas, vigilancia y monitoreo de la seguridad 121
Cuadro 97. Monitoreo del marco de trabajo de control interno. 122
Cuadro 98. Control interno para terceros 123
Cuadro 99. Evaluación del cumplimiento con requerimientos externos 124
Cuadro 100. Aseguramiento independiente 125
Cuadro 101. Administración de identidad 126
Cuadro 102. Administración de cuentas del usuario 127
Cuadro 103. Protección y disponibilidad del recurso de infraestructura 129
Cuadro 104. Mantenimiento de la infraestructura 130
Cuadro 105. Administración de llaves criptográficas 131
Cuadro 106. Seguridad de la red 132
Cuadro 107. Intercambio de datos sensitivos 133
Cuadro 108. Prevención, detección y corrección de software malicioso 134
Cuadro 109. Protección de la tecnología de seguridad 135
Cuadro 110. Medidas de seguridad física 137
Cuadro 111. Acceso físico 138
Cuadro 112. Descripción de los dominios a auditar 143

Lista de Figuras

Figura 1. Plan de seguridad en TI 20
Figura 2. Gestión de políticas TI 21
Figura 3. Modelo de arquitectura de información empresarial 22
Figura 4. Esquema de clasificación de datos 23
Figura 5. Regulaciones y tendencias futuras 24
Figura 6. Estándares tecnológicos 25
Figura 7. Marco de trabajo de administración de riesgos 26
Figura 8. Evaluación de riesgos de TI 27
Figura 9. Mantenimiento y monitoreo de un plan de acción de riesgos 28
Figura 10. Responsabilidad sobre el riesgo, la seguridad y el cumplimiento 30
Figura 11. Administración de seguridad de la información 31
Figura 12. Propiedad de datos y sistemas 32
Figura 13. Segregación de funciones 33
Figura 14. Reclutamiento y retención del personal 35
Figura 15. Competencias del personal 36
Figura 16. Dependencia sobre los individuos 37
Figura 17. Procedimientos de investigación del personal 38
Figura 18. Cambios y terminación de trabajo 39
Figura 19. Transferencia de conocimiento a usuarios finales 40
Figura 20. Transferencia de conocimiento al personal de operaciones y soporte 41
Figura 21. Estándares y procedimientos para cambios 43
Figura 22. Evaluación de impacto, priorización y autorización 44
Figura 23. Ambiente de prueba 45
Figura 24. Pruebas de cambios 46
Figura 25. Promoción a producción 47
Figura 26. Planes de continuidad de TI 48
Figura 27. Pruebas del plan de continuidad de TI 49
Figura 28. Almacenamiento de respaldos fuera de las instalaciones 50
Figura 29. Respaldo y restauración 51
Figura 30. Acuerdos de almacenamiento y conservación 52
Figura 31. Requerimientos de seguridad para la administración de datos 53
Figura 32. Disposición 54
Figura 33. Repositorio y línea base de configuración 55
Figura 34. Identificación y mantenimiento de elementos de configuración 56
Figura 35. Monitoreo y reporte del cumplimento de los niveles de servicio 57
Figura 36. Administración de riesgos del proveedor 58
Figura 37. Definición de incidente de seguridad 59
Figura 38. Escalamiento de incidentes 60
Figura 39. Pruebas, vigilancia y monitoreo de la seguridad 61
Figura 40. Monitoreo del marco de trabajo de control interno. 62

Figura 41. Control interno para terceros 63
Figura 42. Evaluación del cumplimiento con requerimientos externos 64
Figura 43. Aseguramiento independiente 65
Figura 44. Administración de identidad 66
Figura 45. Administración de cuentas del usuario 67
Figura 46. Protección y disponibilidad del recurso de infraestructura 69
Figura 47. Mantenimiento de la infraestructura 70
Figura 48. Administración de llaves criptográficas 71
Figura 49. Seguridad de la red 72
Figura 50. Intercambio de datos sensitivos 73
Figura 51. Prevención, detección y corrección de software malicioso 74
Figura 52. Protección de la tecnología de seguridad 75
Figura 53. Medidas de seguridad física 77
Figura 54. Acceso físico 78
Figura 55. Plan de seguridad en TI 80
Figura 56. Gestión de políticas TI 81
Figura 57. Modelo de arquitectura de información empresarial 82
Figura 58. Esquema de clasificación de datos 83
Figura 59. Regulaciones y tendencias futuras 84
Figura 60. Estándares tecnológicos 85
Figura 61. Marco de trabajo de administración de riesgos 86
Figura 62. Evaluación de riesgos de TI 87
Figura 63. Mantenimiento y monitoreo de un plan de acción de riesgos 88
Figura 64. Responsabilidad sobre el riesgo, la seguridad y el cumplimiento 90
Figura 65. Administración de seguridad de la información 91
Figura 66. Propiedad de datos y sistemas 92
Figura 67. Segregación de funciones 93
Figura 68. Reclutamiento y retención del personal 95
Figura 69. Competencias del personal 96
Figura 70. Dependencia sobre los individuos 97
Figura 71. Procedimientos de investigación del personal 98
Figura 72. Cambios y terminación de trabajo 99
Figura 73. Transferencia de conocimiento a usuarios finales 100
Figura 74. Transferencia de conocimiento al personal de operaciones y soporte 101
Figura 75. Estándares y procedimientos para cambios 103
Figura 76. Evaluación de impacto, priorización y autorización 104
Figura 77. Ambiente de prueba 105
Figura 78. Pruebas de cambios 106
Figura 79. Promoción a producción 107
Figura 80. Planes de continuidad de TI 108
Figura 81. Pruebas del plan de continuidad de TI 109
Figura 82. Almacenamiento de respaldos fuera de las instalaciones 110

Figura 83. Respaldo y restauración 111
Figura 84. Acuerdos de almacenamiento y conservación 112
Figura 85. Requerimientos de seguridad para la administración de datos 113
Figura 86. Disposición 114
Figura 87. Repositorio y línea base de configuración 115
Figura 88. Identificación y mantenimiento de elementos de configuración 116
Figura 89. Monitoreo y reporte del cumplimento de los niveles de servicio 117
Figura 90. Administración de riesgos del proveedor 118
Figura 91. Definición de incidente de seguridad 119
Figura 92. Escalamiento de incidentes 120
Figura 93. Pruebas, vigilancia y monitoreo de la seguridad 121
Figura 94. Monitoreo del marco de trabajo de control interno. 122
Figura 95. Control interno para terceros 123
Figura 96. Evaluación del cumplimiento con requerimientos externos 124
Figura 97. Aseguramiento independiente 125
Figura 98. Administración de identidad 126
Figura 99. Administración de cuentas del usuario 127
Figura 100. Protección y disponibilidad del recurso de infraestructura 129
Figura 101. Mantenimiento de la infraestructura 130
Figura 102. Administración de llaves criptográficas 131
Figura 103. Seguridad de la red 132
Figura 104. Intercambio de datos sensitivos 133
Figura 105. Prevención, detección y corrección de software malicioso 134
Figura 106. Protección de la tecnología de seguridad 135
Figura 107. Medidas de seguridad física 137
Figura 108. Acceso físico 138
Figura 109. Diagrama de Dispersión Actual vs. Urgencia por Dominio 139
Figura 110. Diagrama de Dispersión Actual vs. Urgencia por Nivel de Madurez 140
Figura 111. Gráfico de Burbujas Actual vs. Urgencia por Nivel de Madurez 141
Figura 112. Auditoría en sitio 142

Información General

Nombre del Proyecto

Auditoria al Sistema Informático Programa de Resultados Electorales Preliminares - PREP.

Tipo de proyecto

Gobierno.

Breve descripción del proyecto

La Auditoria al Sistema Informático Programa de Resultados Electorales Preliminares es realizada como parte del cumplimiento a los lineamientos normativos que el Instituto Electoral del Estado de Guanajuato (IEEG) debe cubrir para la jornada electoral 2015. Los procesos a Auditar que integra el PREP son: Proceso de Configuración. Captura y Digitalización, Verificación y Publicación del PREP.

Nombre del Sistema

Sistema Informático Programa de Resultados Electorales Preliminares.

Acrónimo

PREP.

Responsable de proyecto

Ing. Erick Carrillo Werring

Roles de la auditoría

Nombre	Rol	Datos de Contacto	Email	Fecha
Equipo Técnico - Universidad de Guanajuato – UGTO.				
Dr. José Elías Rodríguez Muñoz	Director Facultad de Matemáticas-UGTO	Móvil: Oficina: 473 7320006 / Ext. 1203	elias.rodriguez@ugto.mx	30-Abril-2015
Ing. Edgar Bernal Ramírez	Líder de Auditoría – UGTO	Móvil: 3316006700	edgar@matware.com	30-Abril-2015
Ing. Carlos A. Carballo Monsiváis	Auditor Líder - UGTO	Móvil: 4731170058	carlos@matware.com	30-Abril-2015
Ing. Andrés Fajardo Hernández	Arquitecto de Software-UGTO	Móvil: 4731170058	andres@matware.com	30-Abril-2015
Ing. Mayra Uscanga Castillo	Ingeniero de Pruebas-UGTO	Móvil: 2281736001	mayra@matware.com	30-Abril-2015
Ing. Ana Lilia Jiménez Gómez	Analista de Procesos - UGTO	Móvil: 4731085563	ana@matware.com	30-Abril-2015

Nombre	Rol	Datos de Contacto	Email	Fecha
Equipo técnico - Unidad Técnica de Sistemas de Información y Telecomunicaciones (UTSIT) del Instituto Electoral del Estado de Guanajuato (IEEG)				
Ing. Erick Carrillo Werring	Director de la Unidad Técnica de Sistemas de Información y Telecomunicaciones	Móvil:473-6521092 Oficina: 473-7353000 Ext. 3902	erick.carrillo@ieeg.org.mx	30-Abril-2015
Ing. Concepción Vázquez López	Jefa del Departamento de Desarrollo de Sistemas	Oficina: 473-7353000 Ext. 3906	concepcion.vazquez@ieeg.org.mx	30-Abril-2015
Lic. Evaristo Gama Guerrero	Jefe del Departamento de Telecomunicaciones y Soporte	Oficina: 473-7353000 Ext. 3914	evaristo.gama@ieeg.org.mx	30-Abril-2015

Introducción

Para el Instituto Electoral del Estado de Guanajuato (IEEG), se diseñó un instrumento, alineado con estándares internacionales, cuyo objetivo es detectar oportunidades de mejora en Tecnologías de la Información (TI), relacionados con Sistemas Informáticos como PREP u otros futuros desarrollos de Sistemas Informáticos.

La implementación en línea se realizó con LifeSurvey versión 2.05, evaluándose seis dominios para una madurez de TI (IEEG): Políticas y Estrategias, Organización, Personas, Procesos, Tecnología e Instalaciones.

Con la finalidad de identificar áreas de oportunidad en el IEEG, se realizó una auditoría en sus instalaciones, analizando, evaluando la información y evidencia proporcionada para emitir algunas recomendaciones.

El presente documento pretende evidenciar los resultados de la encuesta de madurez TI y la evaluación de la auditoría en sitio.

Características del instrumento

El instrumento diseñado para Instituto Electoral del Estado de Guanajuato (IEEG), contiene 54 preguntas organizadas en 6 dominios. En el Cuadro 1, se presenta el número de preguntas para cada dominio.

Cuadro 1. Clasificación de las preguntas en el instrumento

Sección	Dominio	No. de preguntas
1	Políticas y Estrategias	9
2	Organización	4
3	Personas	7
4	Procesos	25
5	Tecnología	7
6	Instalaciones	2
TOTAL		54

Se dio un tiempo promedio de 180 minutos al personal para responder la encuesta. Cada pregunta tiene dos escalas de respuesta:

1. **Percepción de la situación actual:**

Es la percepción actual que el participante tiene sobre Tecnologías de Información dentro del IEEG, en relación a la pregunta.

Cuadro 2. Escala de la percepción de la situación actual

Percepción	Porcentaje
Excelente	100%
Bueno	75%
Promedio	50%
Regular	25%
Malo	0%

2. **Sentido de Urgencia:**

Es la percepción que tiene el participante sobre la urgencia, en relación a la pregunta del instrumento.

Cuadro 3. Escala del sentido de urgencia

Sentido de urgencia	Porcentaje
Extremadamente urgente	100%
Urgente	75%
Marginalmente urgente	50%
Algo urgente	25%
Nada urgente	0%

Dominios críticos del instrumento

A continuación se definen cada uno de los dominios críticos que se evalúan en el instrumento de madurez TI.

1. **Políticas y estrategias**

Proporcionar dirección y soporte a la gestión de seguridad de la información de acuerdo con los requerimientos de IEEG, los riesgos, las leyes, normatividad y reglamentos pertinentes.

2. **Organización**

Gestionar la seguridad de la información dentro de IEEG a través de una estructura integral y establecer roles y responsabilidades.

3. **Personas**

Asegurar que todos los empleados, proveedores y terceros son conscientes de las amenazas a la seguridad de la información y afectaciones, sus responsabilidades y obligaciones, y estén equipados para apoyar la política de seguridad organizativa en el curso normal de su trabajo y de reducir el riesgo de error humano.

4. **Procesos**

Asegurar que el sistema y el desarrollo de la infraestructura, mantenimiento y acceso se realiza de una forma segura, cumplir con las políticas de información, estándar, procedimientos, leyes y regulaciones. Las debilidades de seguridad de la Información y las interrupciones del negocio deben contrarrestadas adecuadamente para evitar la exposición negativa de IEEG.

5. Tecnología

Asegurar la protección de la información en la red, la protección y el soporte de la infraestructura y el intercambio seguro de información y con cualquier entidad externa.

6. Instalaciones

Prevenir la pérdida, daño, robo o el compromiso de las premisas de IEEG y la información e interrupción de las actividades de la IEEG.

Resultados del instrumento de madurez de TI

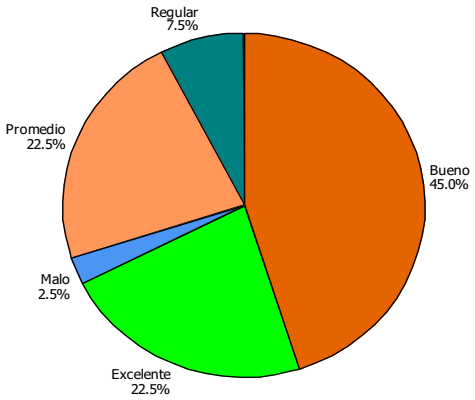
El instrumento de madurez de TI, se aplicó al personal del Instituto Electoral del Estado de Guanajuato (IEEG) del 8 al 16 de Mayo de 2015. El alcance del instrumento fue solo personal de la UTSIT. Se obtuvo una tasa de respuesta del 100% con 40 participantes en total.

En las siguientes páginas se presentan los resultados del instrumento de madurez de TI, se evalúa cada pregunta, acompañada por un gráfico de pastel, una tabla de la distribución de las respuestas y su interpretación.

Resultados de la Situación Actual – Políticas y Estrategias

1. Trasladar los requerimientos de IEEG, riesgos y cumplimiento dentro de un plan de seguridad de TI completo, teniendo en consideración la infraestructura de TI y la cultura de seguridad. Asegurar que el plan esta implementado en las políticas y procedimientos de seguridad junto con las inversiones apropiadas en los servicios, personal, software y hardware. Comunicar las políticas y procedimientos de seguridad a los interesados y a los usuarios.

Figura 1. Plan de seguridad en TI



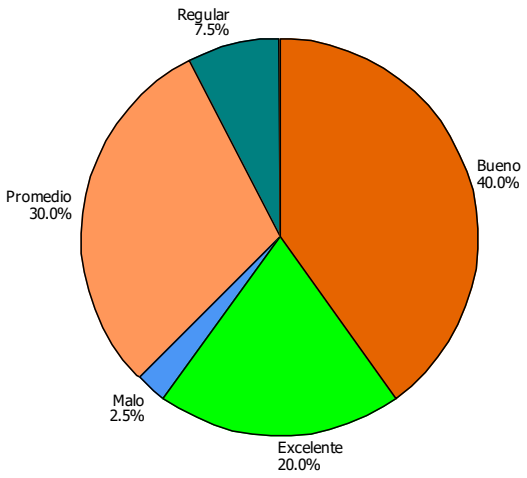
Cuadro 4. Plan de seguridad en TI

Opción		Total	Porcentaje
Excelente	100%	9	22.5
Bueno	75%	18	45.0
Promedio	50%	9	22.5
Regular	25%	3	7.5
Malo	0%	1	2.5
Total		40	100.0

Los resultados de la encuesta reflejan que un porcentaje del 45% de los encuestados considera que es bueno trasladar los requerimientos de la IEEG, riesgos y cumplimiento dentro de un Plan de Seguridad de TI. Existe un empate del 22.5% que considera que es excelente y en promedio. El 7.5% opinó que es regular y el resto, perteneciente a un 2.5%, que es malo

2. Desarrollar y mantener un grupo de políticas para soportar la estrategia de seguridad de la información; procesos de excepción; enfoque de cumplimiento; y referencias para procedimientos, estándares y directrices para el desarrollo, adquisición, mantenimiento y soporte. Su relevancia debe ser confirmada y aprobada regularmente.

Figura 2. Gestión de políticas TI



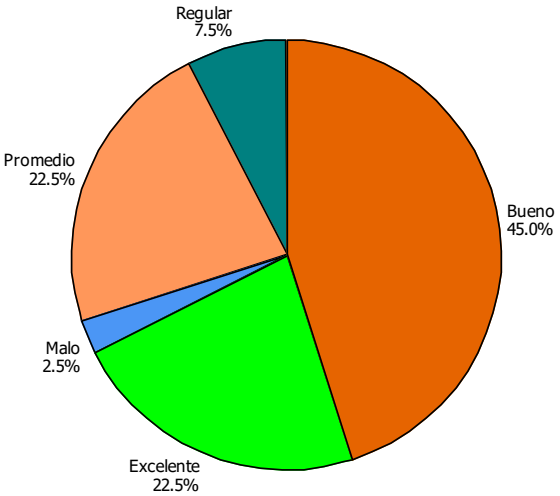
Cuadro 5. Gestión de políticas TI

		Total	Porcentaje
Excelente	100%	8	20.0
Bueno	75%	16	40.0
Promedio	50%	12	30.0
Regular	25%	3	7.5
Malo	0%	1	2.5
Total		40	100.0

Un 40% de los encuestados considera que es bueno que se desarrolle y mantenga un grupo de políticas para soportar la estrategia de Seguridad de la Información. El 30% considera que es en promedio relevante. Un 20% de encuestados lo califica como excelente. El 7.5% considera que actualmente ésta actividad es regular y el restante, el 2.5 % que es malo.

3. Establecer y mantener un modelo de información empresarial que facilite el desarrollo de aplicaciones y las actividades de soporte a la toma de decisiones, consistente con los planes de TI. El modelo debe facilitar la creación, uso y el compartir en forma óptima la información por parte de IEEG de tal manera que se mantenga su integridad, sea flexible, funcional, rentable, oportuna, segura y tolerante a fallos.

Figura 3. Modelo de arquitectura de información empresarial



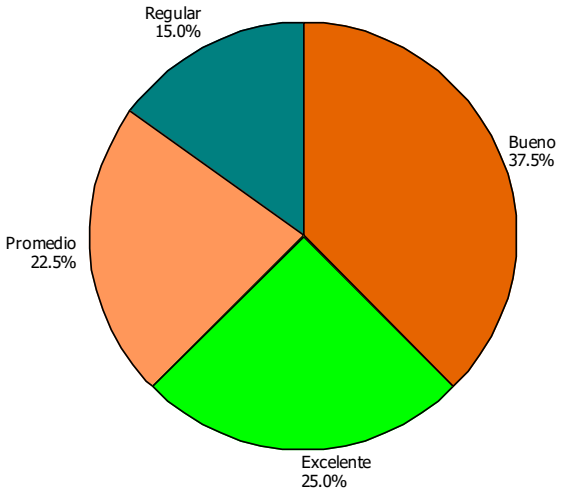
Cuadro 6. Modelo de arquitectura de información empresarial

	Total	Porcentaje
Excelente 100%	9	22.5
Bueno 75%	18	45.0
Promedio 50%	9	22.5
Regular 25%	3	7.5
Malo 0%	1	2.5
Total	40	100.0

De los resultados obtenidos se puede apreciar que el 45% de las personas encuestadas considera bueno el modelo que arquitectura de información empresarial que facilita el desarrollo de aplicaciones. Se refleja un empate del 22.5% que considera es excelente y por otra parte en promedio. El 7.5% opinó que es regular y el 2.5% lo calificó como malo.

4. Establecer un esquema de clasificación que aplique a toda IEEG, basado en que tan crítica y sensible es la información (esto es, pública, confidencial, secreta) de IEEG. Este esquema incluye detalles acerca de la propiedad de datos, la definición de niveles apropiados de seguridad y de controles de protección, y una breve descripción de los requerimientos de retención y destrucción de datos, además de que tan críticos y sensibles son. Se usa como base para aplicar controles como el control de acceso, archivo o cifrado.

Figura 4. Esquema de clasificación de datos



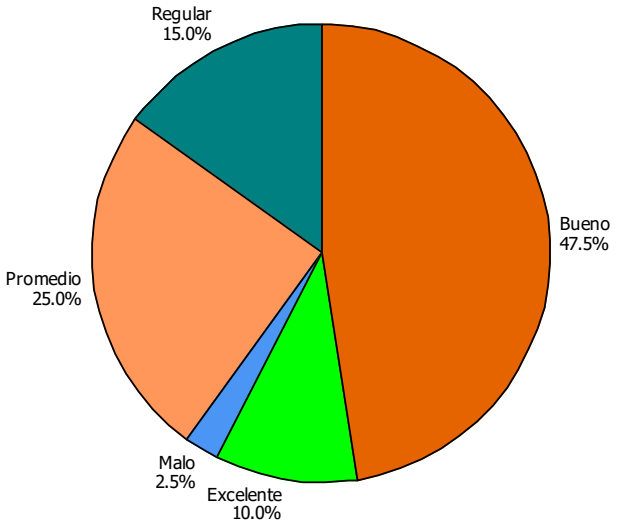
Cuadro 7. Esquema de clasificación de datos

		Total	Porcentaje
Excelente	100%	10	25.0
Bueno	75%	15	37.5
Promedio	50%	9	22.5
Regular	25%	6	15.0
Total		40	100.0

El 37.5% de las personas que contestaron la encuesta considera que es bueno su esquema de clasificación de datos. El 25% lo calificó como excelente. El 22.5% opinó que es un promedio como se realiza dicho esquema. Un 15% de encuestados indica que es regular.

5. Establecer un proceso para monitorear las tendencias ambientales del sector / industria, tecnológicas, de infraestructura, legales y regulatorias. Incluir las consecuencias de estas tendencias en el desarrollo del plan de infraestructura tecnológica de TI.

Figura 5. Regulaciones y tendencias futuras



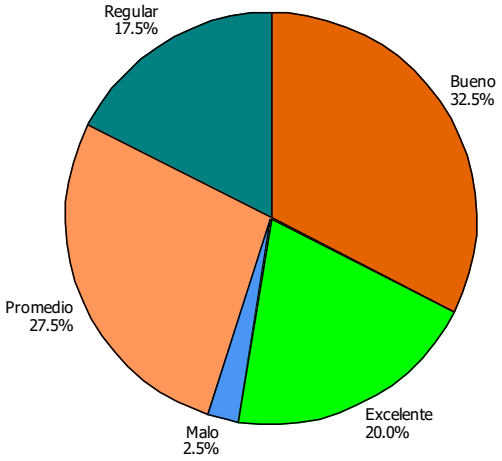
Cuadro 8. Regulaciones y tendencias futuras

		Total	Porcentaje
Excelente	100%	4	10.0
Bueno	75%	19	47.5
Promedio	50%	10	25.0
Regular	25%	6	15.0
Malo	0%	1	2.5
Total		40	100.0

En esta gráfica se observa que el 47.5% de los encuestados considera que es bueno el proceso para monitorear las tendencias ambientales del sector/industria, tecnologías, de infraestructura, etc. El 25% en promedio. El 15% de las personas opina que es regular, el 10% excelente y el resto, un 2.5%, considera que es malo.

6. Proporcionar soluciones tecnológicas consistentes, efectivas y seguras para toda IEEG, establecer un foro tecnológico para brindar directrices tecnológicas, asesoría sobre los productos de la infraestructura y guías sobre la selección de la tecnología, y medir el cumplimiento de estos estándares y directrices. Este foro impulsa los estándares y las prácticas tecnológicas con base en su importancia y riesgo para IEEG y en el cumplimiento de requerimientos externos.

Figura 6. Estándares tecnológicos



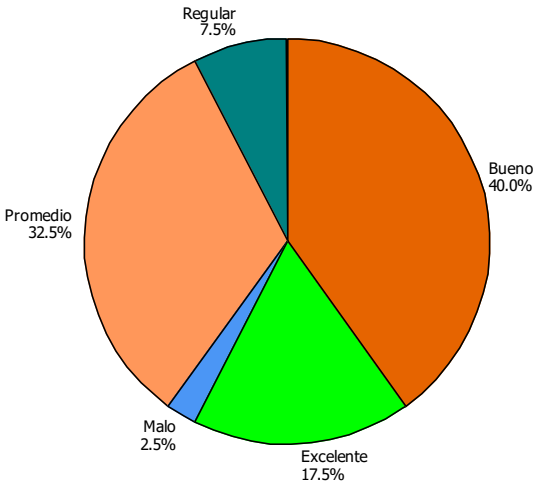
Cuadro 9. Estándares tecnológicos

		Total	Porcentaje
Excelente	100%	8	20.0
Bueno	75%	13	32.5
Promedio	50%	11	27.5
Regular	25%	7	17.5
Malo	0%	1	2.5
Total		40	100.0

El 32.5% de los participantes en la encuesta considera bueno el proporcionar soluciones tecnológicas consistentes, efectivas y seguras para la IEEG. El 27.5% lo considera como en promedio. El 20% que es excelente y 2.5% que es malo.

7. Establecer un marco de trabajo de administración de riesgo de TI que esté alineado al marco de trabajo de administración de riesgos de la organización.

Figura 7. Marco de trabajo de administración de riesgos



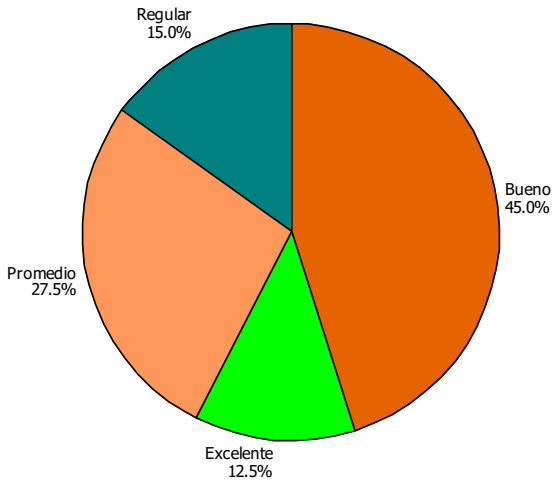
Cuadro 10. Marco de trabajo de administración de riesgos

Opción	Total	Porcentaje
Excelente 100%	7	17.5
Bueno 75%	16	40.0
Promedio 50%	13	32.5
Regular 25%	3	7.5
Malo 0%	1	2.5
Total	40	100.0

Como se puede observar en la gráfica el 40% de los encuestados considera como bueno el marco de trabajo de administración de riesgos de TI. El 32.5% considera que es promedio. El 17.5% considera que es excelente el marco de trabajo dentro de la organización. Por otra parte el 2.5% lo califica como malo.

8. Evaluar de forma recurrente la probabilidad e impacto de todos los riesgos identificados, usando métodos cualitativos y cuantitativos. La probabilidad e impacto asociados a los riesgos inherentes y residuales se debe determinar de forma individual, por categoría y con base en el portafolio.

Figura 8. Evaluación de riesgos de TI



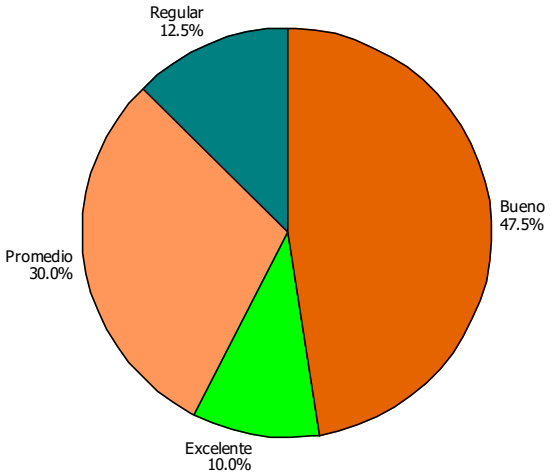
Cuadro 11. Evaluación de riesgos de TI

Opción		Total	Porcentaje
Excelente	100%	5	12.5
Bueno	75%	18	45.0
Promedio	50%	11	27.5
Regular	25%	6	15.0
Total		40	100.0

Los resultados de la encuesta muestran que el 45% de los participantes consideran que evalúan de forma recurrente la probabilidad e impacto de todos los riesgos identificados. El 27.5% que se evalúan en promedio. El 12.5% opinó que los riesgos se evalúan de forma excelente. El resto de un 15% considera que es regular.

9. Priorizar y planear las actividades de control a todos los niveles para implementar las respuestas a los riesgos, identificadas como necesarias, incluyendo la identificación de costos, beneficios y la responsabilidad de la ejecución. Obtener la aprobación para las acciones recomendadas y la aceptación de cualquier riesgo residual, y asegurarse de que las acciones comprometidas están a cargo del dueño (s) de los procesos afectados. Monitorear la ejecución de los planes y reportar cualquier desviación a la alta dirección.

Figura 9. Mantenimiento y monitoreo de un plan de acción de riesgos



Cuadro 12. Mantenimiento y monitoreo de un plan de acción de riesgos

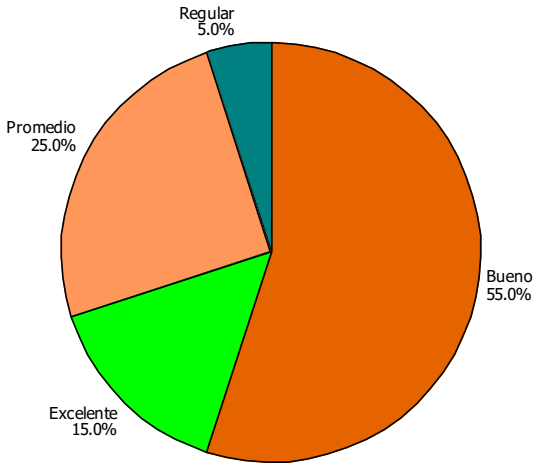
Opción		Total	Porcentaje
Excelente	100%	4	10.0
Bueno	75%	19	47.5
Promedio	50%	12	30.0
Regular	25%	5	12.5
Total		40	100.0

El 47.5% de los encuestados considera bueno el mantenimiento y monitoreo del plan de acción de riesgos. El 30% se mantiene en un promedio. El 12.5% lo califica como regular. El 10% considera que es excelente priorizar y planear las actividades de control de un plan de acción de riesgos.

Resultados de la Situación Actual – Organización

10. Establecer la propiedad y la responsabilidad de los riesgos relacionados con TI a un nivel superior apropiado. Definir y asignar roles críticos para administrar los riesgos de TI, incluyendo la responsabilidad específica de la seguridad de la información, la seguridad física y el cumplimiento. Establecer responsabilidad sobre la administración del riesgo y la seguridad a nivel de todo UTSIT para manejar los problemas a nivel de todo IEEG. Puede ser necesario asignar responsabilidades adicionales de administración de la seguridad a nivel de sistema específico para manejar problemas relacionados con seguridad. Obtener orientación de la alta dirección con respecto al apetito de riesgo de TI y la aprobación de cualquier riesgo residual de TI.

Figura 10. Responsabilidad sobre el riesgo, la seguridad y el cumplimiento



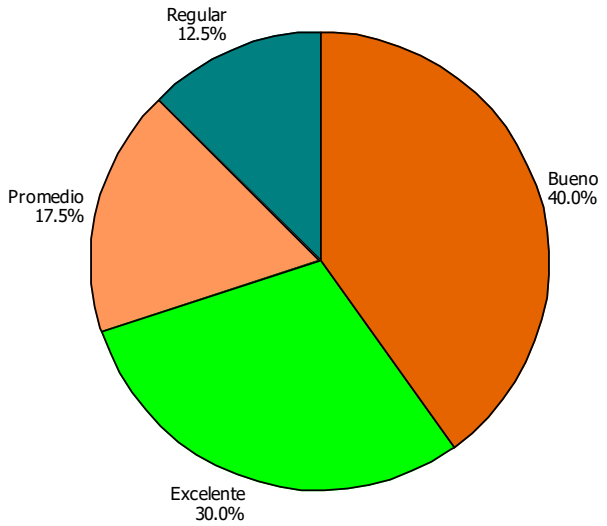
Cuadro 13. Responsabilidad sobre el riesgo, la seguridad y el cumplimiento

Opción		Total	Porcentaje
Excelente	100%	6	15.0
Bueno	75%	22	55.0
Promedio	50%	10	25.0
Regular	25%	2	5.0
Total		40	100.0

Los resultados de la encuesta reflejan que más de la mitad de los encuestados, un 55%, considera bueno que existe responsabilidad sobre el riesgo, la seguridad y el cumplimiento. El 25% opinó en promedio. El 15% que es excelente y el 5% que es regular.

11. Administrar la seguridad de TI al nivel más alto apropiado dentro de IEEG, de manera que las acciones de administración de la seguridad estén en línea con los requerimientos del negocio.

Figura 11. Administración de seguridad de la información



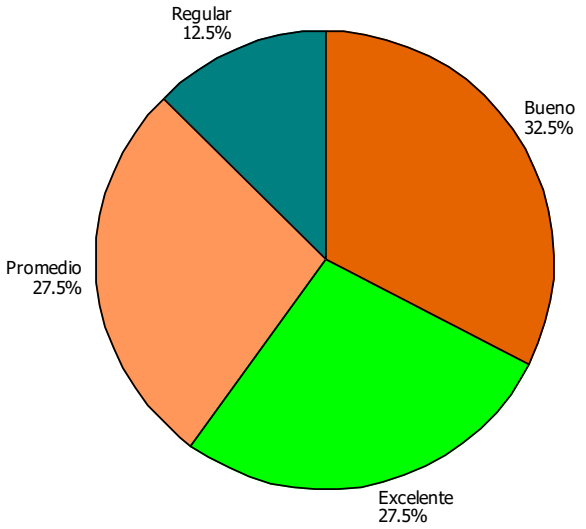
Cuadro 14. Administración de seguridad de la información

Opción	Total	Porcentaje
Excelente 100%	12	30.0
Bueno 75%	16	40.0
Promedio 50%	7	17.5
Regular 25%	5	12.5
Total	40	100.0

En la siguiente gráfica se puede observar que el 40% de los encuestados califica como bueno el administrar la seguridad de TI al nivel más alto apropiado dentro del IEEG. Seguido de un 30% que lo considera excelente. El 17.5% de las personas encuestadas opina que es en promedio y el 12.5% lo calificó como regular.

12. Proporcionar a IEEG los procedimientos y herramientas que le permitan enfrentar sus responsabilidades de propiedad sobre los datos y los sistemas de información. Los directores toman decisiones sobre la clasificación de la información de los sistemas y sobre cómo protegerlos de acuerdo a esta clasificación.

Figura 12. Propiedad de datos y sistemas



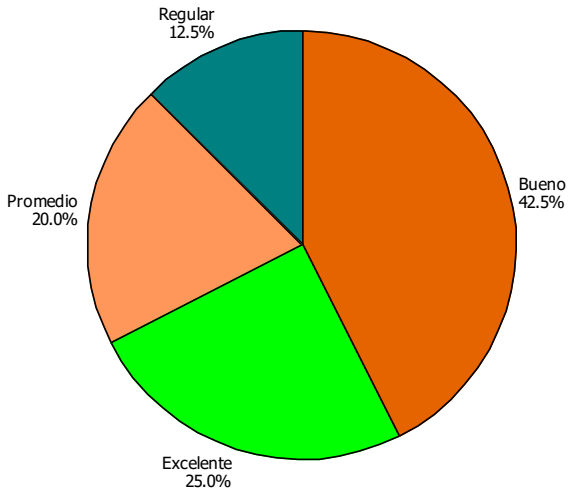
Cuadro 15. Propiedad de datos y sistemas

Opción		Total	Porcentaje
Excelente	100%	11	27.5
Bueno	75%	13	32.5
Promedio	50%	11	27.5
Regular	25%	5	12.5
Total		40	100.0

Los resultados de la encuesta reflejan que un 32.5% de los participantes califican como bueno el cómo llevan el control sobre la propiedad de datos y los sistemas de información. Seguido de un 27.5% que lo considera como en promedio empatando con el mismo porcentaje que lo considera excelente. El 12.5% opinó que es regular.

13. Implementar una división de roles y responsabilidades que reduzca la posibilidad de que un solo individuo afecte negativamente un proceso crítico. La UTSIT también se asegura de que el personal realice sólo las tareas autorizadas, relevantes a sus puestos y posiciones respectivas.

Figura 13. Segregación de funciones



Cuadro 16. Segregación de funciones

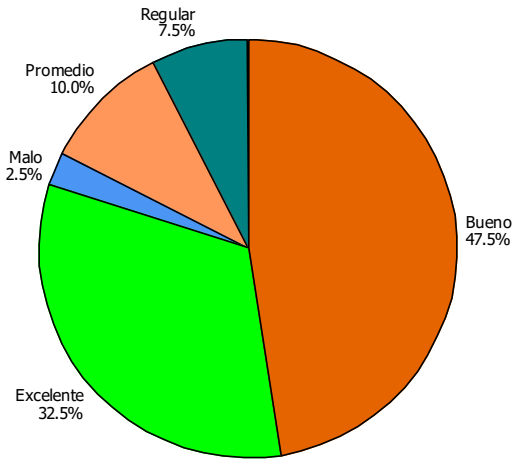
		Total	Porcentaje
Excelente	100%	10	25.0
Bueno	75%	17	42.5
Promedio	50%	8	20.0
Regular	25%	13	12.5
Total		40	100.0

De los resultados de la encuesta se obtiene que el 42.5% de las personas encuestadas califica como bueno la segregación de funciones actual. Seguido del 25% que considera es excelente. El 20% de encuestados cree que es en promedio, sin darle mayor ni menor relevancia. Finalmente, el 12.5% consideró que es regular.

Resultados de la Situación Actual – Personas

14. Asegurarse que los procesos de reclutamiento del personal de TI estén de acuerdo a las políticas y procedimientos generales de personal de IEEG (Ej. contratación, un ambiente positivo de trabajo y orientación). La UTSIT implementa procesos para garantizar que la organización cuente con una fuerza de trabajo posicionada de forma apropiada, que tenga las habilidades necesarias para alcanzar las metas organizacionales.

Figura 14. Reclutamiento y retención del personal



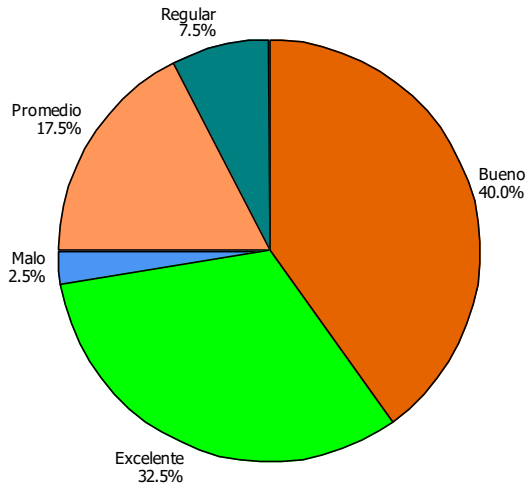
Cuadro 17. Reclutamiento y retención del personal

		Total	Porcentaje
Excelente	100%	13	32.5
Bueno	75%	19	47.5
Promedio	50%	4	10.0
Regular	25%	3	7.5
Malo	0%	1	2.5
Total		40	100.0

Cerca de la mitad de las personas encuestadas, el 47.5%, considera bueno el reclutamiento y retención del personal. El 32.5% de los participantes lo calificó como excelente, por lo cual se puede deducir que tienen un procedimiento establecido sobre el reclutamiento de personal. El 10% opinó que es en promedio. Seguido del 7.5% que considera es regular. Únicamente un 2.5% de encuestado calificó como malo el proceso de reclutamiento actual.

15. Verificar de forma periódica que el personal tenga las habilidades para cumplir sus roles con base en su educación, entrenamiento y/o experiencia. Definir los requerimientos esenciales de habilidades para TI y verificar que se les dé mantenimiento, usando programas de calificación y certificación según sea el caso.

Figura 15. Competencias del personal



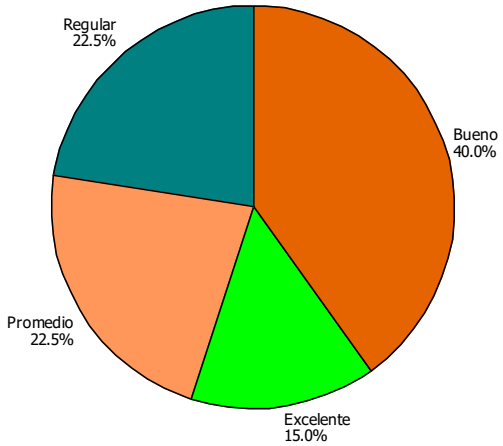
Cuadro 18. Competencias del personal

		Total	Porcentaje
Excelente	100%	13	32.5
Bueno	75%	16	40.0
Promedio	50%	7	17.5
Regular	25%	3	7.5
Malo	0%	1	2.5
Total		40	100.0

La gráfica nos muestra que un 40% de los encuestados califica como bueno las competencias del personal de la IEEG. El 32.5% las calificó como excelente. De lo anterior se puede deducir que el personal cuenta con las habilidades para cumplir sus roles en base a su experiencia o perfil. Un 17.5% considera que es en promedio. Seguido de un 7.5% que lo califica como regular. Finalmente el 2.5% considera que es malo.

16. Minimizar la exposición a dependencias críticas sobre individuos clave por medio de la captura del conocimiento (documentación), compartir el conocimiento, planeación de la sucesión y reemplazos de personal.

Figura 16. Dependencia sobre los individuos



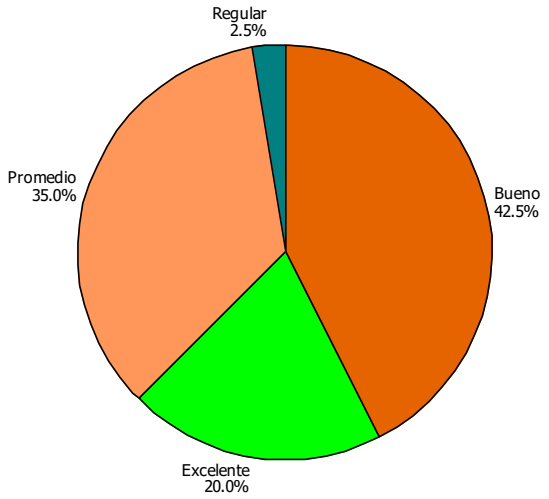
Cuadro 19. Dependencia sobre los individuos

		Total	Porcentaje
Excelente	100%	6	15.0
Bueno	75%	16	40.0
Promedio	50%	9	22.5
Regular	25%	9	22.5
Total		40	100.0

Los resultados de la encuesta demuestran que un 40% de las personas que respondieron la encuesta opina que es bueno minimizar la dependencia sobre los individuos. El 22.5% considera que es en promedio empatando con el mismo porcentaje que considera es regular. Esto nos indica que en parte las personas consideran que se puede llegar a depender de compañeros del trabajo. El 15% considera que es excelente.

17. Incluir verificaciones de antecedentes en el proceso de reclutamiento de TI. El grado y la frecuencia de estas verificaciones dependen de estas verificaciones, dependen de que tan delicada o crítica sea la función y se deben aplicar a los empleados, y proveedores.

Figura 17. Procedimientos de investigación del personal



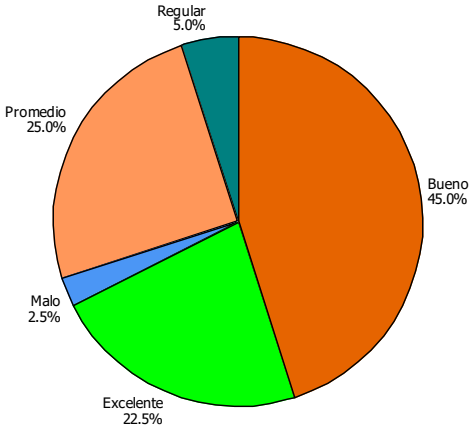
Cuadro 20. Procedimientos de investigación del personal

		Total	Porcentaje
Excelente	100%	8	20.0
Bueno	75%	17	42.5
Promedio	50%	14	35.0
Regular	25%	1	2.5
Total		40	100.0

La gráfica nos muestra que el 42.5% de los encuestados respondieron que es bueno incluir verificaciones de antecedentes en el proceso de reclutamiento de TI. Seguido del 35% que lo considera en promedio. El 20% considera como excelente el procedimiento de investigación del personal. Finalmente el 2.5% considera que es malo.

18. Tomar medidas expeditas respecto a los cambios en los puestos, en especial las terminaciones. Se debe realizar la transferencia del conocimiento, reasignar responsabilidades y se deben eliminar los privilegios de acceso, de tal modo que los riesgos se minimicen y se garantice la continuidad de la función.

Figura 18. Cambios y terminación de trabajo



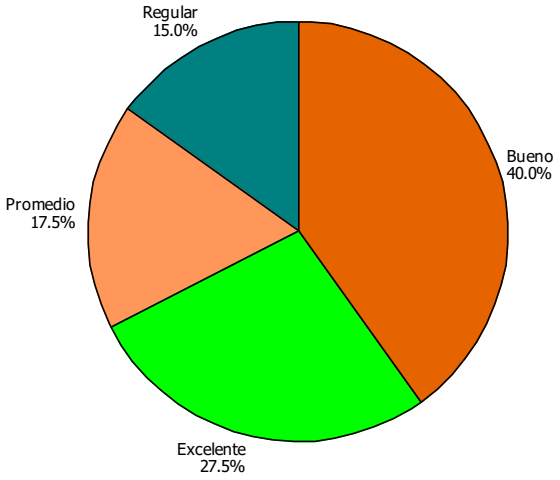
Cuadro 21. Cambios y terminación de trabajo

	Total	Porcentaje
Excelente 100%	9	22.5
Bueno 75%	18	45.0
Promedio 50%	10	25.0
Regular 25%	2	5.0
Malo 0%	1	2.5
Total	40	100.0

Los resultados de la encuesta reflejan que el 45% de las personas que participaron consideran que es bueno tomar medidas expeditas respecto a los cambios en los puestos. El 25% de los encuestados opinó que es en promedio, seguido del 22.5% que cree es excelente. El 5% considera que es regular y el 2.5% opina que es mala dicha rotación.

19. Transferencia de conocimiento y habilidades para permitir que los usuarios finales utilicen con efectividad y eficiencia el sistema de aplicación como apoyo a los procesos del IEEG. La transferencia de conocimiento incluye el desarrollo de un plan de entrenamiento que aborde al entrenamiento inicial y al continuo, así como el desarrollo de habilidades, materiales de entrenamiento, manuales de usuario, manuales de procedimiento, ayuda en línea, asistencia a usuarios, identificación del usuario clave, y evaluación.

Figura 19. Transferencia de conocimiento a usuarios finales



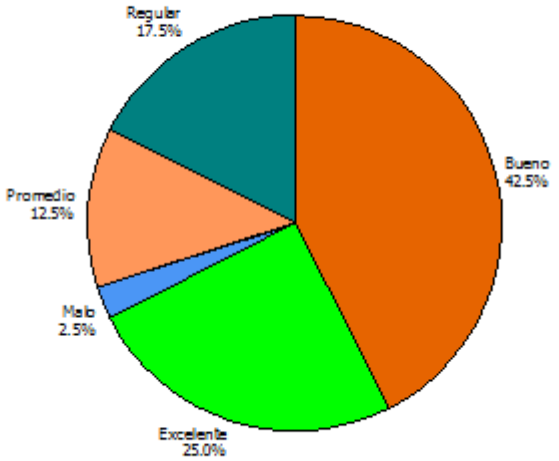
Cuadro 22. Transferencia de conocimiento a usuarios finales

		Total	Porcentaje
Excelente	100%	11	27.5
Bueno	75%	16	40.0
Promedio	50%	7	17.5
Regular	25%	6	15.0
Total		40	100.0

La gráfica refleja que un 40% de encuestados considera buena la transferencia de conocimiento a Usuarios Finales. El 27.5% opina que es excelente. Se interpreta que se considera una atención adecuada a usuarios finales. El 17.5% lo calificó como en promedio. Finalmente el 15% de los encuestados piensa que es regular.

20. Transferir el conocimiento y las habilidades para permitir al personal de soporte técnico y de operaciones que entregue, apoyen y mantenga la aplicación y la infraestructura asociada de manera efectiva y eficiente de acuerdo a los niveles de servicio requeridos. La transferencia del conocimiento debe incluir el entrenamiento inicial y continuo, el desarrollo de las habilidades, los materiales de entrenamiento, los manuales de operación, los manuales de procedimientos y escenarios de atención al usuario.

Figura 20. Transferencia de conocimiento al personal de operaciones y soporte



Cuadro 23. Transferencia de conocimiento al personal de operaciones y soporte

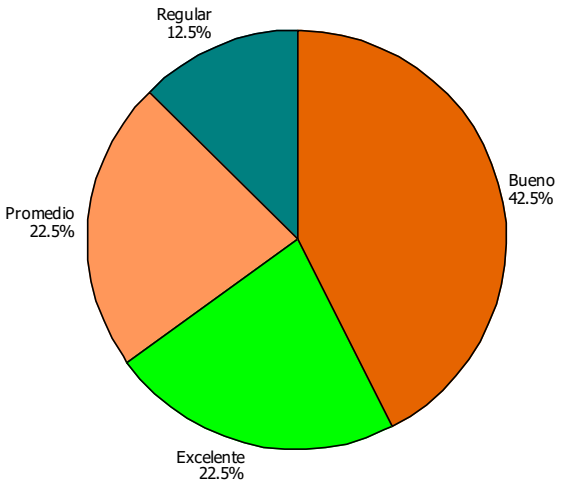
		Total	Porcentaje
Excelente	100%	10	25.0
Bueno	75%	17	42.5
Promedio	50%	5	12.5
Regular	25%	7	17.5
Malo	0%	1	2.5
Total		40	100.0

La gráfica nos muestra que el 42.5% de los encuestados consideran buena la transferencia de conocimiento al personal de operaciones y soporte. Se interpreta que existe una buena relación entre dichas áreas dado que el 25% lo calificó como excelente. El 17.5% piensa que es regular. El 12.5% lo calificó como en promedio y el 2.5% como malo.

Resultados de la Situación Actual – Procesos

21. Establecer procedimientos de administración de cambio formales para manejar de manera estándar todas las solicitudes (incluyendo mantenimiento y parches) para cambios a aplicaciones, procedimientos, procesos, parámetros de sistema y servicio, y las plataformas fundamentales.

Figura 21. Estándares y procedimientos para cambios



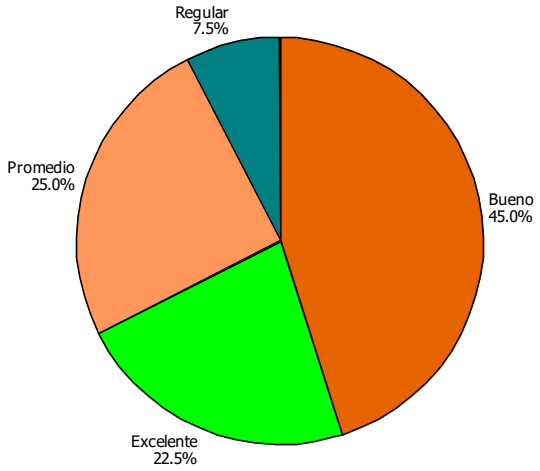
Cuadro 24. Estándares y procedimientos para cambios

	Total	Porcentaje
Excelente 100%	9	22.5
Bueno 75%	17	42.5
Promedio 50%	9	22.5
Regular 25%	5	12.5
Total	40	100.0

Los resultados de la encuesta reflejan que el 42.5% de los encuestados considera bueno establecer estándares y procedimientos para los cambios. Existe un empate del 22.5% entre los encuestados que consideraron es excelente y en promedio. El 12.5% consideró que es regular.

22. Garantizar que todas las solicitudes de cambio se evalúan de una manera estructurada en cuanto a impactos en el sistema operacional y su funcionalidad. Esta evaluación deberá incluir categorización y priorización de los cambios. Previo a la migración hacia producción, los interesados correspondientes autorizan los cambios.

Figura 22. Evaluación de impacto, priorización y autorización



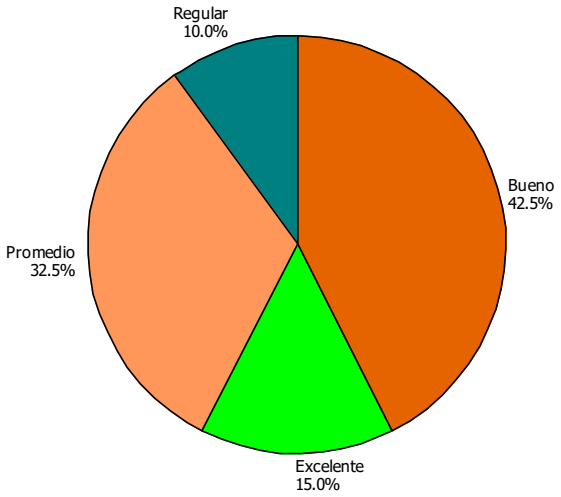
Cuadro 25. Evaluación de impacto, priorización y autorización

		Total	Porcentaje
Excelente	100%	9	22.5
Bueno	75%	18	45.0
Promedio	50%	10	25.0
Regular	25%	3	7.5
Total		40	100.0

El 45% de los participantes de la encuesta califican como bueno la evaluación de los impactos de los cambios, la priorización y autorización de los mismos. El 25% lo consideró como en promedio. El 22.5% piensa que es excelente. Finalmente el 7.5% lo calificó como malo.

23. Definir y establecer un entorno seguro de pruebas representativo del entorno de operaciones planeado relativo a seguridad, controles internos, practicas operativos, calidad de los datos y requerimientos de privacidad, y cargas de trabajo.

Figura 23. Ambiente de prueba



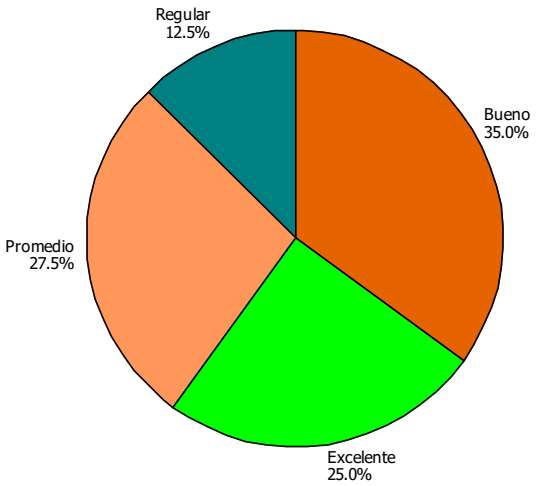
Cuadro 26. Ambiente de prueba

	Total	Porcentaje
Excelente 100%	6	15.0
Bueno 75%	17	42.5
Promedio 50%	13	32.5
Regular 25%	4	10.0
Total	40	100.0

La encuesta refleja, conforme a sus resultados, que el 42.5% de los encuestados califica como bueno el ambiente de pruebas establecido para las aplicaciones. El 32.5% considera que es en promedio, es decir, no destacan que sea bueno ni malo. El 15% opinó que es excelente y finalmente el 10% que es malo.

24. Pruebas de cambios independientemente en acuerdo con los planes de pruebas definidos antes de la migración al entorno de operaciones. Asegurar que el plan considera la seguridad y el desempeño.

Figura 24. Pruebas de cambios



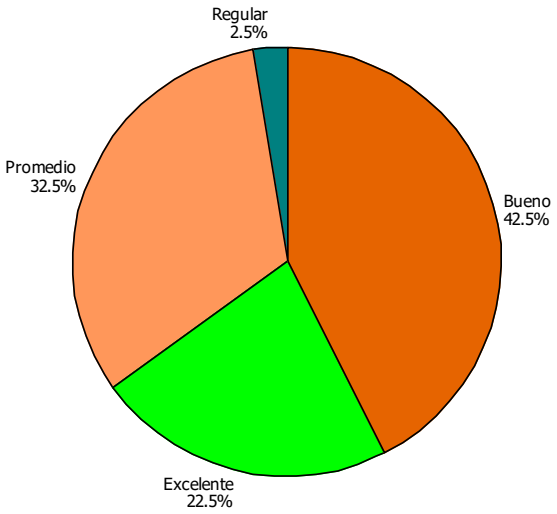
Cuadro 27. Pruebas de cambios

		Total	Porcentaje
Excelente	100%	10	25.0
Bueno	75%	14	35.0
Promedio	50%	11	27.5
Regular	25%	5	12.5
Total		40	100.0

La gráfica nos muestra que el 35% de los encuestados respondió que es bueno el cómo se llevan las pruebas de cambios. El 27.5% considera que es en promedio. El 25% opinó que es excelente y el resto, que forma parte de un 12.5% de encuestados cree que es regular.

25. Seguimiento a pruebas, controlar la entrega de los sistemas cambiados a operaciones, manteniéndolo en línea con el plan de implantación. Obtener la aprobación de los interesados clave, tales como usuarios, dueño de sistemas y gerente de operaciones. Cuando sea apropiado, ejecutar el sistema en paralelo con el viejo sistema por un tiempo, y comparar el comportamiento y los resultados.

Figura 25. Promoción a producción



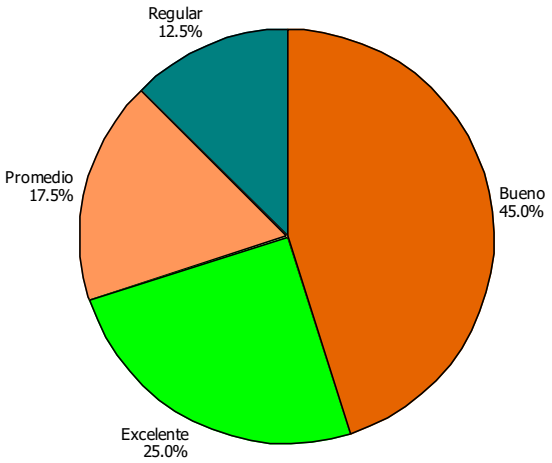
Cuadro 28. Promoción a producción

		Total	Porcentaje
Excelente	100%	9	22.5
Bueno	75%	17	42.5
Promedio	50%	13	32.5
Regular	25%	1	2.5
Total		40	100.0

Los resultados de la encuesta reflejan que un 42.5% de los participantes calificaron como bueno el ambiente de producción establecido para las aplicaciones. El 32.5% lo considera en promedio, seguido de un 22.5% que lo calificó como excelente. Finalmente el 2.5% expresó que es regular su ambiente de producción.

26. Desarrollar planes de continuidad de TI con base en el marco de trabajo, diseñado para reducir el impacto de una interrupción mayor de las funciones y los procesos clave de IEEG. Los planes deben considerar requerimientos de resistencia, procesamiento alternativo, y capacidad de recuperación de todos los servicios críticos de TI. También deben cubrir los lineamientos de uso, los roles y responsabilidades, los procedimientos, los procesos de comunicación y el enfoque de pruebas.

Figura 26. Planes de continuidad de TI



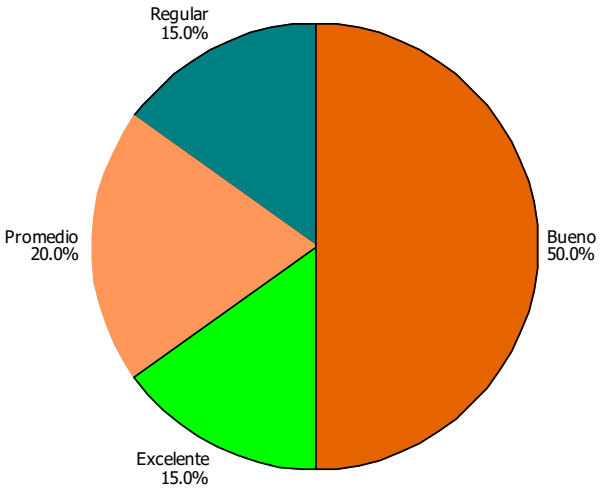
Cuadro 29. Planes de continuidad de TI

		Total	Porcentaje
Excelente	100%	10	25.0
Bueno	75%	18	45.0
Promedio	50%	7	17.5
Regular	25%	5	12.5
Total		40	100.0

La gráfica nos muestra que el 45% de los encuestados respondieron que es bueno el tener planes de continuidad de TI. Dichos planes en base a un marco de trabajo. Seguido del 25% que lo considera excelente. El 17.5% de los encuestados opina que es en promedio y el 12.5% que es regular.

27. Probar el plan de continuidad de TI de forma regular para asegurar que los sistemas de TI pueden ser recuperados de forma efectiva, que las deficiencias son atendidas y que el plan permanece aplicable. Esto requiere una preparación cuidadosa, documentación, reporte de los resultados de las pruebas y, de acuerdo con los resultados, la implementación de un plan de acción. Considerar el alcance de las pruebas de recuperación en aplicaciones individuales, en escenarios de pruebas integrados, en pruebas de punta a punta y en pruebas integradas con el proveedor.

Figura 27. Pruebas del plan de continuidad de TI



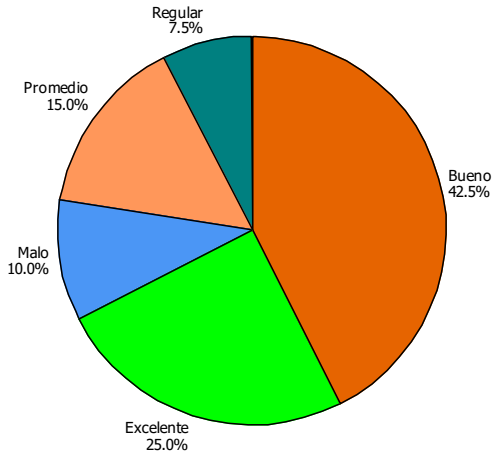
Cuadro 30. Pruebas del plan de continuidad de TI

	Total	Porcentaje
Excelente 100%	6	15.0
Bueno 75%	6	15.0
Promedio 50%	8	20.0
Regular 25%	20	50.0
Total	40	100.0

Los resultados de la encuesta reflejan que un 50% de los encuestados considera regular las pruebas del plan de continuidad de TI. Seguido de un 20% que lo considera en promedio. Existe un empate del 15% entre los encuestados que opinan es excelente y bueno. Se concluye que tienen que prestar atención a las pruebas del Plan de Continuidad de TI.

28. Almacenar fuera de las instalaciones todos los medios de respaldo, documentación y otros recursos de TI críticos, necesarios para la recuperación de TI y para los planes de continuidad del negocio. El contenido de los respaldos a almacenar debe determinarse en conjunto entre los responsables de los procesos de negocio y el personal de TI. La administración del sitio de almacenamiento externo a las instalaciones, debe apegarse a la política de clasificación de datos y a las prácticas de almacenamiento de datos de la empresa. La UTSIT de TI debe asegurar que los acuerdos con sitios externos sean evaluados periódicamente, al menos una vez por año, respecto al contenido, a la protección ambiental y a la seguridad. Asegurarse de la compatibilidad del hardware y del software para poder recuperar los datos archivados y periódicamente probar y renovar los datos archivados.

Figura 28. Almacenamiento de respaldos fuera de las instalaciones



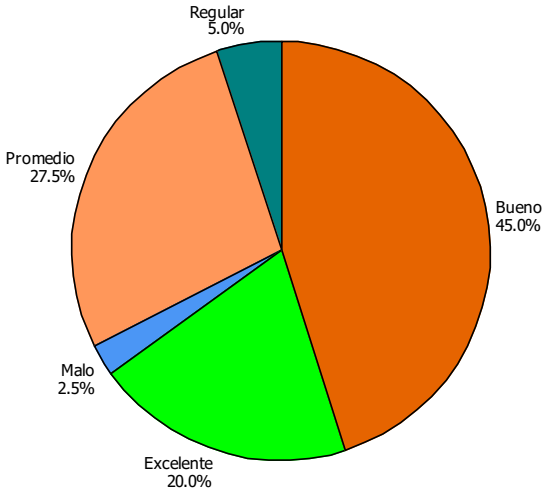
Cuadro 31. Almacenamiento de respaldos fuera de las instalaciones

	Total	Porcentaje
Excelente 100%	10	25.0
Bueno 75%	17	42.5
Promedio 50%	6	15.0
Regular 25%	3	7.5
Malo 0%	4	10.0
Total	40	100.0

La gráfica nos muestra que el 42.5% de los encuestados respondieron que es bueno almacenar fuera de las instalaciones todos los medios de respaldo, seguido del 25.0% que piensan que es excelente el almacén externo, el 15% que piensan que es en promedio, el 10.0% opinan que es malo y el 7.5% que es regular.

29. Definir e implementar procedimientos de respaldo y restauración de los sistemas, aplicaciones, datos y documentación en línea con los requerimientos de negocio y el plan de continuidad.

Figura 29. Respaldo y restauración



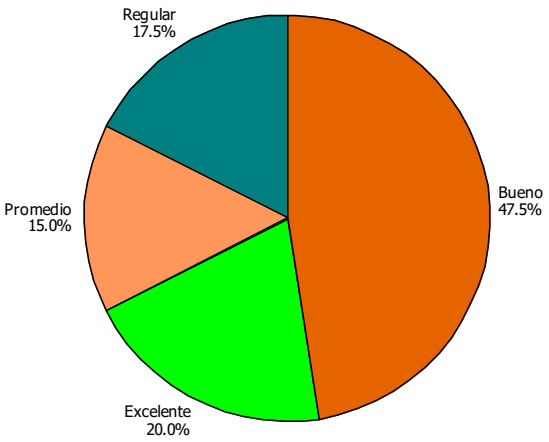
Cuadro 32. Respaldo y restauración

		Total	Porcentaje
Excelente	100%	8	20.0
Bueno	75%	18	45.0
Promedio	50%	11	27.5
Regular	25%	2	5.0
Malo	0%	1	2.5
Total		40	100.0

La gráfica nos muestra que el 45.0% de las personas opinan que es bueno definir e implementar el procedimiento de respaldo y restauración de los sistemas, seguido del 27% opinan que están definidos medianamente, el 10.0% que opinan que lo tienen en excelencia, el 5.0% en regular y 2.5% que opinan que está mal definido.

30. Definir e implementar procedimientos para el archivo, almacenamiento y retención de los datos, de forma efectiva y eficiente para conseguir los objetivos de negocio, la política de seguridad de la organización y los requerimientos regulatorios.

Figura 30. Acuerdos de almacenamiento y conservación



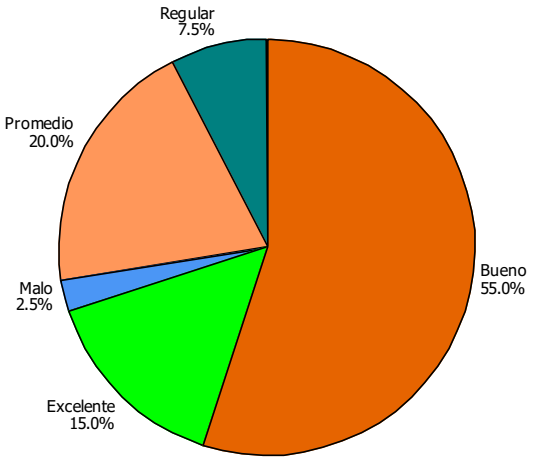
Cuadro 33. Acuerdos de almacenamiento y conservación

	Total	Porcentaje
Excelente 100%	8	20.0
Bueno 75%	19	47.5
Promedio 50%	6	15.0
Regular 25%	7	17.5
Total	40	100.0

La gráfica nos muestra que el 47.5% de las personas encuestadas opinan que es buen definir e implementar procedimientos para el archivo, almacenamiento y retención de datos, el 20.0% que opinan que estaría excelente implementar tales procedimientos, el 17.5% opinan que es malo definir estos acuerdos, y el 15.0% que es medianamente importante.

31. Definir e implementar las políticas y procedimientos para identificar y aplicar los requerimientos de seguridad aplicables al recibo, procesamiento, almacén y salida de los datos para conseguir los objetivos de negocio, las políticas de seguridad de la organización y requerimientos regulatorios.

Figura 31. Requerimientos de seguridad para la administración de datos



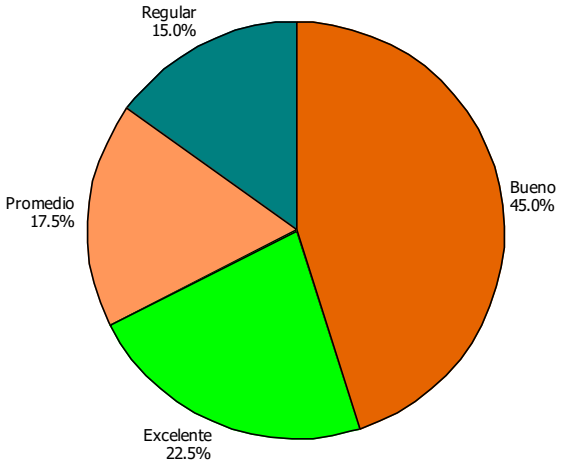
Cuadro 34. Requerimientos de seguridad para la administración de datos

	Total	Porcentaje
Excelente 100%	6	15.0
Bueno 75%	22	55.0
Promedio 50%	8	20.0
Regular 25%	3	7.5
Malo 0%	1	2.5
Total	40	100.0

La gráfica nos muestra que el 55.0% de las personas encuestadas opinan que es bueno identificar los requerimientos de seguridad aplicables, el 20.0% opinan se deben de identificar los requerimientos medianamente, el 15.0% creen que es excelente el identificar los requerimientos, el 7.5% opinan que regular y el 2.5% opinan que es malo.

32. Definir e implementar procedimientos para asegurar que los requerimientos de negocio para la protección de datos sensitivos y el software se consiguen cuando se eliminan o transfieren los datos y/o el hardware.

Figura 32. Disposición



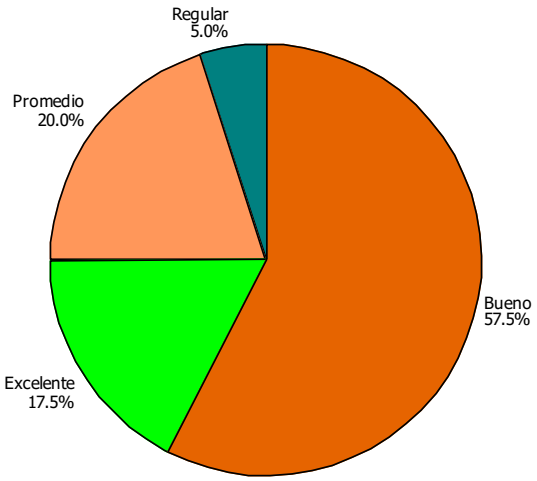
Cuadro 35. Disposición

	Total	Porcentaje
Excelente 100%	9	22.5
Bueno 75%	18	45.0
Promedio 50%	7	17.5
Regular 25%	6	15.0
Total	40	100.0

La gráfica nos muestra que el 45.0% de las personas encuestadas creen que es bueno asegurar los requerimientos del negocio para la protección de datos sensitivos y el software se consiguen cuando se eliminan o transfieren los datos, seguido del 22.5% que piensan que es excelente, el 17.5% que es en promedio y el 15.0% que es regular.

33. Establecer una herramienta de soporte y un repositorio central que contenga toda la información relevante sobre los elementos de configuración. Monitorear y grabar todos los activos y los cambios a los activos. Mantener una línea base de los elementos de la configuración para todos los sistemas y servicios como punto de comprobación al que volver tras el cambio.

Figura 33. Repositorio y línea base de configuración



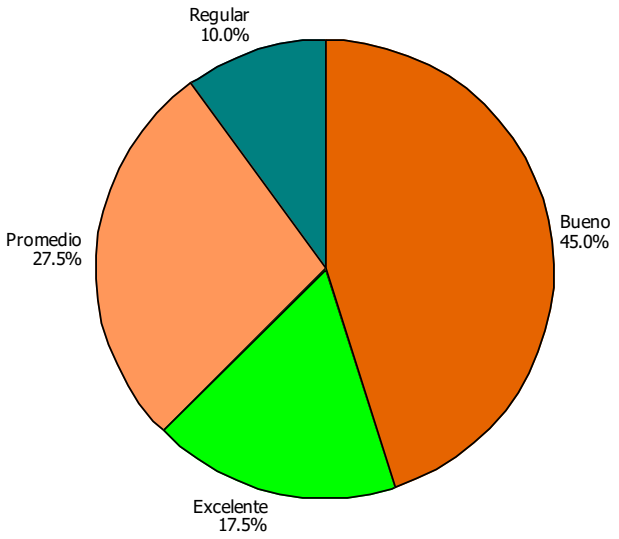
Cuadro 36. Repositorio y línea base de configuración

	Total	Porcentaje
Excelente 100%	7	17.5
Bueno 75%	23	57.5
Promedio 50%	8	20.0
Regular 25%	2	5.0
Total	40	100.0

La gráfica nos muestra que el 57.5% de las personas encuestadas opinan que es bueno establecer un repositorio y línea base de configuración, seguido del 20.0% que piensan que es un promedio, el 17.5% que es excelente y el 5.0% que piensan que es regularmente importante establecer dicho repositorio.

34. Establecer procedimientos de configuración para soportar la gestión y rastro de todos los cambios al repositorio de configuración. Integrar estos procedimientos con la gestión de cambios, gestión de incidentes y procedimientos de gestión de problemas.

Figura 34. Identificación y mantenimiento de elementos de configuración



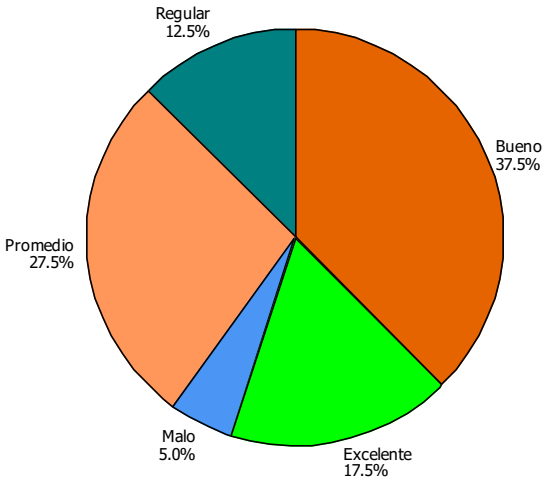
Cuadro 37. Identificación y mantenimiento de elementos de configuración

		Total	Porcentaje
Excelente	100%	7	17.5
Bueno	75%	18	45.0
Promedio	50%	11	27.5
Regular	25%	4	10.0
Total		40	100.0

La gráfica nos muestra que el 45.0% de las personas que se encuestaron opinan que es bueno establecer procedimientos para identificar y mantener los elementos de configuración, el 27.5% piensan que es mediamente importante, el 17.5% que es excelente y el 10.0% que opinan que es regular.

35. Monitorear continuamente los criterios de desempeño especificados para el nivel de servicio. Los reportes sobre el cumplimiento de los niveles de servicio deben emitirse en un formato que sea entendible para los interesados. Las estadísticas de monitoreo son analizadas para identificar tendencias positivas y negativas tanto de servicios individuales como de los servicios en conjunto.

Figura 35. Monitoreo y reporte del cumplimento de los niveles de servicio



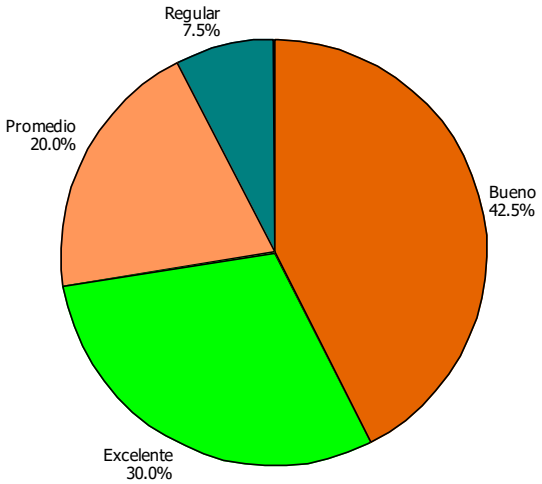
Cuadro 38. Monitoreo y reporte del cumplimento de los niveles de servicio

	Total	Porcentaje
Excelente 100%	7	17.5
Bueno 75%	15	37.5
Promedio 50%	11	27.5
Regular 25%	5	12.5
Malo 0%	2	5.0
Total	40	100.0

La gráfica nos muestra que el 37.5% de las personas que se encuestaron piensan que es bueno monitorear y reportar continuamente el cumplimiento de los niveles de servicio, seguido del 27.5% que creen que es un promedio, el 17.5% que es excelente, el 12.5% que es regular y el 5.0% opinan que es malo.

36. Identificar y mitigar los riesgos relacionados con la habilidad de los proveedores para mantener un efectivo servicio de entrega de forma segura y eficiente sobre una base de continuidad. Asegurar que los contratos están de acuerdo con los requerimientos legales y regulatorios de los estándares universales del negocio. La administración del riesgo debe considerar además acuerdos de confidencialidad (NDAs), contratos de garantía, viabilidad de la continuidad del proveedor, conformidad con los requerimientos de seguridad, proveedores alternativos, penalizaciones e incentivos, etc.

Figura 36. Administración de riesgos del proveedor



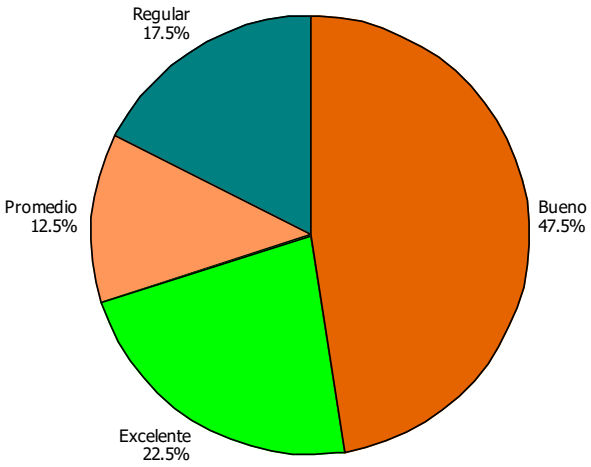
Cuadro 39. Administración de riesgos del proveedor

		Total	Porcentaje
Excelente	100%	12	30.0
Bueno	75%	17	42.5
Promedio	50%	3	7.5
Regular	25%	8	20.0
Total		40	100.0

La gráfica nos muestra que el 42.5% de los encuestados respondieron como buena la administración de riesgos del proveedor, con un 30.0% los que creen que es excelente, el 20.0% consideran que es regular y con un 7.5% los que piensan que es promedio.

37. Definir claramente y comunicar las características de incidentes de seguridad potenciales para que puedan ser clasificados propiamente y tratados por el proceso de gestión de incidentes y problemas.

Figura 37. Definición de incidente de seguridad



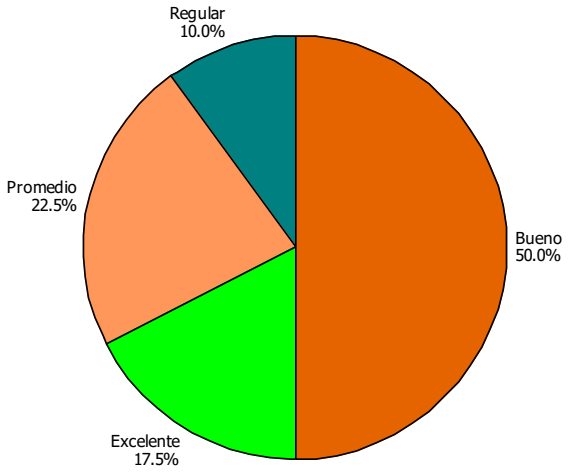
Cuadro 40. Definición de incidente de seguridad

	Total	Porcentaje
Excelente 100%	9	22.5
Bueno 75%	7	17.5
Promedio 50%	5	12.5
Regular 25%	19	47.5
Total	40	100.0

La gráfica nos muestra que el 47.5% de las personas encuestadas opinan que es regularmente importante definir los incidentes de seguridad, seguido del 22.5% que es excelente definir tales incidentes, el 17.5% piensan que es bueno y el 12.5% que es un promedio.

38. Establecer procedimientos de mesa de servicios de manera que los incidentes que no puedan resolverse de forma inmediata sean escalados apropiadamente de acuerdo con los límites acordados en el SLA y, si es adecuado, brindar soluciones alternas. Garantizar que la asignación de incidentes y el monitoreo del ciclo de vida permanecen en la mesa de servicios, independientemente de qué grupo de TI trabajando en las actividades de resolución.

Figura 38. Escalamiento de incidentes



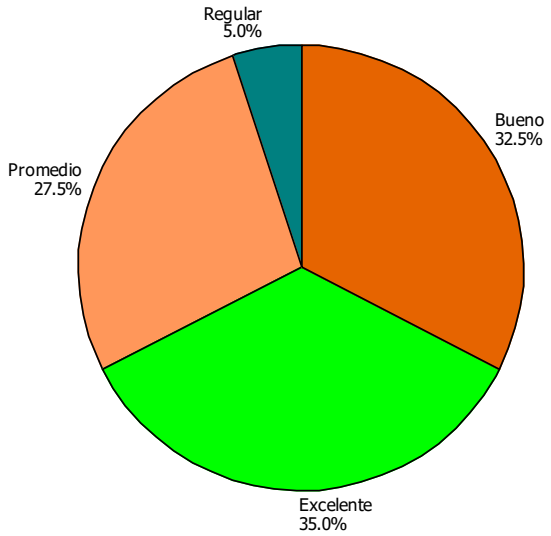
Cuadro 41. Escalamiento de incidentes

	Total	Porcentaje
Excelente 100%	7	17.5
Bueno 75%	20	50.0
Promedio 50%	9	22.5
Regular 25%	4	10.0
Total	40	100.0

La gráfica nos muestra que el 50.0% de las personas encuestadas creen que es bueno establecer una mesa de servicios de manera que los incidentes puedan resolverse de forma escalada y brindar soluciones alternas, seguido del 22.5% que creen que es un promedio, el 17.5% que es excelente, el 100% que es regular.

39. Garantizar que la implementación de la seguridad en TI sea probada y monitoreada de forma pro-activa. La seguridad en TI debe ser reacreditada periódicamente para garantizar que se mantiene el nivel seguridad aprobado. Una función de ingreso al sistema (logging) y de monitoreo permite la detección oportuna de actividades inusuales o anormales que pueden requerir atención.

Figura 39. Pruebas, vigilancia y monitoreo de la seguridad



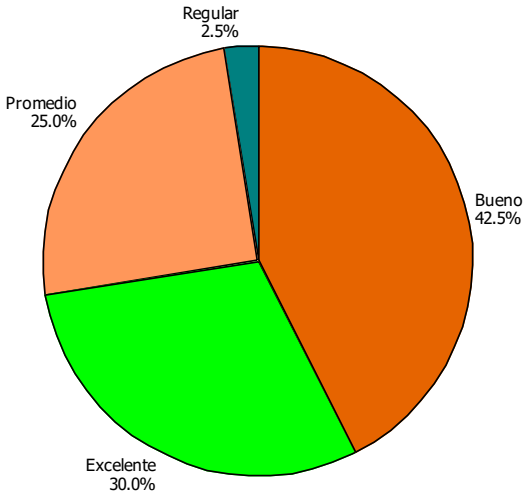
Cuadro 42. Pruebas, vigilancia y monitoreo de la seguridad

		Total	Porcentaje
Excelente	100%	14	35.0
Bueno	75%	13	32.5
Promedio	50%	11	27.5
Regular	25%	2	5.0
Total		40	100.0

La gráfica nos muestra que el 35.0% de las personas encuestadas opinan que es excelente garantizar la implementación de la seguridad en TI para que sea aprobada, vigilada y monitoreada, seguida del 32.5% que dicen que es bueno, el 27.5 que es un promedio y el 5.0% que es regular.

40. Monitorear de forma continua, comparar y mejorar el ambiente de control de TI y el marco de trabajo de control de TI para satisfacer los objetivos organizacionales.

Figura 40. Monitoreo del marco de trabajo de control interno.



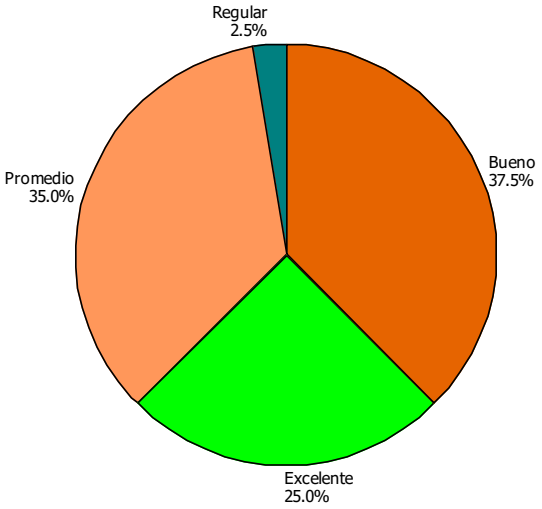
Cuadro 43. Monitoreo del marco de trabajo de control interno

		Total	Porcentaje
Excelente	100%	12	30.0
Bueno	75%	17	42.5
Promedio	50%	10	25.0
Regular	25%	1	2.5
Total		40	100.0

La gráfica nos muestra que el 42.5% de las personas encuestadas creen que es bueno el monitorear de forma continua el marco de trabajo de control interno, seguido del 30.0% que opinan que es excelente, el 25.0% que es promedio y el 2.5% que es regular.

41. Evaluar el estado de los controles internos de los proveedores de servicios externos. Confirmar que los proveedores de servicios externos cumplen con los requerimientos legales y regulatorios y obligaciones contractuales.

Figura 41. Control interno para terceros



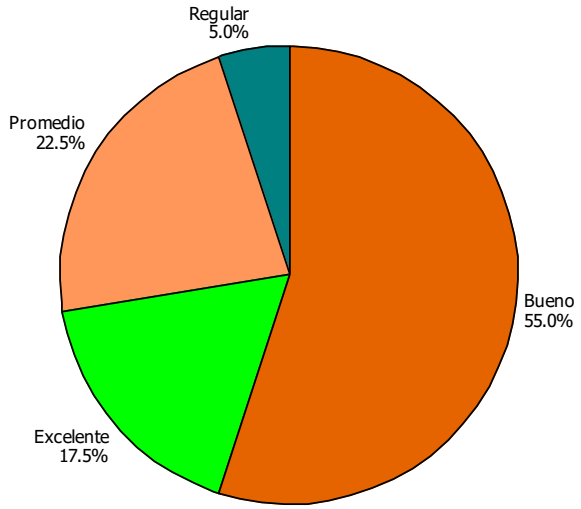
Cuadro 44. Control interno para terceros

		Total	Porcentaje
Excelente	100%	10	25.0
Bueno	75%	15	37.5
Promedio	50%	14	35.0
Regular	25%	1	2.5
Total		40	100.0

La gráfica nos muestra que el 37.5% de las personas encuestadas opinan que es bueno evaluar el control interno de los proveedores de servicios externos, seguido del 35.0% que opinan que es promedio, el 25.0% opinan que es excelente y el 2.5% que es regular.

42. Confirmar el cumplimiento de políticas, estándares, procedimientos y metodologías de TI con requerimientos legales y regulatorios.

Figura 42. Evaluación del cumplimiento con requerimientos externos



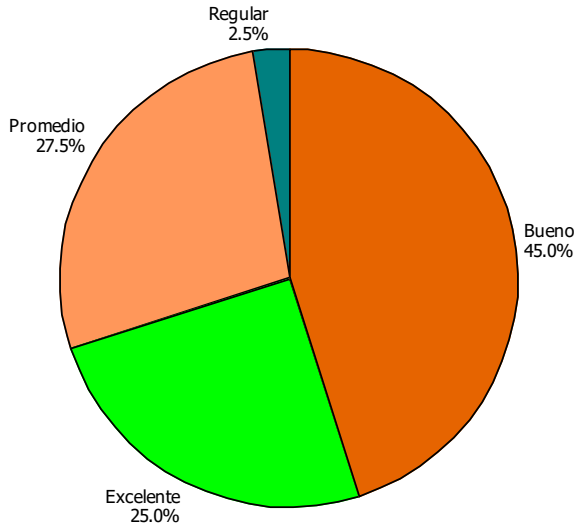
Cuadro 45. Evaluación del cumplimiento con requerimientos externos

		Total	Porcentaje
Excelente	100%	7	17.5
Bueno	75%	22	55.0
Promedio	50%	9	22.5
Regular	25%	2	5.0
Total		40	100.0

La gráfica nos muestra que el 55.0% de las personas encuestadas opinan que es bueno confirmar el cumplimiento con los requerimientos externos, seguido del 22.5% que creen que es en promedio, el 17.5% que es excelente y el 5.0% que es regular.

43. Garantizar de forma independiente (interna o externa) la conformidad de TI con la legislación y regulación relevante; las políticas de la organización, estándares y procedimientos; prácticas generalmente aceptadas; y la efectividad y eficiencia del desempeño de TI.

Figura 43. Aseguramiento independiente



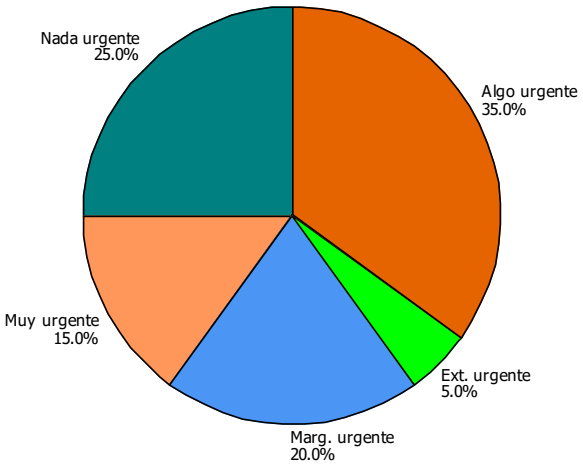
Cuadro 46. Aseguramiento independiente

		Total	Porcentaje
Excelente	100%	10	25.0
Bueno	75%	18	45.0
Promedio	50%	11	27.5
Regular	25%	1	2.5
Total		40	100.0

La gráfica nos muestra que el 45.0% de las personas que se encuestaron opinan que es bueno garantizar de forma independiente la conformidad de TI con la legislación y regulación relevante, seguido del 27.5% de las personas que creen que es un promedio, el 25.0% que es excelente y el 2.5% que es regular.

44. Asegurar que todos los usuarios (internos, externos y temporales) y su actividad en sistemas de TI (aplicación de negocio, entorno de TI, operación de sistemas, desarrollo y mantenimiento) deben ser identificables de manera única. Permitir que el usuario se identifique a través de mecanismos de autenticación. Confirmar que los permisos de acceso del usuario al sistema y los datos están en línea con las necesidades del negocio definidas y documentadas y que los requerimientos de trabajo están adjuntos a las identidades del usuario. Asegurar que los derechos de acceso del usuario se solicitan por la UTSIT del usuario, aprobados por el responsable del sistema e implementado por la persona responsable de la seguridad. Las identidades del usuario y los derechos de acceso se mantienen en un repositorio central. Se despliegan técnicas efectivas en coste y procedimientos rentables, y se mantienen actualizados para establecer la identificación del usuario, realizar la autenticación y habilitar los derechos de acceso.

Figura 44. Administración de identidad



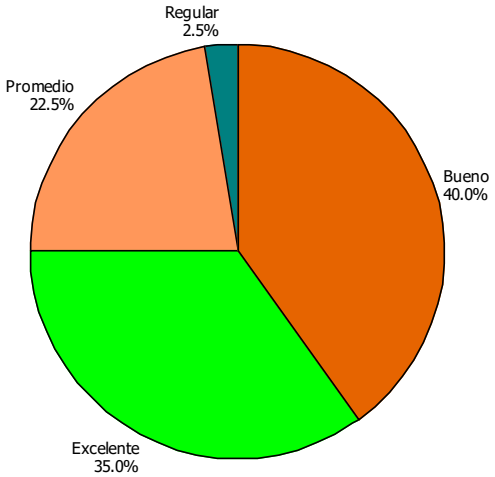
Cuadro 47. Administración de identidad

	Total	Porcentaje
Excelente 100%	12	30.0
Bueno 75%	17	42.5
Promedio 50%	10	25.0
Regular 25%	1	2.5
Total	40	100.0

La gráfica nos muestra que el 42.5% de las personas encuestadas opinan que bueno que todos los usuario y su actividad en sistemas de TI sean identificables de la misma manera, seguido del 30.0% que creen que es excelente, el 25.0% que es en promedio y el 2.5% que es regular.

45. Garantizar que la solicitud, establecimiento, emisión, suspensión, modificación y cierre de cuentas de usuario y de los privilegios relacionados, sean tomados en cuenta por un conjunto de procedimientos de la gerencia de cuentas de usuario. Debe incluirse un procedimiento de aprobación que describa al responsable de los datos o del sistema otorgando los privilegios de acceso. Estos procedimientos deben aplicarse a todos los usuarios, incluyendo administradores (usuarios privilegiados), usuarios externos e internos, para casos normales y de emergencia. Los derechos y obligaciones relativos al acceso a los sistemas e información de la empresa deben acordarse contractualmente para todos los tipos de usuarios. Realizar revisiones regulares de la gestión de todas las cuentas y los privilegios asociados.

Figura 45. Administración de cuentas del usuario



Cuadro 48. Administración de cuentas del usuario

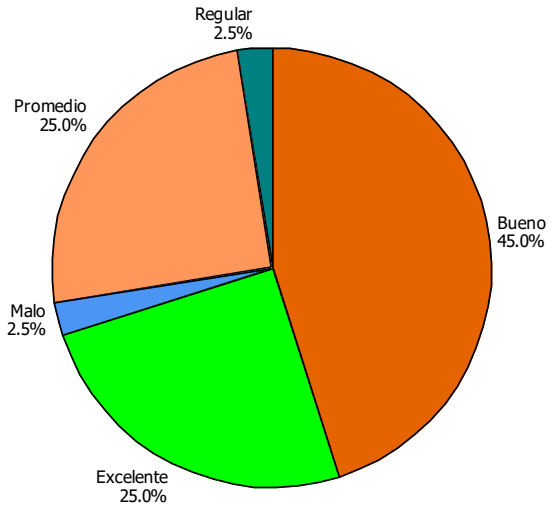
	Total	Porcentaje
Excelente 100%	14	35.0
Bueno 75%	16	40.0
Promedio 50%	9	22.5
Regular 25%	1	2.5
Total	40	100.0

La gráfica nos muestra que el 40.0% de las personas encuestadas opinan que es bueno que sean tomados en cuenta los procedimientos de la gerencia de cuentas de usuario, seguido del 35.0% que creen que es excelente, el 22.5% dice que es un promedio y el 2.5% que es regular.

Resultados de la Situación Actual – Tecnología

46. Implementar medidas de control interno, seguridad y auditabilidad durante la configuración, integración y mantenimiento del hardware y del software de la infraestructura para proteger los recursos y garantizar su disponibilidad e integridad. Se deben definir y comprender claramente las responsabilidades al utilizar componentes de infraestructura sensitivos por todos aquellos que desarrollan e integran los componentes de infraestructura. Se debe monitorear y evaluar su uso.

Figura 46. Protección y disponibilidad del recurso de infraestructura



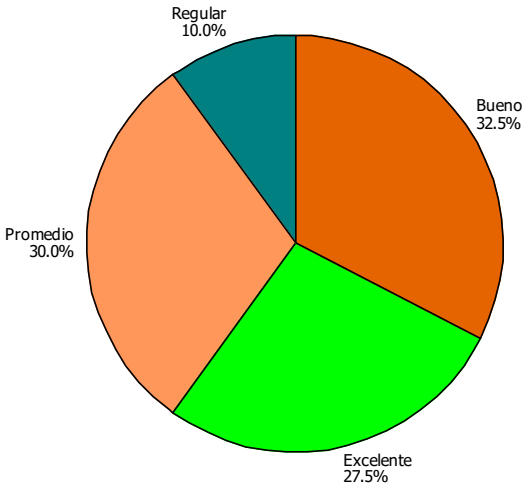
Cuadro 49. Protección y disponibilidad del recurso de infraestructura

		Total	Porcentaje
Excelente	100%	10	25.0
Bueno	75%	18	45.0
Promedio	50%	10	25.0
Regular	25%	1	2.5
Malo	0%	1	2.5
Total		40	100.0

La gráfica nos muestra que el 45.0% de las personas encuestadas opinan que es bueno implementar medidas de control para proteger los recursos y garantizar su disponibilidad e integridad de protección y disponibilidad de recursos de infraestructura, seguido de un 25.0% que opinan que es excelente y otro 25.0% que es un promedio, otro 2.5% que opina que es regular y 2.5% que es malo.

47. Desarrollar una estrategia y un plan de mantenimiento de la infraestructura y garantizar que se controlan los cambios, de acuerdo con el procedimiento de administración de cambios de la organización. Incluir una revisión periódica contra las necesidades del negocio, administración de parches y estrategias de actualización, riesgos, evaluación de vulnerabilidades y requerimientos de seguridad.

Figura 47. Mantenimiento de la infraestructura



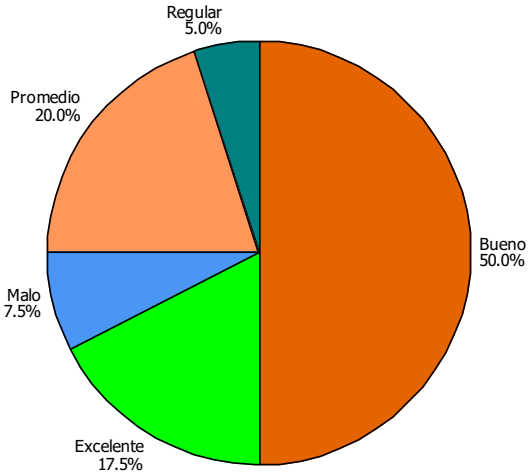
Cuadro 50. Mantenimiento de la infraestructura

	Total	Porcentaje
Excelente 100%	11	27.5
Bueno 75%	13	32.5
Promedio 50%	12	30.0
Regular 25%	4	10.0
Total	40	100.0

La gráfica nos muestra que el 32.5% de las personas encuestadas opinan que es bueno desarrollar una estrategia y un plan de mantenimiento de la infraestructura, seguido del 30.0% de las personas que opinan que es un promedio, el 27.5% que es excelente y el 10.0% que es regular.

48. Determinar que las políticas y procedimientos para organizar la generación, cambio, revocación, destrucción, distribución, certificación, almacenamiento, captura, uso y archivo de llaves criptográficas estén implantadas, para garantizar la protección de las llaves contra modificaciones y divulgación no autorizadas.

Figura 48. Administración de llaves criptográficas



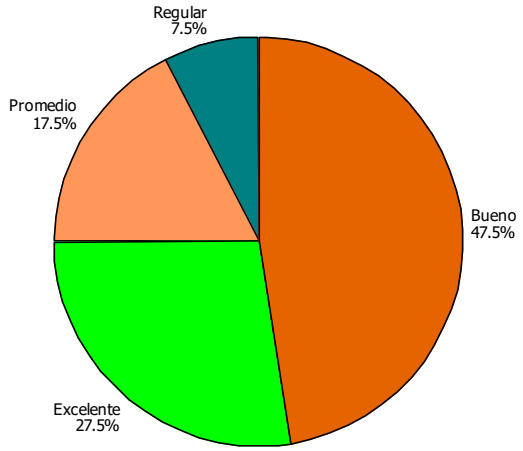
Cuadro 51. Administración de llaves criptográficas

	Total	Porcentaje
Excelente 100%	7	17.5
Bueno 75%	20	50.0
Promedio 50%	8	20.0
Regular 25%	2	5.0
Malo 0%	3	7.5
Total	40	100.0

La gráfica nos muestra que el 50.0% de las personas encuestadas opinan que es bueno determinar las políticas y procedimientos en la administración de llaves criptográficas, seguido del 20.0% que opinan que es un promedio, el 17.5% de las personas creen que es excelente, el 7.5% que es malo y sólo el 5.0% piensan que es regular.

49. Uso de técnicas de seguridad y procedimientos de administración asociados (por ejemplo, firewalls, dispositivos de seguridad, segmentación de redes, y detección de intrusos) para autorizar acceso y controlar los flujos de información desde y hacia las redes.

Figura 49. Seguridad de la red



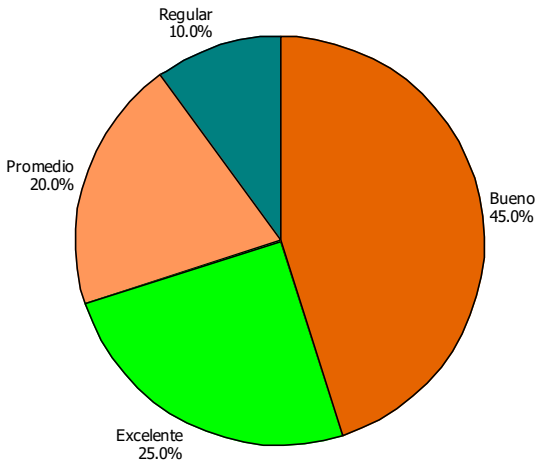
Cuadro 52. Seguridad de la red

	Total	Porcentaje
Excelente 100%	11	27.5
Bueno 75%	19	47.5
Promedio 50%	7	17.5
Regular 25%	3	7.5
Total	40	100.0

La gráfica nos muestra que el 47.5% de las personas encuestadas opinan que es bueno el uso de seguridad y procedimientos de administración de la red, seguido del 27.5% de las personas que creen que es excelente, el 17.5% que es un promedio y el 7.5% que es regular.

50. Transacciones de datos sensibles (confidenciales) se intercambian solo a través de una ruta o medio con controles para proporcionar autenticidad de contenido, prueba de envío, prueba de recepción y no repudio del origen.

Figura 50. Intercambio de datos sensitivos



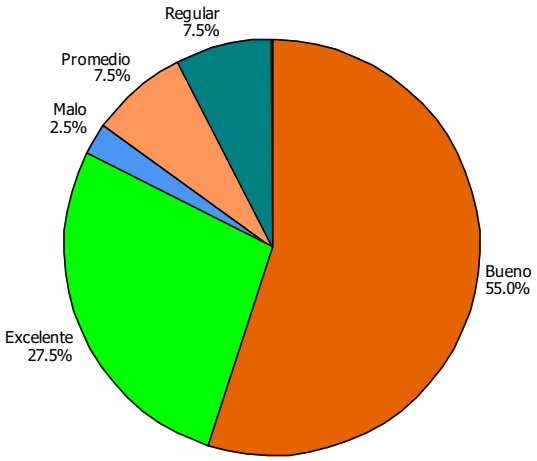
Cuadro 53. Intercambio de datos sensitivos

	Total	Porcentaje
Excelente 100%	10	25.0
Bueno 75%	18	45.0
Promedio 50%	8	20.0
Regular 25%	4	10.0
Total	40	100.0

La gráfica nos muestra que el 45.0% de las personas encuestadas creen que es buena la transacción de datos sensibles, seguida del 25.0% que opinan que es excelente, el 20.0% que es promedio y el 10.0% que es regular.

51. Poner medidas preventivas, detectivas y correctivas (en especial contar con parches de seguridad y control de virus actualizados) en toda la organización para proteger los sistemas de la información y a la tecnología contra malware (virus, gusanos, spyware, correo basura).

Figura 51. Prevención, detección y corrección de software malicioso



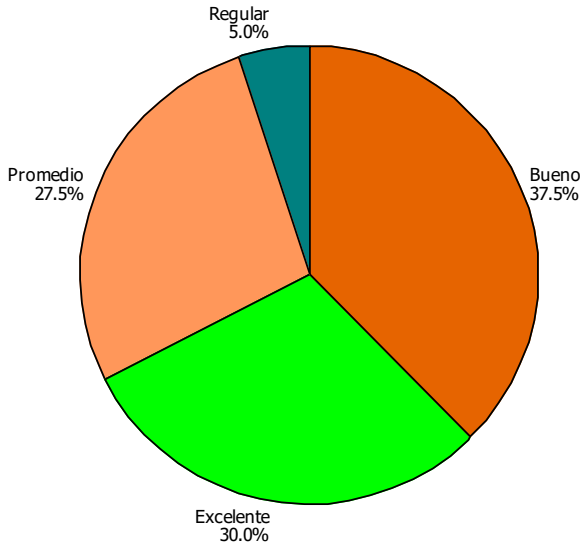
Cuadro 54. Prevención, detección y corrección de software malicioso

		Total	Porcentaje
Excelente	100%	11	27.5
Bueno	75%	22	55.0
Promedio	50%	3	7.5
Regular	25%	3	7.5
Malo	0%	1	2.5
Total		40	100.0

La gráfica nos muestra que el 55.0% de las personas encuestadas opinan que es bueno prevenir, detener y corregir los software maliciosos, seguido del 27.5% que sería excelente, los que piensan que es regular y promedio es un doble porcentaje del 7.5% de las personas y el 2.5% que es malo.

52. Garantizar que la tecnología relacionada con la seguridad sea resistente al sabotaje y no revele documentación de seguridad innecesaria.

Figura 52. Protección de la tecnología de seguridad



Cuadro 55. Protección de la tecnología de seguridad

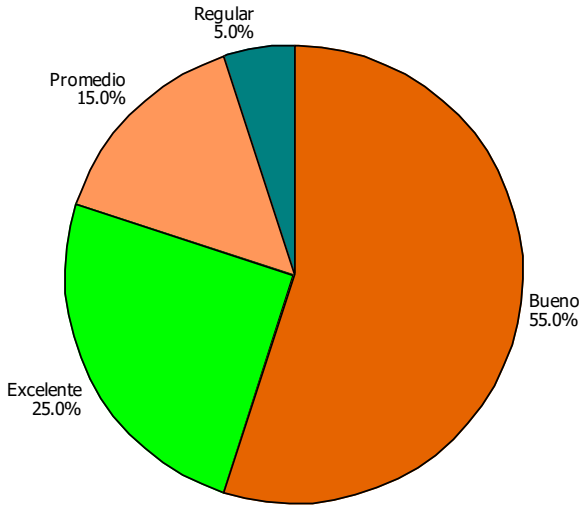
		Total	Porcentaje
Excelente	100%	12	30.0
Bueno	75%	15	37.5
Promedio	50%	11	27.5
Regular	25%	2	5.0
Total		40	100.0

La gráfica nos muestra que el 37.5% del personal encuestado cree es bueno el garantizar que la tecnología relacionada con la seguridad, seguido del 30.0% de las personas que creen que es excelente, el 27.5% que es promedio, el 5.0% es regular.

Resultados de la Situación Actual – Instalaciones

53. Definir e implementar medidas de seguridad físicas alineadas con los requerimientos del negocio. Las medidas deben incluir, pero no limitarse al esquema del perímetro de seguridad, de las zonas de seguridad, la ubicación de equipo crítico y de las áreas de envío y recepción. En particular, mantenga un perfil bajo respecto a la presencia de operaciones críticas de TI. Deben establecerse las responsabilidades sobre el monitoreo y los procedimientos de reporte y de resolución de incidentes de seguridad física.

Figura 53. Medidas de seguridad física



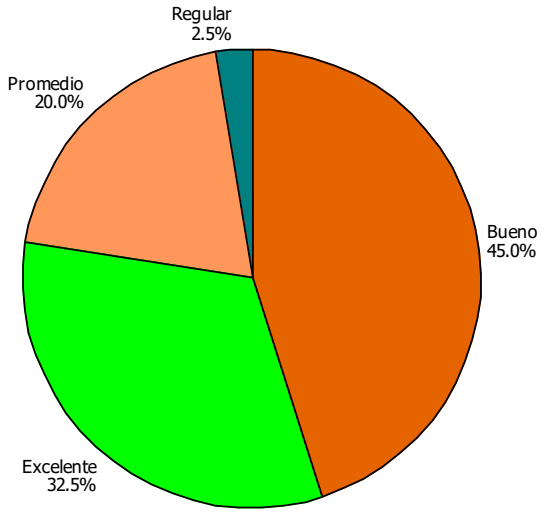
Cuadro 56. Medidas de seguridad física

		Total	Porcentaje
Excelente	100%	10	25.0
Bueno	75%	22	55.0
Promedio	50%	6	15.0
Regular	25%	2	5.0
Total		40	100.0

La gráfica nos muestra que el 55.0% de las personas encuestadas opinan que es bueno definir e implementar las medidas de seguridad físicas alineadas con los requerimientos del negocio, seguido del 25.0% que es excelente, el 15.0% que es un promedio y el 5.0% que es regular.

54. Definir e implementar procedimientos para otorgar, limitar y revocar el acceso a locales, edificios y áreas de acuerdo con las necesidades del negocio, incluyendo las emergencias. El acceso a locales, edificios y áreas debe justificarse, autorizarse, registrarse y monitorearse. Esto aplica para todas las personas que accedan a las instalaciones, incluyendo personal, clientes, proveedores, visitantes o cualquier tercera persona.

Figura 54. Acceso físico



Cuadro 57. Acceso físico

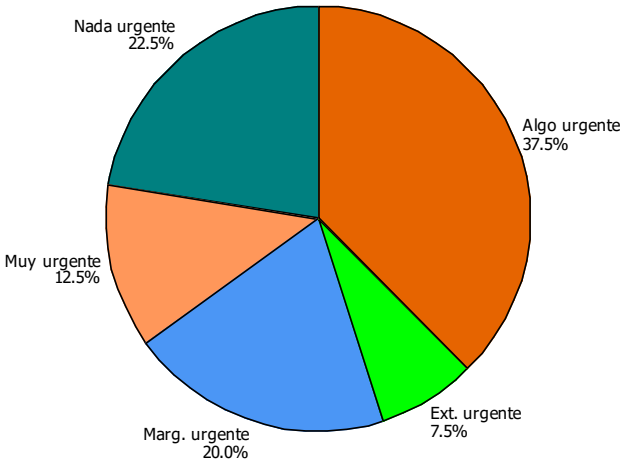
		Total	Porcentaje
Excelente	100%	13	32.5
Bueno	75%	18	45.0
Promedio	50%	8	20.0
Regular	25%	1	2.5
Total		40	100.0

La gráfica nos muestra que el 45.0% de las personas encuestadas creen que es bueno definir e implementar procedimientos para otorgar, limitar y revocar el acceso a locales, seguido del 32.5% de las personas que creen que es excelente, el 20.0% del promedio y el 2.5% de las personas creen que es regular.

Resultados de la percepción del sentido de urgencia – Políticas y Estrategias

1. Trasladar los requerimientos de IEEG, riesgos y cumplimiento dentro de un plan de seguridad de TI completo, teniendo en consideración la infraestructura de TI y la cultura de seguridad. Asegurar que el plan esta implementado en las políticas y procedimientos de seguridad junto con las inversiones apropiadas en los servicios, personal, software y hardware. Comunicar las políticas y procedimientos de seguridad a los interesados y a los usuarios.

Figura 55. Plan de seguridad en TI



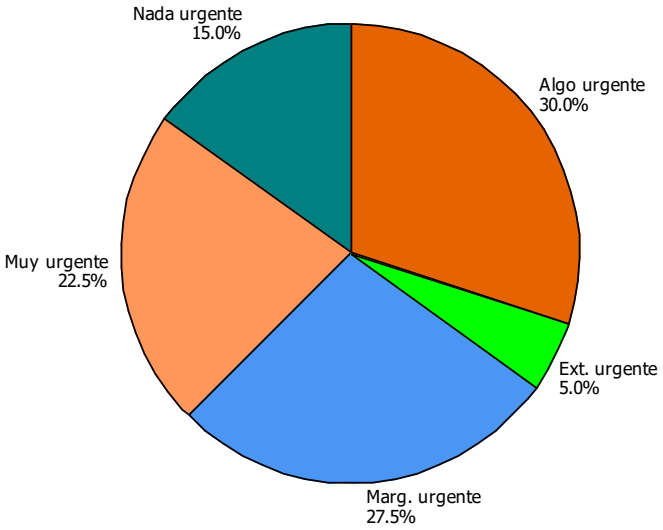
Cuadro 58. Plan de seguridad en TI

Opción		Total	Porcentaje
Extremada. Urgente	100%	3	7.5
Muy urgente	75%	11	27.5
Marginal. Urgente	50%	8	20.0
Algo urgente	25%	11	27.5
Nada urgente	0%	7	17.5
Total		40	100.0

En la gráfica se muestra que el 27.5% de los encuestados consideran como muy urgente y algo urgente el traslado de los requerimientos de IEEG, riesgos y cumplimiento del plan de seguridad en TI, con un 20.0% lo califica como marginalmente urgente, el 17.5% nada urgente y el 7.5% cree que es excelente.

2. Desarrollar y mantener un grupo de políticas para soportar la estrategia de seguridad de la información; procesos de excepción; enfoque de cumplimiento; y referencias para procedimientos, estándares y directrices para el desarrollo, adquisición, mantenimiento y soporte. Su relevancia debe ser confirmada y aprobada regularmente.

Figura 56. Gestión de políticas TI



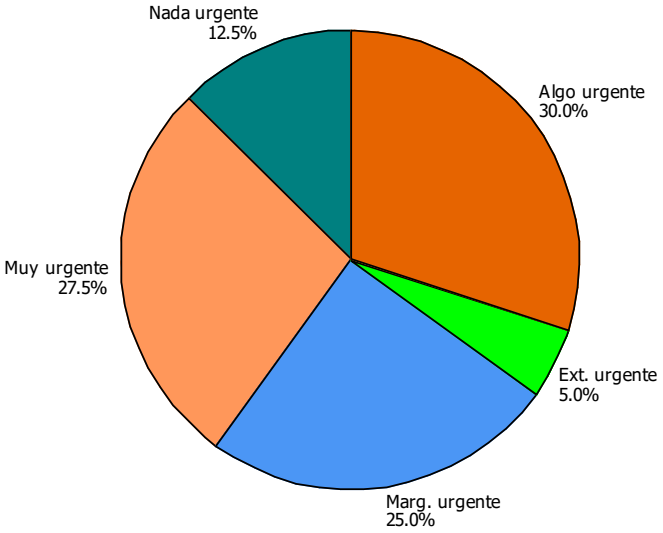
Cuadro 59. Gestión de políticas TI

	Total	Porcentaje
Extremada. Urgente 100%	2	5.0
Muy urgente 75%	9	22.5
Marginal. Urgente 50%	11	27.5
Algo urgente 25%	12	30.0
Nada urgente 0%	6	15.0
Total	40	100.0

Como se aprecia en la gráfica el 30% consideran que se desarrollan y mantienen el grupo de polí-ticas para soportar la estrategias de seguridad de información, el 27.5% lo califican como marginalmente urgente, sin embargo el 22.5% cree que es muy urgente, el 15% nada urgente y solo el 5% consideran que extremadamente urgente.

3. Establecer y mantener un modelo de información empresarial que facilite el desarrollo de aplicaciones y las actividades de soporte a la toma de decisiones, consistente con los planes de TI. El modelo debe facilitar la creación, uso y el compartir en forma óptima la información por parte de IEEG de tal manera que se mantenga su integridad, sea flexible, funcional, rentable, oportuna, segura y tolerante a fallos.

Figura 57. Modelo de arquitectura de información empresarial



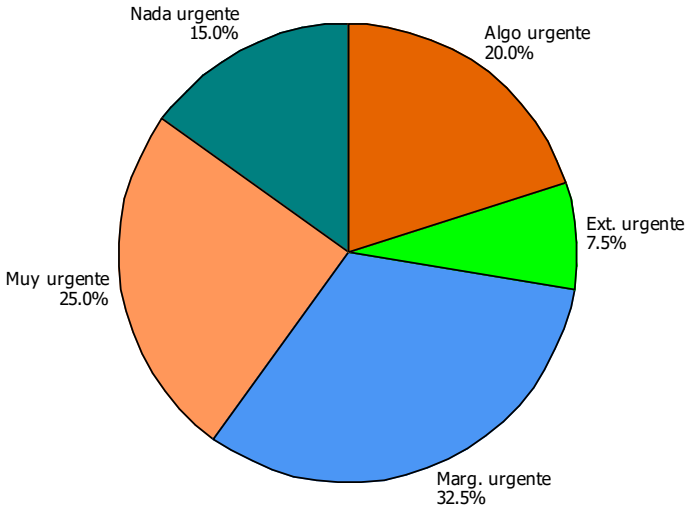
Cuadro 60. Modelo de arquitectura de información empresarial

		Total	Porcentaje
Extremada. Urgente	100%	2	5.0
Muy urgente	75%	11	27.5
Marginal. Urgente	50%	10	25.0
Algo urgente	25%	12	30.0
Nada urgente	0%	5	12.5
Total		40	100.0

En la gráfica se muestra el 30% de los encuestados cree que es algo urgente que se establezca y mantenga un modelo de información empresarial, seguido del 27.5% lo considera como muy urgente, el 25% califica como marginalmente urgente, el 12.5% nada urgente y solo el 5% lo con-sidera como extremadamente urgente.

4. Establecer un esquema de clasificación que aplique a toda IEEG, basado en que tan crítica y sensible es la información (esto es, pública, confidencial, secreta) de IEEG. Este esquema incluye detalles acerca de la propiedad de datos, la definición de niveles apropiados de seguridad y de controles de protección, y una breve descripción de los requerimientos de retención y destrucción de datos, además de qué tan críticos y sensibles son. Se usa como base para aplicar controles como el control de acceso, archivo o cifrado.

Figura 58. Esquema de clasificación de datos



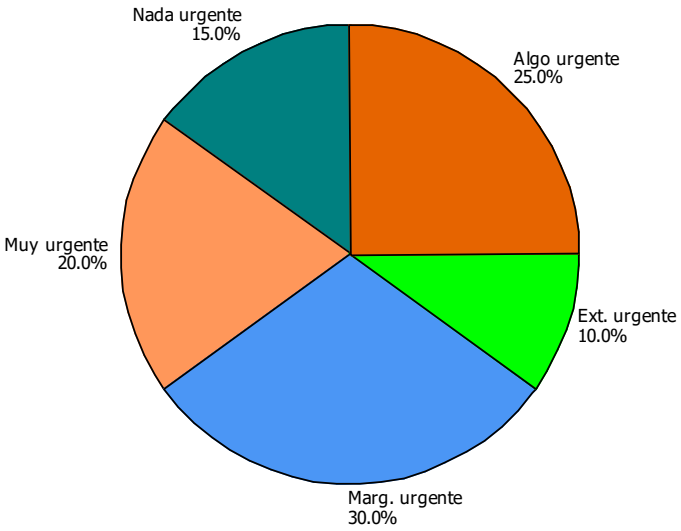
Cuadro 61. Esquema de clasificación de datos

	Total	Porcentaje
Extremada. Urgente 100%	3	7.5
Muy urgente 75%	10	25.0
Marginal. Urgente 50%	13	32.5
Algo urgente 25%	8	20.0
Nada urgente 0%	6	15.0
Total	40	100.0

En esta gráfica el 32.5% califica como marginalmente urgente, que se establezca un esquema de clasificación que aplique a toda IEEG, seguido del 25% muy urgente, el 20% lo considera como algo urgente, el 15% nada urgente y el 7.5% cree que es extremadamente urgente.

5. Establecer un proceso para monitorear las tendencias ambientales del sector / industria, tecnológicas, de infraestructura, legales y regulatorias. Incluir las consecuencias de estas tendencias en el desarrollo del plan de infraestructura tecnológica de TI.

Figura 59. Regulaciones y tendencias futuras



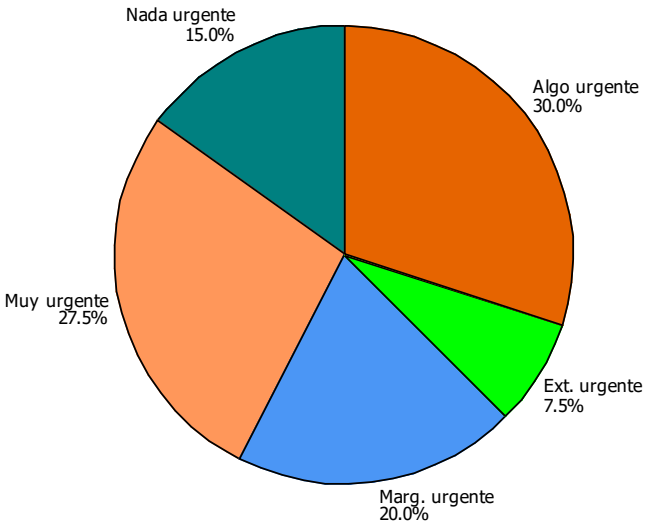
Cuadro 62. Regulaciones y tendencias futuras

		Total	Porcentaje
Extremada. Urgente	100%	4	10.0
Muy urgente	75%	8	20.0
Marginal. Urgente	50%	12	30.0
Algo urgente	25%	10	25.0
Nada urgente	0%	6	15.0
Total		40	100.0

En esta gráfica se observa que el 30% del personal califica como marginalmente urgente a que se establezca un proceso para monitorear las tendencias futuras, el 25% lo considera como algo urgente, el 20% muy urgente, seguido del 15% cree que no es urgente y el 10% cree que es extre-madamente urgente.

6. Proporcionar soluciones tecnológicas consistentes, efectivas y seguras para toda IEEG, establecer un foro tecnológico para brindar directrices tecnológicas, asesoría sobre los productos de la infraestructura y guías sobre la selección de la tecnología, y medir el cumplimiento de estos estándares y directrices. Este foro impulsa los estándares y las prácticas tecnológicas con base en su importancia y riesgo para el negocio y en el cumplimiento de requerimientos externos.

Figura 60. Estándares tecnológicos



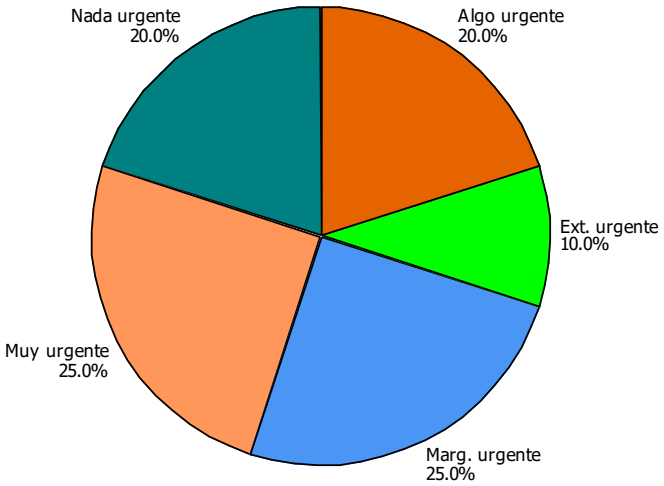
Cuadro 63. Estándares tecnológicos

	Total	Porcentaje
Extremada. Urgente 100%	3	7.5
Muy urgente 75%	11	27.5
Marginal. Urgente 50%	8	20.0
Algo urgente 25%	12	30.0
Nada urgente 0%	6	15.0
Total	40	100.0

Esta gráfica muestra que el 30% del personal respondió como algo urgente a proporcionar solu-ciones tecnológicas consistente y seguras para toda IEEG, el 27.5% considera que es muy urgente, el 20% marginalmente urgente, seguido del 15% que opina que no es urgente, y el 7.5% extrema-damente urgente.

7. Establecer un marco de trabajo de administración de riesgos de TI que éste alineado al marco de trabajo de administración de riesgos de la organización.

Figura 61. Marco de trabajo de administración de riesgos



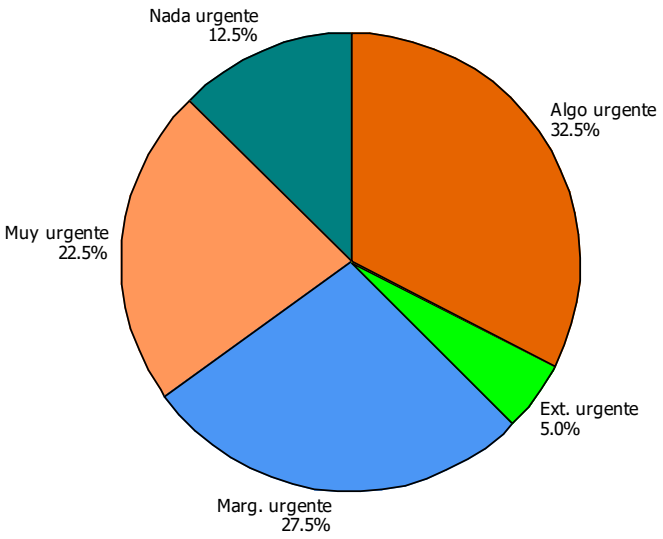
Cuadro 64. Marco de trabajo de administración de riesgos

Opción		Total	Porcentaje
Extremada. Urgente	100%	4	10.0
Muy urgente	75%	10	25.0
Marginal. Urgente	50%	10	25.0
Algo urgente	25%	8	20.0
Nada urgente	0%	8	20.0
Total		40	100.0

Como se puede observar en la gráfica el 25% de los encuestados califican como muy urgente y marginalmente urgente a establecer un marco de trabajo de administración de riesgos en TI, seguido del 20% los que consideran como algo urgente y nada urgente y solo el 10% cree que es extremadamente urgente.

8. Evaluar de forma recurrente la probabilidad e impacto de todos los riesgos identificados, usando métodos cualitativos y cuantitativos. La probabilidad e impacto asociados a los riesgos inherentes y residuales se debe determinar de forma individual, por categoría y con base en el portafolio.

Figura 62. Evaluación de riesgos de TI



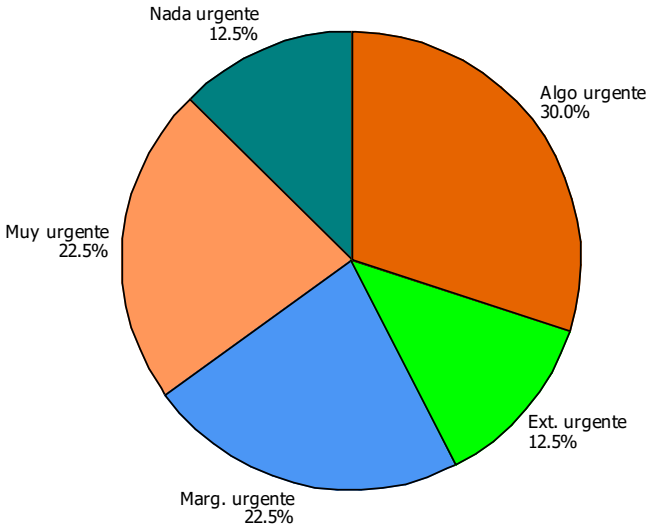
Cuadro 65. Evaluación de riesgos de TI

Opción		Total	Porcentaje
Extremada. Urgente	100%	2	5.0
Muy urgente	75%	9	22.5
Marginal. Urgente	50%	11	27.5
Algo urgente	25%	13	32.5
Nada urgente	0%	5	12.5
Total		40	100.0

El 32.5% del personal califica como algo urgente a evaluar de forma recurrente la probabilidad e impacto de los riesgos identificados de TI, con un 27.5% los que consideran que es marginalmente urgente, el 22.5% muy urgente, el 12.5% los que creen que no es urgente y solo el 5% extremada-mente urgente.

9. Priorizar y planear las actividades de control a todos los niveles para implementar las respuestas a los riesgos, identificadas como necesarias, incluyendo la identificación de costos, beneficios y la responsabilidad de la ejecución. Obtener la aprobación para las acciones recomendadas y la aceptación de cualquier riesgo residual, y asegurarse de que las acciones comprometidas están a cargo del dueño (s) de los procesos afectados. Monitorear la ejecución de los planes y reportar cualquier desviación a la alta dirección.

Figura 63. Mantenimiento y monitoreo de un plan de acción de riesgos



Cuadro 66. Mantenimiento y monitoreo de un plan de acción de riesgos

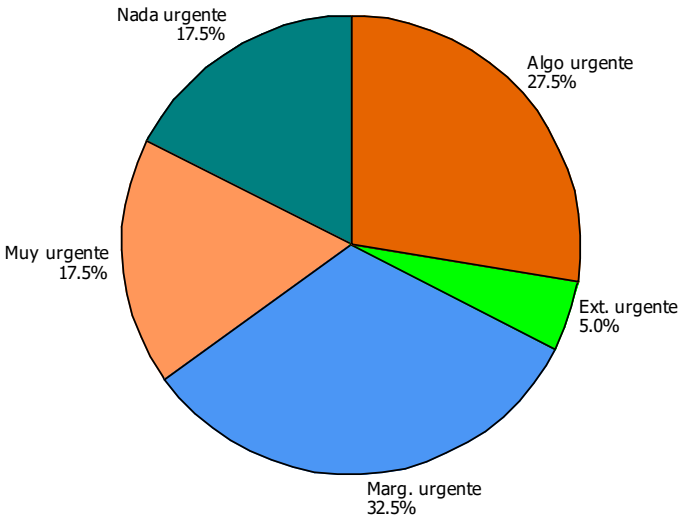
Opción		Total	Porcentaje
Extremada. Urgente	100%	5	12.5
Muy urgente	75%	9	22.5
Marginal. Urgente	50%	9	22.5
Algo urgente	25%	12	30.0
Nada urgente	0%	5	12.5
Total		40	100.0

El 30% de los encuestados considera como algo urgente priorizar el mantenimiento y monitoreo de un plan de acción de riesgos, seguido del 22.5% los que califican como muy y marginalmente urgente y con el 12.5% los que creen se es extremadamente urgente y nada urgente.

Resultados de la percepción del sentido de urgencia – Organización

10. Establecer la propiedad y la responsabilidad de los riesgos relacionados con TI a un nivel superior apropiado. Definir y asignar roles críticos para administrar los riesgos de TI, incluyendo la responsabilidad específica de la seguridad de la información, la seguridad física y el cumplimiento. Establecer responsabilidad sobre la administración del riesgo y la seguridad a nivel de toda la organización para manejar los problemas a nivel de toda la empresa. Puede ser necesario asignar responsabilidades adicionales de administración de la seguridad a nivel de sistema específico para manejar problemas relacionados con seguridad. Obtener orientación de la alta dirección con respecto al apetito de riesgo de TI y la aprobación de cualquier riesgo residual de TI.

Figura 64. Responsabilidad sobre el riesgo, la seguridad y el cumplimiento



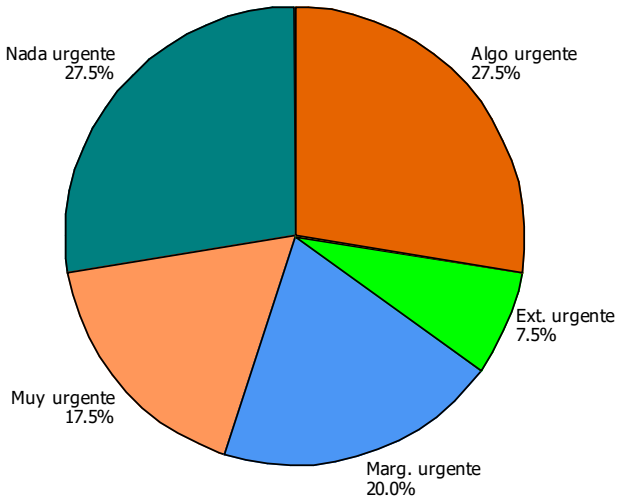
Cuadro 67. Responsabilidad sobre el riesgo, la seguridad y el cumplimiento

Opción	Total	Porcentaje
Extremada. Urgente 100%	2	5.0
Muy urgente 75%	7	17.5
Marginal. Urgente 50%	13	32.5
Algo urgente 25%	11	27.5
Nada urgente 0%	7	17.5
Total	40	100.0

En la gráfica se muestra que el 32.5% califica como marginalmente urgente a establecer la propiedad y responsabilidad de los riesgos relacionados con TI, el 27.5% cree que es algo urgente, el 17.5% considera que es nada urgente y muy urgente y solo el 5% extremadamente urgente.

11. Administrar la seguridad de TI al nivel más alto apropiado dentro de IEEG, de manera que las acciones de administración de la seguridad estén en línea con los requerimientos del negocio.

Figura 65. Administración de seguridad de la información



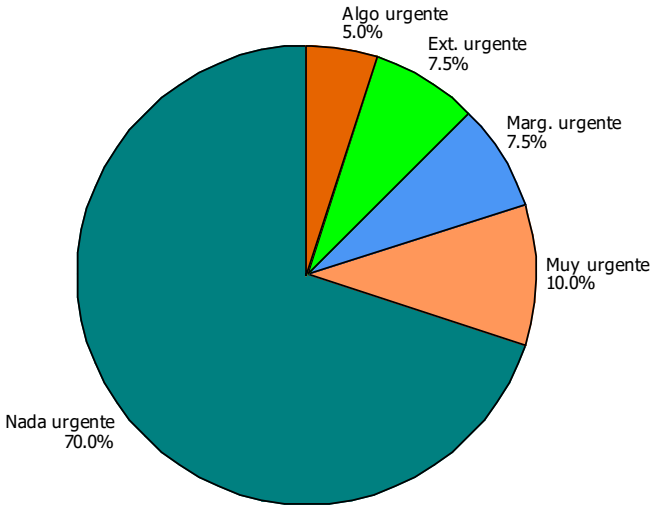
Cuadro 68. Administración de seguridad de la información

Opción		Total	Porcentaje
Extremada. Urgente	100%	3	7.5
Muy urgente	75%	7	17.5
Marginal. Urgente	50%	8	20.0
Algo urgente	25%	11	27.5
Nada urgente	0%	11	27.5
Total		40	100.0

Con 27.5% el personal califica como algo y nada urgente a administrar la seguridad de TI al nivel más alto apropiado dentro de IEEG, el 20% considera que es marginalmente urgente, seguido del 17.5% muy urgente y solo el 7.5% lo califica como extremadamente urgente.

12. Proporcionar a IEEG los procedimientos y herramientas que le permitan enfrentar sus responsabilidades de propiedad sobre los datos y los sistemas de información. Los directores toman decisiones sobre la clasificación de la información y de los sistemas y sobre cómo protegerlos de acuerdo a esta clasificación.

Figura 66. Propiedad de datos y sistemas



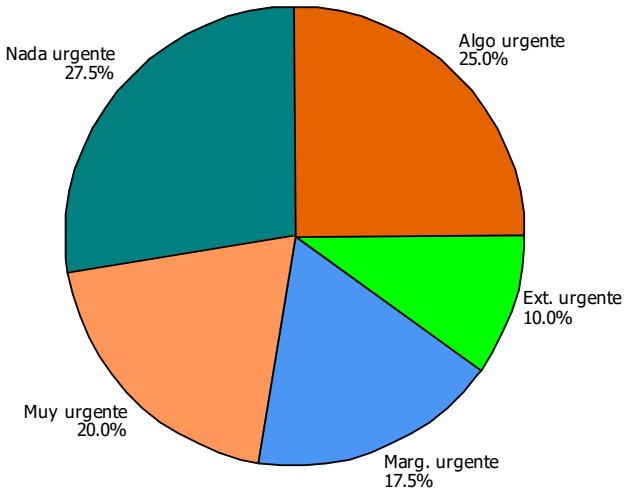
Cuadro 69. Propiedad de datos y sistemas

Opción	Total	Porcentaje
Extremada. Urgente 100%	3	7.5
Muy urgente 75%	4	10.0
Marginal. Urgente 50%	3	7.5
Algo urgente 25%	2	5.0
Nada urgente 0%	28	70.0
Total	40	100.0

Con base a la gráfica anterior, se muestra que el 70% de los encuestados califica como nada urgente a proporcionar a IEEG los procedimientos y herramientas que le permitan enfrentar sus responsabilidades de propiedad de datos y sistemas, seguido del 10% muy urgente, el 7.5% considera que es extremadamente y marginalmente urgente y el 5% califica como algo urgente.

13. Implementar una división de roles y responsabilidades que reduzca la posibilidad de que un solo individuo afecte negativamente un proceso crítico. La UTSIT también se asegura de que el personal realice sólo las tareas autorizadas, relevantes a sus puestos y posiciones respectivas.

Figura 67. Segregación de funciones



Cuadro 70. Segregación de funciones

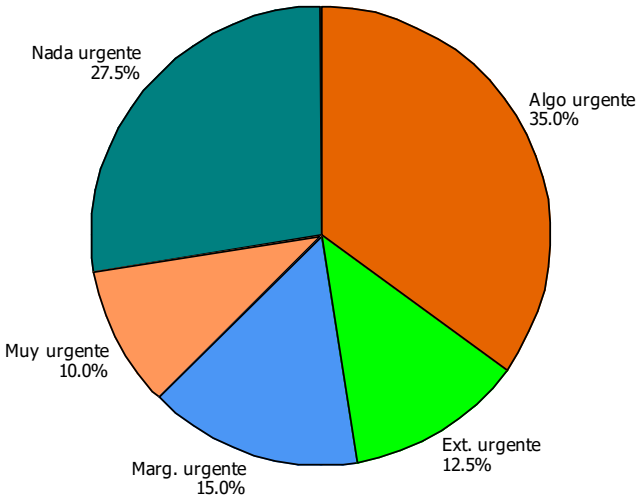
		Total	Porcentaje
Extremada. Urgente	100%	4	10.0
Muy urgente	75%	8	20.0
Marginal. Urgente	50%	7	17.5
Algo urgente	25%	10	25.0
Nada urgente	0%	11	27.5
Total		40	100.0

La gráfica nos muestra que el 27.5% del personal considera como nada urgente a implementar una división de roles y responsabilidades que reduzca la posibilidad que de individuo afecte negativamente al proceso crítico, seguido del 25% califica como algo urgente, el 20% muy urgen-te, el 17.5% considera que es margi-nalmente urgente y el 10% como extremadamente urgente.

Resultados de la percepción del sentido de urgencia – Personas

14. Asegurarse que los procesos de reclutamiento del personal de TI estén de acuerdo a las políticas y procedimientos generales de personal de la organización (Ej. contratación, un ambiente positivo de trabajo y orientación). La UTSIT implementa procesos para garantizar que la organización cuente con una fuerza de trabajo posicionada de forma apropiada, que tenga las habilidades necesarias para alcanzar las metas organizacionales.

Figura 68. Reclutamiento y retención del personal



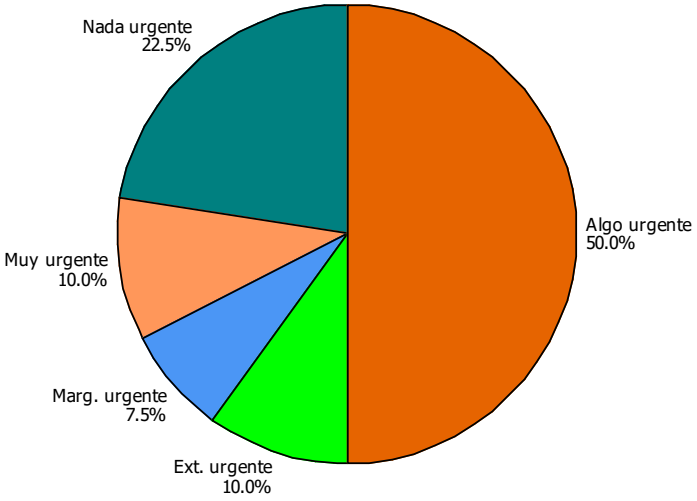
Cuadro 71. Reclutamiento y retención del personal

	Total	Porcentaje
Extremada. Urgente 100%	5	12.5
Muy urgente 75%	4	10.0
Marginal. Urgente 50%	6	15.0
Algo urgente 25%	14	35.0
Nada urgente 0%	11	27.5
Total	40	100.0

El 35% del personal considera como algo urgente el asegurarse que los procesos de reclutamien-to del personal de TI estén de acuerdo a las políticas y procedimientos generales de personal de IEGG, el 27.5% nada urgente, seguido del 15% califican como marginalmente urgente, el 12.5% lo considera como extremadamente urgente y el 10% como muy urgente.

15. Verificar de forma periódica que el personal tenga las habilidades para cumplir sus roles con base en su educación, entrenamiento y/o experiencia. Definir los requerimientos esenciales de habilidades para TI y verificar que se les dé mantenimiento, usando programas de calificación y certificación según sea el caso.

Figura 69. Competencias del personal



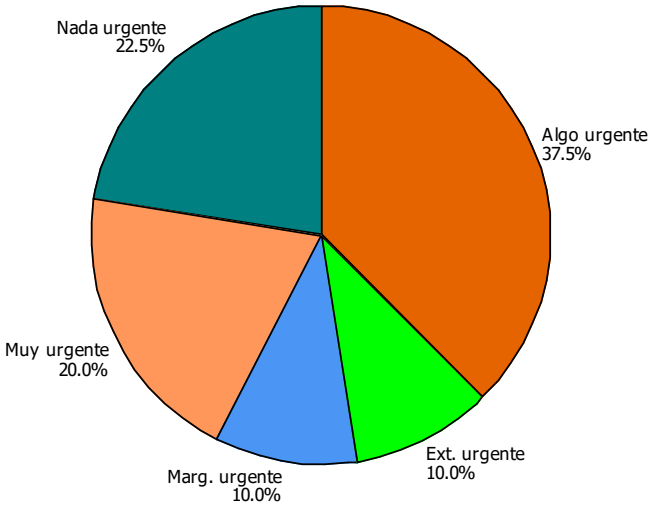
Cuadro 72. Competencias del personal

		Total	Porcentaje
Extremada. Urgente	100%	4	10.0
Muy urgente	75%	4	10.0
Marginal. Urgente	50%	3	7.5
Algo urgente	25%	20	50.0
Nada urgente	0%	9	22.5
Total		40	100.0

La gráfica nos muestra que la mitad de los encuestados (50%) respondieron como algo urgente a verificar de forma periódica que el personal tenga las habilidades para cumplir sus roles en base a su educación, entrenamiento o experiencia, el 22.5% califica como nada urgente, seguido del 10% los que creen que es extremadamente urgente y muy urgente y el 7.5% como marginalmente urgente.

16. Minimizar la exposición a dependencias críticas sobre individuos clave por medio de la captura del conocimiento (documentación), compartir el conocimiento, planeación de la sucesión y respaldos de personal.

Figura 70. Dependencia sobre los individuos



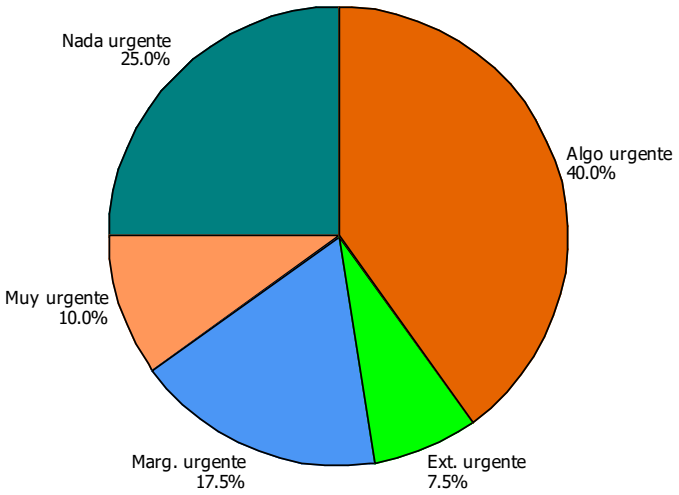
Cuadro 73. Dependencia sobre los individuos

	Total	Porcentaje
Extremada. Urgente 100%	4	10.0
Muy urgente 75%	8	20.0
Marginal. Urgente 50%	4	10.0
Algo urgente 25%	15	37.5
Nada urgente 0%	9	22.5
Total	40	100.0

El 37.5% califica como algo urgente el minimizar la exposición a dependencias críticas sobre individuos clave por medio de la captura del conocimiento, el 22.5% considera que no es urgente, seguido del 20% muy urgente y el 10% cree que es extremadamente urgente.

17. Incluir verificaciones de antecedentes en el proceso de reclutamiento de TI. El grado y la frecuencia de estas verificaciones dependen de estas verificaciones dependen de que tan delicada ó crítica sea la función y se deben aplicar a los empleados, y proveedores.

Figura 71. Procedimientos de investigación del personal



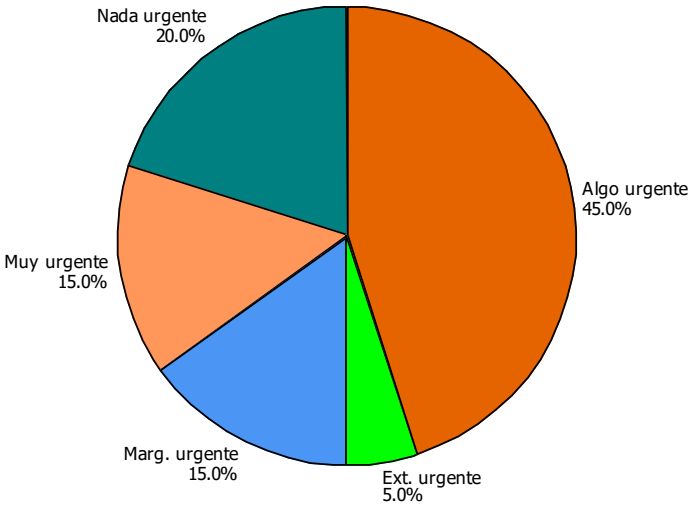
Cuadro 74. Procedimientos de investigación del personal

	Total	Porcentaje
Extremada. Urgente 100%	3	7.5
Muy urgente 75%	4	10.0
Marginal. Urgente 50%	7	17.5
Algo urgente 25%	16	40.0
Nada urgente 0%	10	25.0
Total	40	100.0

El 40% de los encuestados creen que es algo urgente incluir verificaciones de antecedente en el proceso de reclutamiento de TI, seguido del 25% que no lo considera urgente, el 17.5% como marginalmente urgente, el 10% muy urgente y el 7.5% califica como extremadamente urgente.

18. Tomar medidas expeditas respecto a los cambios en los puestos, en especial las terminaciones. Se debe realizar la transferencia del conocimiento, reasignar responsabilidades y se deben eliminar los privilegios de acceso, de tal modo que los riesgos se minimicen y se garantice la continuidad de la función.

Figura 72. Cambios y terminación de trabajo



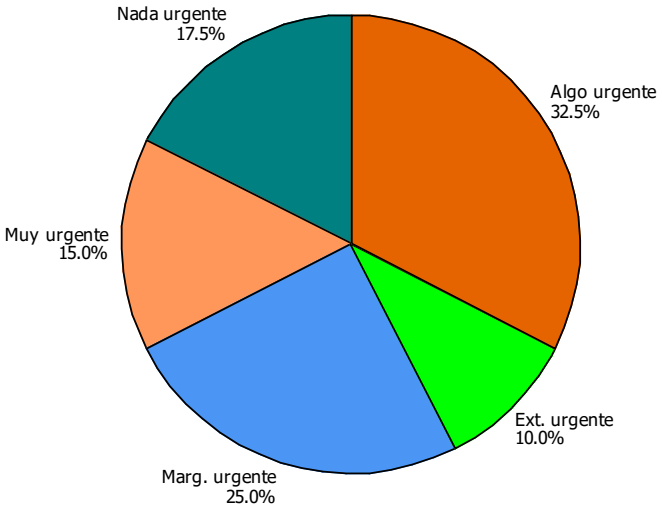
Cuadro 75. Cambios y terminación de trabajo

		Total	Porcentaje
Extremada. Urgente	100%	2	5.0
Muy urgente	75%	6	15.0
Marginal. Urgente	50%	6	15.0
Algo urgente	25%	18	45.0
Nada urgente	0%	8	20.0
Total		40	100.0

La gráfica nos muestra que el 45% del personal respondió como algo urgente a tomar medidas expeditas respecto a los cambios en los puestos, como las terminaciones, el 20% no lo considera urgente, con un 15% califican como muy urgente y marginalmente urgente, solo el 5% considera que es extremadamente urgente.

19. Transferencia de conocimiento y habilidades para permitir que los usuarios finales utilicen con efectividad y eficiencia el sistema de aplicación como apoyo a los procesos del IEEG. La transferencia de conocimiento incluye el desarrollo de un plan de entrenamiento que aborde al entrenamiento inicial y al continuo, así como el desarrollo de habilidades, materiales de entrenamiento, manuales de usuario, manuales de procedimiento, ayuda en línea, asistencia a usuarios, identificación del usuario clave, y evaluación.

Figura 73. Transferencia de conocimiento a usuarios finales



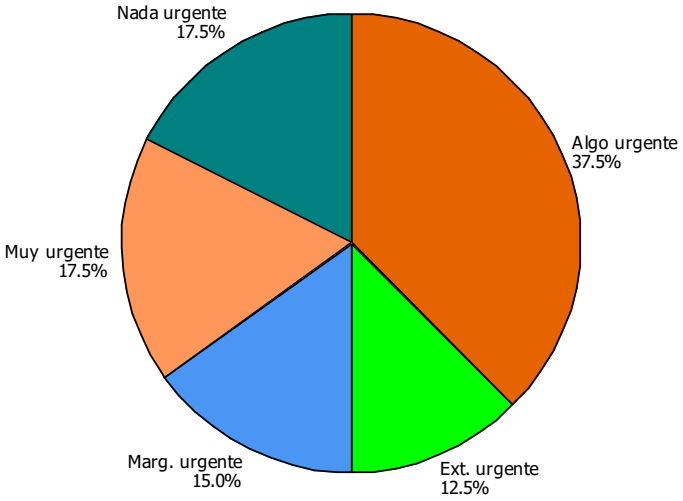
Cuadro 76. Transferencia de conocimiento a usuarios finales

		Total	Porcentaje
Extremada. Urgente	100%	4	10.0
Muy urgente	75%	6	15.0
Marginal. Urgente	50%	10	25.0
Algo urgente	25%	13	32.5
Nada urgente	0%	7	17.5
Total		40	100.0

La gráfica nos muestra que el 32.5% considera que es algo urgente la transferencia de conocimiento y habilidades para permitir que los usuarios finales utilicen con efectividad y eficiencia el sistema de aplicación, el 25% califica como marginalmente urgente, seguido de 17.5% nada urgente, el 15% califica como muy urgente y el 10% extremadamente urgente.

20. Transferir el conocimiento y las habilidades para permitir al personal de soporte técnico y de operaciones que entregue, apoyen y mantenga la aplicación y la infraestructura asociada de manera efectiva y eficiente de acuerdo a los niveles de servicio requeridos. La transferencia del conocimiento debe incluir al entrenamiento inicial y continuo, el desarrollo de las habilidades, los materiales de entrenamiento, los manuales de operación, los manuales de procedimientos y escenarios de atención al usuario.

Figura 74. Transferencia de conocimiento al personal de operaciones y soporte



Cuadro 77. Transferencia de conocimiento al personal de operaciones y soporte

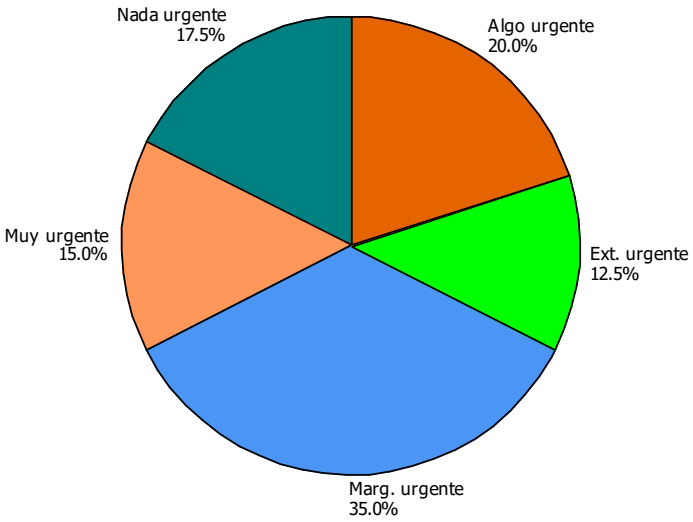
	Total	Porcentaje
Extremada. Urgente 100%	5	12.5
Muy urgente 75%	7	17.5
Marginal. Urgente 50%	6	15.0
Algo urgente 25%	15	37.5
Nada urgente 0%	7	17.5
Total	40	100.0

Como se muestra en la gráfica el 37.5% de los encuestados respondió algo urgente el transferir el conocimiento y las habilidades para permitir al personal de soporte técnico y de operaciones que entregue, apoyen y mantengan la aplicación, el 17.5% lo considera nada urgente y muy urgente y el 12.5% califica como extremadamente urgente.

Resultados de la percepción del sentido de urgencia – Procesos

21. Establecer procedimientos de administración de cambio formales para manejar de manera estándar todas las solicitudes (incluyendo mantenimiento y parches) para cambios a aplicaciones, procedimientos, procesos, parámetros de sistema y servicio, y las plataformas fundamentales.

Figura 75. Estándares y procedimientos para cambios



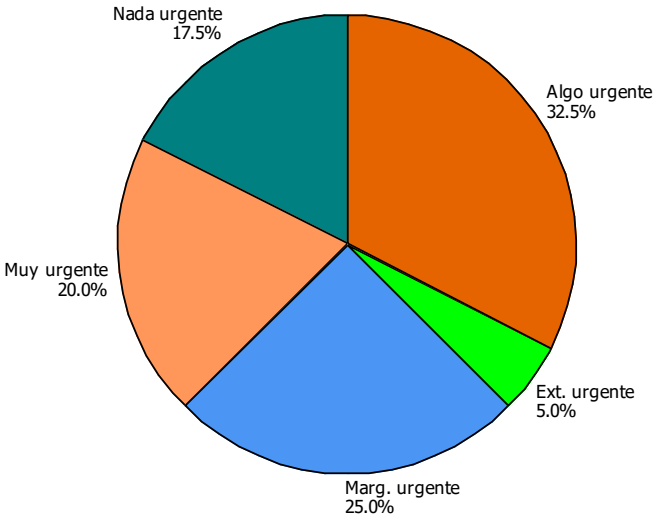
Cuadro 78. Estándares y procedimientos para cambios

	Total	Porcentaje
Extremada. Urgente 100%	5	12.5
Muy urgente 75%	6	15.0
Marginal. Urgente 50%	14	35.0
Algo urgente 25%	8	20.0
Nada urgente 0%	7	17.5
Total	40	100.0

El 35% del personal considera que es marginalmente urgente, estableces procedimiento de administración de cambio formales para manejar todas las solicitudes para los cambios, seguido del 20% los que califican como algo urgente, el 17.5% no lo consideran importante, el 15% muy ur-gente y el 12.5% creen que es extremadamente urgente.

22. Garantizar que todas las solicitudes de cambio se evalúan de una manera estructurada en cuanto a impactos en el sistema operacional y su funcionalidad. Esta evaluación deberá incluir categorización y priorización de los cambios. Previo a la migración hacia producción, los interesados correspondientes autorizan los cambios.

Figura 76. Evaluación de impacto, priorización y autorización



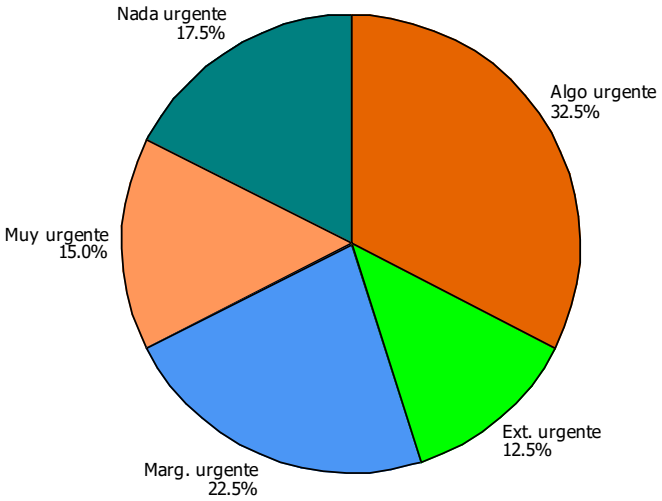
Cuadro 79. Evaluación de impacto, priorización y autorización

		Total	Porcentaje
Extremada. Urgente	100%	2	5.0
Muy urgente	75%	8	20.0
Marginal. Urgente	50%	10	25.0
Algo urgente	25%	13	32.5
Nada urgente	0%	7	17.5
Total		40	100.0

La gráfica nos muestra que el 32.5% de los encuestados respondieron como algo urgente a garantizar que todas las solicitudes de cambio se evalúan de una manera estructurada , el 25% considera que es marginalmente urgente, seguido del 20% muy urgente, el 17.5% lo califica como nada urgente y 5% extremadamente urgente.

23. Definir y establecer un entorno seguro de pruebas representativo del entorno de operaciones planeado relativo a seguridad, controles internos, practicas operativos, calidad de los datos y requerimientos de privacidad, y cargas de trabajo.

Figura 77. Ambiente de prueba



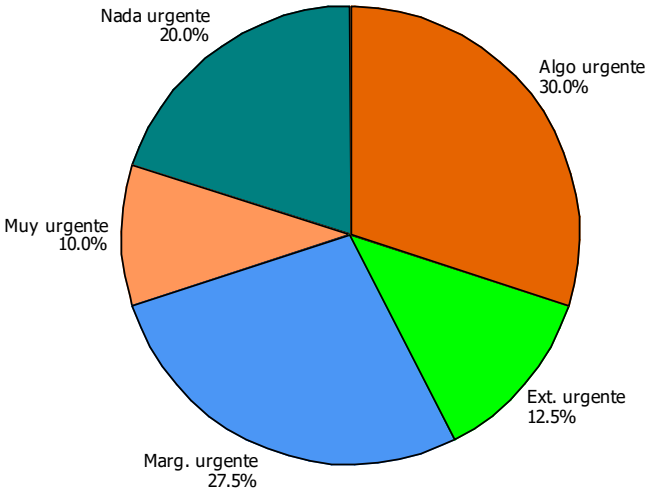
Cuadro 80. Ambiente de prueba

		Total	Porcentaje
Extremada. Urgente	100%	5	12.5
Muy urgente	75%	6	15.0
Marginal. Urgente	50%	9	22.5
Algo urgente	25%	13	32.5
Nada urgente	0%	7	17.5
Total		40	100.0

El 32.5% de los encuestados califica como algo urgente el definir y establecer un entorno seguro de pruebas representativo del entorno de operaciones planeado, seguido del 22.5% como margi-nalmente urgente, el 15% muy urgente, los que consideran que no es urgente es el 17.5%, y representando al 12.5% los que creen es extremadamente urgente.

24. Pruebas de cambios independientemente en acuerdo con los planes de pruebas definidos antes de la migración al entorno de operaciones. Asegurar que el plan considera la seguridad y el desempeño.

Figura 78. Pruebas de cambios



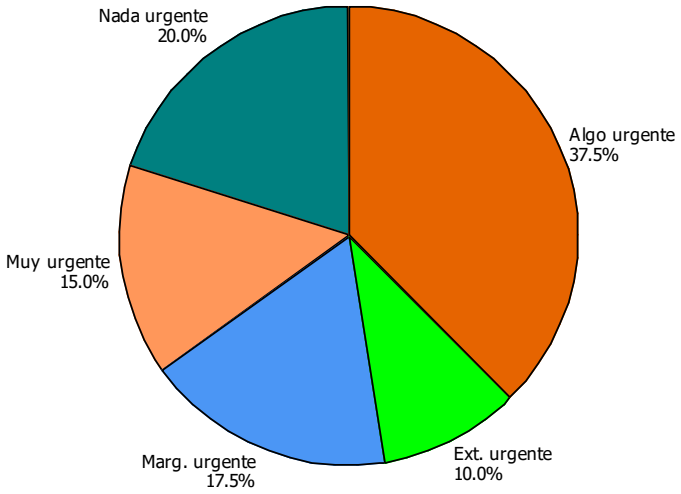
Cuadro 81. Pruebas de cambios

	Total	Porcentaje
Extremada. Urgente 100%	5	12.5
Muy urgente 75%	4	10.0
Marginal. Urgente 50%	11	27.5
Algo urgente 25%	12	30.0
Nada urgente 0%	8	20.0
Total	40	100.0

La gráfica nos muestra que el 30% de los encuestados respondieron es algo urgente las pruebas de cambios, el 27.5% califica como marginalmente urgente, con 20% los que creen que no es urgente, el 12.5% extremadamente urgente y el 10% los que consideran que es muy urgente.

25. Seguimiento a pruebas, controlar la entrega de los sistemas cambiados a operaciones, manteniéndolo en línea con el plan de implantación. Obtener la aprobación de los interesados clave, tales como usuarios, dueño de sistemas y gerente de operaciones. Cuando sea apropiado, ejecutar el sistema en paralelo con el viejo sistema por un tiempo, y comparar el comportamiento y los resultados.

Figura 79. Promoción a producción



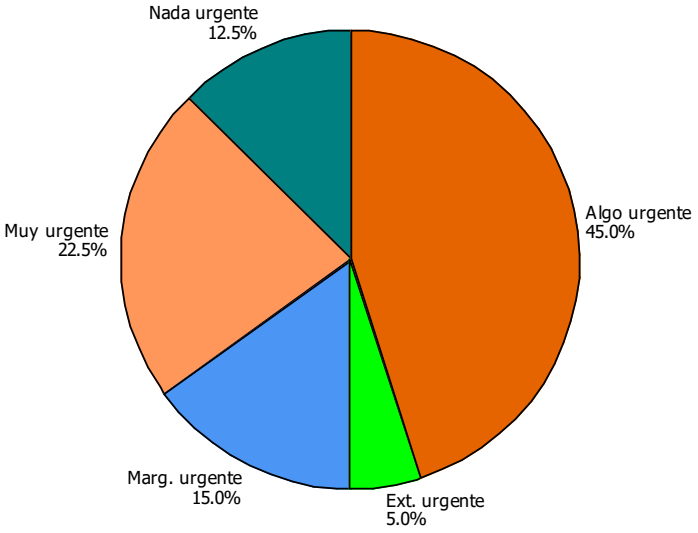
Cuadro 82. Promoción a producción

		Total	Porcentaje
Extremada. Urgente	100%	4	10.0
Muy urgente	75%	6	15.0
Marginal. Urgente	50%	7	17.5
Algo urgente	25%	15	37.5
Nada urgente	0%	8	20.0
Total		40	100.0

Representando el 37.5% de los encuestados consideran que es algo urgente dar seguimiento a pruebas, controlar la entrega de los sistemas cambiados a operaciones, el 20% como nada urgente, seguido del 17.5% que califica como marginalmente urgente, como muy urgente lo consideraron el 15% y el 10% califican como extremadamente urgente.

26. Desarrollar planes de continuidad de TI con base en el marco de trabajo, diseñado para reducir el impacto de una interrupción mayor de las funciones y los procesos clave de IEEG. Los planes deben considerar requerimientos de resistencia, procesamiento alternativo, y capacidad de recuperación de todos los servicios críticos de TI. También deben cubrir los lineamientos de uso, los roles y responsabilidades, los procedimientos, los procesos de comunicación y el enfoque de pruebas.

Figura 80. Planes de continuidad de TI



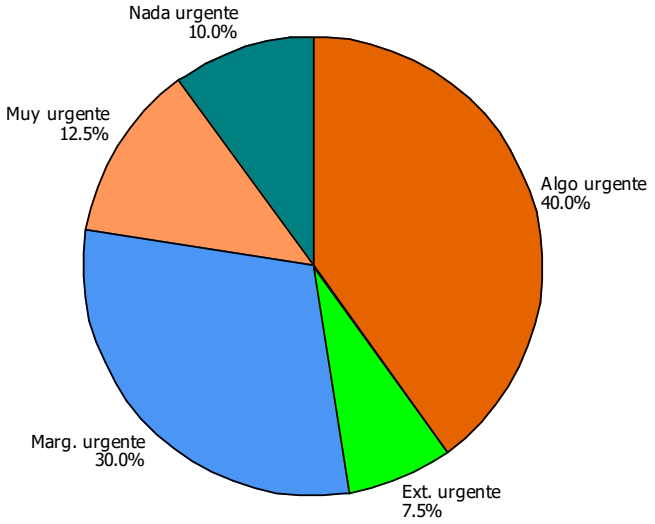
Cuadro 83. Planes de continuidad de TI

	Total	Porcentaje
Extremada. Urgente 100%	2	5.0
Muy urgente 75%	9	22.5
Marginal. Urgente 50%	6	15.0
Algo urgente 25%	18	45.0
Nada urgente 0%	5	12.5
Total	40	100.0

La gráfica nos muestra que el 45% del personal consideran como algo urgente desarrollar planes de continuidad de TI con base en el marco de trabajo, con 22.5% los que califican como muy urgente, el 15% considera que es marginalmente urgente, seguido del 12.5% nada urgente y solo el 5% los que creen que es extremadamente urgente.

27. Probar el plan de continuidad de TI de forma regular para asegurar que los sistemas de TI pueden ser recuperados de forma efectiva, que las deficiencias son atendidas y que el plan permanece aplicable. Esto requiere una preparación cuidadosa, documentación, reporte de los resultados de las pruebas y, de acuerdo con los resultados, la implementación de un plan de acción. Considerar el alcance de las pruebas de recuperación en aplicaciones individuales, en escenarios de pruebas integrados, en pruebas de punta a punta y en pruebas integradas con el proveedor.

Figura 81. Pruebas del plan de continuidad de TI



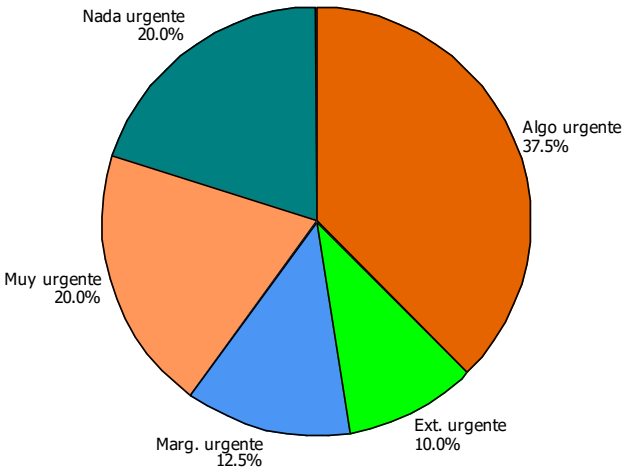
Cuadro 84. Pruebas del plan de continuidad de TI

		Total	Porcentaje
Extremada. Urgente	100%	3	7.5
Muy urgente	75%	5	12.5
Marginal. Urgente	50%	12	30.0
Algo urgente	25%	16	40.0
Nada urgente	0%	4	10.0
Total		40	100.0

El 40% de los encuestados considera como algo urgente el probar los planes de continuidad de TI de forma regular para asegurar que los sistemas de TI pueden ser recuperados de forma efectiva, seguido del 30% que cree que es marginalmente urgente, el 12.5% muy urgente, el 10% con nada urgente y el 7.5% califican como extremadamente urgente.

28. Almacenar fuera de las instalaciones todos los medios de respaldo, documentación y otros recursos de TI críticos, necesarios para la recuperación de TI y para los planes de continuidad del negocio. El contenido de los respaldos a almacenar debe determinarse en conjunto entre los responsables de los procesos de negocio y el personal de TI. La administración del sitio de almacenamiento externo a las instalaciones, debe apegarse a la política de clasificación de datos y a las prácticas de almacenamiento de datos de la empresa. La UTSIT de TI debe asegurar que los acuerdos con sitios externos sean evaluados periódicamente, al menos una vez por año, respecto al contenido, a la protección ambiental y a la seguridad. Asegurarse de la compatibilidad del hardware y del software para poder recuperar los datos archivados y periódicamente probar y renovar los datos archivados.

Figura 82. Almacenamiento de respaldos fuera de las instalaciones



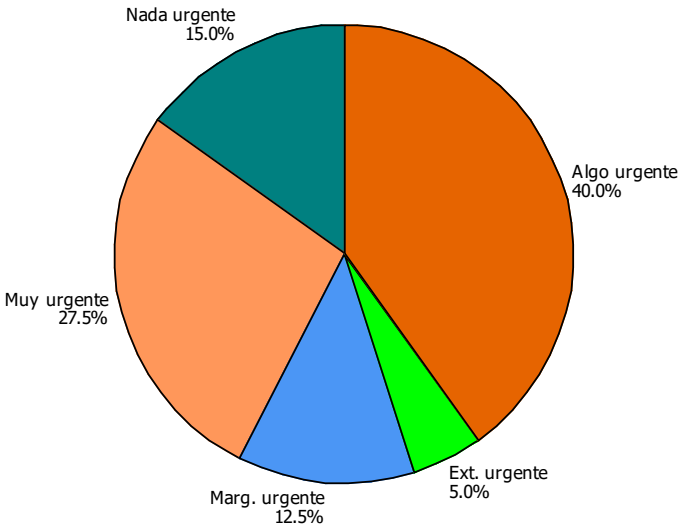
Cuadro 85. Almacenamiento de respaldos fuera de las instalaciones

		Total	Porcentaje
Extremada. Urgente	100%	4	10.0
Muy urgente	75%	8	20.0
Marginal. Urgente	50%	5	12.5
Algo urgente	25%	15	37.5
Nada urgente	0%	8	20.0
Total		40	100.0

La gráfica nos muestra que el 37.5% de los encuestados respondieron que es algo urgente el almacenamiento de respaldos fuera de las instalaciones, con un mismo porcentaje (20.0%) se encuentran los que respondieron que es muy urgente y nada urgente, y el 12.5% indican que es marginalmente urgente y con el 10.0% los que indican que es extremadamente urgente.

29. Definir e implementar procedimientos de respaldo y restauración de los sistemas, aplicaciones, datos y documentación en línea con los requerimientos de negocio y el plan de continuidad.

Figura 83. Respaldo y restauración



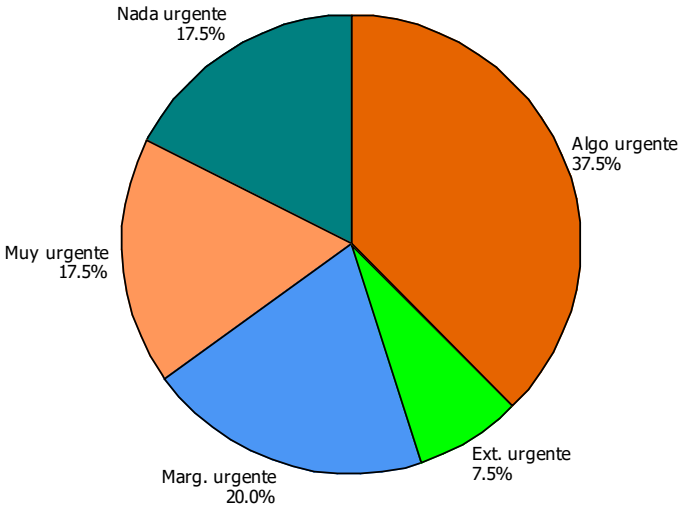
Cuadro 86. Respaldo y restauración

	Total	Porcentaje
Extremada. Urgente 100%	2	5.0
Muy urgente 75%	11	27.5
Marginal. Urgente 50%	5	12.5
Algo urgente 25%	16	40.0
Nada urgente 0%	6	15.0
Total	40	100.0

Del total de los encuestados la mayoría considera que es algo urgente (40%) que se haga respaldo y restauración de los sistemas, seguido del 27.5% que opinan que es muy urgente, el 15% indica que es nada urgente, el porcentaje de los que opinan que es marginalmente urgente es de 12.5%, el 5% determinó que es extremadamente urgente.

30. Definir e implementar procedimientos para el archivo, almacenamiento y retención de los datos, de forma efectiva y eficiente para conseguir los objetivos de negocio, la política de seguridad de la organización y los requerimientos regulatorios.

Figura 84. Acuerdos de almacenamiento y conservación



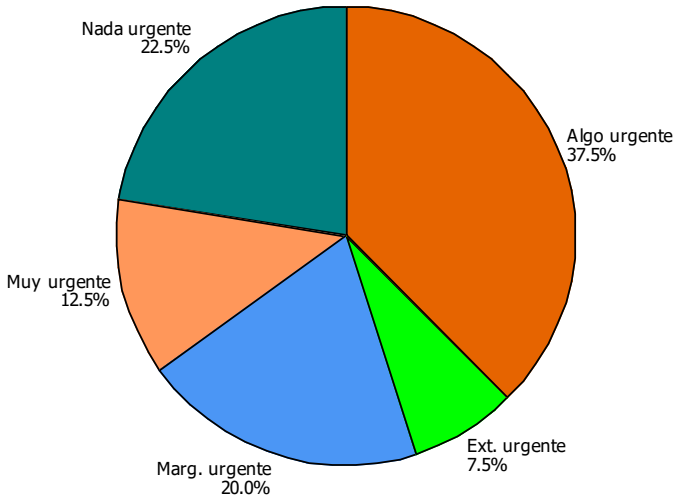
Cuadro 87. Acuerdos de almacenamiento y conservación

		Total	Porcentaje
Extremada. Urgente	100%	3	7.5
Muy urgente	75%	7	17.5
Marginal. Urgente	50%	8	20.0
Algo urgente	25%	15	37.5
Nada urgente	0%	7	17.5
Total		40	100.0

La gráfica muestra que el 37.5% de los encuestados opina que es algo urgente que se establezcan acuerdos de almacenamiento y conservación, mientras que el 20% que es marginalmente urgente, con el mismo porcentaje se encuentran los que opinan que es muy urgente y nada urgente (17.5%) y los que piensan que es extremadamente urgente tienen un porcentaje de 7.5%.

31. Definir e implementar las políticas y procedimientos para identificar y aplicar los requerimientos de seguridad aplicables al recibo, procesamiento, almacén y salida de los datos para conseguir los objetivos de negocio, las políticas de seguridad de la organización y requerimientos regulatorios.

Figura 85. Requerimientos de seguridad para la administración de datos



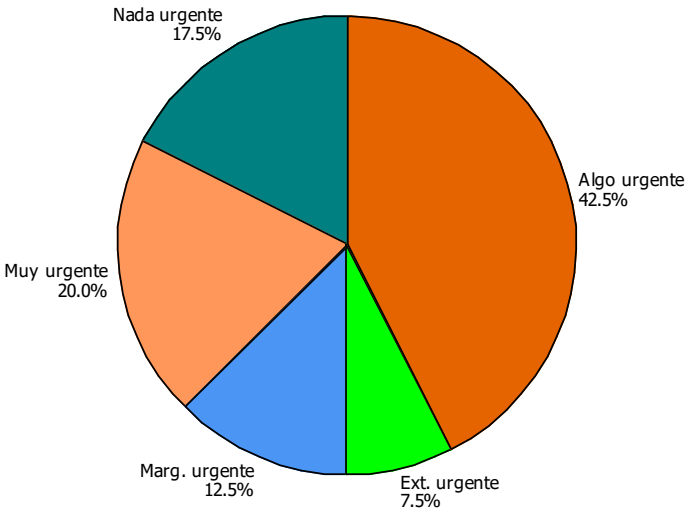
Cuadro 88. Requerimientos de seguridad para la administración de datos

	Total	Porcentaje
Extremada. Urgente 100%	3	7.5
Muy urgente 75%	5	12.5
Marginal. Urgente 50%	8	20.0
Algo urgente 25%	15	37.5
Nada urgente 0%	9	22.5
Total	40	100.0

La gráfica nos muestra que el 37.5% de los encuestados respondieron algo urgente que se establezcan requerimientos de seguridad para la administración de tareas, con un 22.5% los creen que es nada urgente, el 20% marginalmente urgente, seguido del 7.5% que indican que es extremadamente urgente.

32. Definir e implementar procedimientos para asegurar que los requerimientos de negocio para la protección de datos sensitivos y el software se consiguen cuando se eliminan o transfieren los datos y/o el hardware.

Figura 86. Disposición



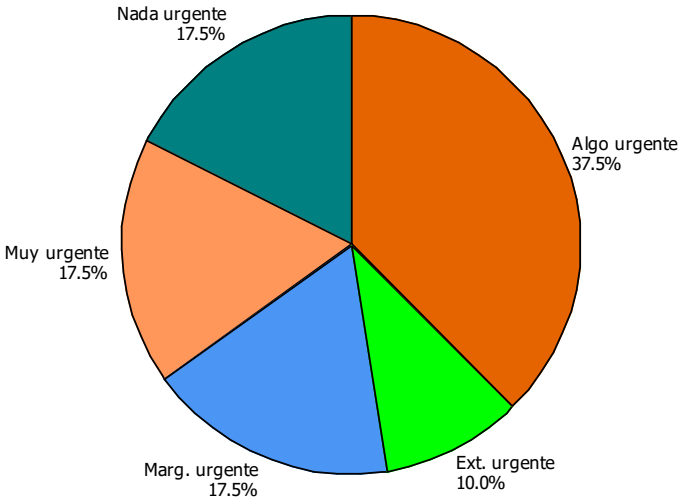
Cuadro 89. Disposición

		Total	Porcentaje
Extremada. Urgente	100%	3	7.5
Muy urgente	75%	8	20.0
Marginal. Urgente	50%	5	12.5
Algo urgente	25%	17	42.5
Nada urgente	0%	7	17.5
Total		40	100.0

La gráfica nos muestra que es algo urgente (42.5%) definir la disposición de datos, el 20% considera que es muy urgente, el 17.5% nada urgente, seguido del porcentaje de los que indican que es marginalmente urgente (12.5%) y 7.5% opinan que es extremadamente urgente.

33. Establecer una herramienta de soporte y un repositorio central que contenga toda la información relevante sobre los elementos de configuración. Monitorear y grabar todos los activos y los cambios a los activos. Mantener una línea base de los elementos de la configuración para todos los sistemas y servicios como punto de comprobación al que volver tras el cambio.

Figura 87. Repositorio y línea base de configuración



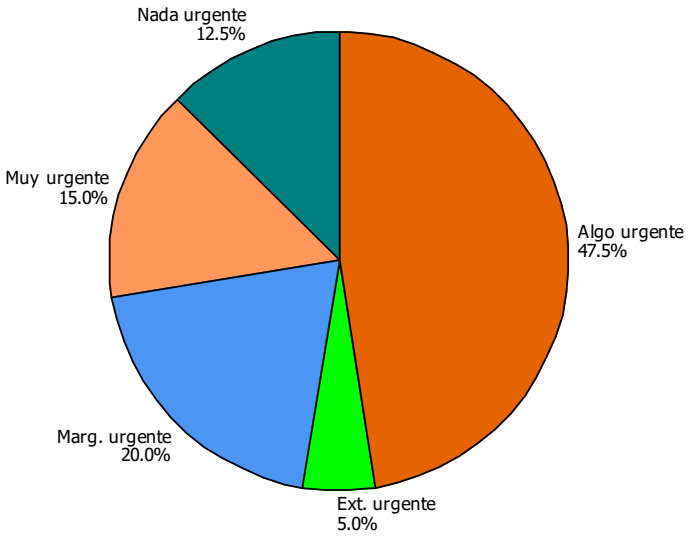
Cuadro 90. Repositorio y línea base de configuración

		Total	Porcentaje
Extremada. Urgente	100%	4	10.0
Muy urgente	75%	7	17.5
Marginal. Urgente	50%	7	17.5
Algo urgente	25%	15	37.5
Nada urgente	0%	7	17.5
Total		40	100.0

La gráfica nos muestra que el 37.5% de los encuestados respondieron que es importante establecer un repositorio y línea base de configuración, con un porcentaje de 17.5% los que indicaron muy urgente, marginalmente urgente y nada urgente respectivamente, los que piensan que es extremadamente urgente son un porcentaje de 10.0%.

34. Establecer procedimientos de configuración para soportar la gestión y rastro de todos los cambios al repositorio de configuración. Integrar estos procedimientos con la gestión de cambios, gestión de incidentes y procedimientos de gestión de problemas.

Figura 88. Identificación y mantenimiento de elementos de configuración



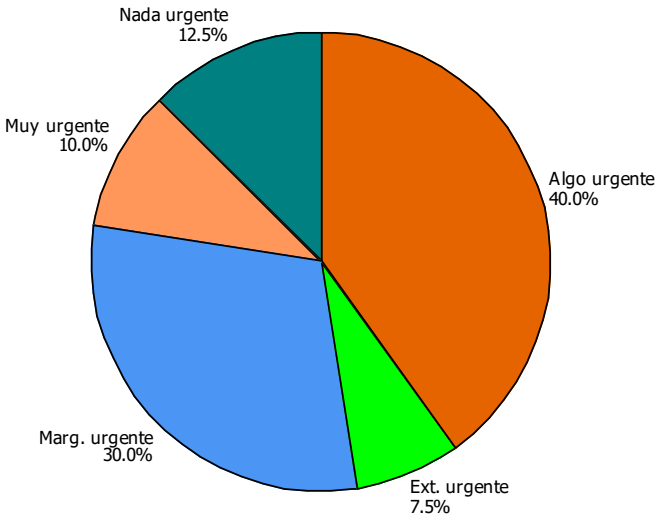
Cuadro 91. Identificación y mantenimiento de elementos de configuración

	Total	Porcentaje
Extremada. Urgente 100%	2	5.0
Muy urgente 75%	6	15.0
Marginal. Urgente 50%	8	20.0
Algo urgente 25%	19	47.5
Nada urgente 0%	5	12.5
Total	40	100.0

La gráfica nos muestra que el 47.5% de los encuestados respondieron que es algo urgente identificar y dar mantenimiento a los elemento de configuración, 20% los que opinan que es marginalmente urgente, 15% que es muy urgente, 12.5% nada urgente y finalmente 0.5% los que indican que es extremadamente urgente.

35. Monitorear continuamente los criterios de desempeño especificados para el nivel de servicio. Los reportes sobre el cumplimiento de los niveles de servicio deben emitirse en un formato que sea entendible para los interesados. Las estadísticas de monitoreo son analizadas para identificar tendencias positivas y negativas tanto de servicios individuales como de los servicios en conjunto.

Figura 89. Monitoreo y reporte del cumplimento de los niveles de servicio



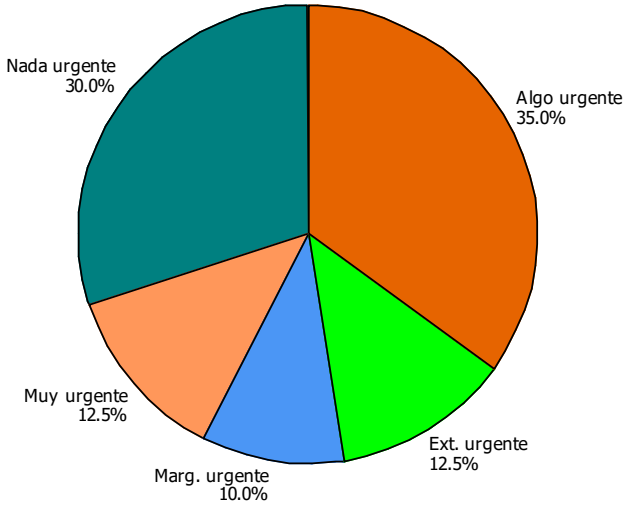
Cuadro 92. Monitoreo y reporte del cumplimento de los niveles de servicio

	Total	Porcentaje
Extremada. Urgente 100%	3	7.5
Muy urgente 75%	4	10.0
Marginal. Urgente 50%	12	30.0
Algo urgente 25%	16	40.0
Nada urgente 0%	5	12.5
Total	40	100.0

La gráfica nos muestra que el que el 40% de los encuestados contestó que es algo urgente el monitoreo y reporte del cumplimento de los niveles de servicio, seguido del 30% de los que piensan que es marginalmente urgente, 12.5% que es nada urgente, 10% muy urgente y 7.5% respondieron que es extremadamente urgente.

36. Identificar y mitigar los riesgos relacionados con la habilidad de los proveedores para mantener un efectivo servicio de entrega de forma segura y eficiente sobre una base de continuidad. Asegurar que los contratos están de acuerdo con los requerimientos legales y regulatorios de los estándares universales del negocio. La administración del riesgo debe considerar además acuerdos de confidencialidad (NDAs), contratos de garantía, viabilidad de la continuidad del proveedor, conformidad con los requerimientos de seguridad, proveedores alternativos, penalizaciones e incentivos, etc.

Figura 90. Administración de riesgos del proveedor



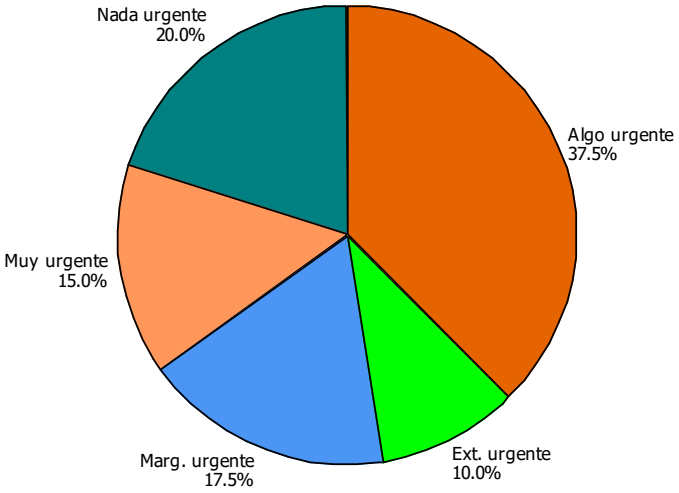
Cuadro 93. Administración de riesgos del proveedor

		Total	Porcentaje
Extremada. Urgente	100%	5	12.5
Muy urgente	75%	5	12.5
Marginal. Urgente	50%	4	10.0
Algo urgente	25%	14	35.0
Nada urgente	0%	12	30.0
Total		40	100.0

La gráfica nos muestra que el 35.0% de los encuestados opina que es algo urgente que es establezca una administración del riesgos del proveedor, 30.0% nada urgente, 12.5% opinan que es extremadamente urgente y el 10.0% que es marginalmente urgente.

37. Definir claramente y comunicar las características de incidentes de seguridad potenciales para que puedan ser clasificados propiamente y tratados por el proceso de gestión de incidentes y problemas.

Figura 91. Definición de incidente de seguridad



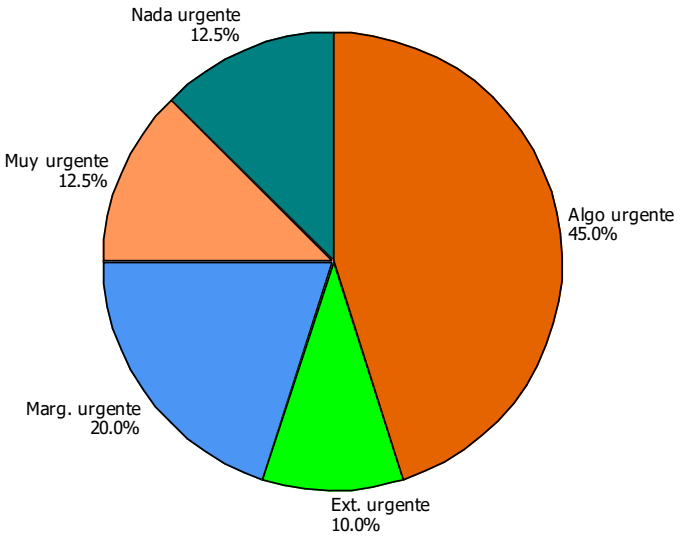
Cuadro 94. Definición de incidente de seguridad

	Total	Porcentaje
Extremada. Urgente 100%	4	10.0
Muy urgente 75%	6	15.0
Marginal. Urgente 50%	7	17.5
Algo urgente 25%	15	37.5
Nada urgente 0%	8	20.0
Total	40	100.0

Del total de encuestados el 37.5% indicó que es algo urgente la definición de incidentes de seguridad, 20.0% respondieron nada urgente, seguidos de los que consideran que es marginalmente urgente 17.5%, muy urgente con un 15.0% y extremadamente urgente 10.0%.

38. Establecer procedimientos de mesa de servicios de manera que los incidentes que no puedan resolverse de forma inmediata sean escalados apropiadamente de acuerdo con los límites acordados en el SLA y, si es adecuado, brindar soluciones alternas. Garantizar que la asignación de incidentes y el monitoreo del ciclo de vida permanecen en la mesa de servicios, independientemente de qué grupo de TI esté trabajando en las actividades de resolución.

Figura 92. Escalamiento de incidentes



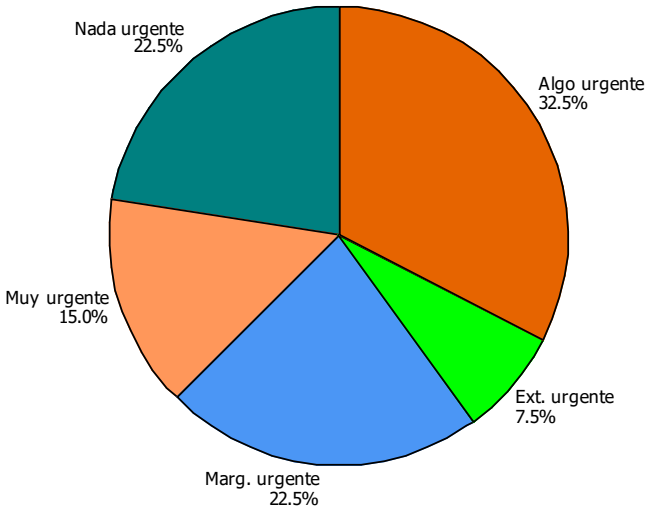
Cuadro 95. Escalamiento de incidentes

	Total	Porcentaje
Extremada. Urgente 100%	4	10.0
Muy urgente 75%	5	12.5
Marginal. Urgente 50%	8	20.0
Algo urgente 25%	18	45.0
Nada urgente 0%	5	12.5
Total	40	100.0

La gráfica nos muestra que el 45.0% de los encuestados, respondió que es algo urgente que haya un escalamiento de incidentes, 20.0% los que piensan que es marginalmente urgente, con el mismo porcentaje (12.5%) los que consideran que es muy y nada urgente y finalmente los que indican que es extremadamente urgente con 10.0%.

39. Garantizar que la implementación de la seguridad en TI sea probada y monitoreada de forma pro-activa. La seguridad en TI debe ser reacreditada periódicamente para garantizar que se mantiene el nivel seguridad aprobado. Una función de ingreso al sistema (logging) y de monitoreo permite la detección oportuna de actividades inusuales o anormales que pueden requerir atención.

Figura 93. Pruebas, vigilancia y monitoreo de la seguridad



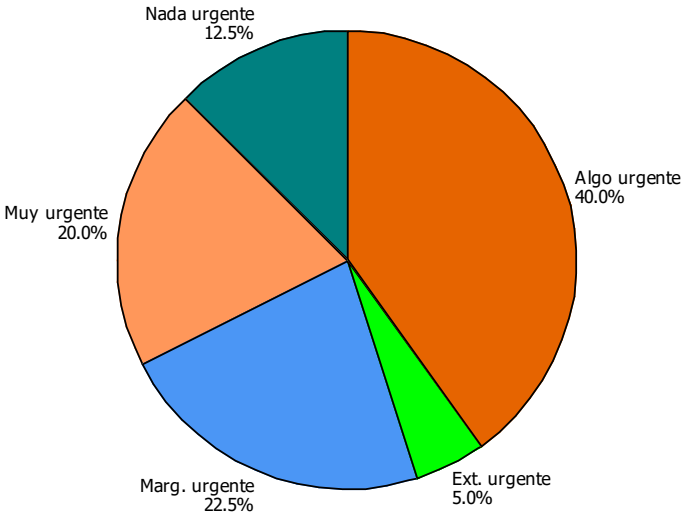
Cuadro 96. Pruebas, vigilancia y monitoreo de la seguridad

		Total	Porcentaje
Extremada. Urgente	100%	3	7.5
Muy urgente	75%	6	15.0
Marginal. Urgente	50%	9	22.5
Algo urgente	25%	13	32.5
Nada urgente	0%	9	22.5
Total		40	100.0

La mayoría de los encuestados (32.5%) opinan que es algo urgente establecer pruebas, vigilancia y monitoreo de la seguridad, el 22.5% contestaron con el mismo porcentaje que es nada urgente y muy urgente respectivamente, el 15.0% indicaron que es muy urgente y el 7.5% que es extremadamente urgente.

40. Monitorear de forma continua, comparar y mejorar el ambiente de control de TI y el marco de trabajo de control de TI para satisfacer los objetivos organizacionales.

Figura 94. Monitoreo del marco de trabajo de control interno.



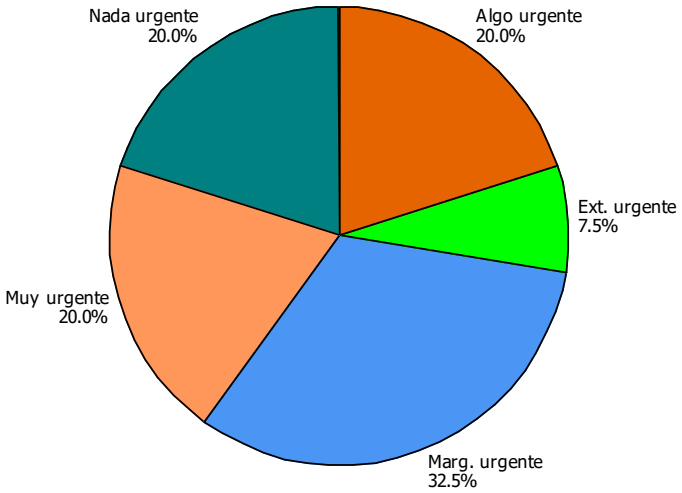
Cuadro 97. Monitoreo del marco de trabajo de control interno.

		Total	Porcentaje
Extremada. Urgente	100%	2	5.0
Muy urgente	75%	8	20.0
Marginal. Urgente	50%	9	22.5
Algo urgente	25%	16	40.0
Nada urgente	0%	5	12.5
Total		40	100.0

La gráfica nos muestra que el 40.0% de los encuestados respondieron que es algo urgente que el monitores del marco de trabajo de control interno, mientras que el 22.5% considera que es marginalmente urgente, el 20.0% contestaron que es muy urgente, el 12.5 que es nada urgente y 5.0% que es extremadamente urgente.

41. Evaluar el estado de los controles internos de los proveedores de servicios externos. Confirmar que los proveedores de servicios externos cumplen con los requerimientos legales y regulatorios y obligaciones contractuales.

Figura 95. Control interno para terceros



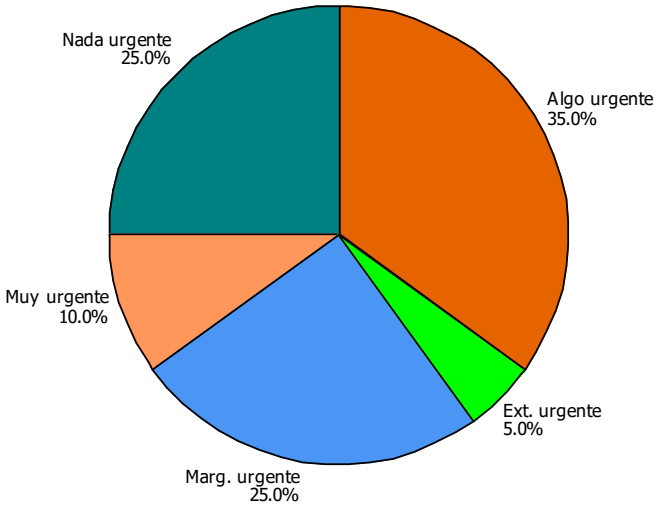
Cuadro 98. Control interno para terceros

		Total	Porcentaje
Extremada. Urgente	100%	3	7.5
Muy urgente	75%	8	20.0
Marginal. Urgente	50%	13	32.5
Algo urgente	25%	8	20.0
Nada urgente	0%	8	20.0
Total		40	100.0

La mayoría de los encuestados (32.5%) respondieron que es marginalmente urgente evaluar el estado de control interno para terceros, mientras que con el mismo porcentaje (20.0%) opinaron que es muy urgente, algo urgente y nada urgente y finalmente los que contestaron que es extremadamente urgente es un porcentaje de 7.5%.

42. Confirmar el cumplimiento de políticas, estándares, procedimientos y metodologías de TI con requerimientos legales y regulatorios.

Figura 96. Evaluación del cumplimiento con requerimientos externos



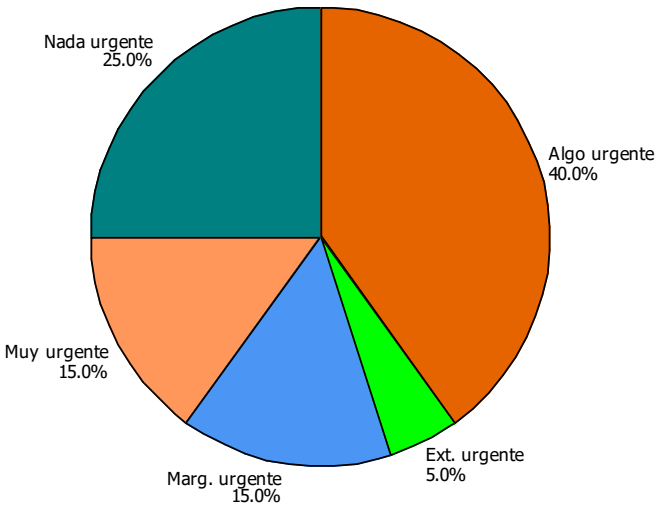
Cuadro 99. Evaluación del cumplimiento con requerimientos externos

	Total	Porcentaje
Extremada. Urgente 100%	2	5.0
Muy urgente 75%	4	10.0
Marginal. Urgente 50%	10	25.0
Algo urgente 25%	14	35.0
Nada urgente 0%	10	25.0
Total	40	100.0

La gráfica muestra con un 35.0% a los encuestados que respondieron que es necesaria la evaluación del cumplimiento con requerimientos externos, con 25.0% respectivamente los que opinan que es marginalmente urgente y nada urgente, muy urgente opinan el 10.0% y extremadamente urgente un 5.0%.

43. Garantizar de forma independiente (interna o externa) la conformidad de TI con la legislación y regulación relevante; las políticas de la organización, estándares y procedimientos; prácticas generalmente aceptadas; y la efectividad y eficiencia del desempeño de TI.

Figura 97. Aseguramiento independiente



Cuadro 100. Aseguramiento independiente

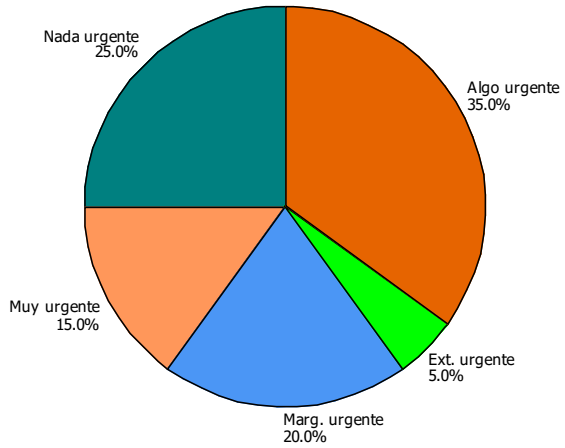
	Total	Porcentaje
Extremada. Urgente 100%	2	5.0
Muy urgente 75%	6	15.0
Marginal. Urgente 50%	6	15.0
Algo urgente 25%	16	40.0
Nada urgente 0%	10	25.0
Total	40	100.0

La gráfica muestra que el 40.0% opinan que es algo urgente garantizar el aseguramiento independiente, seguido del porcentaje de los que contestaron que es nada urgente 25.0%, mientras que el 15.0% opinan con el mismo porcentaje que es marginalmente urgente y muy urgente y finalmente el 5.0% los que indican que es extremadamente urgente.

.

44. Asegurar que todos los usuarios (internos, externos y temporales) y su actividad en sistemas de TI (aplicación de negocio, entorno de TI, operación de sistemas, desarrollo y mantenimiento) deben ser identificables de manera única. Permitir que el usuario se identifique a través de mecanismos de autenticación. Confirmar que los permisos de acceso del usuario al sistema y los datos están en línea con las necesidades del negocio definidas y documentadas y que los requerimientos de trabajo están adjuntos a las identidades del usuario. Asegurar que los derechos de acceso del usuario se solicitan por la UTSIT del usuario, aprobados por el responsable del sistema e implementado por la persona responsable de la seguridad. Las identidades del usuario y los derechos de acceso se mantienen en un repositorio central. Se despliegan técnicas efectivas en coste y procedimientos rentables, y se mantienen actualizados para establecer la identificación del usuario, realizar la autenticación y habilitar los derechos de acceso.

Figura 98. Administración de identidad



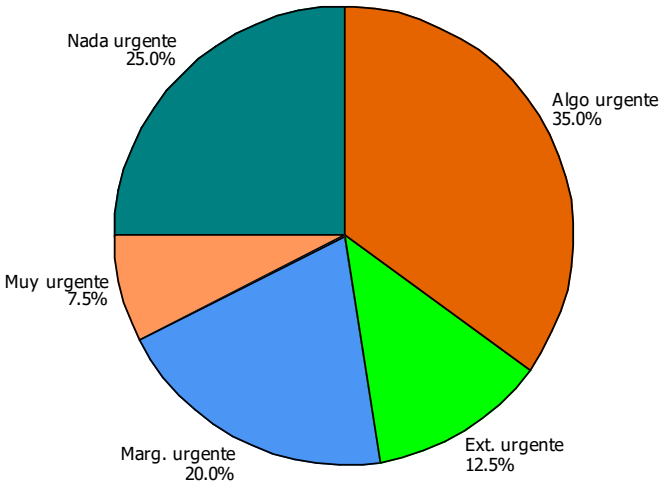
Cuadro 101. Administración de identidad

	Total	Porcentaje
Extremada. Urgente 100%	2	5.0
Muy urgente 75%	6	15.0
Marginal. Urgente 50%	8	20.0
Algo urgente 25%	14	35.0
Nada urgente 0%	10	25.0
Total	40	100.0

La gráfica nos muestra que el 35.0% de los encuestados respondieron que es algo urgente 35.0% asegurar la administración de la identidad, seguido del 25.0% de los que indican que es nada urgente, 20.0% el porcentaje de los que indicaron que es marginalmente urgente, 15.0% para muy urgente y extremadamente urgente 5.0%.

45. Garantizar que la solicitud, establecimiento, emisión, suspensión, modificación y cierre de cuentas de usuario y de los privilegios relacionados, sean tomados en cuenta por un conjunto de procedimientos de la gerencia de cuentas de usuario. Debe incluirse un procedimiento de aprobación que describa al responsable de los datos o del sistema otorgando los privilegios de acceso. Estos procedimientos deben aplicarse a todos los usuarios, incluyendo administradores (usuarios privilegiados), usuarios externos e internos, para casos normales y de emergencia. Los derechos y obligaciones relativos al acceso a los sistemas e información de la empresa deben acordarse contractualmente para todos los tipos de usuarios. Realizar revisiones regulares de la gestión de todas las cuentas y los privilegios asociados.

Figura 99. Administración de cuentas del usuario



Cuadro 102. Administración de cuentas del usuario

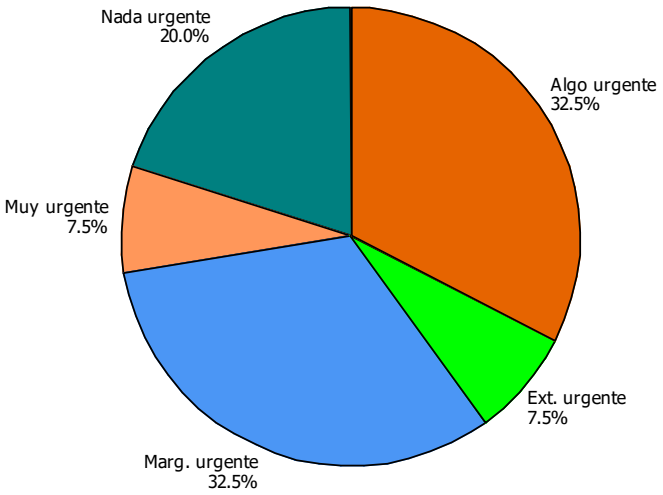
	Total	Porcentaje
Extremada. Urgente 100%	5	12.5
Muy urgente 75%	3	7.5
Marginal. Urgente 50%	8	20.0
Algo urgente 25%	14	35.0
Nada urgente 0%	10	25.0
Total	40	100.0

La gráfica nos muestra que el 35.0% contestaron que es algo urgente garantizar la administración de cuentas de usuario, seguido del 25.0% de los que piensan que es nada urgente, los que opinan que es marginalmente urgente 20.0%, 12.5% los que indicaron que es extremadamente urgente y finalmente el 7.5% opina que es muy urgente.

Resultados de la percepción del sentido de urgencia – Tecnología

46. Implementar medidas de control interno, seguridad y auditabilidad durante la configuración, integración y mantenimiento del hardware y del software de la infraestructura para proteger los recursos y garantizar su disponibilidad e integridad. Se deben definir y comprender claramente las responsabilidades al utilizar componentes de infraestructura sensitivos por todos aquellos que desarrollan e integran los componentes de infraestructura. Se debe monitorear y evaluar su uso.

Figura 100. Protección y disponibilidad del recurso de infraestructura



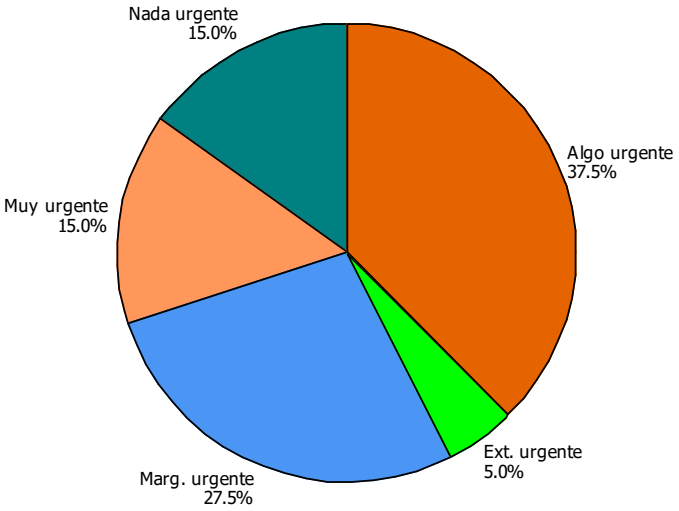
Cuadro 103. Protección y disponibilidad del recurso de infraestructura

	Total	Porcentaje
Extremada. Urgente 100%	3	7.5
Muy urgente 75%	3	7.5
Marginal. Urgente 50%	13	32.5
Algo urgente 25%	13	32.5
Nada urgente 0%	8	20.0
Total	40	100.0

El 32.5% de los encuestados indican que es marginalmente urgente y algo urgente con el mismo porcentaje la protección y disponibilidad del recurso de infraestructura, mientras que los que opinan que es nada urgente son un 20.0% y con el mismo porcentaje 7.5% respectivamente se encuentran los que respondieron que es extremadamente urgente y muy urgente.

47. Desarrollar una estrategia y un plan de mantenimiento de la infraestructura y garantizar que se controlan los cambios, de acuerdo con el procedimiento de administración de cambios de la organización. Incluir una revisión periódica contra las necesidades del negocio, administración de parches y estrategias de actualización, riesgos, evaluación de vulnerabilidades y requerimientos de seguridad.

Figura 101. Mantenimiento de la infraestructura



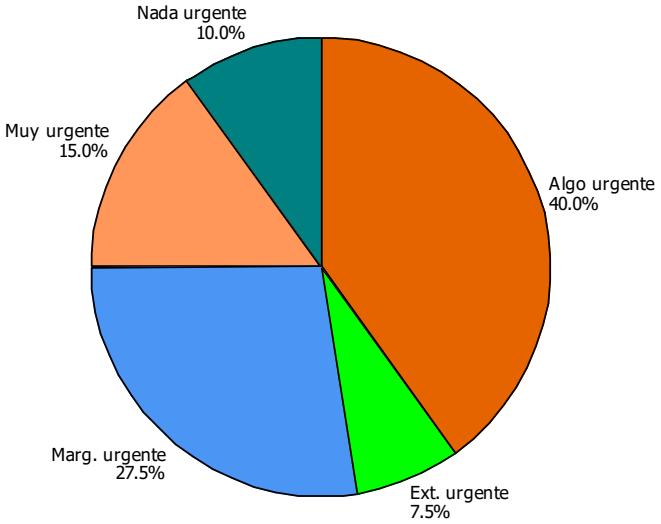
Cuadro 104. Mantenimiento de la infraestructura

		Total	Porcentaje
Extremada. Urgente	100%	2	5.0
Muy urgente	75%	6	15.0
Marginal. Urgente	50%	11	27.5
Algo urgente	25%	15	37.5
Nada urgente	0%	6	15.0
Total		40	100.0

La gráfica nos muestra con un 37.5% los que respondieron que es algo urgente el mantenimiento de la infraestructura, seguido del 27.5% de los que opinan que es marginalmente urgente, el 15% con el mismo porcentaje se encuentran los que piensan que es muy urgente y nada urgente y finalmente los que piensan que es extremadamente urgente son un 5.0%.

48. Determinar que las políticas y procedimientos para organizar la generación, cambio, revocación, destrucción, distribución, certificación, almacenamiento, captura, uso y archivo de llaves criptográficas estén implantadas, para garantizar la protección de las llaves contra modificaciones y divulgación no autorizadas.

Figura 102. Administración de llaves criptográficas



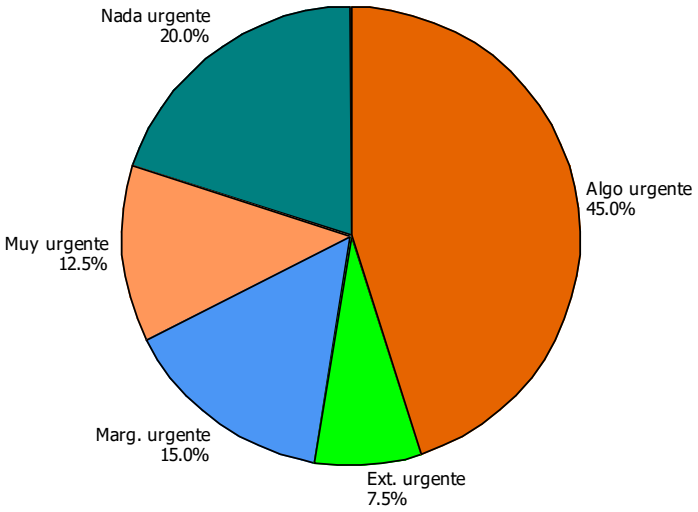
Cuadro 105. Administración de llaves criptográficas

	Total	Porcentaje
Extremada. Urgente 100%	3	7.5
Muy urgente 75%	6	15.0
Marginal. Urgente 50%	11	27.5
Algo urgente 25%	16	40.0
Nada urgente 0%	4	10.0
Total	40	100.0

La mayoría de los encuestados 40% indicaron que es algo urgente el establecimiento de administración de llaves criptográficas, el 27.5% que es marginalmente urgente, muy urgente el 15.0%, nada urgente 10.0% y extremadamente urgente 7.5%.

49. Uso de técnicas de seguridad y procedimientos de administración asociados (por ejemplo, firewalls, dispositivos de seguridad, segmentación de redes, y detección de intrusos) para autorizar acceso y controlar los flujos de información desde y hacia las redes.

Figura 103. Seguridad de la red



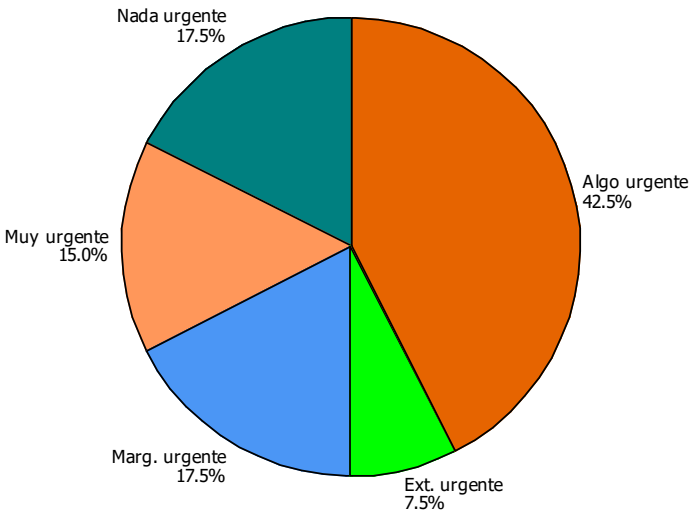
Cuadro 106. Seguridad de la red

		Total	Porcentaje
Extremada. Urgente	100%	3	7.5
Muy urgente	75%	5	12.5
Marginal. Urgente	50%	6	15.0
Algo urgente	25%	18	45.0
Nada urgente	0%	8	20.0
Total		40	100.0

La gráfica nos muestra que 45.0% contestaron que es algo urgente establecer seguridad en la red, seguido del porcentaje de 20.0% de los que piensan que es nada urgente, el 15.0% marginalmente urgente, muy urgente 12.5% y finalmente 7.5% los que opinan que es extremadamente urgente.

50. Transacciones de datos sensibles (confidenciales) se intercambian solo a través de una ruta o medio con controles para proporcionar autenticidad de contenido, prueba de envío, prueba de recepción y no repudio del origen.

Figura 104. Intercambio de datos sensitivos



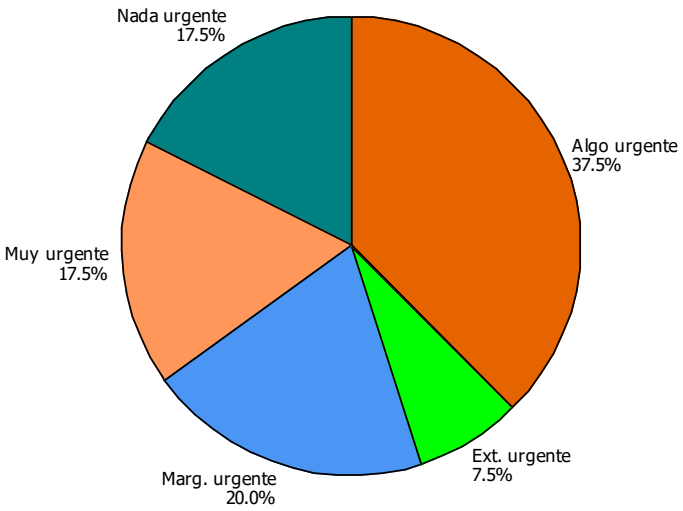
Cuadro 107. Intercambio de datos sensitivos

		Total	Porcentaje
Extremada. Urgente	100%	3	7.5
Muy urgente	75%	6	15.0
Marginal. Urgente	50%	7	17.5
Algo urgente	25%	17	42.5
Nada urgente	0%	7	17.5
Total		40	100.0

La gráfica nos muestra que el 42.5% opinan que es algo urgente establecer como debe ser el intercambio de datos sensitivos, seguido del 17.5% que con el mismo porcentaje opinan que es nada urgente y marginalmente urgente respectivamente, el 15.0% muy urgente y 7.5% extremadamente urgente.

51. Poner medidas preventivas, detectivas y correctivas (en especial contar con parches de seguridad y control de virus actualizados) en toda la organización para proteger los sistemas de la información y a la tecnología contra malware (virus, gusanos, spyware, correo basura).

Figura 105. Prevención, detección y corrección de software malicioso



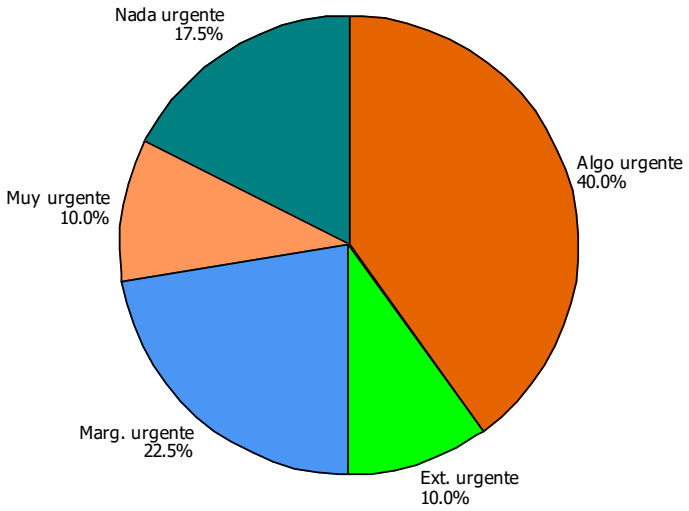
Cuadro 108. Prevención, detección y corrección de software malicioso

	Total	Porcentaje
Extremada. Urgente 100%	3	7.5
Muy urgente 75%	7	17.5
Marginal. Urgente 50%	8	20.0
Algo urgente 25%	15	37.5
Nada urgente 0%	7	17.5
Total	40	100.0

La mayoría de los encuestados indicaron que es algo urgente, el 37.5% la Prevención, detección y corrección de software malicioso, mientras que el 20% marginalmente urgente, con el mismo porcentaje los que opina que es muy urgente, nada urgente y marginalmente urgente con un 17.5% respectivamente y extremadamente urgente 7.5%.

52. Garantizar que la tecnología relacionada con la seguridad sea resistente al sabotaje y no revele documentación de seguridad innecesaria.

Figura 106. Protección de la tecnología de seguridad



Cuadro 109. Protección de la tecnología de seguridad

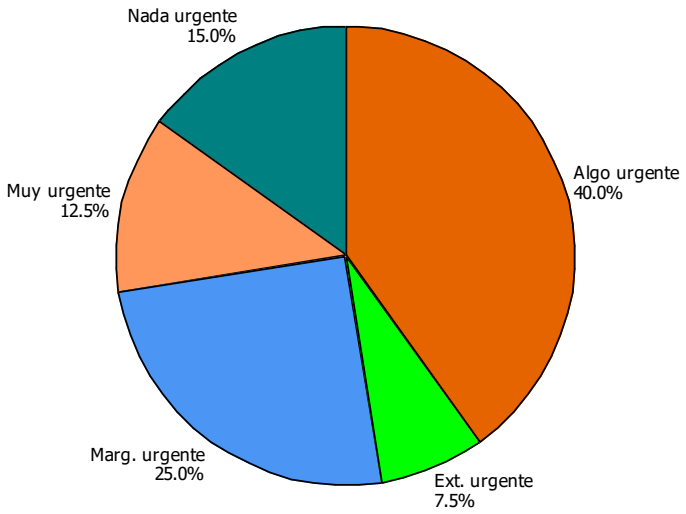
		Total	Porcentaje
Extremada. Urgente	100%	4	10.0
Muy urgente	75%	4	10.0
Marginal. Urgente	50%	9	22.5
Algo urgente	25%	16	40.0
Nada urgente	0%	7	17.5
Total		40	100.0

La gráfica nos muestra que es algo urgente 40.0% la protección de la tecnología de seguridad, seguido de los encuestados que opinan que es marginalmente urgente 22.5%, nada urgente 17.5% y extremadamente urgente 10.0%.

Resultados de la percepción del sentido de urgencia – Instalaciones

53. Definir e implementar medidas de seguridad físicas alineadas con los requerimientos del negocio. Las medidas deben incluir, pero no limitarse al esquema del perímetro de seguridad, de las zonas de seguridad, la ubicación de equipo crítico y de las áreas de envío y recepción. En particular, mantenga un perfil bajo respecto a la presencia de operaciones críticas de TI. Deben establecerse las responsabilidades sobre el monitoreo y los procedimientos de reporte y de resolución de incidentes de seguridad física.

Figura 107. Medidas de seguridad física



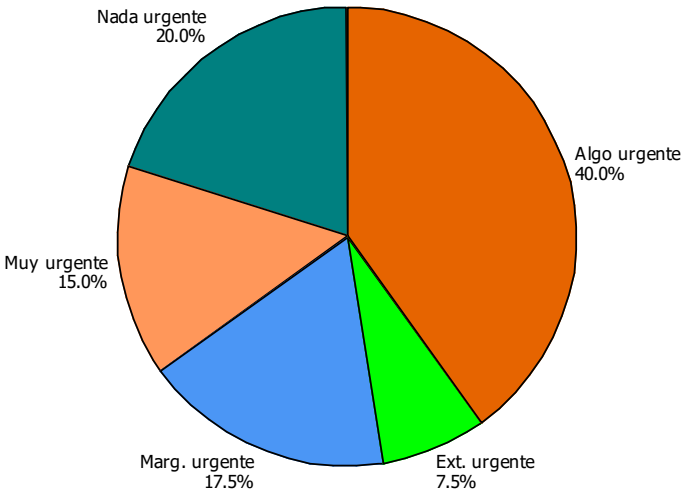
Cuadro 110. Medidas de seguridad física

	Total	Porcentaje
Extremada. Urgente 100%	3	7.5
Muy urgente 75%	5	12.5
Marginal. Urgente 50%	10	25.0
Algo urgente 25%	16	40.0
Nada urgente 0%	6	15.0
Total	40	100.0

La gráfica nos muestra que el 40.0% respondió que es algo urgente 40% el establecimiento de medidas de seguridad física, seguido de los que opinan que es marginalmente urgente, 25.0%, 15.0% de los que indican que es nada urgente, 12.5% opinan que es muy urgente y el 7.5% que es muy urgente.

54. Definir e implementar procedimientos para otorgar, limitar y revocar el acceso a locales, edificios y áreas de acuerdo con las necesidades del negocio, incluyendo las emergencias. El acceso a locales, edificios y áreas debe justificarse, autorizarse, registrarse y monitorearse. Esto aplica para todas las personas que accedan a las instalaciones, incluyendo personal, clientes, proveedores, visitantes o cualquier tercera persona.

Figura 108. Acceso físico



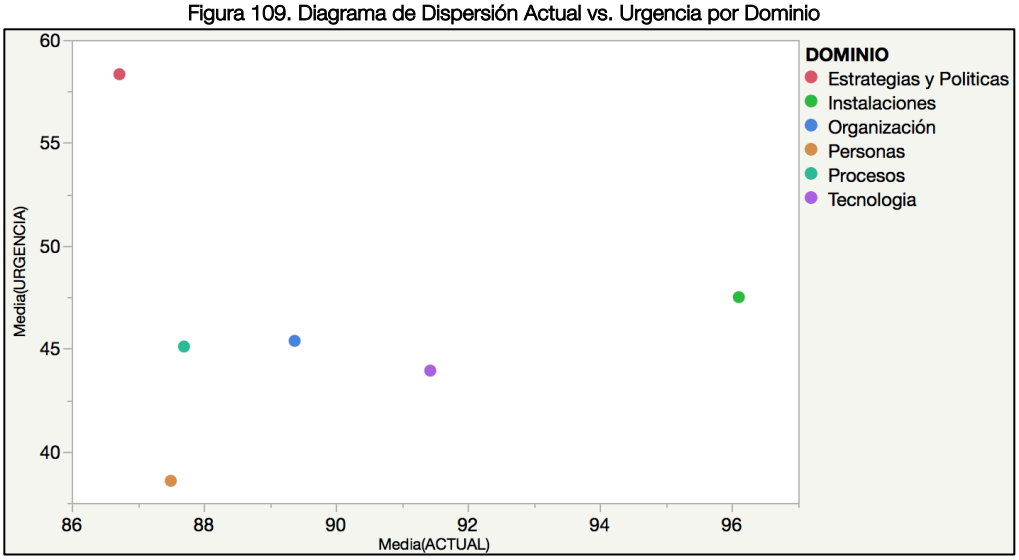
Cuadro 111. Acceso físico

	Total	Porcentaje
Extremada. Urgente 100%	3	7.5
Muy urgente 75%	6	15.0
Marginal. Urgente 50%	7	17.5
Algo urgente 25%	16	40.0
Nada urgente 0%	8	20.0
Total	40	100.0

La mayoría de los encuestados 40.0% respondieron que es algo urgente definir el acceso físico, seguido de los que indican que nada 20.0%, los que indicaron marginalmente urgente 17.5%, muy urgente 15.0% y 7.5% extremadamente urgente.

Análisis Bivariado Actual vs. Urgencia por Dominio

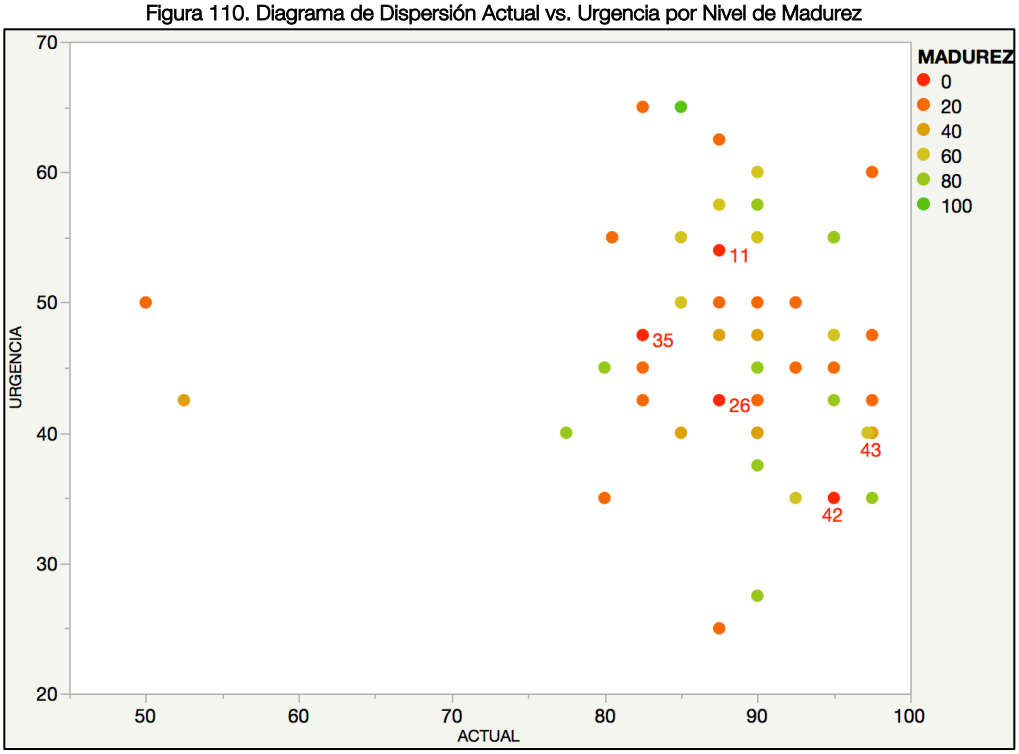
Figura 109. Diagrama de Dispersión Actual vs. Urgencia por Dominio



En el diagrama de dispersión se observa que el dominio Estrategias y Políticas es evaluado como el más bajo de la situación actual y urgencia alta. Los dominios de procesos y organización tienen una oportunidad pro-medio del 10%. Y el dominio personas presenta la urgencia más baja y situación actual baja. Una fortaleza de la situación actual son las instalaciones de TI.

Análisis Bivariado Actual vs. Urgencia por Nivel de Madurez

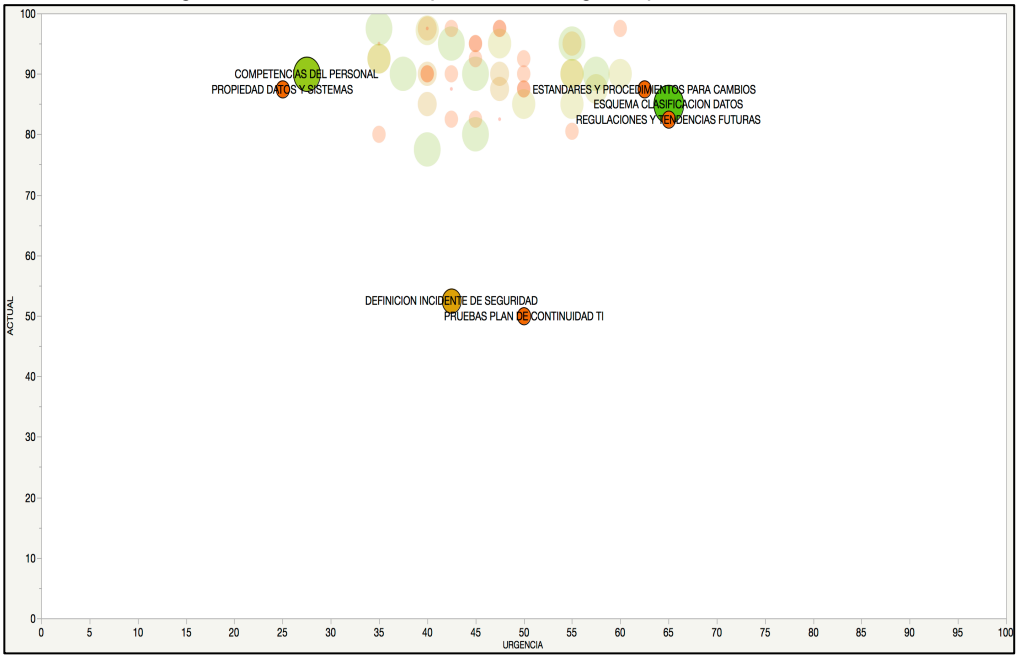
Figura 110. Diagrama de Dispersión Actual vs. Urgencia por Nivel de Madurez



En el diagrama de dispersión se rotulan cinco de los 54 aspectos como críticos para mejorar el nivel de madurez de la UTSIT para realizar gobernancia TI. Cuatro de ellas pertenecen al dominio de procesos (26-Planes de continuidad TI, 35-Monitoreo y reporte de cumplimiento de servicio, 42-Evaluación de cumplimineto con requerimientos externos y 43-Aseguramiento independiente) con un nivel de madurez nulo y la otra al dominio organización (11. Gestión de la organización).

Gráfico de Burbuja Actual vs. Urgencia por Nivel de Madurez

Figura 111. Gráfico de Burbujas Actual vs. Urgencia por Nivel de Madurez



En el gráfico de burbajas, el diámetro de a burbuja representa el nivel de madurez en verde es mayor nivel de madurez y en rojo menor nivel de madurez. Es notable que los aspectos competencias del personal (madurez alta) y propiedad de datos (madurez baja) son calificacos como poco urgentes y situación alta. La denifición de incidentes de seguridad y pruebas de plan de continuidad TI son aspectos críticos con oportunidad de su situación actual y urgencia alta además poseen un nivel de madurez medio.

Resultado de auditoría en sitio

Una auditoría interna consiste en la revisión de las operaciones de las diferentes áreas o actividades funcionales con la intención de informar acerca de sus fundamentos y promover mediante recomendaciones las mejoras oportunas dirigidas tanto a proteger los sistemas informáticos, como a optimizar los recursos disponibles.

El día 11 de mayo de 2015 se presentó el equipo auditor en las instalaciones del Instituto Electoral del Estado de Guanajuato (IEEG), para la realización de la auditoría en sitio, con el objetivo de identificar áreas de oportunidad de la Unidad Técnica de Sistemas de Información y Telecomunicaciones (UTSIT) para el desarrollo de sistemas Informáticos como PREP u otros proyectos de desarrollo futuros.

Figura 112. Auditoría en sitio



En la auditoría se evaluaron seis dominios: Políticas y Planeación, Organización, Procesos, Tecnología, Personas e Instalaciones, cada uno maneja una escala para identificar el nivel de madurez según lo analizado y observado.

Cuadro 112. Descripción de los dominios a auditar

Dominio	Criterio	Subcriterio
Estrategias y Políticas	1. Definir un plan de seguridad de la información	1a. Plan de seguridad de la información 1b. Gestión de políticas TI
	2. Definir la arquitectura de la información	2a. Modelo de arquitectura de la información de la empresa 2b. Esquema de clasificación de datos
	3. Determinar la dirección de la tecnología	3a. Monitorear las regulaciones y tendencias futuras 3b. Estándares de Tecnología
	4. Evaluar y gestionar los riesgos (TI)	4a. Framework de gestión de riesgos TI 4b. Evaluación de riesgos 4c. Mantenimiento y monitoreo de un plan de acción de riesgos
Organización	5. Organización de la seguridad de la información	5a. Responsabilidad para el riesgo, seguridad y conformidad 5b. Gestión de la seguridad de la información
	6. Propiedad de los datos y del sistema	6b. Propiedad de los datos y del sistema
	7. Administrar la segregación de funciones	7a. Segregación de funciones
Personas	8. Gestión de recursos humanos de TI	8a. Retención y reclutamiento de personal 8b. Competencias del personal 8c. Dependencia de los individuos 8d. Procedimientos de compensación del personal 8e. Cambio de empleo y terminación
	9. Asegurar el uso y las operaciones	9a. La transferencia de conocimientos a los usuarios finales 9b. La transferencia de conocimientos a las operaciones y personal de apoyo
Procesos	10. Gestión del cambio	10a. Cambio de estándares y procedimientos 10b. Evaluación de impacto, priorización y autorización 10c. Ambiente de la prueba 10d. Pruebas de cambios 10e. Promoción a la producción
	11. Gestión de la continuidad	11a. Los planes de continuidad de TI 11b. Pruebas del plan de continuidad de TI 11c. Almacenamiento de pruebas de seguridad remotas 11d. Copia de seguridad y restauración
	12. Gestión de los datos	12a. Acuerdos de retención y almacenamiento

Dominio	Criterio	Subcriterio
		12b. Disposición 12c. Requerimientos de seguridad para la gestión de los datos
	13. Gestión de la configuración	13a. Configuración del repositorio y línea base 13b. Identificación y mantenimiento de los elementos de configuración
	14. Gestión de terceros y servicios de proveedores	14a. Monitoreo y reportes de SLA's 14b. Proveedor de gestión de riesgos
	15. Gestión de incidentes	15a. Definición de seguridad del incidente 15b. Escalada de incidentes
	16. Monitoreo	16a. Pruebas de seguridad, vigilancia y monitoreo 16b. Monitoreo del framework de control interno 16c. Control interno de terceras partes 16d. La evaluación del cumplimiento con los requerimientos externos 16e. Aseguramiento de la independencia
	17. Gestión de la cuenta de usuario	17a. Gestión de la identificación 17b. Gestión de la cuenta de usuario
Tecnología	18. Seguridad de la infraestructura	18a. Disponibilidad y protección de los recursos de infraestructura. 18b. Mantenimiento de la infraestructura 18c. Administración de claves criptográficas 18d. Seguridad de la red 18e. El intercambio de datos confidenciales
	19. Gestión de ataques malware	19a. de software malicioso, detección y corrección
	20. Proteger los componentes de la infraestructura	20a. Protección de la tecnología de seguridad
Instalaciones	21. Seguridad Física	21a. Medición de la seguridad física 21b. Acceso físico

A continuación se presentan los resultados en la auditoría en sitio, con su respectiva escala de madurez para cada dominio. Se identificaron las principales fortalezas y se propusieron áreas de mejora.

Criterio 1: Definir un plan de seguridad de la información **Proporcionar dirección y mantenimiento para la seguridad de la información de acuerdo con el negocio, los riesgos y los requisitos de cumplimiento con la participación del negocio y las TI, para que las prioridades puedan ser de mutuo acuerdo.**					
Subcriterio 1a. Plan de seguridad de la información Negocio, riesgo y requerimientos de cumplimiento dentro de un plan general de seguridad de TI, tomando en cuenta la infraestructura de TI y la cultura de seguridad. El plan esta implementado dentro de las políticas de seguridad y procedimientos, junto con las inversiones adecuadas en servicios, personal, software y hardware. Las políticas de seguridad y procedimientos son comunicados a las partes interesadas y los usuarios.					
Fortalezas Se tiene un plan de seguridad de información, el plan de seguridad incluye funciones y responsabilidades, necesidades de personal, inversiones en seguridad. **Áreas de mejora** Mejorar la efectividad de la recolección e integración de los requisitos de seguridad de la información. Incorporar un proceso para la actualización periódica del plan de seguridad TI y y si el proceso requiere de niveles adecuados de revisión y aprobación de la gestión de cambios. Documentar el plan de seguridad de la información.					
No existente	**Inicial / Ad Hoc**	**Repetible pero Intuitivo**	**Definido**	**Administrado y Medible**	**Optimizado**
		X			

Interpretación del Modelo de Madurez
DS5. Garantizar la Seguridad de los Sistemas
0 No Existente La organización no reconoce la necesidad de la seguridad para TI. Las responsabilidades y la rendición de cuentas no están asignadas para garantizar la seguridad. Las medidas para soportar la administrar la seguridad de TI no están implementadas. No hay reportes de seguridad de TI ni un proceso de respuesta para resolver brechas de seguridad de TI. Hay una total falta de procesos reconocibles de administración de seguridad de sistemas. **1 Inicial / Ad Hoc** La organización reconoce la necesidad de seguridad para TI. La conciencia de la necesidad de seguridad depende principalmente del individuo. La seguridad de TI se lleva a cabo de forma reactiva. No se mide la seguridad de TI. Las brechas de seguridad de TI ocasionan respuestas con acusaciones personales, debido a que las responsabilidades no son claras. Las respuestas a las brechas de seguridad de TI son impredecibles. **2 Repetible pero Intuitivo** Las responsabilidades y la rendición de cuentas sobre la seguridad, están asignadas a un coordinador de seguridad de TI, pero la autoridad gerencial del coordinador es limitada. La conciencia sobre la necesidad de la seguridad esta fraccionada y limitada. Aunque los sistemas producen información relevante respecto a la seguridad, ésta no se analiza. Los servicios de terceros pueden no cumplir con los requerimientos específicos de seguridad de la empresa. Las políticas de seguridad se han estado desarrollando, pero las herramientas y las habilidades son inadecuadas. Los reportes de la seguridad de TI son incompletos, engañosos o no aplicables. El entrenamiento sobre seguridad está disponible pero depende principalmente de la iniciativa del individuo. La seguridad de TI es vista primordialmente como responsabilidad y disciplina de TI, y el negocio no ve la seguridad de TI como parte de su propia disciplina. **3 Definido** Existe conciencia sobre la seguridad y ésta es promovida por la gerencia. Los procedimientos de seguridad de TI están definidos y alineados con la política de seguridad de TI. Las responsabilidades de la seguridad de TI están asignadas y entendidas, pero no continuamente implementadas. Existe un plan de seguridad de TI y existen soluciones de seguridad motivadas por un análisis de riesgo. Los reportes no contienen un enfoque claro de negocio. Se realizan pruebas de seguridad adecuadas (por ejemplo, pruebas contra intrusos). Existe entrenamiento en seguridad para TI y para el negocio, pero se programa y se comunica de manera informal. **4 Administrado y Medible** Las responsabilidades sobre la seguridad de TI son asignadas, administradas e implementadas de forma clara. Regularmente se lleva a cabo un análisis de impacto y de riesgos de seguridad. Las políticas y prácticas de seguridad se complementan con referencias de seguridad específicas. El contacto con métodos para promover la conciencia de la seguridad es obligatorio. La identificación, autenticación y autorización de los usuarios está estandarizada. La certificación en seguridad es buscada por parte del personal que es responsable de la auditoría y la administración de la seguridad. Las pruebas de seguridad se hacen utilizando procesos estándares y formales que llevan a mejorar los niveles de seguridad. Los procesos de seguridad de TI están coordinados con la función de seguridad de toda la organización. Los reportes de seguridad están ligados con los objetivos del negocio. El entrenamiento sobre seguridad se imparte tanto para TI como para el negocio. El entrenamiento sobre seguridad de TI se planea y se administra de manera que responda a las necesidades del negocio y a los perfiles de riesgo de seguridad. Los KGIs y KPIs ya están definidos pero no se miden aún. **5 Optimizado** La seguridad en TI es una responsabilidad conjunta del negocio y de la gerencia de TI y está integrada con los objetivos de seguridad del negocio en la corporación. Los requerimientos de seguridad de TI están definidos de forma clara, optimizados e incluidos en un plan de seguridad aprobado. Los usuarios y los clientes se responsabilizan cada vez más de definir requerimientos de seguridad, y las funciones de seguridad están integradas con las aplicaciones en la fase de diseño. Los incidentes de seguridad son atendidos de forma inmediata con procedimientos formales de respuesta soportados por herramientas automatizadas. Se llevan a cabo valoraciones de seguridad de forma periódica para evaluar la efectividad de la implementación del plan de seguridad. La información sobre amenazas y vulnerabilidades se recolecta y analiza de manera sistemática. Se recolectan e implementan de forma oportuna controles adecuados para mitigar riesgos. Se llevan a cabo pruebas de seguridad, análisis de causa-efecto e identificación pro-activa de riesgos para la mejora continua de procesos. Los procesos de seguridad y la tecnología están integrados a lo largo de toda la organización. Los KGIs y KPIs para administración

Criterio 1: Definir un plan de seguridad de la información **Proporcionar dirección y mantenimiento para la seguridad de la información de acuerdo con el negocio, los riesgos y los requisitos de cumplimiento con la participación del negocio y las TI, para que las prioridades puedan ser de mutuo acuerdo.**					
Subcriterio 1b. Gestión de políticas TI Desarrollar y mantener un grupo de políticas para soportar la estrategia de seguridad de la información; procesos de excepción; enfoque de cumplimiento; y referencias para procedimientos, estándares y directrices para el desarrollo, adquisición, mantenimiento y soporte. Su relevancia debe ser confirmada y aprobada regularmente.					
Fortalezas Se tienen politicas sobre la calidad, seguridad, confidencialidad, controles internos. La politica se actualiza al menos una vez al año. **Áreas de mejora** Mejorar la efectividad de la recolección e integración de los requisitos de seguridad de la información, Robustecer un conjunto jerárquico de las políticas, normas y procedimientos y que se alinea con la estrategia de seguridad de la información y entorno de control. Documentar políticas específicas sobre la ética y los derechos de propiedad intelectual. Pregunte si existe y confirme si el proceso de actualización de la política se ha definido, que es lo que requiere, como mínimo y las revisiones anuales. Desarrollar procedimientos se realizar un seguimiento del cumplimiento y definir las consecuencias de su incumplimiento.					
No existente	**Inicial / Ad Hoc**	**Repetible pero Intuitivo**	**Definido**	**Administrado y Medible**	**Optimizado**
		X			

Interpretación del Modelo de Madurez
PO6. Comunicar las Aspiraciones y la Dirección de la Gerencia.
0 No Existente La gerencia no ha establecido un ambiente positivo de control de información. No hay reconocimiento de la necesidad de establecer un conjunto de políticas, procedimientos, estándares y procesos de cumplimiento. **1 Inicial / Ad Hoc** La gerencia es reactiva al resolver los requerimientos del ambiente de control de información. Las políticas, procedimientos y se elaboran y comunican de forma ad hoc de acuerdo a los temas. Los procesos de elaboración, comunicación y son informales e inconsistentes. **2 Repetible pero Intuitivo** La gerencia tiene un entendimiento implícito de las necesidades y de los requerimientos de un ambiente de control de información efectivo, aunque las prácticas son en su mayoría informales. La gerencia ha comunicado la necesidad de políticas, procedimientos y estándares de control, pero la elaboración se delega a la discreción de gerentes y áreas de negocio individuales. La calidad se reconoce como una filosofía deseable a seguir, pero las prácticas se dejan a discreción de gerentes individuales. El entrenamiento se realiza de forma individual, según se requiera. **3 Definido** La gerencia ha elaborado, documentado y comunicado un ambiente completo de administración de calidad y control de la información, que incluye un marco para las políticas, procedimientos y estándares. El proceso de elaboración de políticas es estructurado, mantenido y conocido por el personal, y las políticas, procedimientos y estándares existentes son razonablemente sólidos y cubren temas clave. La gerencia ha reconocido la importancia de la conciencia de la seguridad de TI y ha iniciado programas de concienciación. El entrenamiento formal está disponible para apoyar al ambiente de control de información, aunque no se aplica de forma rigurosa. Aunque existe un marco general de desarrollo para las políticas y estándares de control, el monitoreo del cumplimiento de estas políticas y estándares es inconsistente. Las técnicas para fomentar la conciencia de la seguridad están estandarizadas y formalizadas. **4 Administrado y Medible** La gerencia asume la responsabilidad de comunicar las políticas de control interno y delega la responsabilidad y asigna suficientes recursos para mantener el ambiente en línea con los cambios significativos. Se ha establecido un ambiente de control de información positivo y proactivo. Se ha establecido un juego completo de políticas, procedimientos y estándares, los cuales se mantienen y comunican, y forman un componente de buenas prácticas internas. Se ha establecido un marco de trabajo para la implantación y las verificaciones subsiguientes de cumplimiento. **5 Optimizado** El ambiente de control de la información está alineado con el marco administrativo estratégico y con la visión, y con frecuencia se revisa, actualiza y mejora. Se asignan expertos internos y externos para garantizar que se adoptan las mejores prácticas de la industria, con respecto a las guías de control y a las técnicas de comunicación. El monitoreo, la auto-evaluación y las verificaciones de cumplimiento están extendidas en la organización. La tecnología se usa para mantener bases de conocimiento de políticas y de concienciación y para optimizar la comunicación, usando herramientas de automatización de oficina y de entrenamiento basado en computadora.

Criterio 2: Definir la arquitectura de la información **Asegurar que la información es confiable, segura y fiable para soportar los procesos del negocio y sin problemas integrar las aplicaciones dentro de los procesos del negocio.**					
Subcriterio 2a. Modelo de arquitectura de la información de la empresa Establecer y mantener un modelo de información de la empresa para permitir desarrollo de aplicaciones y actividades de toma decisiones y planes consistentes con TI. El modelo debe facilitar la creación óptima, usar y compartir la información del negocio de manera que se mantenga la integridad y sea flexible, funcional, costo efectivo, oportuno, seguro y resistente a la falla.					
Fortalezas Existe un modelo de información empresarial, basado en estándares aceptados y es conocido o adecuado y por los propietarios del negocio o interesados. El modelo es utilizado y mantenido en paralelo con el proceso, que se traduce en la estrategia de planes tácticos dentro de los proyectos. Se cuentan con métricas del modelo de arquitectura de la información. **Áreas de mejora** Mejorar la evaluación del modelo considerando la flexibilidad, funcionalidad, rentabilidad, seguridad, resistencia a la falla, cumplimiento, etc.					
No existente	**Inicial / Ad Hoc**	**Repetible pero Intuitivo**	**Definido**	**Administrado y Medible**	**Optimizado**
				X	

Interpretación del Modelo de Madurez
P02. Definir la Arquitectura de la Información.
0 No Existente No existe conciencia de la importancia de la arquitectura de la información para la organización. El conocimiento, la experiencia y las responsabilidades necesarias para desarrollar esta arquitectura no existen en la organización. **1 Inicial / Ad Hoc** La gerencia reconoce la necesidad de una arquitectura de información. El desarrollo de algunos componentes de una arquitectura de información ocurre de manera ad hoc. Las definiciones abarcan datos en lugar de información, y son impulsadas por ofertas de proveedores de software aplicativo. Existe una comunicación esporádica e inconsistente de la necesidad de una arquitectura de información. **2 Repetible pero Intuitivo** Surge un proceso de arquitectura de información y existen procedimientos similares, aunque intuitivos e informales, que se siguen por distintos individuos dentro de la organización. Las personas obtienen sus habilidades al construir la arquitectura de información por medio de experiencia práctica y la aplicación repetida de técnicas. Los requerimientos tácticos impulsan el desarrollo de los componentes de la arquitectura de la información por parte de los individuos. **3 Definido** La importancia de la arquitectura de la información se entiende y se acepta, y la responsabilidad de su aplicación se asigna y se comunica de forma clara. Los procedimientos, herramientas y técnicas relacionados, aunque no son sofisticados, se han estandarizado y documentado y son parte de actividades informales de entrenamiento. Se han desarrollado políticas básicas de arquitectura de información, incluyendo algunos requerimientos estratégicos, aunque el cumplimiento de políticas, estándares y herramientas no se refuerza de manera consistente. Existe una función de administración de datos definida formalmente, que establece estándares para toda la organización, y empieza a reportar sobre la aplicación y uso de la arquitectura de la información. Las herramientas automatizadas se empiezan a utilizar, aunque los procesos y reglas son definidos por los proveedores de software de bases de datos. Un plan formal de entrenamiento ha sido desarrollado, pero el entrenamiento formal se basa en iniciativas individuales. **4 Administrado y Medible** Se da soporte completo al desarrollo e implantación de la arquitectura de información por medio de métodos y técnicas formales. La responsabilidad sobre el desempeño del proceso de desarrollo de la arquitectura se refuerza y se mide el éxito de la arquitectura de información. Las herramientas automatizadas de soporte están ampliamente generalizadas, pero todavía no están integradas. Se han identificado métricas básicas y existe un sistema de medición. El proceso de definición de la arquitectura de información es proactivo y se enfoca en resolver necesidades futuras del negocio. La organización de administración de datos está activamente involucrada en todos los esfuerzos de desarrollo de las aplicaciones, para garantizar la consistencia. Un repositorio automatizado está totalmente implementado. Se encuentran en implantación modelos de datos más complejos para aprovechar el contenido informativo de las bases de datos. Los sistemas de información ejecutiva y los sistemas de soporte a la toma de decisiones aprovechan la información existente. **5 Optimizado** La arquitectura de información es reforzada de forma consistente a todos los niveles. El valor de la arquitectura de la información para el negocio se enfatiza de forma continua. El personal de TI cuenta con la experiencia y las habilidades necesarias para desarrollar y dar mantenimiento a una arquitectura de información robusta y sensible que refleje todos los requerimientos del negocio. La información provista por la arquitectura se aplica de modo consistente y amplio. Se hace un uso amplio de las mejores prácticas de la industria en el desarrollo y mantenimiento de la arquitectura de información incluyendo un proceso de mejora continua. La estrategia para el aprovechamiento de la información por medio de tecnologías de bodega de datos y minería de datos está bien definida. La arquitectura de la información se encuentra en mejora continua y toma en cuenta información no tradicional sobre los procesos, organizaciones y sistemas.

Criterio 2: Definir la arquitectura de la información **Asegurar que la información es confiable, segura y fiable para soportar los procesos del negocio y sin problemas integrar las aplicaciones dentro de los procesos del negocio.**					
2b. Esquema de clasificación de datos Establecer un esquema de clasificación que se aplique a través de la empresa, basado en la criticidad y sensibilidad (ej. Pública, confidencial, reservada) de los datos de la empresa. Este esquema debe incluir detalles sobre la propiedad de los datos; y una breve descripción de la retención de los datos y destrucción de requerimientos criticidad y sensibilidad. Estos deben ser usados como datos básicos para la aplicación de controles tales como controles de acceso, archivado o encriptación.					
Fortalezas Se tiene un esquema de clasificación de los datos, todos los componentes importantes estén cubiertos y completados, el sistema está en equilibrio razonable costo vs riesgo. Las clasificaciones de seguridad han sido impugnadas y confirmadas con los propietarios del negocio a intervalos regulares. **Áreas de mejora** No se identifica evidencia de áreas de mejora durante la auditoría.					
No existente	**Inicial / Ad Hoc**	**Repetible pero Intuitivo**	**Definido**	**Administrado y Medible**	**Optimizado**
					X

Interpretación del Modelo de Madurez
P02. Definir la Arquitectura de la Información.
0 No Existente No existe conciencia de la importancia de la arquitectura de la información para la organización. El conocimiento, la experiencia y las responsabilidades necesarias para desarrollar esta arquitectura no existen en la organización. **1 Inicial / Ad Hoc** La gerencia reconoce la necesidad de una arquitectura de información. El desarrollo de algunos componentes de una arquitectura de información ocurre de manera ad hoc. Las definiciones abarcan datos en lugar de información, y son impulsadas por ofertas de proveedores de software aplicativo. Existe una comunicación esporádica e inconsistente de la necesidad de una arquitectura de información. **2 Repetible pero Intuitivo** Surge un proceso de arquitectura de información y existen procedimientos similares, aunque intuitivos e informales, que se siguen por distintos individuos dentro de la organización. Las personas obtienen sus habilidades al construir la arquitectura de información por medio de experiencia práctica y la aplicación repetida de técnicas. Los requerimientos tácticos impulsan el desarrollo de los componentes de la arquitectura de la información por parte de los individuos. **3 Definido** La importancia de la arquitectura de la información se entiende y se acepta, y la responsabilidad de su aplicación se asigna y se comunica de forma clara. Los procedimientos, herramientas y técnicas relacionados, aunque no son sofisticados, se han estandarizado y documentado y son parte de actividades informales de entrenamiento. Se han desarrollado políticas básicas de arquitectura de información, incluyendo algunos requerimientos estratégicos, aunque el cumplimiento de políticas, estándares y herramientas no se refuerza de manera consistente. Existe una función de administración de datos definida formalmente, que establece estándares para toda la organización, y empieza a reportar sobre la aplicación y uso de la arquitectura de la información. Las herramientas automatizadas se empiezan a utilizar, aunque los procesos y reglas son definidos por los proveedores de software de bases de datos. Un plan formal de entrenamiento ha sido desarrollado, pero el entrenamiento formal se basa en iniciativas individuales. **4 Administrado y Medible** Se da soporte completo al desarrollo e implantación de la arquitectura de información por medio de métodos y técnicas formales. La responsabilidad sobre el desempeño del proceso de desarrollo de la arquitectura se refuerza y se mide el éxito de la arquitectura de información. Las herramientas automatizadas de soporte están ampliamente generalizadas, pero todavía no están integradas. Se han identificado métricas básicas y existe un sistema de medición. El proceso de definición de la arquitectura de información es proactivo y se enfoca en resolver necesidades futuras del negocio. La organización de administración de datos está activamente involucrada en todos los esfuerzos de desarrollo de las aplicaciones, para garantizar la consistencia. Un repositorio automatizado está totalmente implementado. Se encuentran en implantación modelos de datos más complejos para aprovechar el contenido informativo de las bases de datos. Los sistemas de información ejecutiva y los sistemas de soporte a la toma de decisiones aprovechan la información existente. **5 Optimizado** La arquitectura de información es reforzada de forma consistente a todos los niveles. El valor de la arquitectura de la información para el negocio se enfatiza de forma continua. El personal de TI cuenta con la experiencia y las habilidades necesarias para desarrollar y dar mantenimiento a una arquitectura de información robusta y sensible que refleje todos los requerimientos del negocio. La información provista por la arquitectura se aplica de modo consistente y amplio. Se hace un uso amplio de las mejores prácticas de la industria en el desarrollo y mantenimiento de la arquitectura de información incluyendo un proceso de mejora continua. La estrategia para el aprovechamiento de la información por medio de tecnologías de bodega de datos y minería de datos está bien definida. La arquitectura de la información se encuentra en mejora continua y toma en cuenta información no tradicional sobre los procesos, organizaciones y sistemas.

Criterio 3: Determinar la dirección de la tecnología
Proporcionar soluciones tecnológicas estables, eficaces y seguras en toda la empresa para permitir una respuesta oportuna a los requerimientos del negocio y los cambios en las leyes y regulaciones, la industria y los desarrollos tecnológicos.

Subcriterio 3a. Monitorear las regulaciones y tendencias futuras
Un proceso es establecido para monitorear el sector del negocio, industria, tecnología, infraestructura, tendencias entorno jurídico y reglamentario. Las consecuencias de estas tendencias son incorporadas dentro del desarrollo del plan de infraestructura de tecnologías de TI.

Fortalezas
Se asiste a eventos para mantenerse actualizado de tendencias en TI.

Áreas de mejora

No se tiene un responsable de monitorear las tendencias actuales y futuras y los reglamentos son controlados (ej., los avances tecnológicos, las actividades de la competencia, las cuestiones relativas a la infraestructura, los requisitos legales y reglamentarios, los cambios en el entorno de terceros expertos) y si los riesgos relacionados u oportunidades relacionadas para la creación de valor se evalúan correctamente.
No se comparte el resultado de la supervisión de las personas pertinentes (Comité de dirección TI) y para las tácticas TI y los procesos de planificación de la infraestructura para la acción.

No existente	Inicial / Ad Hoc	Repetible pero Intuitivo	Definido	Administrado y Medible	Optimizado
	X				

Interpretación del Modelo de Madurez
P03. Determinar la Dirección Tecnológica.
0 No Existente cuando No existe conciencia sobre la importancia de la planeación de la infraestructura tecnológica para la entidad. El conocimiento y la experiencia necesarios para desarrollar dicho plan de infraestructura tecnológica no existen. Hay una carencia de entendimiento de que la planeación del cambio tecnológico es crítica para asignar recursos de manera efectiva. **1 Inicial / Ad Hoc cuando** La gerencia reconoce la necesidad de planear la infraestructura tecnológica. El desarrollo de componentes tecnológicos y la implementación de tecnologías emergentes son ad hoc y aisladas. Existe un enfoque reactivo y con foco operativo hacia la planeación de la infraestructura. La dirección tecnológica está impulsada por los planes evolutivos, con frecuencia contradictorios, del hardware, del software de sistemas y de los proveedores de software aplicativo. La comunicación del impacto potencial de los cambios en la tecnología es inconsistente. **2 Repetible pero Intuitivo cuando** Se difunde la necesidad e importancia de la planeación tecnológica. La planeación es táctica y se enfoca en generar soluciones técnicas a problemas técnicos, en lugar de usar la tecnología para satisfacer las necesidades del negocio. La evaluación de los cambios tecnológicos se delega a individuos que siguen procesos intuitivos, aunque similares. Las personas obtienen sus habilidades sobre planeación tecnológica a través de un aprendizaje práctico y de una aplicación repetida de las técnicas. Están surgiendo técnicas y estándares comunes para el desarrollo de componentes de la infraestructura. **3 Definido cuando** La gerencia está consciente de la importancia del plan de infraestructura tecnológica. El proceso para el plan de infraestructura tecnológica es razonablemente sólido y está alineado con el plan estratégico de TI. Existe un plan de infraestructura tecnológica definido, documentado y bien difundido, aunque se aplica de forma inconsistente. La orientación de la infraestructura tecnológica incluye el entendimiento de dónde la empresa desea ser líder y dónde desea rezagarse respecto al uso de tecnología, con base en los riesgos y en la alineación con la estrategia organizacional. Los proveedores clave se seleccionan con base en su entendimiento de la tecnología a largo plazo y de los planes de desarrollo de productos, de forma consistente con la dirección de la organización. **4 Administrado y Medible cuando** La dirección garantiza el desarrollo del plan de infraestructura tecnológica. El equipo de TI cuenta con la experiencia y las habilidades necesarias para desarrollar un plan de infraestructura tecnológica. El impacto potencial de las tecnologías cambiantes y emergentes se toma en cuenta. La dirección puede identificar las desviaciones respecto al plan y anticipar los problemas. La responsabilidad del desarrollo y mantenimiento del plan de infraestructura tecnológica ha sido asignado. El proceso para desarrollar el plan de infraestructura tecnológica es sofisticado y sensible a los cambios. Se han incluido buenas prácticas internas en el proceso. La estrategia de recursos humanos está alineada con la dirección tecnológica, para garantizar que el equipo de TI pueda administrar los cambios tecnológicos. Los planes de migración para la introducción de nuevas tecnologías están definidos. Los recursos externos y las asociaciones se aprovechan para tener acceso a la experiencia y a las habilidades necesarias. La dirección ha evaluado la aceptación del riesgo de usar la tecnología como líder, o rezagarse en su uso, para desarrollar nuevas oportunidades de negocio o eficiencias operativas. **5 Optimizado cuando** Existe una función de investigación que revisa las tecnologías emergentes y evolutivas y para evaluar la organización por comparación contra las normas industriales. La dirección del plan de infraestructura tecnológica está impulsada por los estándares y avances industriales e internacionales, en lugar de estar orientada por los proveedores de tecnología. El impacto potencial de los cambios tecnológicos sobre el negocio se revisa al nivel de la alta dirección. Existe una aprobación ejecutiva formal para el cambio de la dirección tecnológica o para adoptar una nueva. La entidad cuenta con un plan robusto de infraestructura tecnológica que refleja los requerimientos del negocio, es sensible a los cambios en el ambiente del negocio y puede reflejar los cambios en éste. Existe un proceso continuo y reforzado para mejorar el plan de infraestructura tecnológica. Las mejores prácticas de la industria se usan de forma amplia para determinar la dirección técnica.

Criterio 3: Determinar la dirección de la tecnología
Proporcionar soluciones tecnológicas estables, eficaces y seguras en toda la empresa para permitir una respuesta oportuna a los requerimientos del negocio y los cambios en las leyes y regulaciones, la industria y los desarrollos tecnológicos.

Subcriterio 3b. Estándares de Tecnología
Soluciones tecnológicas coherentes, eficaces y seguros se ofrecen en toda la empresa, un foro de tecnología es establecido para proveer directrices de tecnología, asesoramiento en productos de infraestructura y directrices en la selección de la tecnología y el cumplimiento de estos estándares y directrices se mide. Este foro dirige estándares de tecnología y prácticas basadas en su relevancia del negocio, riesgos y el cumplimiento con los requisitos externos.

Fortalezas
Se sigue el estándar básico del ciclo de desarrollo.

Áreas de mejora

Los estándares tecnológicos corporativos están siendo aprobados por la UTSIT.
No se evalua la eficacia del proceso para la comunicación de las normas técnicas a los miembros del personal de TI (por ejemplo, los directores de proyectos, arquitectos de información).
Validar por medio de entrevistas al personal su comprensión de las normas técnicas.
Determinar a partir de la gestión de TI que el seguimiento y la evaluación comparativa de procesos se ponen en marcha para confirmar el cumplimiento de las normas y directrices tecnológicas establecidas.
Evaluar la documentación técnica de análisis de viabilidad de proyectos seleccionados para evaluar el cumplimiento de los estándares tecnológicos corporativos.

No existente	Inicial / Ad Hoc	Repetible pero Intuitivo	Definido	Administrado y Medible	Optimizado
	X				

Interpretación del Modelo de Madurez
P03. Determinar la Dirección Tecnológica.
0 No Existente cuando No existe conciencia sobre la importancia de la planeación de la infraestructura tecnológica para la entidad. El conocimiento y la experiencia necesarios para desarrollar dicho plan de infraestructura tecnológica no existen. Hay una carencia de entendimiento de que la planeación del cambio tecnológico es crítica para asignar recursos de manera efectiva. **1 Inicial / Ad Hoc cuando** La gerencia reconoce la necesidad de planear la infraestructura tecnológica. El desarrollo de componentes tecnológicos y la implementación de tecnologías emergentes son ad hoc y aisladas. Existe un enfoque reactivo y con foco operativo hacia la planeación de la infraestructura. La dirección tecnológica está impulsada por los planes evolutivos, con frecuencia contradictorios, del hardware, del software de sistemas y de los proveedores de software aplicativo. La comunicación del impacto potencial de los cambios en la tecnología es inconsistente. **2 Repetible pero Intuitivo cuando** Se difunde la necesidad e importancia de la planeación tecnológica. La planeación es táctica y se enfoca en generar soluciones técnicas a problemas técnicos, en lugar de usar la tecnología para satisfacer las necesidades del negocio. La evaluación de los cambios tecnológicos se delega a individuos que siguen procesos intuitivos, aunque similares. Las personas obtienen sus habilidades sobre planeación tecnológica a través de un aprendizaje práctico y de una aplicación repetida de las técnicas. Están surgiendo técnicas y estándares comunes para el desarrollo de componentes de la infraestructura. **3 Definido cuando** La gerencia está consciente de la importancia del plan de infraestructura tecnológica. El proceso para el plan de infraestructura tecnológica es razonablemente sólido y está alineado con el plan estratégico de TI. Existe un plan de infraestructura tecnológica definido, documentado y bien difundido, aunque se aplica de forma inconsistente. La orientación de la infraestructura tecnológica incluye el entendimiento de dónde la empresa desea ser líder y dónde desea rezagarse respecto al uso de tecnología, con base en los riesgos y en la alineación con la estrategia organizacional. Los proveedores clave se seleccionan con base en su entendimiento de la tecnología a largo plazo y de los planes de desarrollo de productos, de forma consistente con la dirección de la organización. **4 Administrado y Medible cuando** La dirección garantiza el desarrollo del plan de infraestructura tecnológica. El equipo de TI cuenta con la experiencia y las habilidades necesarias para desarrollar un plan de infraestructura tecnológica. El impacto potencial de las tecnologías cambiantes y emergentes se toma en cuenta. La dirección puede identificar las desviaciones respecto al plan y anticipar los problemas. La responsabilidad del desarrollo y mantenimiento del plan de infraestructura tecnológica ha sido asignado. El proceso para desarrollar el plan de infraestructura tecnológica es sofisticado y sensible a los cambios. Se han incluido buenas prácticas internas en el proceso. La estrategia de recursos humanos está alineada con la dirección tecnológica, para garantizar que el equipo de TI pueda administrar los cambios tecnológicos. Los planes de migración para la introducción de nuevas tecnologías están definidos. Los recursos externos y las asociaciones se aprovechan para tener acceso a la experiencia y a las habilidades necesarias. La dirección ha evaluado la aceptación del riesgo de usar la tecnología como líder, o rezagarse en su uso, para desarrollar nuevas oportunidades de negocio o eficiencias operativas. **5 Optimizado cuando** Existe una función de investigación que revisa las tecnologías emergentes y evolutivas y para evaluar la organización por comparación contra las normas industriales. La dirección del plan de infraestructura tecnológica está impulsada por los estándares y avances industriales e internacionales, en lugar de estar orientada por los proveedores de tecnología. El impacto potencial de los cambios tecnológicos sobre el negocio se revisa al nivel de la alta dirección. Existe una aprobación ejecutiva formal para el cambio de la dirección tecnológica o para adoptar una nueva. La entidad cuenta con un plan robusto de infraestructura tecnológica que refleja los requerimientos del negocio, es sensible a los cambios en el ambiente del negocio y puede reflejar los cambios en éste. Existe un proceso continuo y reforzado para mejorar el plan de infraestructura tecnológica. Las mejores prácticas de la industria se usan de forma amplia para determinar la dirección técnica.

Criterio 4: Evaluar y gestionar los riesgos (TI)
Asegurar que los riesgos de seguridad de la información están descubiertos, priorizados y son aceptados a tiempo y alineados de manera estructurada con los deseos de la empresa para los riesgos de TI y el framework de gestión de riesgos de la organización.

Subcriterio 4a. Framework de gestión de riesgos TI
Un framework de gestión de riesgos es establecido y alineado al framework de gestión de riesgos de la organización.

Fortalezas
Se identifican riesgos en los proyectos la menos al nivel de UTSIT.

Áreas de mejora

Los estándares tecnológicos corporativos están siendo aprobados por la UTSIT.
No se evalua la eficacia del proceso para la comunicación de las normas técnicas a los miembros del personal de TI (por ejemplo, los directores de proyectos, arquitectos de información).
Validar por medio de entrevistas al personal su comprensión de las normas técnicas.
Determinar a partir de la gestión de TI que el seguimiento y la evaluación comparativa de procesos se ponen en marcha para confirmar el cumplimiento de las normas y directrices tecnológicas establecidas.
Evaluar la documentación técnica de análisis de viabilidad de proyectos seleccionados para evaluar el cumplimiento de los estándares tecnológicos corporativos.

No existente	Inicial / Ad Hoc	Repetible pero Intuitivo	Definido	Administrado y Medible	Optimizado
		X			

Interpretación del Modelo de Madurez
P09. Evaluar y Administrar los Riesgos de TI.
0 No Existente La evaluación de riesgos para los procesos y las decisiones de negocio no ocurre. La organización no toma en cuenta los impactos en el negocio asociados a las vulnerabilidades de seguridad y a las incertidumbres del desarrollo de proyectos. La administración de riesgos no se ha identificado como algo relevante para adquirir soluciones de TI y para prestar servicios de TI. **1 Inicial / Ad Hoc** Los riesgos de TI se toman en cuenta de manera ad hoc. Se realizan evaluaciones informales de riesgos según lo determine cada proyecto. En algunas ocasiones se identifican evaluaciones de riesgos en un plan de proyectos pero se asignan rara vez a gerentes específicos. Los riesgos específicos relacionados con TI tales como seguridad, disponibilidad e integridad se toman en cuenta ocasionalmente proyecto por proyecto. Los riesgos relativos a TI que afectan las operaciones del día a día, son rara vez discutidas en reuniones gerenciales. Cuando se toman en cuenta los riesgos, la mitigación es inconsistente. Existe un entendimiento emergente de que los riesgos de TI son importantes y necesitan ser considerados. **2 Repetible pero Intuitivo** Existe un enfoque de evaluación de riesgos en desarrollo y se implementa a discreción de los gerentes de proyecto. La administración de riesgos se da por lo general a alto nivel y típicamente se aplica solo a proyectos grandes o como respuesta a problemas. Los procesos de mitigación de riesgos están empezando a ser implementados donde se identifican riesgos. **3 Definido** Una política de administración de riesgos para toda la organización define cuándo y cómo realizar las evaluaciones de riesgos. La administración de riesgos sigue un proceso definido, el cual está documentado. El entrenamiento sobre administración de riesgos está disponible para todo el personal. La decisión de seguir el proceso de administración de riesgos y de recibir entrenamiento se deja a la discreción del individuo. La metodología para la evaluación de riesgos es convincente y sólida, y garantiza que los riesgos claves para el negocio sean identificados. Un proceso para mitigar los riesgos clave por lo general se institucionaliza una vez que los riesgos se identifican. Las descripciones de puestos consideran las responsabilidades de administración de riesgos. **4 Administrado y Medible** La evaluación y administración de riesgos son procedimientos estándar. Las excepciones al proceso de administración de riesgos se reportan a la gerencia de TI. La administración de riesgos de TI es una responsabilidad de alto nivel. Los riesgos se evalúan y se mitigan a nivel de proyecto individual y también por lo regular se hace con respecto a la operación global de TI. La gerencia recibe notificación sobre los cambios en el ambiente de negocios y de TI que pudieran afectar de manera significativa los escenarios de riesgo relacionados con TI. La gerencia puede monitorear la posición de riesgo y tomar decisiones informadas respecto a la exposición que está dispuesta a aceptar. Todos los riesgos identificados tienen un dueño nombrado, y la alta dirección, así como la gerencia de TI han determinado los niveles de riesgo que la organización está dispuesta a tolerar. La gerencia de TI ha elaborado medidas estándar para evaluar el riesgo y para definir las proporciones riesgo/retorno. La gerencia presupuesta un proyecto de administración de riesgo operativo para re-evaluar los riesgos de manera regular. Se establece una base de datos de administración de riesgos, y parte del proceso de administración de riesgos se empieza a automatizar. La gerencia de TI considera las estrategias de mitigación de riesgo. **5 Optimizado** La administración de riesgos ha evolucionado al nivel en que un proceso estructurado está implantado en toda la organización y es bien administrado. Las buenas prácticas se aplican en toda la organización. La captura, análisis y reporte de los datos de administración de riesgos están altamente automatizados. La orientación se toma de los líderes en el campo y la organización de TI participa en grupos de interés para intercambiar experiencias. La administración de riesgos está altamente integrada en todo el negocio y en las operaciones de TI, está bien aceptada, y abarca a los usuarios de servicios de TI. La dirección detecta y actúa cuando se toman decisiones grandes de inversión o de operación de TI, sin considerar el plan de administración de riesgos. La dirección evalúa las estrategias de mitigación de riesgos de manera continua.

Criterio 4: Evaluar y gestionar los riesgos (TI) **Asegurar que los riesgos de seguridad de la información están descubiertos, priorizados y son aceptados a tiempo y alineados de manera estructurada con los deseos de la empresa para los riesgos de TI y el framework de gestión de riesgos de la organización.**					
Subcriterio 4b. Evaluación de riesgos La probabilidad y el impacto de todos los riesgos identificados son evaluados sobre una base recurrente, usando métodos cualitativos y cuantitativos. La probabilidad y el impacto asociados con los riesgos inherentes y residuales son determinados individualmente, por categoría y dentro de un portafolio básico.					
Fortalezas Se evaluan riesgos en los proyecto clave. Se realiza una evalaución cualitativa de los riesgos. **Áreas de mejora** El marco de gestión de riesgos de TI se alinea con el marco de gestión de riesgos para IEEG e incluye componentes de negocio impulsado por la estrategia, los programas, proyectos y operaciones. Revise las clasificaciones de riesgo de TI para verificar que se basan en un grupo común de características del framework de gestión del riesgo. Las mediciones de riesgo TI, deben estandarizarse y priorizarse, incluir el impacto, la aceptación del riesgo residual y las probabilidades alineadas con el framework de gestión del riesgo empresarial. Pregunte por si existe y confirmar que el proceso de gestión de riesgos evalúa los riesgos identificados cualitativa y / o cuantitativamente. Incorporar una evaluación de riesgos cuantitativa. Fomentar el uso de análisis y determinaciones de probabilidad estadística para medir la probabilidad cualitativa o cuantitativamente.					
No existente	**Inicial / Ad Hoc**	**Repetible pero Intuitivo**	**Definido**	**Administrado y Medible**	**Optimizado**
		X			

Interpretación del Modelo de Madurez
P09. Evaluar y Administrar los Riesgos de TI.
0 No Existente La evaluación de riesgos para los procesos y las decisiones de negocio no ocurre. La organización no toma en cuenta los impactos en el negocio asociados a las vulnerabilidades de seguridad y a las incertidumbres del desarrollo de proyectos. La administración de riesgos no se ha identificado como algo relevante para adquirir soluciones de TI y para prestar servicios de TI. **1 Inicial / Ad Hoc** Los riesgos de TI se toman en cuenta de manera ad hoc. Se realizan evaluaciones informales de riesgos según lo determine cada proyecto. En algunas ocasiones se identifican evaluaciones de riesgos en un plan de proyectos pero se asignan rara vez a gerentes específicos. Los riesgos específicos relacionados con TI tales como seguridad, disponibilidad e integridad se toman en cuenta ocasionalmente proyecto por proyecto. Los riesgos relativos a TI que afectan las operaciones del día a día, son rara vez discutidas en reuniones gerenciales. Cuando se toman en cuenta los riesgos, la mitigación es inconsistente. Existe un entendimiento emergente de que los riesgos de TI son importantes y necesitan ser considerados. **2 Repetible pero Intuitivo** Existe un enfoque de evaluación de riesgos en desarrollo y se implementa a discreción de los gerentes de proyecto. La administración de riesgos se da por lo general a alto nivel y típicamente se aplica solo a proyectos grandes o como respuesta a problemas. Los procesos de mitigación de riesgos están empezando a ser implementados donde se identifican riesgos. **3 Definido** Una política de administración de riesgos para toda la organización define cuándo y cómo realizar las evaluaciones de riesgos. La administración de riesgos sigue un proceso definido, el cual está documentado. El entrenamiento sobre administración de riesgos está disponible para todo el personal. La decisión de seguir el proceso de administración de riesgos y de recibir entrenamiento se deja a la discreción del individuo. La metodología para la evaluación de riesgos es convincente y sólida, y garantiza que los riesgos claves para el negocio sean identificados. Un proceso para mitigar los riesgos clave por lo general se institucionaliza una vez que los riesgos se identifican. Las descripciones de puestos consideran las responsabilidades de administración de riesgos. **4 Administrado y Medible** La evaluación y administración de riesgos son procedimientos estándar. Las excepciones al proceso de administración de riesgos se reportan a la gerencia de TI. La administración de riesgos de TI es una responsabilidad de alto nivel. Los riesgos se evalúan y se mitigan a nivel de proyecto individual y también por lo regular se hace con respecto a la operación global de TI. La gerencia recibe notificación sobre los cambios en el ambiente de negocios y de TI que pudieran afectar de manera significativa los escenarios de riesgo relacionados con TI. La gerencia puede monitorear la posición de riesgo y tomar decisiones informadas respecto a la exposición que está dispuesta a aceptar. Todos los riesgos identificados tienen un dueño nombrado, y la alta dirección, así como la gerencia de TI han determinado los niveles de riesgo que la organización está dispuesta a tolerar. La gerencia de TI ha elaborado medidas estándar para evaluar el riesgo y para definir las proporciones riesgo/retorno. La gerencia presupuesta un proyecto de administración de riesgo operativo para re-evaluar los riesgos de manera regular. Se establece una base de datos de administración de riesgos, y parte del proceso de administración de riesgos se empieza a automatizar. La gerencia de TI considera las estrategias de mitigación de riesgo. **5 Optimizado** La administración de riesgos ha evolucionado al nivel en que un proceso estructurado está implantado en toda la organización y es bien administrado. Las buenas prácticas se aplican en toda la organización. La captura, análisis y reporte de los datos de administración de riesgos están altamente automatizados. La orientación se toma de los líderes en el campo y la organización de TI participa en grupos de interés para intercambiar experiencias. La administración de riesgos está altamente integrada en todo el negocio y en las operaciones de TI, está bien aceptada, y abarca a los usuarios de servicios de TI. La dirección detecta y actúa cuando se toman decisiones grandes de inversión o de operación de TI, sin considerar el plan de administración de riesgos. La dirección evalúa las estrategias de mitigación de riesgos de manera continua.

Criterio 4: Evaluar y gestionar los riesgos (TI) **Asegurar que los riesgos de seguridad de la información están descubiertos, priorizados y son aceptados a tiempo y alineados de manera estructurada con los deseos de la empresa para los riesgos de TI y el framework de gestión de riesgos de la organización.**					
Subcriterio 4c. Mantenimiento y monitoreo de un plan de acción de riesgos Las actividades de control son priorizadas y planeadas para todos los niveles para implementar las respuestas a los riesgos identificados como necesarios, incluyendo identificación de costos, beneficios y responsabilidad de la ejecución. La aprobación se obtiene por acciones recomendadas y aceptadas de cualquier riesgo residual y se asegura de que las acciones comprometidas son propiedad del encargado (s) del proceso afectado. La ejecución es monitoreada de los planes y cualquiera de las desviaciones se reportan al personal directivo superior.					
Fortalezas Se revisan los riesgos más importantes con un plan de acción para mitigarlo. Se revisan las acciones para mitigar los riesgos. **Áreas de mejora** Adecuar los elementos del plan de gestión de riesgos. Incorporar la ejecución, el progreso y el informe de desviaciones para monitoreo. Manterner el plan de acción de riesgo y se ajusta de manera efectiva.					
No existente	**Inicial / Ad Hoc**	**Repetible pero Intuitivo**	**Definido**	**Administrado y Medible**	**Optimizado**
		X			

Interpretación del Modelo de Madurez
P09. Evaluar y Administrar los Riesgos de TI.
0 No Existente La evaluación de riesgos para los procesos y las decisiones de negocio no ocurre. La organización no toma en cuenta los impactos en el negocio asociados a las vulnerabilidades de seguridad y a las incertidumbres del desarrollo de proyectos. La administración de riesgos no se ha identificado como algo relevante para adquirir soluciones de TI y para prestar servicios de TI. **1 Inicial / Ad Hoc** Los riesgos de TI se toman en cuenta de manera ad hoc. Se realizan evaluaciones informales de riesgos según lo determine cada proyecto. En algunas ocasiones se identifican evaluaciones de riesgos en un plan de proyectos pero se asignan rara vez a gerentes específicos. Los riesgos específicos relacionados con TI tales como seguridad, disponibilidad e integridad se toman en cuenta ocasionalmente proyecto por proyecto. Los riesgos relativos a TI que afectan las operaciones del día a día, son rara vez discutidas en reuniones gerenciales. Cuando se toman en cuenta los riesgos, la mitigación es inconsistente. Existe un entendimiento emergente de que los riesgos de TI son importantes y necesitan ser considerados. **2 Repetible pero Intuitivo** Existe un enfoque de evaluación de riesgos en desarrollo y se implementa a discreción de los gerentes de proyecto. La administración de riesgos se da por lo general a alto nivel y típicamente se aplica solo a proyectos grandes o como respuesta a problemas. Los procesos de mitigación de riesgos están empezando a ser implementados donde se identifican riesgos. **3 Definido** Una política de administración de riesgos para toda la organización define cuándo y cómo realizar las evaluaciones de riesgos. La administración de riesgos sigue un proceso definido, el cual está documentado. El entrenamiento sobre administración de riesgos está disponible para todo el personal. La decisión de seguir el proceso de administración de riesgos y de recibir entrenamiento se deja a la discreción del individuo. La metodología para la evaluación de riesgos es convincente y sólida, y garantiza que los riesgos claves para el negocio sean identificados. Un proceso para mitigar los riesgos clave por lo general se institucionaliza una vez que los riesgos se identifican. Las descripciones de puestos consideran las responsabilidades de administración de riesgos. **4 Administrado y Medible** La evaluación y administración de riesgos son procedimientos estándar. Las excepciones al proceso de administración de riesgos se reportan a la gerencia de TI. La administración de riesgos de TI es una responsabilidad de alto nivel. Los riesgos se evalúan y se mitigan a nivel de proyecto individual y también por lo regular se hace con respecto a la operación global de TI. La gerencia recibe notificación sobre los cambios en el ambiente de negocios y de TI que pudieran afectar de manera significativa los escenarios de riesgo relacionados con TI. La gerencia puede monitorear la posición de riesgo y tomar decisiones informadas respecto a la exposición que está dispuesta a aceptar. Todos los riesgos identificados tienen un dueño nombrado, y la alta dirección, así como la gerencia de TI han determinado los niveles de riesgo que la organización está dispuesta a tolerar. La gerencia de TI ha elaborado medidas estándar para evaluar el riesgo y para definir las proporciones riesgo/retorno. La gerencia presupuesta un proyecto de administración de riesgo operativo para re-evaluar los riesgos de manera regular. Se establece una base de datos de administración de riesgos, y parte del proceso de administración de riesgos se empieza a automatizar. La gerencia de TI considera las estrategias de mitigación de riesgo. **5 Optimizado** La administración de riesgos ha evolucionado al nivel en que un proceso estructurado está implantado en toda la organización y es bien administrado. Las buenas prácticas se aplican en toda la organización. La captura, análisis y reporte de los datos de administración de riesgos están altamente automatizados. La orientación se toma de los líderes en el campo y la organización de TI participa en grupos de interés para intercambiar experiencias. La administración de riesgos está altamente integrada en todo el negocio y en las operaciones de TI, está bien aceptada, y abarca a los usuarios de servicios de TI. La dirección detecta y actúa cuando se toman decisiones grandes de inversión o de operación de TI, sin considerar el plan de administración de riesgos. La dirección evalúa las estrategias de mitigación de riesgos de manera continua.

Organización

Criterio 5: Organización de la seguridad de la información **La seguridad de la información es gestionada apropiadamente en el nivel organizacional más alto, así que la gestión de las acciones de seguridad está en línea con el negocio, riesgo y cumplimiento de los objetivos.**					
Subcriterio 5a. Responsabilidad para el riesgo, seguridad y conformidad La propiedad y responsabilidad, son parte integrante de los riesgos relacionados a las TI dentro del negocio a un nivel superior apropiado. Los roles críticos para gestionar los riesgos TI están definidos y asignados, incluyendo la responsabilidad específica para la seguridad de la información, seguridad y física y cumplimiento. El riesgo y la responsabilidad de la gestión de la seguridad están establecidas para el nivel de empresa de acuerdo con los problemas a lo largo de la organización. Las responsabilidades de gestión de la seguridad adicional pueden ser asignadas al nivel específico del sistema, para hacer frente a los problemas de seguridad relacionados.					
Fortalezas Los riesgos de la información se encuentran identificados. Las responsabilidades están correctamente asignadas y tienen experiencia en riesgos de seguridad de la información. **Áreas de mejora** Establecer un plan de seguridad de la información y un plan de gestión de riesgos desde la Dirección. Gestionar los riesgos de la seguridad de la información. Establecer informes para la gestión de riesgos y de seguridad de la información y reportar a un superior. La Dirección debe involucrarse en la gestión de riesgos y seguridad de la información. Evaluar periódicamente el recurso que se utiliza para la gestión de riesgos y seguridad de la información, para asegurar que cubre con las necesidades de la Dependencia.					
No existente	**Inicial / Ad Hoc**	**Repetible pero Intuitivo**	**Definido**	**Administrado y Medible**	**Optimizado**
		X			

Interpretación del Modelo de Madurez
P04. Definir los Procesos, Organización y Relaciones de TI.
0 No Existente La organización de TI no está establecida de forma efectiva para enfocarse en el logro de los objetivos del negocio. **1 Inicial / Ad Hoc** Las actividades y funciones de TI son reactivas y se implantan de forma inconsistente. TI se involucra en los proyectos solamente en las etapas finales. La función de TI se considera como una función de soporte, sin una perspectiva organizacional general. Existe un entendimiento explícito de la necesidad de una organización de TI; sin embargo, los roles y las responsabilidades no están formalizados ni reforzados. **2 Repetible pero Intuitivo** La función de TI está organizada para responder de forma táctica aunque de forma inconsistente, a las necesidades de los clientes y a las relaciones con los proveedores. La necesidad de contar con una organización estructurada y una administración de proveedores se comunica, pero las decisiones todavía dependen del conocimiento y habilidades de individuos clave. Surgen técnicas comunes para administrar la organización de TI y las relaciones con los proveedores. **3 Definido** Existen roles y responsabilidades definidos para la organización de TI y para terceros. La organización de TI se desarrolla, documenta, comunica y se alinea con la estrategia de TI. Se define el ambiente de control interno. Se formulan las relaciones con terceros, incluyendo los comités de dirección, auditoría interna y administración de proveedores. La organización de TI está funcionalmente completa. Existen definiciones de las funciones a ser realizadas por parte del personal de TI y las que deben realizar los usuarios. Los requerimientos esenciales de personal de TI y experiencia están definidos y satisfechos. Existe una definición formal de las relaciones con los usuarios y con terceros. La división de roles y responsabilidades está definida e implantada. **4 Administrado y Medible** La organización de TI responde de forma proactiva al cambio e incluye todos los roles necesarios para satisfacer los requerimientos del negocio. La administración, la propiedad de procesos, la delegación y la responsabilidad de TI están definidas y balanceadas. Se han aplicado buenas prácticas internas en la organización de las funciones de TI. La gerencia de TI cuenta con la experiencia y habilidades apropiadas para definir, implementar y monitorear la organización deseada y las relaciones. Las métricas medibles para dar soporte a los objetivos del negocio y los factores críticos de éxito definidos por el usuario siguen un estándar. Existen inventarios de habilidades para apoyar al personal de los proyectos y el desarrollo profesional. El equilibrio entre las habilidades y los recursos disponibles internamente, y los que se requieren de organizaciones externas están definidos y reforzados. La estructura organizacional de TI refleja de manera apropiada las necesidades del negocio proporcionando servicios alineados con los procesos estratégicos del negocio, en lugar de estar alineados con tecnologías aisladas. **5 Optimizado** La estructura organizacional de TI es flexible y adaptable. Se ponen en funcionamiento las mejores prácticas de la industria. Existe un uso amplio de la tecnología para monitorear el desempeño de la organización y de los procesos de TI. La tecnología se aprovecha para apoyar la complejidad y distribución geográfica de la organización. Un proceso de mejora continua existe y está implantado.

Criterio 5: Organización de la seguridad de la información **La seguridad de la información es gestionada apropiadamente en el nivel organizacional más alto, así que la gestión de las acciones de seguridad está en línea con el negocio, riesgo y cumplimiento de los objetivos.**					
Subcriterio 5b. Gestión de la seguridad de la información La seguridad de la información es gestionada apropiadamente por el nivel organizacional más alto, así que la gestión de las acciones de seguridad está en línea con los requerimientos del negocio.					
Fortalezas No se observo evidencia durante la auditoría. **Áreas de mejora** Crear un Comité de Seguridad, determinando las políticas y estándares a seguir, forma de comunicación y proceso documentado. Identificar políticas de seguridad, estándares, y procedimientos detallados. Priorizar las iniciativas de seguridad propuestas, incluidos los niveles requeridos de políticas, estándares y procedimientos.					
No existente	**Inicial / Ad Hoc**	**Repetible pero Intuitivo**	**Definido**	**Administrado y Medible**	**Optimizado**
X					

Interpretación del Modelo de Madurez
DS5. Garantizar la Seguridad de los Sistemas
0 No Existente La organización no reconoce la necesidad de la seguridad para TI. Las responsabilidades y la rendición de cuentas no están asignadas para garantizar la seguridad. Las medidas para soportar la administrar la seguridad de TI no están implementadas. No hay reportes de seguridad de TI ni un proceso de respuesta para resolver brechas de seguridad de TI. Hay una total falta de procesos reconocibles de administración de seguridad de sistemas. **1 Inicial / Ad Hoc** La organización reconoce la necesidad de seguridad para TI. La conciencia de la necesidad de seguridad depende principalmente del individuo. La seguridad de TI se lleva a cabo de forma reactiva. No se mide la seguridad de TI. Las brechas de seguridad de TI ocasionan respuestas con acusaciones personales, debido a que las responsabilidades no son claras. Las respuestas a las brechas de seguridad de TI son impredecibles. **2 Repetible pero Intuitivo** Las responsabilidades y la rendición de cuentas sobre la seguridad, están asignadas a un coordinador de seguridad de TI, pero la autoridad gerencial del coordinador es limitada. La conciencia sobre la necesidad de la seguridad está fraccionada y limitada. Aunque los sistemas producen información relevante respecto a la seguridad, ésta no se analiza. Los servicios de terceros pueden no cumplir con los requerimientos específicos de seguridad de la empresa. Las políticas de seguridad se han estado desarrollando, pero las herramientas y las habilidades son inadecuadas. Los reportes de la seguridad de TI son incompletos, engañosos o no aplicables. El entrenamiento sobre seguridad está disponible pero depende principalmente de la iniciativa del individuo. La seguridad de TI es vista primordialmente como responsabilidad y disciplina de TI, y el negocio no ve la seguridad de TI como parte de su propia disciplina. **3 Definido** Existe conciencia sobre la seguridad y ésta es promovida por la gerencia. Los procedimientos de seguridad de TI están definidos y alineados con la política de seguridad de TI. Las responsabilidades de la seguridad de TI están asignadas y entendidas, pero no continuamente implementadas. Existe un plan de seguridad de TI y existen soluciones de seguridad motivadas por un análisis de riesgo. Los reportes no contienen un enfoque claro de negocio. Se realizan pruebas de seguridad adecuadas (por ejemplo, pruebas contra intrusos). Existe entrenamiento en seguridad para TI y para el negocio, pero se programa y se comunica de manera informal. **4 Administrado y Medible** Las responsabilidades sobre la seguridad de TI son asignadas, administradas e implementadas de forma clara. Regularmente se lleva a cabo un análisis de impacto y de riesgos de seguridad. Las políticas y prácticas de seguridad se complementan con referencias de seguridad específicas. El contacto con métodos para promover la conciencia de la seguridad es obligatorio. La identificación, autenticación y autorización de los usuarios está estandarizada. La certificación en seguridad es buscada por parte del personal que es responsable de la auditoría y la administración de la seguridad. Las pruebas de seguridad se hacen utilizando procesos estándares y formales que llevan a mejorar los niveles de seguridad. Los procesos de seguridad de TI están coordinados con la función de seguridad de toda la organización. Los reportes de seguridad están ligados con los objetivos del negocio. El entrenamiento sobre seguridad se imparte tanto para TI como para el negocio. El entrenamiento sobre seguridad de TI se planea y se administra de manera que responda a las necesidades del negocio y a los perfiles de riesgo de seguridad. Los KGIs y KPIs ya están definidos pero no se miden aún. **5 Optimizado** La seguridad en TI es una responsabilidad conjunta del negocio y de la gerencia de TI y está integrada con los objetivos de seguridad del negocio en la corporación. Los requerimientos de seguridad de TI están definidos de forma clara, optimizados e incluidos en un plan de seguridad aprobado. Los usuarios y los clientes se responsabilizan cada vez más de definir requerimientos de seguridad, y las funciones de seguridad están integradas con las aplicaciones en la fase de diseño. Los incidentes de seguridad son atendidos de forma inmediata con procedimientos formales de respuesta soportados por herramientas automatizadas. Se llevan a cabo valoraciones de seguridad de forma periódica para evaluar la efectividad de la implementación del plan de seguridad. La información sobre amenazas y vulnerabilidades se recolecta y analiza de manera sistemática. Se recolectan e implementan de forma oportuna controles adecuados para mitigar riesgos. Se llevan a cabo pruebas de seguridad, análisis de causa-efecto e identificación pro-activa de riesgos para la mejora continua de procesos. Los procesos de seguridad y la tecnología están integrados a lo largo de toda la organización. Los KGIs y KPIs para administración de seguridad son recopilados y comunicados. La gerencia utiliza los KGIs y KPIs para ajustar el plan de seguridad en un proceso de mejora continua.

Criterio 6: Propiedad de los datos y del sistema **La seguridad de la información es gestionada apropiadamente por el nivel organizacional más alto, así que la gestión de las acciones de seguridad está en línea con los requerimientos del negocio.**					
Subcriterio 6a. Propiedad de los datos y del sistema La seguridad de la información es gestionada apropiadamente por el nivel organizacional más alto, así que la gestión de las acciones de seguridad está en línea con los requerimientos del negocio. El negocio es provisto con los procedimientos y herramientas, habilitándolas para dirigir sus responsabilidades para la propiedad de los datos y los sistemas de información. Los propietarios toman decisiones acerca de la clarificación de la información y los sistemas y se les protege de acuerdo con esta clasificación.					
Fortalezas Se identifica la clasificación de datos y del sistema **Áreas de mejora** Determinar una política de clasificación de datos y comunicarla. Documentar y evaluar el proceso de clasificación de datos.					
No existente	**Inicial / Ad Hoc**	**Repetible pero Intuitivo**	**Definido**	**Administrado y Medible**	**Optimizado**
	X				

Interpretación del Modelo de Madurez
P04. Definir los Procesos, Organización y Relaciones de TI.
0 No Existente La organización de TI no está establecida de forma efectiva para enfocarse en el logro de los objetivos del negocio. **1 Inicial / Ad Hoc** Las actividades y funciones de TI son reactivas y se implantan de forma inconsistente. TI se involucra en los proyectos solamente en las etapas finales. La función de TI se considera como una función de soporte, sin una perspectiva organizacional general. Existe un entendimiento explícito de la necesidad de una organización de TI; sin embargo, los roles y las responsabilidades no están formalizados ni reforzados. **2 Repetible pero Intuitivo** La función de TI está organizada para responder de forma táctica aunque de forma inconsistente, a las necesidades de los clientes y a las relaciones con los proveedores. La necesidad de contar con una organización estructurada y una administración de proveedores se comunica, pero las decisiones todavía dependen del conocimiento y habilidades de individuos clave. Surgen técnicas comunes para administrar la organización de TI y las relaciones con los proveedores. **3 Definido** Existen roles y responsabilidades definidos para la organización de TI y para terceros. La organización de TI se desarrolla, documenta, comunica y se alinea con la estrategia de TI. Se define el ambiente de control interno. Se formulan las relaciones con terceros, incluyendo los comités de dirección, auditoría interna y administración de proveedores. La organización de TI está funcionalmente completa. Existen definiciones de las funciones a ser realizadas por parte del personal de TI y las que deben realizar los usuarios. Los requerimientos esenciales de personal de TI y experiencia están definidos y satisfechos. Existe una definición formal de las relaciones con los usuarios y con terceros. La división de roles y responsabilidades está definida e implantada. **4 Administrado y Medible** La organización de TI responde de forma proactiva al cambio e incluye todos los roles necesarios para satisfacer los requerimientos del negocio. La administración, la propiedad de procesos, la delegación y la responsabilidad de TI están definidas y balanceadas. Se han aplicado buenas prácticas internas en la organización de las funciones de TI. La gerencia de TI cuenta con la experiencia y habilidades apropiadas para definir, implementar y monitorear la organización deseada y las relaciones. Las métricas medibles para dar soporte a los objetivos del negocio y los factores críticos de éxito definidos por el usuario siguen un estándar. Existen inventarios de habilidades para apoyar al personal de los proyectos y el desarrollo profesional. El equilibrio entre las habilidades y los recursos disponibles internamente, y los que se requieren de organizaciones externas están definidos y reforzados. La estructura organizacional de TI refleja de manera apropiada las necesidades del negocio proporcionando servicios alineados con los procesos estratégicos del negocio, en lugar de estar alineados con tecnologías aisladas. **5 Optimizado** La estructura organizacional de TI es flexible y adaptable. Se ponen en funcionamiento las mejores prácticas de la industria. Existe un uso amplio de la tecnología para monitorear el desempeño de la organización y de los procesos de TI. La tecnología se aprovecha para apoyar la complejidad y distribución geográfica de la organización. Un proceso de mejora continua existe y está implantado.

Criterio 7: Administrar la segregación de funciones **Una división de roles y responsabilidades es implementado para reducir la posibilidad de que un solo individuo pueda poner en peligro un proceso crítico.**					
Subcriterio 7a. Segregación de funciones Una división de roles y responsabilidades es implementado para reducir la posibilidad de que un solo individuo pueda poner en peligro un proceso crítico.					
Fortalezas Existen estándares para la adecuada distribución de funciones y se aplica actualmente. El proceso para identificar funciones críticas se encuentra documentado. **Áreas de mejora** Implementar una división de roles y responsabilidades que reduzca la posibilidad de que un solo individuo afecte negativamente un proceso crítico. La Dirección debe asegurarse de que el personal realice sólo las tareas autorizadas, relevantes a sus puestos y posiciones respectivas.					
No existente	**Inicial / Ad Hoc**	**Repetible pero Intuitivo**	**Definido**	**Administrado y Medible**	**Optimizado**
		X			

Interpretación del Modelo de Madurez
P04. Definir los Procesos, Organización y Relaciones de TI.
0 No Existente La organización de TI no está establecida de forma efectiva para enfocarse en el logro de los objetivos del negocio. **1 Inicial / Ad Hoc** Las actividades y funciones de TI son reactivas y se implantan de forma inconsistente. TI se involucra en los proyectos solamente en las etapas finales. La función de TI se considera como una función de soporte, sin una perspectiva organizacional general. Existe un entendimiento explícito de la necesidad de una organización de TI; sin embargo, los roles y las responsabilidades no están formalizados ni reforzados. **2 Repetible pero Intuitivo** La función de TI está organizada para responder de forma táctica aunque de forma inconsistente, a las necesidades de los clientes y a las relaciones con los proveedores. La necesidad de contar con una organización estructurada y una administración de proveedores se comunica, pero las decisiones todavía dependen del conocimiento y habilidades de individuos clave. Surgen técnicas comunes para administrar la organización de TI y las relaciones con los proveedores. **3 Definido** Existen roles y responsabilidades definidos para la organización de TI y para terceros. La organización de TI se desarrolla, documenta, comunica y se alinea con la estrategia de TI. Se define el ambiente de control interno. Se formulan las relaciones con terceros, incluyendo los comités de dirección, auditoría interna y administración de proveedores. La organización de TI está funcionalmente completa. Existen definiciones de las funciones a ser realizadas por parte del personal de TI y las que deben realizar los usuarios. Los requerimientos esenciales de personal de TI y experiencia están definidos y satisfechos. Existe una definición formal de las relaciones con los usuarios y con terceros. La división de roles y responsabilidades está definida e implantada. **4 Administrado y Medible** La organización de TI responde de forma proactiva al cambio e incluye todos los roles necesarios para satisfacer los requerimientos del negocio. La administración, la propiedad de procesos, la delegación y la responsabilidad de TI están definidas y balanceadas. Se han aplicado buenas prácticas internas en la organización de las funciones de TI. La gerencia de TI cuenta con la experiencia y habilidades apropiadas para definir, implementar y monitorear la organización deseada y las relaciones. Las métricas medibles para dar soporte a los objetivos del negocio y los factores críticos de éxito definidos por el usuario siguen un estándar. Existen inventarios de habilidades para apoyar al personal de los proyectos y el desarrollo profesional. El equilibrio entre las habilidades y los recursos disponibles internamente, y los que se requieren de organizaciones externas están definidos y reforzados. La estructura organizacional de TI refleja de manera apropiada las necesidades del negocio proporcionando servicios alineados con los procesos estratégicos del negocio, en lugar de estar alineados con tecnologías aisladas. **5 Optimizado** La estructura organizacional de TI es flexible y adaptable. Se ponen en funcionamiento las mejores prácticas de la industria. Existe un uso amplio de la tecnología para monitorear el desempeño de la organización y de los procesos de TI. La tecnología se aprovecha para apoyar la complejidad y distribución geográfica de la organización. Un proceso de mejora continua existe y está implantado.

Criterio 8: Gestión de Recursos Humanos de TI
Asegurar que las funciones están completadas apropiadamente con personas de confianza que poseen las habilidades necesarias para cumplir con su función de reducir el riesgo de error humano.
Subcriterio 8a. Retención y reclutamiento de personal Los procesos de reclutamiento de personal de TI son mantenidos en línea con las políticas y procedimientos del personal de la organización en general (ej. la contratación, el medio ambiente de trabajo positivo, la orientación). Los procesos están implementados para asegurar que la organización tiene una fuerza de trabajo de TI apropiada con las habilidades necesarias para lograr las metas organizacionales.
Fortalezas Se cuenta con un plan de gestión de Recursos Humanos de TI, que incluye planes de acción de reclutamiento y selección. Existe un proceso documentado para la contratación y retención de personal TI. El personal de Recursos Humanos revisa y aprueba la contratación y el proceso de retención. **Áreas de mejora** Asegurar que los procesos de reclutamiento del personal de TI estén de acuerdo a las políticas y procedimientos generales de personal de la organización (Ej. contratación, un ambiente positivo de trabajo y orientación). La Dirección debe implementar procesos para garantizar que la organización cuente con una fuerza de trabajo posicionada de forma apropiada, que tenga las habilidades necesarias para alcanzar las metas organizacionales.

No existente	Inicial / Ad Hoc	Repetible pero Intuitivo	Definido	Administrado y Medible	Optimizado
				X	

Interpretación del Modelo de Madurez
P07. Administrar los Recursos Humanos de TI
0 No Existente No existe conciencia sobre la importancia de alinear la administración de recursos humanos de TI con el proceso de planeación de la tecnología para la organización. No hay persona o grupo formalmente responsable de la administración de los recursos humanos de TI. **1 Inicial / Ad Hoc** La gerencia reconoce la necesidad de contar con administración de recursos humanos de TI. El proceso de administración de recursos humanos de TI es informal y reactivo. El proceso de recursos humanos de TI está enfocado de manera operacional en la contratación y administración del personal de TI. Se está desarrollando la conciencia con respecto al impacto que tienen los cambios rápidos de negocio y de tecnología, y las soluciones cada vez más complejas, sobre la necesidad de nuevos niveles de habilidades y de competencia. **2 Repetible pero Intuitivo** Existe un enfoque táctico para contratar y administrar al personal de TI, dirigido por necesidades específicas de proyectos, en lugar de hacerlo con base en un equilibrio entendido de disponibilidad interna y externa de personal calificado. Se imparte entrenamiento informal al personal nuevo, quienes después reciben entrenamiento según sea necesario. **3 Definido** Existe un proceso definido y documentado para administrar los recursos humanos de TI. Existe un plan de administración de recursos humanos. Existe un enfoque estratégico para la contratación y la administración del personal de TI. El plan de entrenamiento formal está diseñado para satisfacer las necesidades de los recursos humanos de TI. Está establecido un programa de rotación, diseñado para expandir las habilidades gerenciales y de negocio. **4 Administrado y Medible** La responsabilidad de la elaboración y el mantenimiento de un plan de administración de recursos humanos para TI han sido asignados a un individuo o grupo con las habilidades y experiencia necesarias para elaborar y mantener el plan. El proceso para elaborar y mantener el plan de administración de recursos humanos de TI responde al cambio. La organización cuenta con métricas estandarizadas que le permiten identificar desviaciones respecto al plan de administración de recursos humanos de TI con énfasis especial en el manejo del crecimiento y rotación del personal. Las revisiones de compensación y de desempeño se están estableciendo y se comparan con otras organizaciones de TI y con las mejores prácticas de la industria. La administración de recursos humanos es proactiva, tomando en cuenta el desarrollo de un plan de carrera. **5 Optimizado** El plan de administración de recursos humanos de TI se actualiza de forma constante para satisfacer los cambiantes requerimientos del negocio. La administración de recursos humanos de TI está integrada y responde a la dirección estratégica de la entidad. Los componentes de la administración de recursos humanos de TI son consistentes con las mejores prácticas de la industria, tales como compensación, revisiones de desempeño, participación en foros de la industria, transferencia de conocimiento, entrenamiento y adiestramiento. Los programas de entrenamiento se desarrollan para todos los nuevos estándares tecnológicos y productos antes de su implantación en la organización.

Criterio 8: Gestión de Recursos Humanos de TI **Asegurar que las funciones están completadas apropiadamente con personas de confianza que poseen las habilidades necesarias para cumplir con su función de reducir el riesgo de error humano.**					
Subcriterio 8b. Competencias del personal Regularmente se verifica que el personal tiene las competencias para cubrir sus roles en base de a su educación, capacitación y/o experiencia. Los requerimientos de la competencia Core TI son definidos y están siendo mantenidas, usando programas de calificación y certificación, en su caso.					
Fortalezas Existe una descripción de puestos del personal de TI, que describe conocimientos, competencias y calificaciones. Se maneja un proceso de actualización de descripciones de puesto. **Áreas de mejora** Establecer un proceso de actualización de descripciones de puestos, identificando cada cuando se van a revisar y mejorar.					
No existente	**Inicial / Ad Hoc**	**Repetible pero Intuitivo**	**Definido**	**Administrado y Medible**	**Optimizado**
				X	

Interpretación del Modelo de Madurez
P07. Administrar los Recursos Humanos de TI
0 No Existente No existe conciencia sobre la importancia de alinear la administración de recursos humanos de TI con el proceso de planeación de la tecnología para la organización. No hay persona o grupo formalmente responsable de la administración de los recursos humanos de TI. **1 Inicial / Ad Hoc** La gerencia reconoce la necesidad de contar con administración de recursos humanos de TI. El proceso de administración de recursos humanos de TI es informal y reactivo. El proceso de recursos humanos de TI está enfocado de manera operacional en la contratación y administración del personal de TI. Se está desarrollando la conciencia con respecto al impacto que tienen los cambios rápidos de negocio y de tecnología, y las soluciones cada vez más complejas, sobre la necesidad de nuevos niveles de habilidades y de competencia. **2 Repetible pero Intuitivo** Existe un enfoque táctico para contratar y administrar al personal de TI, dirigido por necesidades específicas de proyectos, en lugar de hacerlo con base en un equilibrio entendido de disponibilidad interna y externa de personal calificado. Se imparte entrenamiento informal al personal nuevo, quienes después reciben entrenamiento según sea necesario. **3 Definido** Existe un proceso definido y documentado para administrar los recursos humanos de TI. Existe un plan de administración de recursos humanos. Existe un enfoque estratégico para la contratación y la administración del personal de TI. El plan de entrenamiento formal está diseñado para satisfacer las necesidades de los recursos humanos de TI. Está establecido un programa de rotación, diseñado para expandir las habilidades gerenciales y de negocio. **4 Administrado y Medible** La responsabilidad de la elaboración y el mantenimiento de un plan de administración de recursos humanos para TI han sido asignados a un individuo o grupo con las habilidades y experiencia necesarias para elaborar y mantener el plan. El proceso para elaborar y mantener el plan de administración de recursos humanos de TI responde al cambio. La organización cuenta con métricas estandarizadas que le permiten identificar desviaciones respecto al plan de administración de recursos humanos de TI con énfasis especial en el manejo del crecimiento y rotación del personal. Las revisiones de compensación y de desempeño se están estableciendo y se comparan con otras organizaciones de TI y con las mejores prácticas de la industria. La administración de recursos humanos es proactiva, tomando en cuenta el desarrollo de un plan de carrera. **5 Optimizado** El plan de administración de recursos humanos de TI se actualiza de forma constante para satisfacer los cambiantes requerimientos del negocio. La administración de recursos humanos de TI está integrada y responde a la dirección estratégica de la entidad. Los componentes de la administración de recursos humanos de TI son consistentes con las mejores prácticas de la industria, tales como compensación, revisiones de desempeño, participación en foros de la industria, transferencia de conocimiento, entrenamiento y adiestramiento. Los programas de entrenamiento se desarrollan para todos los nuevos estándares tecnológicos y productos antes de su implantación en la organización.

Criterio 8: Gestión de Recursos Humanos de TI
Asegurar que las funciones están completadas apropiadamente con personas de confianza que poseen las habilidades necesarias para cumplir con su función de reducir el riesgo de error humano.
Subcriterio 8c. Dependencia de los individuos La exposición para la dependencia crítica en los individuos clave a través de la captura del conocimiento (documentación), intercambio de conocimientos, planificación de la sucesión y el respaldo del personal es minimizado.
Fortalezas Los programas de capacitación incluyen documentación de tareas clave, rotación de puestos, intercambio de conocimientos y sucesión de funciones críticas. **Áreas de mejora** Inspeccionar la documentación de los puestos del personal clave a seguir para la dependencia de las personas individuales para los procesos críticos de la organización de TI. Los programas de formación deben incorporar técnicas para mitigar el riesgo de la excesiva dependencia de los recursos clave. Los programas deben incluir el entrenamiento cruzado, documentación de las tareas clave, rotación de puestos, el intercambio de conocimientos y la planificación de la sucesión de funciones críticas dentro de la organización. Minimizar la exposición a dependencias críticas sobre individuos clave por medio de la captura del conocimiento (documentación), compartir el conocimiento, planeación de la sucesión y respaldos de personal.

No existente	Inicial / Ad Hoc	Repetible pero Intuitivo	Definido	Administrado y Medible	Optimizado
				X	

Interpretación del Modelo de Madurez
P07. Administrar los Recursos Humanos de TI
0 No Existente No existe conciencia sobre la importancia de alinear la administración de recursos humanos de TI con el proceso de planeación de la tecnología para la organización. No hay persona o grupo formalmente responsable de la administración de los recursos humanos de TI. **1 Inicial / Ad Hoc** La gerencia reconoce la necesidad de contar con administración de recursos humanos de TI. El proceso de administración de recursos humanos de TI es informal y reactivo. El proceso de recursos humanos de TI está enfocado de manera operacional en la contratación y administración del personal de TI. Se está desarrollando la conciencia con respecto al impacto que tienen los cambios rápidos de negocio y de tecnología, y las soluciones cada vez más complejas, sobre la necesidad de nuevos niveles de habilidades y de competencia. **2 Repetible pero Intuitivo** Existe un enfoque táctico para contratar y administrar al personal de TI, dirigido por necesidades específicas de proyectos, en lugar de hacerlo con base en un equilibrio entendido de disponibilidad interna y externa de personal calificado. Se imparte entrenamiento informal al personal nuevo, quienes después reciben entrenamiento según sea necesario. **3 Definido** Existe un proceso definido y documentado para administrar los recursos humanos de TI. Existe un plan de administración de recursos humanos. Existe un enfoque estratégico para la contratación y la administración del personal de TI. El plan de entrenamiento formal está diseñado para satisfacer las necesidades de los recursos humanos de TI. Está establecido un programa de rotación, diseñado para expandir las habilidades gerenciales y de negocio. **4 Administrado y Medible** La responsabilidad de la elaboración y el mantenimiento de un plan de administración de recursos humanos para TI han sido asignados a un individuo o grupo con las habilidades y experiencia necesarias para elaborar y mantener el plan. El proceso para elaborar y mantener el plan de administración de recursos humanos de TI responde al cambio. La organización cuenta con métricas estandarizadas que le permiten identificar desviaciones respecto al plan de administración de recursos humanos de TI con énfasis especial en el manejo del crecimiento y rotación del personal. Las revisiones de compensación y de desempeño se están estableciendo y se comparan con otras organizaciones de TI y con las mejores prácticas de la industria. La administración de recursos humanos es proactiva, tomando en cuenta el desarrollo de un plan de carrera. **5 Optimizado** El plan de administración de recursos humanos de TI se actualiza de forma constante para satisfacer los cambiantes requerimientos del negocio. La administración de recursos humanos de TI está integrada y responde a la dirección estratégica de la entidad. Los componentes de la administración de recursos humanos de TI son consistentes con las mejores prácticas de la industria, tales como compensación, revisiones de desempeño, participación en foros de la industria, transferencia de conocimiento, entrenamiento y adiestramiento. Los programas de entrenamiento se desarrollan para todos los nuevos estándares tecnológicos y productos antes de su implantación en la organización.

Criterio 8: Gestión de Recursos Humanos de TI
Asegurar que las funciones están completadas apropiadamente con personas de confianza que poseen las habilidades necesarias para cumplir con su función de reducir el riesgo de error humano.
Subcriterio 8d. Procedimientos de compensación del personal La verificación de los antecedentes son incluidos en el proceso de reclutamiento TI. La extensión y frecuencia de revisiones periódicas dependen de la sensibilidad y/o de la función y son aplicados para los empleados, contratistas y proveedores.
Fortalezas Se establecen los controles de seguridad para comprobadores de antecedentes, en los criterios de selección. Se establecen los controles de seguridad para comprobaciones de antecedentes del personal. Están definidos controles de seguridad para funciones críticas. El proceso de contratación incluye verificaciones de antecedentes de liquidación. **Áreas de mejora** En la documentación de contratación de los miembros del personal de TI se debe revisar que la verificación de antecedentes se han completado y evaluado. Incluir verificaciones de antecedentes en el proceso de reclutamiento de TI, el grado y la frecuencia de estas verificaciones dependen de que tan delicada ó crítica sea la función y se deben aplicar a los empleados, contratistas y proveedores.

No existente	Inicial / Ad Hoc	Repetible pero Intuitivo	Definido	Administrado y Medible	Optimizado
				X	

Interpretación del Modelo de Madurez
P07. Administrar los Recursos Humanos de TI
0 No Existente No existe conciencia sobre la importancia de alinear la administración de recursos humanos de TI con el proceso de planeación de la tecnología para la organización. No hay persona o grupo formalmente responsable de la administración de los recursos humanos de TI. **1 Inicial / Ad Hoc** La gerencia reconoce la necesidad de contar con administración de recursos humanos de TI. El proceso de administración de recursos humanos de TI es informal y reactivo. El proceso de recursos humanos de TI está enfocado de manera operacional en la contratación y administración del personal de TI. Se está desarrollando la conciencia con respecto al impacto que tienen los cambios rápidos de negocio y de tecnología, y las soluciones cada vez más complejas, sobre la necesidad de nuevos niveles de habilidades y de competencia. **2 Repetible pero Intuitivo** Existe un enfoque táctico para contratar y administrar al personal de TI, dirigido por necesidades específicas de proyectos, en lugar de hacerlo con base en un equilibrio entendido de disponibilidad interna y externa de personal calificado. Se imparte entrenamiento informal al personal nuevo, quienes después reciben entrenamiento según sea necesario. **3 Definido** Existe un proceso definido y documentado para administrar los recursos humanos de TI. Existe un plan de administración de recursos humanos. Existe un enfoque estratégico para la contratación y la administración del personal de TI. El plan de entrenamiento formal está diseñado para satisfacer las necesidades de los recursos humanos de TI. Está establecido un programa de rotación, diseñado para expandir las habilidades gerenciales y de negocio. **4 Administrado y Medible** La responsabilidad de la elaboración y el mantenimiento de un plan de administración de recursos humanos para TI han sido asignados a un individuo o grupo con las habilidades y experiencia necesarias para elaborar y mantener el plan. El proceso para elaborar y mantener el plan de administración de recursos humanos de TI responde al cambio. La organización cuenta con métricas estandarizadas que le permiten identificar desviaciones respecto al plan de administración de recursos humanos de TI con énfasis especial en el manejo del crecimiento y rotación del personal. Las revisiones de compensación y de desempeño se están estableciendo y se comparan con otras organizaciones de TI y con las mejores prácticas de la industria. La administración de recursos humanos es proactiva, tomando en cuenta el desarrollo de un plan de carrera. **5 Optimizado** El plan de administración de recursos humanos de TI se actualiza de forma constante para satisfacer los cambiantes requerimientos del negocio. La administración de recursos humanos de TI está integrada y responde a la dirección estratégica de la entidad. Los componentes de la administración de recursos humanos de TI son consistentes con las mejores prácticas de la industria, tales como compensación, revisiones de desempeño, participación en foros de la industria, transferencia de conocimiento, entrenamiento y adiestramiento. Los programas de entrenamiento se desarrollan para todos los nuevos estándares tecnológicos y productos antes de su implantación en la organización.

Criterio 8: Gestión de Recursos Humanos de TI **Asegurar que las funciones están completadas apropiadamente con personas de confianza que poseen las habilidades necesarias para cumplir con su función de reducir el riesgo de error humano.**					
Subcriterio 8e. Cambio de empleo y terminación Las acciones oportunas son tomadas de acuerdo a los cambios de trabajo, especialmente de trabajo terminado. El conocimiento transmitido es organizado, las responsabilidades son reasignadas y los derechos de acceso se eliminan de tal manera que se minimicen los riesgos y la continuidad de la función está garantizada.					
Fortalezas Los procedimientos de salida voluntaria del empleado están documentados. **Áreas de mejora** Para la documentación de los procedimientos de salida de la terminación voluntaria del empleo debe contener todos los elementos necesarios, tales como el conocimiento necesario de transferencia, obtención oportuna de acceso lógico y físico, el retorno de los activos de la organización, y la realización de entrevistas de salida. Los procedimientos de cambio de empleo deben contener todos los elementos necesarios para minimizar la interrupción de los procesos de negocio. Los ejemplos incluyen la necesidad de tutoría trabajo, medidas de traspaso de puestos de trabajo y formación académica preparatoria, además que deben ser seguidos constantemente.					
No existente	**Inicial / Ad Hoc**	**Repetible pero Intuitivo**	**Definido**	**Administrado y Medible**	**Optimizado**
			X		

Interpretación del Modelo de Madurez
P07. Administrar los Recursos Humanos de TI
0 No Existente No existe conciencia sobre la importancia de alinear la administración de recursos humanos de TI con el proceso de planeación de la tecnología para la organización. No hay persona o grupo formalmente responsable de la administración de los recursos humanos de TI. **1 Inicial / Ad Hoc** La gerencia reconoce la necesidad de contar con administración de recursos humanos de TI. El proceso de administración de recursos humanos de TI es informal y reactivo. El proceso de recursos humanos de TI está enfocado de manera operacional en la contratación y administración del personal de TI. Se está desarrollando la conciencia con respecto al impacto que tienen los cambios rápidos de negocio y de tecnología, y las soluciones cada vez más complejas, sobre la necesidad de nuevos niveles de habilidades y de competencia. **2 Repetible pero Intuitivo** Existe un enfoque táctico para contratar y administrar al personal de TI, dirigido por necesidades específicas de proyectos, en lugar de hacerlo con base en un equilibrio entendido de disponibilidad interna y externa de personal calificado. Se imparte entrenamiento informal al personal nuevo, quienes después reciben entrenamiento según sea necesario. **3 Definido** Existe un proceso definido y documentado para administrar los recursos humanos de TI. Existe un plan de administración de recursos humanos. Existe un enfoque estratégico para la contratación y la administración del personal de TI. El plan de entrenamiento formal está diseñado para satisfacer las necesidades de los recursos humanos de TI. Está establecido un programa de rotación, diseñado para expandir las habilidades gerenciales y de negocio. **4 Administrado y Medible** La responsabilidad de la elaboración y el mantenimiento de un plan de administración de recursos humanos para TI han sido asignados a un individuo o grupo con las habilidades y experiencia necesarias para elaborar y mantener el plan. El proceso para elaborar y mantener el plan de administración de recursos humanos de TI responde al cambio. La organización cuenta con métricas estandarizadas que le permiten identificar desviaciones respecto al plan de administración de recursos humanos de TI con énfasis especial en el manejo del crecimiento y rotación del personal. Las revisiones de compensación y de desempeño se están estableciendo y se comparan con otras organizaciones de TI y con las mejores prácticas de la industria. La administración de recursos humanos es proactiva, tomando en cuenta el desarrollo de un plan de carrera. **5 Optimizado** El plan de administración de recursos humanos de TI se actualiza de forma constante para satisfacer los cambiantes requerimientos del negocio. La administración de recursos humanos de TI está integrada y responde a la dirección estratégica de la entidad. Los componentes de la administración de recursos humanos de TI son consistentes con las mejores prácticas de la industria, tales como compensación, revisiones de desempeño, participación en foros de la industria, transferencia de conocimiento, entrenamiento y adiestramiento. Los programas de entrenamiento se desarrollan para todos los nuevos estándares tecnológicos y productos antes de su implantación en la organización.

Criterio 9: Asegurar el uso y las operaciones **Asegurar que las personas tiene el conocimiento y las habilidades para permitir operaciones eficaces y eficientes nuevas o ajustadas de función de aplicación/ tecnología en línea con las políticas de seguridad y los procedimientos.**					
Subcriterio 9a. La transferencia de conocimientos a los usuarios finales Transferir el conocimiento y las habilidades para permitir a los usuarios finales para la eficiencia y efectividad del uso del sistema En apoyo de los procesos de negocio.					
Fortalezas Existen entrenamiento y desarrollo de actividades, materiales de capacitación, ayuda en línea, soporte de mesa de servicio, identificación de clave de usuario final para realizar sus funciones. **Áreas de mejora** Establecer una evaluación para comprobar que los recursos sean utilizados, sirven al usuario final para realizar sus funciones. La transferencia de conocimiento debe incluir el desarrollo de un plan de entrenamiento que aborde al entrenamiento inicial y al continuo, así como el desarrollo de habilidades, materiales de entrenamiento, manuales de usuario, manuales de procedimiento, ayuda en línea, asistencia a usuarios, identificación del usuario clave, y evaluación.					
No existente	**Inicial / Ad Hoc**	**Repetible pero Intuitivo**	**Definido**	**Administrado y Medible**	**Optimizado**
			X		

Interpretación del Modelo de Madurez
AI4 Facilitar la Operación y el Uso
0 No Existente No existe el proceso con respecto a la producción de documentación de usuario, manuales de operación y material de entrenamiento. Los únicos materiales existentes son aquellos que se suministran con los productos que se adquieren. **1 Inicial / Ad Hoc** Existe la percepción de que la documentación de proceso es necesaria. La documentación se genera ocasionalmente y se distribuye en forma desigual a grupos limitados. Mucha de la documentación y muchos de los procedimientos ya caducaron. Los materiales de entrenamiento tienden a ser esquemas únicos con calidad variable. Virtualmente no existen procedimientos de integración a través de los diferentes sistemas y unidades de negocio. No hay aportes de las unidades de negocio en el diseño de programas de entrenamiento. **2 Repetible pero Intuitivo** Se utilizan enfoques similares para generar procedimientos y documentación, pero no se basan en un enfoque estructural o marco de trabajo. No hay un enfoque uniforme para el desarrollo de procedimientos de usuario y de operación. Individuos o equipos de proyecto generan los materiales de entrenamiento, y la calidad depende de los individuos que se involucran. Los procedimientos y la calidad del soporte al usuario van desde pobre a muy buena, con una consistencia e integración muy pequeña a lo largo de la organización. Se proporcionan o facilitan programas de entrenamiento para el negocio y los usuarios, pero no hay un plan general para ofrecer o dar entrenamiento. **3 Definido** Existe un esquema bien definido, aceptado y comprendido para documentación del usuario, manuales de operación y materiales de entrenamiento. Se guardan y se mantienen los procedimientos en una biblioteca formal y cualquiera que necesite saber tiene acceso a ella. Las correcciones a la documentación y a los procedimientos se realizan por reacción. Los procedimientos se encuentran disponibles fuera de línea y se pueden acceder y mantener en caso de desastre. Existe un proceso que especifica las actualizaciones de procedimientos y los materiales de entrenamiento para que sea un entregable explícito de un proyecto de cambio. A pesar de la existencia de enfoques definidos, el contenido actual varía debido a que no hay un control para reforzar el cumplimiento de estándares. Los usuarios se involucran en los procesos informalmente. Cada vez se utilizan más herramientas automatizadas en la generación y distribución de procedimientos. Se planea y programa tanto el entrenamiento del negocio como de los usuario. **4 Administrado y Medible** Existe un esquema definido para los procedimientos de mantenimiento y para los materiales de entrenamiento que cuentan con el soporte de la administración de TI. El enfoque considerado para los procedimientos de mantenimiento y los manuales de entrenamiento cubren todos los sistemas y las unidades de negocio, de manera que se pueden observar los procesos desde una perspectiva de negocio. Los procedimientos y materiales de entrenamiento se integran para que contengan interdependencias e interfaces. Existen controles para garantizar que se adhieren los estándares y que se desarrollan y mantienen procedimientos para todos los procesos. La retroalimentación del negocio y del usuario sobre la documentación y el entrenamiento se recopila y evalúa como parte de un proceso continuo de mejora. Los materiales de documentación y entrenamiento se encuentran generalmente a un buen nivel, predecible, de confiabilidad y disponibilidad. Se implanta un proceso emergente para el uso de documentación y administración automatizada de procedimiento. El desarrollo automatizado de procedimientos se integra cada vez más con el desarrollo de sistemas aplicativos, facilitando la consistencia y el acceso al usuario. El entrenamiento de negocio y usuario es sensible a las necesidades del negocio. La administración de TI está desarrollando medidas para el desarrollo y la entrega de documentación, materiales y programas de entrenamiento. **5 Optimizado** El proceso para la documentación de usuario y de operación se mejora constantemente con la adopción de nuevas herramientas o métodos. Los materiales de procedimiento y de entrenamiento se tratan como una base de conocimiento en evolución constante que se mantiene en forma electrónica, con el uso de administración de conocimiento actualizada, flujo de trabajo y tecnologías de distribución, que los hacen accesibles y fáciles de mantener. El material de documentación y entrenamiento se actualiza para reflejar los cambios en la organización, en la operación y en el software. Tanto el desarrollo de materiales de documentación y entrenamiento como la entrega de programas de entrenamiento, se encuentran completamente integrados con el negocio y con las definiciones de proceso del negocio, siendo así un apoyo a los requerimientos de toda la organización y no tan sólo procedimientos orientados a TI.

Criterio 9: Asegurar el uso y las operaciones
Asegurar que las personas tiene el conocimiento y las habilidades para permitir operaciones eficaces y eficientes nuevas o ajustadas de función de aplicación/ tecnología en línea con las políticas de seguridad y los procedimientos.
Subcriterio 9b. La transferencia de conocimientos a las operaciones y personal de apoyo El conocimiento y las habilidades son trasferidas para permitir que las operaciones y el personal de apoyo técnico entreguen de manera eficaz y eficiente, soporte y mantenimiento del sistema y de la infraestructura asociada.
Fortalezas El personal clave esta sensibilizado en aspectos como apoyo técnico, conocimiento del proceso de entrega eficaz, soporte y mantenimiento del sistema de aplicaciones e infraestructura de acuerdo con los niveles del servicio. **Áreas de mejora** Involucrar al personal en el desarrollo y mantenimiento de las operaciones y elaboración de documentación de apoyo

No existente	Inicial / Ad Hoc	Repetible pero Intuitivo	Definido	Administrado y Medible	Optimizado
				X	

Interpretación del Modelo de Madurez
AI4 Facilitar la Operación y el Uso
0 No Existente No existe el proceso con respecto a la producción de documentación de usuario, manuales de operación y material de entrenamiento. Los únicos materiales existentes son aquellos que se suministran con los productos que se adquieren. **1 Inicial / Ad Hoc** Existe la percepción de que la documentación de proceso es necesaria. La documentación se genera ocasionalmente y se distribuye en forma desigual a grupos limitados. Mucha de la documentación y muchos de los procedimientos ya caducaron. Los materiales de entrenamiento tienden a ser esquemas únicos con calidad variable. Virtualmente no existen procedimientos de integración a través de los diferentes sistemas y unidades de negocio. No hay aportes de las unidades de negocio en el diseño de programas de entrenamiento. **2 Repetible pero Intuitivo** Se utilizan enfoques similares para generar procedimientos y documentación, pero no se basan en un enfoque estructural o marco de trabajo. No hay un enfoque uniforme para el desarrollo de procedimientos de usuario y de operación. Individuos o equipos de proyecto generan los materiales de entrenamiento, y la calidad depende de los individuos que se involucran. Los procedimientos y la calidad del soporte al usuario van desde pobre a muy buena, con una consistencia e integración muy pequeña a lo largo de la organización. Se proporcionan o facilitan programas de entrenamiento para el negocio y los usuarios, pero no hay un plan general para ofrecer o dar entrenamiento. **3 Definido** Existe un esquema bien definido, aceptado y comprendido para documentación del usuario, manuales de operación y materiales de entrenamiento. Se guardan y se mantienen los procedimientos en una biblioteca formal y cualquiera que necesite saber tiene acceso a ella. Las correcciones a la documentación y a los procedimientos se realizan por reacción. Los procedimientos se encuentran disponibles fuera de línea y se pueden acceder y mantener en caso de desastre. Existe un proceso que especifica las actualizaciones de procedimientos y los materiales de entrenamiento para que sea un entregable explícito de un proyecto de cambio. A pesar de la existencia de enfoques definidos, el contenido actual varía debido a que no hay un control para reforzar el cumplimiento de estándares. Los usuarios se involucran en los procesos informalmente. Cada vez se utilizan más herramientas automatizadas en la generación y distribución de procedimientos. Se planea y programa tanto el entrenamiento del negocio como de los usuario. **4 Administrado y Medible** Existe un esquema definido para los procedimientos de mantenimiento y para los materiales de entrenamiento que cuentan con el soporte de la administración de TI. El enfoque considerado para los procedimientos de mantenimiento y los manuales de entrenamiento cubren todos los sistemas y las unidades de negocio, de manera que se pueden observar los procesos desde una perspectiva de negocio. Los procedimientos y materiales de entrenamiento se integran para que contengan interdependencias e interfaces. Existen controles para garantizar que se adhieren los estándares y que se desarrollan y mantienen procedimientos para todos los procesos. La retroalimentación del negocio y del usuario sobre la documentación y el entrenamiento se recopila y evalúa como parte de un proceso continuo de mejora. Los materiales de documentación y entrenamiento se encuentran generalmente a un buen nivel, predecible, de confiabilidad y disponibilidad. Se implanta un proceso emergente para el uso de documentación y administración automatizada de procedimiento. El desarrollo automatizado de procedimientos se integra cada vez más con el desarrollo de sistemas aplicativos, facilitando la consistencia y el acceso al usuario. El entrenamiento de negocio y usuario es sensible a las necesidades del negocio. La administración de TI está desarrollando medidas para el desarrollo y la entrega de documentación, materiales y programas de entrenamiento. **5 Optimizado** El proceso para la documentación de usuario y de operación se mejora constantemente con la adopción de nuevas herramientas o métodos. Los materiales de procedimiento y de entrenamiento se tratan como una base de conocimiento en evolución constante que se mantiene en forma electrónica, con el uso de administración de conocimiento actualizada, flujo de trabajo y tecnologías de distribución, que los hacen accesibles y fáciles de mantener. El material de documentación y entrenamiento se actualiza para reflejar los cambios en la organización, en la operación y en el software. Tanto el desarrollo de materiales de documentación y entrenamiento como la entrega de programas de entrenamiento, se encuentran completamente integrados con el negocio y con las definiciones de proceso del negocio, siendo así un apoyo a los requerimientos de toda la organización y no tan sólo procedimientos orientados a TI.

Criterio 10: Gestión del cambio **Asegurar que todos los cambios, incluyendo parches, objetivos de soporte de la empresa y se llevan a cabo de una manera segura. Asegurar que los procesos de negocio del día a día no se ven afectados.**					
Subcriterio 10a. Cambio de estándares y procedimientos Los procedimientos de gestión de cambio formales han sido establecidos para para manejar de una manera estandarizada todas las solicitudes (incluyendo mantenimiento y parches) para cambios de aplicaciones, procedimientos, procesos, sistema y parámetros del servicio y plataformas subyacentes.					
FortalezaS Cuentan con un Mecanismo de Control de Versiones (SourceSafe) para el Desarrollo de las Aplicaciones. Se tienen cambios descritos en algunos documentos del sistema PREP, aunque dispersos. **Áreas de mejora** Establecer un documento formal del Proceso de Gestión de Cambios para el manejo de solicitudes de cambio en las aplicaciones e infraestructura. Definir en dicho documento los roles y responsabilidades, clasificar las solicitudes de cambio, incluir una evaluación de cambios, definir quien autoriza y quien aprueba los cambios. Realizar una gestión del cambio desde el inicio hasta la revisión y el cierre. Realizar un seguimiento de los cambios. Establecer procesos de cambios de emergencia.					
No existente	**Inicial / Ad Hoc**	**Repetible pero Intuitivo**	**Definido**	**Administrado y Medible**	**Optimizado**
	X				

Interpretación del Modelo de Madurez
AI6 Administrar Cambios
0 No Existente No existe un proceso definido de administración de cambio y los cambios se pueden realizar virtualmente sin control. No hay conciencia de que el cambio puede causar una interrupción para TI y las operaciones del negocio y no hay conciencia de los beneficios de la buena administración de cambio. **1 Inicial / Ad Hoc** Se reconoce que los cambios se deben administrar y controlar. Las prácticas varían y es muy probable que se puedan dar cambios sin autorización. Hay documentación de cambio pobre o no existente y la documentación de configuración es incompleta y no confiable. Es posible que ocurran errores junto con interrupciones al ambiente de producción, provocados por una pobre administración de cambios. **2 Repetible pero Intuitivo** Existe un proceso de administración de cambio informal y la mayoría de los cambios siguen este enfoque; sin embargo, el proceso no está estructurado, es rudimentario y propenso a errores. La exactitud de la documentación de la configuración es inconsistente y de planeación limitada y la evaluación de impacto se da previa al cambio. **3 Definido** Existe un proceso formal definido para la administración del cambio, que incluye la categorización, asignación de prioridades, procedimientos de emergencia, autorización del cambio y administración de liberación, y va surgiendo el cumplimiento. Se dan soluciones temporales a los problemas y los procesos a menudo se omiten o se hacen a un lado. Aún pueden ocurrir errores y los cambios no autorizados ocurren ocasionalmente. El análisis de impacto de los cambios de TI en operaciones de negocio se está volviendo formal, para apoyar la implantación planeada de nuevas aplicaciones y tecnologías. **4 Administrado y Medible** El proceso de administración de cambio se desarrolla bien y es consistente para todos los cambios, y la gerencia confía que hay excepciones mínimas. El proceso es eficiente y efectivo, pero se basa en manuales de procedimientos y controles considerables para garantizar el logro de la calidad. Todos los cambios están sujetos a una planeación minuciosa y a la evaluación del impacto para minimizar la probabilidad de tener problemas de post-producción. Se da un proceso de aprobación para cambios. La documentación de administración de cambios es vigente y correcta, con seguimiento formal a los cambios. La documentación de configuración es generalmente exacta. La planeación e implantación de la administración de cambios en TI se van integrando con los cambios en los procesos de negocio, para asegurar que se resuelven los asuntos referentes al entrenamiento, cambio organizacional y continuidad del negocio. Existe una coordinación creciente entre la administración de cambio de TI y el rediseño del proceso de negocio. Hay un proceso consistente para monitorear la calidad y el desempeño del proceso de administración de cambios. **5 Optimizado** El proceso de administración de cambios se revisa con regularidad y se actualiza para permanecer en línea con las buenas prácticas. El proceso de revisión refleja los resultados del monitoreo. La información de la configuración es computarizada y proporciona un control de versión. El rastreo del cambio es sofisticado e incluye herramientas para detectar software no autorizado y sin licencia. La administración de cambio de TI se integra con la administración de cambio del negocio para garantizar que TI sea un factor que hace posible el incremento de productividad y la creación de nuevas oportunidades de negocio para la organización.

Criterio 10: Gestión del cambio

Asegurar que todos los cambios, incluyendo parches, objetivos de soporte de la empresa y se llevan a cabo de una manera segura. Asegurar que los procesos de negocio del día a día no se ven afectados.

Subcriterio 10b. Evaluación de impacto, priorización y autorización

Todas las solicitudes para el cambio, se evalúan de una manera estructurada para determinar el impacto en el sistema operativo y su funcionalidad. Todos los cambios se clasifican, priorizan y autorizan.

Fortalezas

Se llevan a cabo los cambios aunque de una forma apalabrada.

Áreas de mejora

Incluir en un documento formal del proceso de Gestión de Cambios la priorización de los mismos con el objetivo de solventar las solicitudes de mayor importancia.

Dicha priorización de solicitudes de cambio deben ser en función de criterios predefinidos.

Evaluar y documentar las solicitudes de cambios.

Establecer un método estructurado para abordar el análisis de impacto en las aplicaciones e infraestructura.

No existente	Inicial / Ad Hoc	Repetible pero Intuitivo	Definido	Administrado y Medible	Optimizado
	X				

Interpretación del Modelo de Madurez
AI6 Administrar Cambios
0 No Existente No existe un proceso definido de administración de cambio y los cambios se pueden realizar virtualmente sin control. No hay conciencia de que el cambio puede causar una interrupción para TI y las operaciones del negocio y no hay conciencia de los beneficios de la buena administración de cambio. **1 Inicial / Ad Hoc** Se reconoce que los cambios se deben administrar y controlar. Las prácticas varían y es muy probable que se puedan dar cambios sin autorización. Hay documentación de cambio pobre o no existente y la documentación de configuración es incompleta y no confiable. Es posible que ocurran errores junto con interrupciones al ambiente de producción, provocados por una pobre administración de cambios. **2 Repetible pero Intuitivo** Existe un proceso de administración de cambio informal y la mayoría de los cambios siguen este enfoque; sin embargo, el proceso no está estructurado, es rudimentario y propenso a errores. La exactitud de la documentación de la configuración es inconsistente y de planeación limitada y la evaluación de impacto se da previa al cambio. **3 Definido** Existe un proceso formal definido para la administración del cambio, que incluye la categorización, asignación de prioridades, procedimientos de emergencia, autorización del cambio y administración de liberación, y va surgiendo el cumplimiento. Se dan soluciones temporales a los problemas y los procesos a menudo se omiten o se hacen a un lado. Aún pueden ocurrir errores y los cambios no autorizados ocurren ocasionalmente. El análisis de impacto de los cambios de TI en operaciones de negocio se está volviendo formal, para apoyar la implantación planeada de nuevas aplicaciones y tecnologías. **4 Administrado y Medible** El proceso de administración de cambio se desarrolla bien y es consistente para todos los cambios, y la gerencia confía que hay excepciones mínimas. El proceso es eficiente y efectivo, pero se basa en manuales de procedimientos y controles considerables para garantizar el logro de la calidad. Todos los cambios están sujetos a una planeación minuciosa y a la evaluación del impacto para minimizar la probabilidad de tener problemas de post-producción. Se da un proceso de aprobación para cambios. La documentación de administración de cambios es vigente y correcta, con seguimiento formal a los cambios. La documentación de configuración es generalmente exacta. La planeación e implantación de la administración de cambios en TI se van integrando con los cambios en los procesos de negocio, para asegurar que se resuelven los asuntos referentes al entrenamiento, cambio organizacional y continuidad del negocio. Existe una coordinación creciente entre la administración de cambio de TI y el rediseño del proceso de negocio. Hay un proceso consistente para monitorear la calidad y el desempeño del proceso de administración de cambios. **5 Optimizado** El proceso de administración de cambios se revisa con regularidad y se actualiza para permanecer en línea con las buenas prácticas. El proceso de revisión refleja los resultados del monitoreo. La información de la configuración es computarizada y proporciona un control de versión. El rastreo del cambio es sofisticado e incluye herramientas para detectar software no autorizado y sin licencia. La administración de cambio de TI se integra con la administración de cambio del negocio para garantizar que TI sea un factor que hace posible el incremento de productividad y la creación de nuevas oportunidades de negocio para la organización.

Criterio 10: Gestión del cambio **Asegurar que todos los cambios, incluyendo parches, objetivos de soporte de la empresa y se llevan a cabo de una manera segura. Asegurar que los procesos de negocio del día a día no se ven afectados.**					
Subcriterio 10c. Ambiente de la prueba Un ambiente de prueba segura es definido y representativamente establecido del ambiente de las operaciones planeadas, relativas a la seguridad, controles internos, prácticas operaciones, calidad de los datos y requerimientos de privacidad y cargas de trabajo.					
Fortalezas Existe un ambiente pruebas configurado que refleja el ambiente de producción. Se llevan a cabo diferentes tipo de pruebas. Como medidas de protección y autorización de acceso al entorno de pruebas se utiliza un método de autenticación mediante cuentas de acceso y sus respectivas contraseñas. El ambiente de pruebas es independiente del ambiente de producción. Existe una Base de Datos para cada ambiente. **Áreas de mejora** Establecer un proceso formal y documentado para la configuración de ambientes y para la gestión de la retención o eliminación de resultados de las pruebas.					
No existente	**Inicial / Ad Hoc**	**Repetible pero Intuitivo**	**Definido**	**Administrado y Medible**	**Optimizado**
		x			

Interpretación del Modelo de Madurez
AI7 Instalar y Acreditar Soluciones y Cambios
1 Inicial / Ad Hoc Existe la percepción de la necesidad de verificar y confirmar que las soluciones implantadas sirven para el propósito esperado. Las pruebas se realizan para algunos proyectos, pero la iniciativa de pruebas se deja a los equipos de proyectos particulares y los enfoques que se toman varían. La acreditación formal y la autorización son raras o no existentes. **2 Repetible pero Intuitivo** Existe cierta consistencia entre los enfoques de prueba y acreditación, pero por lo regular no se basan en ninguna metodología. Los equipos individuales de desarrollo deciden normalmente el enfoque de prueba y casi siempre hay ausencia de pruebas de integración. Hay un proceso de aprobación informal. **3 Definido** Se cuenta con una metodología formal en relación con la instalación, migración, conversión y aceptación. Los procesos de TI para instalación y acreditación están integrados dentro del ciclo de vida del sistema y están automatizados hasta cierto punto. El entrenamiento, pruebas y transición y acreditación a producción tienen muy probablemente variaciones respecto al proceso definido, con base en las decisiones individuales. La calidad de los sistemas que pasan a producción es inconsistente, y los nuevos sistemas a menudo generan un nivel significativo de problemas posteriores a la implantación. **4 Administrado y Medible** Los procedimientos son formales y se desarrollan para ser organizados y prácticos con ambientes de prueba definidos y con procedimientos de acreditación. En la práctica, todos los cambios mayores de sistemas siguen este enfoque formal. La evaluación de la satisfacción a los requerimientos del usuario es estándar y medible, y produce mediciones que la gerencia puede revisar y analizar de forma efectiva. La calidad de los sistemas que entran en producción es satisfactoria para la gerencia, aún con niveles razonables de problemas posteriores a la implantación. La automatización del proceso es ad hoc y depende del proyecto. Es posible que la gerencia esté satisfecha con el nivel actual de eficiencia a pesar de la ausencia de una evaluación posterior a la implantación. El sistema de prueba refleja adecuadamente el ambiente de producción. La prueba de stress para los nuevos sistemas y la prueba de regresión para sistemas existentes se aplican para proyectos mayores. **5 Optimizado** Los procesos de instalación y acreditación se han refinado a un nivel de buena práctica, con base en los resultados de mejora continua y refinamiento. Los procesos de TI para la instalación y acreditación están totalmente integrados dentro del ciclo de vida del sistema y se automatizan cuando es apropiado, arrojando el estatus más eficiente de entrenamiento, pruebas y transición a producción para los nuevos sistemas. Los ambientes de prueba bien desarrollados, los registros de problemas y los procesos de resolución de fallas aseguran la transición eficiente y efectiva al ambiente de producción. La acreditación toma lugar regularmente sin repetición de trabajos, y los problemas posteriores a la implantación se limitan normalmente a correcciones menores. Las revisiones posteriores a la implantación son estándar, y las lecciones aprendidas se canalizan nuevamente hacia el proceso para asegurar el mejoramiento continuo de la calidad. Las pruebas de stress para los nuevos sistemas y las pruebas de regresión para sistemas modificados se aplican en forma consistente.

Criterio 10: Gestión del cambio
Asegurar que todos los cambios, incluyendo parches, objetivos de soporte de la empresa y se llevan a cabo de una manera segura. Asegurar que los procesos de negocio del día a día no se ven afectados.
Subcriterio 10d. Pruebas de cambios Un ambiente de prueba segura es definido y representativamente establecido del ambiente de las operaciones planeadas, relativas a la seguridad, controles internos, prácticas operaciones, calidad de los datos y requerimientos de privacidad y cargas de trabajo.
Fortalezas Se toman en cuenta algunas pruebas definidas en un documento aunque no como un proceso formal. Las pruebas realizadas se llevan únicamente en el ambiente de pruebas. Los cambios realizados sobre las pruebas son validados antes de liberarse en producción. **Áreas de mejora** Realizar una mejor estructuración del documento inicial enfocado a un proceso formal. En dicho documento incluir los requisitos se seguridad y rendimiento para las aplicaciones.

No existente	Inicial / Ad Hoc	Repetible pero Intuitivo	Definido	Administrado y Medible	Optimizado
		X			

Interpretación del Modelo de Madurez

AI7 Instalar y Acreditar Soluciones y Cambios

1 Inicial / Ad Hoc
Existe la percepción de la necesidad de verificar y confirmar que las soluciones implantadas sirven para el propósito esperado. Las pruebas se realizan para algunos proyectos, pero la iniciativa de pruebas se deja a los equipos de proyectos particulares y los enfoques que se toman varían. La acreditación formal y la autorización son raras o no existentes.

2 Repetible pero Intuitivo
Existe cierta consistencia entre los enfoques de prueba y acreditación, pero por lo regular no se basan en ninguna metodología. Los equipos individuales de desarrollo deciden normalmente el enfoque de prueba y casi siempre hay ausencia de pruebas de integración. Hay un proceso de aprobación informal.

3 Definido
Se cuenta con una metodología formal en relación con la instalación, migración, conversión y aceptación. Los procesos de TI para instalación y acreditación están integrados dentro del ciclo de vida del sistema y están automatizados hasta cierto punto. El entrenamiento, pruebas y transición y acreditación a producción tienen muy probablemente variaciones respecto al proceso definido, con base en las decisiones individuales. La calidad de los sistemas que pasan a producción es inconsistente, y los nuevos sistemas a menudo generan un nivel significativo de problemas posteriores a la implantación.

4 Administrado y Medible
Los procedimientos son formales y se desarrollan para ser organizados y prácticos con ambientes de prueba definidos y con procedimientos de acreditación. En la práctica, todos los cambios mayores de sistemas siguen este enfoque formal. La evaluación de la satisfacción a los requerimientos del usuario es estándar y medible, y produce mediciones que la gerencia puede revisar y analizar de forma efectiva. La calidad de los sistemas que entran en producción es satisfactoria para la gerencia, aún con niveles razonables de problemas posteriores a la implantación. La automatización del proceso es ad hoc y depende del proyecto. Es posible que la gerencia esté satisfecha con el nivel actual de eficiencia a pesar de la ausencia de una evaluación posterior a la implantación. El sistema de prueba refleja adecuadamente el ambiente de producción. La prueba de stress para los nuevos sistemas y la prueba de regresión para sistemas existentes se aplican para proyectos mayores.

5 Optimizado
Los procesos de instalación y acreditación se han refinado a un nivel de buena práctica, con base en los resultados de mejora continua y refinamiento. Los procesos de TI para la instalación y acreditación están totalmente integrados dentro del ciclo de vida del sistema y se automatizan cuando es apropiado, arrojando el estatus más eficiente de entrenamiento, pruebas y transición a producción para los nuevos sistemas. Los ambientes de prueba bien desarrollados, los registros de problemas y los procesos de resolución de fallas aseguran la transición eficiente y efectiva al ambiente de producción. La acreditación toma lugar regularmente sin repetición de trabajos, y los problemas posteriores a la implantación se limitan normalmente a correcciones menores. Las revisiones posteriores a la implantación son estándar, y las lecciones aprendidas se canalizan nuevamente hacia el proceso para asegurar el mejoramiento continuo de la calidad. Las pruebas de stress para los nuevos sistemas y las pruebas de regresión para sistemas modificados se aplican en forma consistente.

Criterio 10: Gestión del cambio **Asegurar que todos los cambios, incluyendo parches, objetivos de soporte de la empresa y se llevan a cabo de una manera segura. Asegurar que los procesos de negocio del día a día no se ven afectados.**					
Subcriterio 10d. Promoción a la producción El siguiente procedimiento es seguido: Después de la prueba, la entrega del sistema cambiado para las operaciones es controlado, manteniéndolo en línea con el plan de implementación. La aprobación se obtuvo de las partes interesadas clave, tales como usuarios, gestión operacional y propietario del sistema.					
Fortalezas Se cuenta con un documento de roles de la aplicación PREP. Se tomaron en cuenta pruebas de aceptación para el sistema PREP. **Áreas de mejora** Establecer un proceso formal documentado para la aprobación final del sistema que describa el desarrollo del sistema. Establecer procedimientos para actualizar la documentación de las aplicaciones. Definir un proceso formal documentado que incluya pruebas de aceptación.					
No existente	**Inicial / Ad Hoc**	**Repetible pero Intuitivo**	**Definido**	**Administrado y Medible**	**Optimizado**
	X				

Interpretación del Modelo de Madurez

AI7 Instalar y Acreditar Soluciones y Cambios

1 Inicial / Ad Hoc
Existe la percepción de la necesidad de verificar y confirmar que las soluciones implantadas sirven para el propósito esperado. Las pruebas se realizan para algunos proyectos, pero la iniciativa de pruebas se deja a los equipos de proyectos particulares y los enfoques que se toman varían. La acreditación formal y la autorización son raras o no existentes.

2 Repetible pero Intuitivo
Existe cierta consistencia entre los enfoques de prueba y acreditación, pero por lo regular no se basan en ninguna metodología. Los equipos individuales de desarrollo deciden normalmente el enfoque de prueba y casi siempre hay ausencia de pruebas de integración. Hay un proceso de aprobación informal.

3 Definido
Se cuenta con una metodología formal en relación con la instalación, migración, conversión y aceptación. Los procesos de TI para instalación y acreditación están integrados dentro del ciclo de vida del sistema y están automatizados hasta cierto punto. El entrenamiento, pruebas y transición y acreditación a producción tienen muy probablemente variaciones respecto al proceso definido, con base en las decisiones individuales. La calidad de los sistemas que pasan a producción es inconsistente, y los nuevos sistemas a menudo generan un nivel significativo de problemas posteriores a la implantación.

4 Administrado y Medible
Los procedimientos son formales y se desarrollan para ser organizados y prácticos con ambientes de prueba definidos y con procedimientos de acreditación. En la práctica, todos los cambios mayores de sistemas siguen este enfoque formal. La evaluación de la satisfacción a los requerimientos del usuario es estándar y medible, y produce mediciones que la gerencia puede revisar y analizar de forma efectiva. La calidad de los sistemas que entran en producción es satisfactoria para la gerencia, aún con niveles razonables de problemas posteriores a la implantación. La automatización del proceso es ad hoc y depende del proyecto. Es posible que la gerencia esté satisfecha con el nivel actual de eficiencia a pesar de la ausencia de una evaluación posterior a la implantación. El sistema de prueba refleja adecuadamente el ambiente de producción. La prueba de stress para los nuevos sistemas y la prueba de regresión para sistemas existentes se aplican para proyectos mayores.

5 Optimizado
Los procesos de instalación y acreditación se han refinado a un nivel de buena práctica, con base en los resultados de mejora continua y refinamiento. Los procesos de TI para la instalación y acreditación están totalmente integrados dentro del ciclo de vida del sistema y se automatizan cuando es apropiado, arrojando el estatus más eficiente de entrenamiento, pruebas y transición a producción para los nuevos sistemas. Los ambientes de prueba bien desarrollados, los registros de problemas y los procesos de resolución de fallas aseguran la transición eficiente y efectiva al ambiente de producción. La acreditación toma lugar regularmente sin repetición de trabajos, y los problemas posteriores a la implantación se limitan normalmente a correcciones menores. Las revisiones posteriores a la implantación son estándar, y las lecciones aprendidas se canalizan nuevamente hacia el proceso para asegurar el mejoramiento continuo de la calidad. Las pruebas de stress para los nuevos sistemas y las pruebas de regresión para sistemas modificados se aplican en forma consistente.

Criterio 11: Gestión de la continuidad **Contrarrestar las interrupciones para las actividades del negocio para el proyecto de procesos de negocios crítico a partir de los efectos de mayores fallas de sistemas de información o desastres y para garantizar su reanudación oportuna.**					
Subcriterio 11a. Los planes de continuidad de TI Los planes de continuidad TI son desarrollados basados en el framework y diseñados para reducir el impacto de grandes trastornos en las funciones y procesos de negocio clave. Los planes están basados en el entendimiento del riesgo de impactos potenciales en el negocio y dirigir los requerimientos de resistencia, procesamiento alternativo y capacidad de recuperación de todos los servicios críticos de TI.					
Fortalezas No se observó evidencia durante la auditoría. **Áreas de mejora** Elaborar planes de continuidad de negocio para todas las funciones y procesos clave. El dicho documento definir funciones y responsabilidades, procesos de comunicación. Obtener la estrategia general de las pruebas de los planes de continuidad de negocio y la evidencia de que las pruebas se están ejecutando con la frecuencia acordada Revise los resultados de las pruebas, y asegurar que las acciones resultantes son objeto de seguimiento.					
No existente	**Inicial / Ad Hoc**	**Repetible pero Intuitivo**	**Definido**	**Administrado y Medible**	**Optimizado**
X					

Interpretación del Modelo de Madurez

DS4 Garantizar la Continuidad del Servicio

0 No Existente
No hay entendimiento de los riesgos, vulnerabilidades y amenazas a las operaciones de TI o del impacto en el negocio por la pérdida de los servicios de TI. No se considera que la continuidad en los servicios deba tener atención de la gerencia.

1 Inicial / Ad Hoc
Las responsabilidades sobre la continuidad de los servicios son informales y la autoridad para ejecutar responsabilidades es limitada. La gerencia comienza a darse cuenta de los riesgos relacionados y de la necesidad de mantener continuidad en los servicios. El enfoque de la gerencia sobre la continuidad del servicio radica en los recursos de infraestructura, en vez de radicar en los servicios de TI. Los usuarios utilizan soluciones alternas como respuesta a la interrupción de los servicios. La respuesta de TI a las interrupciones mayores es reactiva y sin preparación. Las pérdidas de energía planeadas están programadas para cumplir con las necesidades de TI pero no consideran los requerimientos del negocio

2 Repetible pero Intuitivo
Se asigna la responsabilidad para mantener la continuidad del servicio. Los enfoques para asegurar la continuidad están fragmentados. Los reportes sobre la disponibilidad son esporádicos, pueden estar incompletos y no toman en cuenta el impacto en el negocio. No hay un plan de continuidad de TI documentado, aunque hay compromiso para mantener disponible la continuidad del servicio y sus principios más importantes se conocen. Existe un inventario de sistemas y componentes críticos, pero puede no ser confiable. Las prácticas de continuidad en los servicios emergen, pero el éxito depende de los individuos.

3 Definido
La responsabilidad sobre la administración de la continuidad del servicio es clara. Las responsabilidades de la planeación y de las pruebas de la continuidad de los servicios están claramente asignadas y definidas. El plan de continuidad de TI está documentado y basado en la criticidad de los sistemas y el impacto al negocio. Hay reportes periódicos de las pruebas de continuidad. Los individuos toman la iniciativa para seguir estándares y recibir entrenamiento para enfrentarse con incidentes mayores o desastres. La gerencia comunica de forma regular la necesidad de planear el aseguramiento de la continuidad del servicio. Se han aplicado componentes de alta disponibilidad y redundancia. Se mantiene un inventario de sistemas y componentes críticos.

4 Administrado y Medible
Se hacen cumplir las responsabilidades y los estándares para la continuidad de los servicios. Se asigna la responsabilidad de mantener un plan de continuidad de servicios. Las actividades de mantenimiento están basadas en los resultados de las pruebas de continuidad, en las buenas prácticas internas y en los cambios en el ambiente del negocio y de TI. Se recopila, analiza y reporta documentación estructurada sobre la continuidad en los servicios y se actúa en consecuencia. Se brinda entrenamiento formal y obligatorio sobre los procesos de continuidad. Se implementan regularmente buenas prácticas de disponibilidad de los sistemas. Las prácticas de disponibilidad y la planeación de la continuidad de los servicios tienen influencia una sobre la otra. Se clasifican los incidentes de discontinuidad y la ruta de escalamiento es bien conocida por todos los involucrados. Se han desarrollado y acordado KGIs y KPIs para la continuidad de los servicios, aunque pueden ser medidos de manera inconsistente.

5 Optimizado
Los procesos integrados de servicio continuo toman en cuenta referencias de la industria y las mejores prácticas externas. El plan de continuidad de TI está integrado con los planes de continuidad del negocio y se le da mantenimiento de manera rutinaria. El requerimiento para asegurar continuidad es garantizado por los proveedores y principales distribuidores. Se realizan pruebas globales de continuidad del servicio, y los resultados de las pruebas se utilizan para actualizar el plan. La recopilación y el análisis de datos se utilizan para mejorar continuamente el proceso. Las prácticas de disponibilidad y la continua planeación de la continuidad están totalmente alineadas. La gerencia asegura que un desastre o un incidente mayor no ocurrirán como resultado de un punto único de falla. Las prácticas de escalamiento se entienden y se hacen cumplir a fondo. Los KGIs y KPIs sobre el cumplimiento de la continuidad de los servicios se miden de manera sistemática. La gerencia ajusta la planeación de continuidad como respuesta a los KGIs y KPIs

Criterio 11: Gestión de la continuidad
Contrarrestar las interrupciones para las actividades del negocio para el proyecto de procesos de negocios crítico a partir de los efectos de mayores fallas de sistemas de información o desastres y para garantizar su reanudación oportuna.
Subcriterio 11b. Pruebas del plan de continuidad de TI El plan de continuidad de TI es probado sobre una regulación básica para asegurar que los sistemas TI puedan ser efectivamente recuperados, las deficiencias se aborden y el plan sigua siendo relevante. Esto requiere una cuidadosa preparación, documentación, informes de los resultados de las pruebas y de acuerdo a los resultados, la implementación del plan de acción. El alcance de la prueba recupera las aplicaciones simples para los escenarios de prueba integrados para el extremo a extremo de la prueba y son consideradas pruebas del vendedor integradas.
Fortalezas Se tomaron en cuenta algunas pruebas del sistema PREP en la planificación inicial. **Áreas de mejora** Implementar y documentar un plan de acción para verificar que las pruebas de continuidad están programadas y completadas de forma regular. Indicar una cronología de eventos para asegurar una secuencia lógica y real de las pruebas. Documentar la revisión de los resultados de las pruebas para determinar la eficacia de funcionamiento.

No existente	Inicial / Ad Hoc	Repetible pero Intuitivo	Definido	Administrado y Medible	Optimizado
	X				

Interpretación del Modelo de Madurez

DS4 Garantizar la Continuidad del Servicio

0 No Existente

No hay entendimiento de los riesgos, vulnerabilidades y amenazas a las operaciones de TI o del impacto en el negocio por la pérdida de los servicios de TI. No se considera que la continuidad en los servicios deba tener atención de la gerencia.

1 Inicial / Ad Hoc

Las responsabilidades sobre la continuidad de los servicios son informales y la autoridad para ejecutar responsabilidades es limitada. La gerencia comienza a darse cuenta de los riesgos relacionados y de la necesidad de mantener continuidad en los servicios. El enfoque de la gerencia sobre la continuidad del servicio radica en los recursos de infraestructura, en vez de radicar en los servicios de TI. Los usuarios utilizan soluciones alternas como respuesta a la interrupción de los servicios. La respuesta de TI a las interrupciones mayores es reactiva y sin preparación. Las pérdidas de energía planeadas están programadas para cumplir con las necesidades de TI pero no consideran los requerimientos del negocio

2 Repetible pero Intuitivo

Se asigna la responsabilidad para mantener la continuidad del servicio. Los enfoques para asegurar la continuidad están fragmentados. Los reportes sobre la disponibilidad son esporádicos, pueden estar incompletos y no toman en cuenta el impacto en el negocio. No hay un plan de continuidad de TI documentado, aunque hay compromiso para mantener disponible la continuidad del servicio y sus principios más importantes se conocen. Existe un inventario de sistemas y componentes críticos, pero puede no ser confiable. Las prácticas de continuidad en los servicios emergen, pero el éxito depende de los individuos.

3 Definido

La responsabilidad sobre la administración de la continuidad del servicio es clara. Las responsabilidades de la planeación y de las pruebas de la continuidad de los servicios están claramente asignadas y definidas. El plan de continuidad de TI está documentado y basado en la criticidad de los sistemas y el impacto al negocio. Hay reportes periódicos de las pruebas de continuidad. Los individuos toman la iniciativa para seguir estándares y recibir entrenamiento para enfrentarse con incidentes mayores o desastres. La gerencia comunica de forma regular la necesidad de planear el aseguramiento de la continuidad del servicio. Se han aplicado componentes de alta disponibilidad y redundancia. Se mantiene un inventario de sistemas y componentes críticos.

4 Administrado y Medible

Se hacen cumplir las responsabilidades y los estándares para la continuidad de los servicios. Se asigna la responsabilidad de mantener un plan de continuidad de servicios. Las actividades de mantenimiento están basadas en los resultados de las pruebas de continuidad, en las buenas prácticas internas y en los cambios en el ambiente del negocio y de TI. Se recopila, analiza y reporta documentación estructurada sobre la continuidad en los servicios y se actúa en consecuencia. Se brinda entrenamiento formal y obligatorio sobre los procesos de continuidad. Se implementan regularmente buenas prácticas de disponibilidad de los sistemas. Las prácticas de disponibilidad y la planeación de la continuidad de los servicios tienen influencia una sobre la otra. Se clasifican los incidentes de discontinuidad y la ruta de escalamiento es bien conocida por todos los involucrados. Se han desarrollado y acordado KGIs y KPIs para la continuidad de los servicios, aunque pueden ser medidos de manera inconsistente.

5 Optimizado

Los procesos integrados de servicio continuo toman en cuenta referencias de la industria y las mejores prácticas externas. El plan de continuidad de TI está integrado con los planes de continuidad del negocio y se le da mantenimiento de manera rutinaria. El requerimiento para asegurar continuidad es garantizado por los proveedores y principales distribuidores. Se realizan pruebas globales de continuidad del servicio, y los resultados de las pruebas se utilizan para actualizar el plan. La recopilación y el análisis de datos se utilizan para mejorar continuamente el proceso. Las prácticas de disponibilidad y la continua planeación de la continuidad están totalmente alineadas. La gerencia asegura que un desastre o un incidente mayor no ocurrirán como resultado de un punto único de falla. Las prácticas de escalamiento se entienden y se hacen cumplir a fondo. Los KGIs y KPIs sobre el cumplimiento de la continuidad de los servicios se miden de manera sistemática. La gerencia ajusta la planeación de continuidad como respuesta a los KGIs y KPIs

Criterio 11: Gestión de la continuidad
Contrarrestar las interrupciones para las actividades del negocio para el proyecto de procesos de negocios crítico a partir de los efectos de mayores fallas de sistemas de información o desastres y para garantizar su reanudación oportuna.
Subcriterio 11c. Almacenamiento de pruebas de seguridad remotas Todos los medios de copia de seguridad crítica, documentación y otros recursos TI necesarios para la recuperación de TI y los planes de continuidad de negocio se almacenan remotamente. El contenido de almacenamiento del respaldo es determinado en colaboración con los propietarios del proceso de negocio y determinado por el personal de TI. La gestión de TI asegura que los acuerdos remotos sean evaluados periódicamente, por lo menos anualmente, por contenido, protección del ambiente y seguridad. La compatibilidad del hardware y software para restaurar los datos archivados y periódicamente probados y garantizar la actualización de los datos archivados.
Fortalezas Establecen un enlace dedicado, la seguridad se basa en la parte del Hardware. Se generan copias de seguridad constantemente. Existe un repositorio de respaldos de las Bases de Datos. **Áreas de mejora** Documentar procedimientos de prueba para accesos remotos.

No existente	Inicial / Ad Hoc	Repetible pero Intuitivo	Definido	Administrado y Medible	Optimizado
		X			

Interpretación del Modelo de Madurez
DS4 Garantizar la Continuidad del Servicio
0 No Existente No hay entendimiento de los riesgos, vulnerabilidades y amenazas a las operaciones de TI o del impacto en el negocio por la pérdida de los servicios de TI. No se considera que la continuidad en los servicios deba tener atención de la gerencia. **1 Inicial / Ad Hoc** Las responsabilidades sobre la continuidad de los servicios son informales y la autoridad para ejecutar responsabilidades es limitada. La gerencia comienza a darse cuenta de los riesgos relacionados y de la necesidad de mantener continuidad en los servicios. El enfoque de la gerencia sobre la continuidad del servicio radica en los recursos de infraestructura, en vez de radicar en los servicios de TI. Los usuarios utilizan soluciones alternas como respuesta a la interrupción de los servicios. La respuesta de TI a las interrupciones mayores es reactiva y sin preparación. Las pérdidas de energía planeadas están programadas para cumplir con las necesidades de TI pero no consideran los requerimientos del negocio **2 Repetible pero Intuitivo** Se asigna la responsabilidad para mantener la continuidad del servicio. Los enfoques para asegurar la continuidad están fragmentados. Los reportes sobre la disponibilidad son esporádicos, pueden estar incompletos y no toman en cuenta el impacto en el negocio. No hay un plan de continuidad de TI documentado, aunque hay compromiso para mantener disponible la continuidad del servicio y sus principios más importantes se conocen. Existe un inventario de sistemas y componentes críticos, pero puede no ser confiable. Las prácticas de continuidad en los servicios emergen, pero el éxito depende de los individuos. **3 Definido** La responsabilidad sobre la administración de la continuidad del servicio es clara. Las responsabilidades de la planeación y de las pruebas de la continuidad de los servicios están claramente asignadas y definidas. El plan de continuidad de TI está documentado y basado en la criticidad de los sistemas y el impacto al negocio. Hay reportes periódicos de las pruebas de continuidad. Los individuos toman la iniciativa para seguir estándares y recibir entrenamiento para enfrentarse con incidentes mayores o desastres. La gerencia comunica de forma regular la necesidad de planear el aseguramiento de la continuidad del servicio. Se han aplicado componentes de alta disponibilidad y redundancia. Se mantiene un inventario de sistemas y componentes críticos. **4 Administrado y Medible** Se hacen cumplir las responsabilidades y los estándares para la continuidad de los servicios. Se asigna la responsabilidad de mantener un plan de continuidad de servicios. Las actividades de mantenimiento están basadas en los resultados de las pruebas de continuidad, en las buenas prácticas internas y en los cambios en el ambiente del negocio y de TI. Se recopila, analiza y reporta documentación estructurada sobre la continuidad en los servicios y se actúa en consecuencia. Se brinda entrenamiento formal y obligatorio sobre los procesos de continuidad. Se implementan regularmente buenas prácticas de disponibilidad de los sistemas. Las prácticas de disponibilidad y la planeación de la continuidad de los servicios tienen influencia una sobre la otra. Se clasifican los incidentes de discontinuidad y la ruta de escalamiento es bien conocida por todos los involucrados. Se han desarrollado y acordado KGIs y KPIs para la continuidad de los servicios, aunque pueden ser medidos de manera inconsistente. **5 Optimizado** Los procesos integrados de servicio continuo toman en cuenta referencias de la industria y las mejores prácticas externas. El plan de continuidad de TI está integrado con los planes de continuidad del negocio y se le da mantenimiento de manera rutinaria. El requerimiento para asegurar continuidad es garantizado por los proveedores y principales distribuidores. Se realizan pruebas globales de continuidad del servicio, y los resultados de las pruebas se utilizan para actualizar el plan. La recopilación y el análisis de datos se utilizan para mejorar continuamente el proceso. Las prácticas de disponibilidad y la continua planeación de la continuidad están totalmente alineadas. La gerencia asegura que un desastre o un incidente mayor no ocurrirán como resultado de un punto único de falla. Las prácticas de escalamiento se entienden y se hacen cumplir a fondo. Los KGIs y KPIs sobre el cumplimiento de la continuidad de los servicios se miden de manera sistemática. La gerencia ajusta la planeación de continuidad como respuesta a los KGIs y KPIs

Criterio 11: Gestión de la continuidad

Contrarrestar las interrupciones para las actividades del negocio para el proyecto de procesos de negocios crítico a partir de los efectos de mayores fallas de sistemas de información o desastres y para garantizar su reanudación oportuna.

Subcriterio 11d. Copia de seguridad y restauración

Los procedimientos son definidos e implementados para el resguardo y restauración de sistemas, aplicaciones, datos y documentación en línea con los requerimientos del negocio y el plan de continuidad.

Fortalezas

Las copias de seguridad se respaldan según se requiera en el caso del PREP.
Se realizan respaldos periódicamente.

Áreas de mejora

Establecer políticas y procedimientos adecuados para las copias de seguridad de los sistemas y considerar factores que incluyen:

- Frecuencia de copia de seguridad (por ejemplo, la duplicación de las copias de seguridad en tiempo real contra DVD-ROM para la retención a largo plazo de disco)
- Tipo de copia de seguridad (por ejemplo, llena vs. incremental)
- Tipo de medios
- Las copias de seguridad en líneas automatizadas
- Los tipos de datos (por ejemplo, voz, óptica)
- Creación de registros
- Datos informáticos críticos usuario final (por ejemplo, hojas de cálculo)
- Ubicación física y lógica de las fuentes de datos
- Seguridad y derechos de acceso
- Encriptación

Elaborar e implementar un documento que defina procedimientos para el respaldo y restauración de los sistemas.

No existente	Inicial / Ad Hoc	Repetible pero Intuitivo	Definido	Administrado y Medible	Optimizado
		x			

Interpretación del Modelo de Madurez
DS11 Administración de Datos
0 No Existente Los datos no son reconocidos como parte de los recursos y los activos de la empresa. No está asignada la propiedad sobre los datos o sobre la rendición de cuentas individual sobre la administración de los datos. La calidad y la seguridad de los datos son deficientes o inexistentes. **1 Inicial / Ad Hoc** La organización reconoce la necesidad de una correcta administración de los datos. Hay un método adecuado para especificar requerimientos de seguridad en la administración de datos, pero no hay procedimientos implementados de comunicación formal. No se lleva a cabo entrenamiento específico sobre administración de los datos. La responsabilidad sobre la administración de los datos no es clara. Los procedimientos de respaldo y recuperación y los acuerdos sobre desechos están en orden. **2 Repetible pero Intuitivo** A lo largo de toda la organización existe conciencia sobre la necesidad de una adecuada administración de los datos. A un alto nivel empieza a observarse la propiedad o responsabilidad sobre los datos. Los requerimientos de seguridad para la administración de datos son documentados por individuos clave. Se lleva a cabo algún tipo de monitoreo dentro de TI sobre algunas actividades clave de la administración de datos (respaldos, recuperación y desecho). Las responsabilidades para la administración de datos son asignadas de manera informal a personal clave de TI. **3 Definido** Se entiende y acepta la necesidad de la administración de datos, tanto dentro de TI como a lo largo de toda la organización. Se establece la responsabilidad sobre la administración de los datos. Se asigna la propiedad sobre los datos a la parte responsable que controla la integridad y la seguridad. Los procedimientos de administración de datos se formalizan dentro de TI y se utilizan algunas herramientas para respaldos / recuperación y desecho de equipo. Se lleva a cabo algún tipo de monitoreo sobre la administración de datos. Se definen métricas básicas de desempeño. Comienza a aparecer el entrenamiento sobre administración de información. **4 Administrado y Medible** Se entiende la necesidad de la administración de los datos y las acciones requeridas son aceptadas a lo largo de toda la organización. La responsabilidad de la propiedad y la administración de los datos están definidas, asignada y comunicada de forma clara en la organización. Los procedimientos se formalizan y son ampliamente conocidos, el conocimiento se comparte. Comienza a aparecer el uso de herramientas. Se acuerdan con los clientes los indicadores de desempeño y meta y se monitorean por medio de un proceso bien definido. Se lleva a cabo entrenamiento formal para el personal de administración de los datos. **5 Optimizado** Se entiende y acepta dentro de la organización la necesidad de realizar todas las actividades requeridas para la administración de datos. Las necesidades y los requerimientos futuros son explorados de manera proactiva. Las responsabilidades sobre la propiedad de los datos y la administración de los mismos están establecidas de forma clara, se conocen ampliamente a lo largo de la organización y se actualizan periódicamente. Los procedimientos se formalizan y se conocen ampliamente, la compartición del conocimiento es una práctica estándar. Se utilizan herramientas sofisticadas con un máximo de automatización de la administración de los datos. Se acuerdan con los clientes los indicadores de desempeño y meta, se ligan con los objetivos del negocio y se monitorean de manera regular utilizando un proceso bien definido. Se exploran constantemente oportunidades de mejora. El entrenamiento para el personal de administración de datos se institucionaliza.

Criterio 12: Gestión de los datos
Mantener la integridad, exactitud, disponibilidad y protección de datos.
Subcriterio 12a. Acuerdos de retención y almacenamiento Los procedimientos están definidos e implementados para el almacenamiento eficiente y eficaz de los datos, retención y archivo para satisfacer los objetivos del negocio, la política de seguridad de la información y requisitos regulatorios.
Fortalezas Para la persistencia de datos se utiliza SQL Server. Se obtienen modelos de datos.
Áreas de mejora Documentar e implementar un proceso definido para la persistencia de datos. Incluyendo técnicas de almacenamiento que satisfagan los requisitos del negocio en el documento.

No existente	Inicial / Ad Hoc	Repetible pero Intuitivo	Definido	Administrado y Medible	Optimizado
		X			

Interpretación del Modelo de Madurez
DS11 Administración de Datos
0 No Existente Los datos no son reconocidos como parte de los recursos y los activos de la empresa. No está asignada la propiedad sobre los datos o sobre la rendición de cuentas individual sobre la administración de los datos. La calidad y la seguridad de los datos son deficientes o inexistentes. **1 Inicial / Ad Hoc** La organización reconoce la necesidad de una correcta administración de los datos. Hay un método adecuado para especificar requerimientos de seguridad en la administración de datos, pero no hay procedimientos implementados de comunicación formal. No se lleva a cabo entrenamiento específico sobre administración de los datos. La responsabilidad sobre la administración de los datos no es clara. Los procedimientos de respaldo y recuperación y los acuerdos sobre desechos están en orden. **2 Repetible pero Intuitivo** A lo largo de toda la organización existe conciencia sobre la necesidad de una adecuada administración de los datos. A un alto nivel empieza a observarse la propiedad o responsabilidad sobre los datos. Los requerimientos de seguridad para la administración de datos son documentados por individuos clave. Se lleva a cabo algún tipo de monitoreo dentro de TI sobre algunas actividades clave de la administración de datos (respaldos, recuperación y desecho). Las responsabilidades para la administración de datos son asignadas de manera informal a personal clave de TI. **3 Definido** Se entiende y acepta la necesidad de la administración de datos, tanto dentro de TI como a lo largo de toda la organización. Se establece la responsabilidad sobre la administración de los datos. Se asigna la propiedad sobre los datos a la parte responsable que controla la integridad y la seguridad. Los procedimientos de administración de datos se formalizan dentro de TI y se utilizan algunas herramientas para respaldos / recuperación y desecho de equipo. Se lleva a cabo algún tipo de monitoreo sobre la administración de datos. Se definen métricas básicas de desempeño. Comienza a aparecer el entrenamiento sobre administración de información. **4 Administrado y Medible** Se entiende la necesidad de la administración de los datos y las acciones requeridas son aceptadas a lo largo de toda la organización. La responsabilidad de la propiedad y la administración de los datos están definidas, asignada y comunicada de forma clara en la organización. Los procedimientos se formalizan y son ampliamente conocidos, el conocimiento se comparte. Comienza a aparecer el uso de herramientas. Se acuerdan con los clientes los indicadores de desempeño y meta y se monitorean por medio de un proceso bien definido. Se lleva a cabo entrenamiento formal para el personal de administración de los datos. **5 Optimizado** Se entiende y acepta dentro de la organización la necesidad de realizar todas las actividades requeridas para la administración de datos. Las necesidades y los requerimientos futuros son explorados de manera proactiva. Las responsabilidades sobre la propiedad de los datos y la administración de los mismos están establecidas de forma clara, se conocen ampliamente a lo largo de la organización y se actualizan periódicamente. Los procedimientos se formalizan y se conocen ampliamente, la compartición del conocimiento es una práctica estándar. Se utilizan herramientas sofisticadas con un máximo de automatización de la administración de los datos. Se acuerdan con los clientes los indicadores de desempeño y meta, se ligan con los objetivos del negocio y se monitorean de manera regular utilizando un proceso bien definido. Se exploran constantemente oportunidades de mejora. El entrenamiento para el personal de administración de datos se institucionaliza.

Criterio 12: Gestión de los datos **Mantener la integridad, exactitud, disponibilidad y protección de datos.**					
Subcriterio 12b. Disposición Los procedimientos están definidos e implementados para el almacenamiento eficiente y eficaz de los datos, retención y archivo para satisfacer los objetivos del negocio, la política de seguridad de la información y requisitos regulatorios.					
Fortalezas Las Bases de Datos son actualizadas y respaldadas continuamente. **Áreas de mejora** Establecer procedimientos para la actualización, procesamiento, almacenamiento y salida de los datos. Definir claramente la responsabilidad del desarrollo y la comunicación de las políticas de eliminación.					
No existente	**Inicial / Ad Hoc**	**Repetible pero Intuitivo**	**Definido**	**Administrado y Medible**	**Optimizado**
		X			

Interpretación del Modelo de Madurez
DS11 Administración de Datos
0 No Existente Los datos no son reconocidos como parte de los recursos y los activos de la empresa. No está asignada la propiedad sobre los datos o sobre la rendición de cuentas individual sobre la administración de los datos. La calidad y la seguridad de los datos son deficientes o inexistentes. **1 Inicial / Ad Hoc** La organización reconoce la necesidad de una correcta administración de los datos. Hay un método adecuado para especificar requerimientos de seguridad en la administración de datos, pero no hay procedimientos implementados de comunicación formal. No se lleva a cabo entrenamiento específico sobre administración de los datos. La responsabilidad sobre la administración de los datos no es clara. Los procedimientos de respaldo y recuperación y los acuerdos sobre desechos están en orden. **2 Repetible pero Intuitivo** A lo largo de toda la organización existe conciencia sobre la necesidad de una adecuada administración de los datos. A un alto nivel empieza a observarse la propiedad o responsabilidad sobre los datos. Los requerimientos de seguridad para la administración de datos son documentados por individuos clave. Se lleva a cabo algún tipo de monitoreo dentro de TI sobre algunas actividades clave de la administración de datos (respaldos, recuperación y desecho). Las responsabilidades para la administración de datos son asignadas de manera informal a personal clave de TI. **3 Definido** Se entiende y acepta la necesidad de la administración de datos, tanto dentro de TI como a lo largo de toda la organización. Se establece la responsabilidad sobre la administración de los datos. Se asigna la propiedad sobre los datos a la parte responsable que controla la integridad y la seguridad. Los procedimientos de administración de datos se formalizan dentro de TI y se utilizan algunas herramientas para respaldos / recuperación y desecho de equipo. Se lleva a cabo algún tipo de monitoreo sobre la administración de datos. Se definen métricas básicas de desempeño. Comienza a aparecer el entrenamiento sobre administración de información. **4 Administrado y Medible** Se entiende la necesidad de la administración de los datos y las acciones requeridas son aceptadas a lo largo de toda la organización. La responsabilidad de la propiedad y la administración de los datos están definidas, asignada y comunicada de forma clara en la organización. Los procedimientos se formalizan y son ampliamente conocidos, el conocimiento se comparte. Comienza a aparecer el uso de herramientas. Se acuerdan con los clientes los indicadores de desempeño y meta y se monitorean por medio de un proceso bien definido. Se lleva a cabo entrenamiento formal para el personal de administración de los datos. **5 Optimizado** Se entiende y acepta dentro de la organización la necesidad de realizar todas las actividades requeridas para la administración de datos. Las necesidades y los requerimientos futuros son explorados de manera proactiva. Las responsabilidades sobre la propiedad de los datos y la administración de los mismos están establecidas de forma clara, se conocen ampliamente a lo largo de la organización y se actualizan periódicamente. Los procedimientos se formalizan y se conocen ampliamente, la compartición del conocimiento es una práctica estándar. Se utilizan herramientas sofisticadas con un máximo de automatización de la administración de los datos. Se acuerdan con los clientes los indicadores de desempeño y meta, se ligan con los objetivos del negocio y se monitorean de manera regular utilizando un proceso bien definido. Se exploran constantemente oportunidades de mejora. El entrenamiento para el personal de administración de datos se institucionaliza.

Criterio 12: Gestión de los datos **Mantener la integridad, exactitud, disponibilidad y protección de datos.**					
Subcriterio 12c. Requerimientos de seguridad para la gestión de los datos Las políticas y los procedimientos están definidos e implementados para identificar y aplicar los requerimientos de seguridad aplicables a la recepción, procesamiento, almacenamiento y salida de los datos cumplir con los objetivos del negocio, la política de seguridad de la organización y los requerimientos regulatorios.					
Fortalezas El acceso a los datos es de uso estricto para los desarrolladores de la aplicación. **Áreas de mejora** Definir e implementar un proceso para identificar los datos sensibles y confidencialidad de los datos. Establecer políticas para proteger los datos confidenciales y mensajes de acceso no autorizado. Establecer requisitos para el acceso físico y lógico a la salida de datos. Establecer normas y procedimientos para el acceso del usuario final a los datos y la gestión y seguridad de los datos sensibles.					
No existente	**Inicial / Ad Hoc**	**Repetible pero Intuitivo**	**Definido**	**Administrado y Medible**	**Optimizado**
		X			

Interpretación del Modelo de Madurez
DS11 Administración de Datos
0 No Existente Los datos no son reconocidos como parte de los recursos y los activos de la empresa. No está asignada la propiedad sobre los datos o sobre la rendición de cuentas individual sobre la administración de los datos. La calidad y la seguridad de los datos son deficientes o inexistentes. **1 Inicial / Ad Hoc** La organización reconoce la necesidad de una correcta administración de los datos. Hay un método adecuado para especificar requerimientos de seguridad en la administración de datos, pero no hay procedimientos implementados de comunicación formal. No se lleva a cabo entrenamiento específico sobre administración de los datos. La responsabilidad sobre la administración de los datos no es clara. Los procedimientos de respaldo y recuperación y los acuerdos sobre desechos están en orden. **2 Repetible pero Intuitivo** A lo largo de toda la organización existe conciencia sobre la necesidad de una adecuada administración de los datos. A un alto nivel empieza a observarse la propiedad o responsabilidad sobre los datos. Los requerimientos de seguridad para la administración de datos son documentados por individuos clave. Se lleva a cabo algún tipo de monitoreo dentro de TI sobre algunas actividades clave de la administración de datos (respaldos, recuperación y desecho). Las responsabilidades para la administración de datos son asignadas de manera informal a personal clave de TI. **3 Definido** Se entiende y acepta la necesidad de la administración de datos, tanto dentro de TI como a lo largo de toda la organización. Se establece la responsabilidad sobre la administración de los datos. Se asigna la propiedad sobre los datos a la parte responsable que controla la integridad y la seguridad. Los procedimientos de administración de datos se formalizan dentro de TI y se utilizan algunas herramientas para respaldos / recuperación y desecho de equipo. Se lleva a cabo algún tipo de monitoreo sobre la administración de datos. Se definen métricas básicas de desempeño. Comienza a aparecer el entrenamiento sobre administración de información. **4 Administrado y Medible** Se entiende la necesidad de la administración de los datos y las acciones requeridas son aceptadas a lo largo de toda la organización. La responsabilidad de la propiedad y la administración de los datos están definidas, asignada y comunicada de forma clara en la organización. Los procedimientos se formalizan y son ampliamente conocidos, el conocimiento se comparte. Comienza a aparecer el uso de herramientas. Se acuerdan con los clientes los indicadores de desempeño y meta y se monitorean por medio de un proceso bien definido. Se lleva a cabo entrenamiento formal para el personal de administración de los datos. **5 Optimizado** Se entiende y acepta dentro de la organización la necesidad de realizar todas las actividades requeridas para la administración de datos. Las necesidades y los requerimientos futuros son explorados de manera proactiva. Las responsabilidades sobre la propiedad de los datos y la administración de los mismos están establecidas de forma clara, se conocen ampliamente a lo largo de la organización y se actualizan periódicamente. Los procedimientos se formalizan y se conocen ampliamente, la compartición del conocimiento es una práctica estándar. Se utilizan herramientas sofisticadas con un máximo de automatización de la administración de los datos. Se acuerdan con los clientes los indicadores de desempeño y meta, se ligan con los objetivos del negocio y se monitorean de manera regular utilizando un proceso bien definido. Se exploran constantemente oportunidades de mejora. El entrenamiento para el personal de administración de datos se institucionaliza.

Criterio 13: Configuración del repositorio y línea base

Una herramienta de soporte y un repositorio son establecidos para contener toda la información relevante en temas de configuración.

Subcriterio 13a. Configuración del repositorio y línea base

Las políticas y los procedimientos están definidos e implementados para identificar y aplicar los requerimientos de seguridad aplicables a la recepción, procesamiento, almacenamiento y salida de los datos cumplir con los objetivos del negocio, la política de seguridad de la organización y los requerimientos regulatorios.

Fortalezas

Se tiene un documento que describe la arquitectura del sistema PREP.

Se utiliza una herramienta para el repositorio.

Áreas de mejora

Documentar e implementar un proceso para la Gestión de la Configuración.

El documento debe describir todas las funciones de la Gestión de la configuración.

Establecer la línea base de la configuración.

Establecer mecanismos para monitoreas los cambios contra el repositorio y la línea de base definida.

Realizar informes regulares y que estos resulten en planes de mejora continua.

No existente	Inicial / Ad Hoc	Repetible pero Intuitivo	Definido	Administrado y Medible	Optimizado
	X				

Interpretación del Modelo de Madurez
DS9 Administrar la Configuración
0 No Existente La gerencia no valora los beneficios de tener un proceso implementado que sea capaz de reportar y administrar las configuraciones de la infraestructura de TI, tanto para configuraciones de hardware como de software. **1 Inicial / Ad Hoc** Se reconoce la necesidad de contar con una administración de configuración. Se llevan a cabo tareas básicas de administración de configuraciones, tales como mantener inventarios de hardware y software pero de manera individual. No están definidas prácticas estandarizadas. **2 Repetible pero Intuitivo** La gerencia esta consiente de la necesidad de controlar la configuración de TI y entiende los beneficios de mantener información completa y precisa sobre las configuraciones, pero hay una dependencia implícita del conocimiento y experiencia del personal técnico. Las herramientas para la administración de configuraciones se utilizan hasta cierto grado, pero difieren entre plataformas. Además no se han definido prácticas estandarizadas de trabajo. El contenido de la información de la configuración es limitado y no lo utilizan los procesos interrelacionados, tales como administración de cambios y administración de problemas. **3 Definido** Los procedimientos y las prácticas de trabajo se han documentado, estandarizado y comunicado, pero el entrenamiento y la aplicación de estándares dependen del individuo. Además se han implementado herramientas similares de administración de configuración entre plataformas. Es poco probable detectar las desviaciones de los procedimientos y las verificaciones físicas se realizan de manera inconsistente. Se lleva a cabo algún tipo de automatización para ayudar a rastrear cambios en el software o en el hardware. La información de la configuración es utilizada por los procesos interrelacionados. **4 Administrado y Medible** En todos los niveles de la organización se reconoce la necesidad de administrar la configuración y las buenas prácticas siguen evolucionando. Los procedimientos y los estándares se comunican e incorporan al entrenamiento y las desviaciones son monitoreadas, rastreadas y reportadas. Se utilizan herramientas automatizadas para fomentar el uso de estándares y mejorar la estabilidad. Los sistemas de administración de configuraciones cubren la mayoría de los activos de TI y permiten una adecuada administración de liberaciones y control de distribución. Los análisis de excepciones, así como las verificaciones físicas, se aplican de manera consistente y se investigan las causas desde su raíz. **5 Optimizado** Todos los activos de TI se administran en un sistema central de configuraciones que contiene toda la información necesaria acerca de los componentes, sus interrelaciones y eventos. La información de las configuraciones está alineada con los catálogos de los proveedores. Hay una completa integración de los procesos interrelacionados, y estos utilizan y actualizan la información de la configuración de manera automática. Los reportes de auditoría de los puntos de referencia, brindan información esencial sobre el software y hardware con respecto a reparaciones, servicios, garantías, actualizaciones y evaluaciones técnicas de cada unidad individual. Se fomentan las reglas para limitar la instalación de software no autorizado. La gerencia proyecta las reparaciones y las actualizaciones utilizando reportes de análisis que proporcionan funciones de programación de actualizaciones y de renovación de tecnología. El rastreo de activos y el monitoreo de activos individuales de TI los protege y previene de robo, de mal uso y de abusos.

Criterio 13: Configuración del repositorio y línea base

Una herramienta de soporte y un repositorio son establecidos para contener toda la información relevante en temas de configuración.

Subcriterio 13b. Identificación y mantenimiento de los elementos de configuración

Los procedimientos de configuración para apoyar la gestión y registro de todos los cambios en el depósito de configuración se establecen para apoyar la gestión y registro de todos los cambios en el repositorio de la configuración.

Fortalezas

Existe una política basada en roles en el sistema PREP.

Se toman en cuenta elementos de configuración.

Áreas de mejora

Realizar un documento formal del proceso para la actualización de los elementos de la configuración.

Realizar un análisis para identificar elementos de configuración críticos. Éste debe apoyar a la Gestión del Cambio.

Realizar análisis de futuras demandas de procesamiento y adquisiciones tecnológicas.

No existente	Inicial / Ad Hoc	Repetible pero Intuitivo	Definido	Administrado y Medible	Optimizado
	X				

Interpretación del Modelo de Madurez
DS9 Administrar la Configuración
0 No Existente La gerencia no valora los beneficios de tener un proceso implementado que sea capaz de reportar y administrar las configuraciones de la infraestructura de TI, tanto para configuraciones de hardware como de software. **1 Inicial / Ad Hoc** Se reconoce la necesidad de contar con una administración de configuración. Se llevan a cabo tareas básicas de administración de configuraciones, tales como mantener inventarios de hardware y software pero de manera individual. No están definidas prácticas estandarizadas. **2 Repetible pero Intuitivo** La gerencia esta consiente de la necesidad de controlar la configuración de TI y entiende los beneficios de mantener información completa y precisa sobre las configuraciones, pero hay una dependencia implícita del conocimiento y experiencia del personal técnico. Las herramientas para la administración de configuraciones se utilizan hasta cierto grado, pero difieren entre plataformas. Además no se han definido prácticas estandarizadas de trabajo. El contenido de la información de la configuración es limitado y no lo utilizan los procesos interrelacionados, tales como administración de cambios y administración de problemas. **3 Definido** Los procedimientos y las prácticas de trabajo se han documentado, estandarizado y comunicado, pero el entrenamiento y la aplicación de estándares dependen del individuo. Además se han implementado herramientas similares de administración de configuración entre plataformas. Es poco probable detectar las desviaciones de los procedimientos y las verificaciones físicas se realizan de manera inconsistente. Se lleva a cabo algún tipo de automatización para ayudar a rastrear cambios en el software o en el hardware. La información de la configuración es utilizada por los procesos interrelacionados. **4 Administrado y Medible** En todos los niveles de la organización se reconoce la necesidad de administrar la configuración y las buenas prácticas siguen evolucionando. Los procedimientos y los estándares se comunican e incorporan al entrenamiento y las desviaciones son monitoreadas, rastreadas y reportadas. Se utilizan herramientas automatizadas para fomentar el uso de estándares y mejorar la estabilidad. Los sistemas de administración de configuraciones cubren la mayoría de los activos de TI y permiten una adecuada administración de liberaciones y control de distribución. Los análisis de excepciones, así como las verificaciones físicas, se aplican de manera consistente y se investigan las causas desde su raíz. **5 Optimizado** Todos los activos de TI se administran en un sistema central de configuraciones que contiene toda la información necesaria acerca de los componentes, sus interrelaciones y eventos. La información de las configuraciones está alineada con los catálogos de los proveedores. Hay una completa integración de los procesos interrelacionados, y estos utilizan y actualizan la información de la configuración de manera automática. Los reportes de auditoría de los puntos de referencia, brindan información esencial sobre el software y hardware con respecto a reparaciones, servicios, garantías, actualizaciones y evaluaciones técnicas de cada unidad individual. Se fomentan las reglas para limitar la instalación de software no autorizado. La gerencia proyecta las reparaciones y las actualizaciones utilizando reportes de análisis que proporcionan funciones de programación de actualizaciones y de renovación de tecnología. El rastreo de activos y el monitoreo de activos individuales de TI los protege y previene de robo, de mal uso y de abusos.

Criterio 14: Gestión de terceros y servicios de proveedores **Asegurarse de que terceros (proveedores, vendedores y socios) conocen los requerimientos de negocio y los negocios relacionados y los riesgos de TI asociados con continuidad y la seguridad sea minimizada.**					
Subcriterio 14a. Monitoreo y reportes del logro del nivel del servicio (service-level agreement) SLA. El criterio del rendimiento del nivel de servicio especificado es continuamente monitoreado. Los informes de logros de niveles del servicio se proporcionan de manera que sea significativo para los socios. Las estadísticas de monitoreo son analizadas y actúan para identificar las tendencias positivas y negativas para servicios individuales tanto como para la totalidad del servicio.					
Fortalezas No se observó evidencia durante la auditoría. **Áreas de mejora** Obtener informes de rendimiento SLA y verificar la distribución. Inspeccione las revisiones para previsión y tendencias en el rendimiento de nivel de servicio.					
No existente	**Inicial / Ad Hoc**	**Repetible pero Intuitivo**	**Definido**	**Administrado y Medible**	**Optimizado**
X					

Interpretación del Modelo de Madurez
DS1 Definir y Administrar los Niveles de Servicio
0 No Existente La gerencia no reconoce la necesidad de un proceso para definir los niveles de servicio. La responsabilidad y la rendición de cuentas sobre el monitoreo no está asignada. **1 Inicial / Ad Hoc** Hay conciencia de la necesidad de administrar los niveles de servicio, pero el proceso es informal y reactivo. La responsabilidad y la rendición de cuentas sobre para la definición y la administración de servicios no está definida. Si existen las medidas para medir el desempeño son solamente cualitativas con metas definidas de forma imprecisa. La notificación es informal, infrecuente e inconsistente. **2 Repetible pero Intuitivo** Los niveles de servicio están acordados pero son informales y no están revisados. Los reportes de los niveles de servicio están incompletos y pueden ser irrelevantes o engañosos para los clientes. Los reportes de los niveles de servicio dependen, en forma individual, de las habilidades y la iniciativa de los administradores. Está designado un coordinador de niveles de servicio con responsabilidades definidas, pero con autoridad limitada. Si existe un proceso para el cumplimiento de los acuerdos de niveles de servicio es voluntario y no está implementado. **3 Definido** Las responsabilidades están bien definidas pero con autoridad discrecional. El proceso de desarrollo del acuerdo de niveles de servicio está en orden y cuenta con puntos de control para revalorar los niveles de servicio y la satisfacción de cliente. Los servicios y los niveles de servicio están definidos, documentados y se ha acordado utilizar un proceso estándar. Las deficiencias en los niveles de servicio están identificadas pero los procedimientos para resolver las deficiencias son informales. Hay un claro vínculo entre el cumplimiento del nivel de servicio esperado y el presupuesto contemplado. Los niveles de servicio están acordados pero pueden no responder a las necesidades del negocio. **4 Administrado y Medible** Aumenta la definición de los niveles de servicio en la fase de definición de requerimientos del sistema y se incorporan en el diseño de la aplicación y de los ambientes de operación. La satisfacción del cliente es medida y valorada de forma rutinaria. Las medidas de desempeño reflejan las necesidades del cliente, en lugar de las metas de TI. Las medidas para la valoración de los niveles de servicio se vuelven estandarizadas y reflejan los estándares de la industria. Los criterios para la definición de los niveles de servicio están basados en la criticidad del negocio e incluyen consideraciones de disponibilidad, confiabilidad, desempeño, capacidad de crecimiento, soporte al usuario, planeación de continuidad y seguridad. Cuando no se cumplen los niveles de servicio, se llevan a cabos análisis causa-raíz de manera rutinaria. El proceso de reporte para monitorear los niveles de servicio se vuelve cada vez más automatizado. Los riesgos operativos y financieros asociados con la falta de cumplimiento de los niveles de servicio, están definidos y se entienden claramente. Se implementa y mantiene un sistema formal de medición de los KPIs y los KGIs. **5 Optimizado** Los niveles de servicio son continuamente reevaluados para asegurar la alineación de TI y los objetivos del negocio, mientras se toma ventaja de la tecnología incluyendo le relación costo-beneficio. Todos los procesos de administración de niveles de servicio están sujetos a mejora continua. Los niveles de satisfacción del cliente son administrados y monitoreados de manera continua. Los niveles de servicio esperados reflejan metas estratégicas de las unidades de negocio y son evaluadas contra las normas de la industria. La administración de TI tiene los recursos y la asignación de responsabilidades necesarias para cumplir con los objetivos de niveles de servicio y la compensación está estructurada para brindar incentivos por cumplir con dichos objetivos. La alta gerencia monitorea los KPIs y los KGIs como parte de un proceso de mejora continua.

Criterio 14: Gestión de terceros y servicios de proveedores

Asegurarse de que terceros (proveedores, vendedores y socios) conocen los requerimientos de negocio y los negocios relacionados y los riesgos de TI asociados con continuidad y la seguridad sea minimizada.

Subcriterio 14b. Proveedor de gestión de riesgos

Los riegos son identificados y mitigados de acuerdo a las capacidades de los proveedores para continuar la entrega del servicio efectivo de una manera segura y eficiente en una base continua. Los contratos se ajustan a los estándares de negocios universales de acuerdo con los requisitos legales y reglamentarios. La gestión de riesgos considera que los acuerdos de no divulgación (NDAs), contratos de fideicomiso, viabilidad continuada de proveedores, de conformidad con los requisitos de seguridad, proveedores alternos, sanciones, recompensas, etc.

Fortalezas

La Coordinación se encarga de la parte legal y Jurídica en el caso de algún incumplimiento de acuerdo con Proveedores.

Áreas de mejora

Realizar un documento formal para el proceso de abastecimiento y selección de proveedores y gestión de los mismos dentro de la organización.

Establecer políticas en caso del incumplimiento de los contratos con proveedores.

Determinar y documentar un proceso de gestión de riesgos para identificar y controlar los riesgos con proveedores.

No existente	Inicial / Ad Hoc	Repetible pero Intuitivo	Definido	Administrado y Medible	Optimizado
	X				

Interpretación del Modelo de Madurez
DS2 Administrar los Servicios de Terceros
0 No Existente Las responsabilidades y la rendición de cuentas no están definidas. No hay políticas y procedimientos formales respecto a la contratación con terceros. Los servicios de terceros no son ni aprobados ni revisados por la gerencia. No hay actividades de medición y los terceros no reportan. A falta de una obligación contractual de reportar, la alta gerencia no está al tanto de la calidad del servicio prestado. **1 Inicial / Ad Hoc** La gerencia está consciente de la importancia de la necesidad de tener políticas y procedimientos documentados para la administración de los servicios de terceros, incluyendo la firma de contratos. No hay condiciones estandarizadas para los convenios con los prestadores de servicios. La medición de los servicios prestados es informal y reactiva. Las prácticas dependen de la experiencia de los individuos y del proveedor (por ejemplo, por demanda). **2 Repetible pero Intuitivo** El proceso de supervisión de los proveedores de servicios de terceros, de los riesgos asociados y de la prestación de servicios es informal. Se utiliza un contrato pro-forma con términos y condiciones estándares del proveedor (por ejemplo, la descripción de servicios que se prestarán). Los reportes sobre los servicios existen, pero no apoyan los objetivos del negocio. **3 Definido** Hay procedimientos bien documentados para controlar los servicios de terceros con procesos claros para tratar y negociar con los proveedores. Cuando se hace un acuerdo de prestación de servicios, la relación con el tercero es meramente contractual. La naturaleza de los servicios a prestar se detalla en el contrato e incluye requerimientos legales, operativos y de control. Se asigna la responsabilidad de supervisar los servicios de terceros. Los términos contractuales se basan en formatos estandarizados. El riesgo del negocio asociado con los servicios del tercero está valorado y reportado. **4 Administrado y Medible** Se establecen criterios formales y estandarizados para definir los términos de un acuerdo, incluyendo alcance del trabajo, servicios/entregables a suministrar, suposiciones, cronograma, costos, acuerdos de facturación y responsabilidades. Se asignan las responsabilidades para la administración del contrato y del proveedor. Las aptitudes, capacidades y riesgos del proveedor son verificadas de forma continua. Los requerimientos del servicio están definidos y alineados con los objetivos del negocio. Existe un proceso para comparar el desempeño contra los términos contractuales, lo cual proporciona información para evaluar los servicios actuales y futuros del tercero. Se utilizan modelos de fijación de precios de transferencia en el proceso de adquisición. Todas las partes involucradas tienen conocimiento de las expectativas del servicio, de los costos y de las etapas. Se acordaron los KPIs y KGIs para la supervisión del servicio. **5 Optimizado** Los contratos firmados con los terceros son revisados de forma periódica en intervalos predefinidos. La responsabilidad de administrar a los proveedores y la calidad de los servicios prestados está asignada. Se monitorea el cumplimiento de las condiciones operativas, legales y de control y se implantan acciones correctivas. El tercero está sujeto a revisiones periódicas independientes y se le retroalimenta sobre su desempeño para mejorar la prestación del servicio. Las mediciones varían como respuesta a los cambios en las condiciones del negocio. Las mediciones ayudan a la detección temprana de problemas potenciales con los servicios de terceros. La notificación completa y bien definida del cumplimiento de los niveles de servicio, está asociada con la compensación del tercero. La gerencia ajusta el proceso de adquisición y monitoreo de servicios de terceros con base en los resultados de los KPIs y KGIs.

Criterio 15: Gestión de incidentes **Asegurar los eventos de seguridad de la información y debilidades asociadas a los sistemas de información que son comunicados de una manera de manera que permite acciones correctivas oportunas que deban tomarse.**					
Subcriterio 15a. Definición de seguridad del incidente Las características de los incidentes de seguridad potencial están definidas y comunicadas, así que están propiamente clasificados y tratados mediante el proceso de gestión de problemas e incidentes y los procesos de gestión de problemas.					
Fortalezas Se consideran incidencias con respecto al sistema PREP. Se establecen escenarios y acciones a realizar. **Áreas de mejora** Documentar e implementar un proceso de Gestión de Incidencias. Implementar un equipo de respuesta a emergencias informáticas (CERT) para reconocer y gestionar las eficazmente las emergencias de seguridad. Proceso de gestión de incidentes de seguridad incluye los siguientes elementos clave: - Detección de eventos - Correlación de eventos y la evaluación de la amenaza / incidente - Para la Resolución de la amenaza, o la creación y la escalada de trabajo - Criterios para iniciar proceso de CERT de la organización - Verificación y niveles requeridos de la documentación de la resolución - El análisis post-remediación - Orden de trabajo de cierre / incidente					
No existente	**Inicial / Ad Hoc**	**Repetible pero Intuitivo**	**Definido**	**Administrado y Medible**	**Optimizado**
		X			

Interpretación del Modelo de Madurez

DS5 Garantizar la Seguridad de los Sistemas

0 No Existente
La organización no reconoce la necesidad de la seguridad para TI. Las responsabilidades y la rendición de cuentas no están asignadas para garantizar la seguridad. Las medidas para soportar la administrar la seguridad de TI no están implementadas. No hay reportes de seguridad de TI ni un proceso de respuesta para resolver brechas de seguridad de TI. Hay una total falta de procesos reconocibles de administración de seguridad de sistemas.

1 Inicial / Ad Hoc
La organización reconoce la necesidad de seguridad para TI. La conciencia de la necesidad de seguridad depende principalmente del individuo. La seguridad de TI se lleva a cabo de forma reactiva. No se mide la seguridad de TI. Las brechas de seguridad de TI ocasionan respuestas con acusaciones personales, debido a que las responsabilidades no son claras. Las respuestas a las brechas de seguridad de TI son impredecibles.

2 Repetible pero Intuitivo
Las responsabilidades y la rendición de cuentas sobre la seguridad, están asignadas a un coordinador de seguridad de TI, pero la autoridad gerencial del coordinador es limitada. La conciencia sobre la necesidad de la seguridad está fraccionada y limitada. Aunque los sistemas producen información relevante respecto a la seguridad, ésta no se analiza. Los servicios de terceros pueden no cumplir con los requerimientos específicos de seguridad de la empresa. Las políticas de seguridad se han estado desarrollando, pero las herramientas y las habilidades son inadecuadas. Los reportes de la seguridad de TI son incompletos, engañosos o no aplicables. El entrenamiento sobre seguridad está disponible pero depende principalmente de la iniciativa del individuo. La seguridad de TI es vista primordialmente como responsabilidad y disciplina de TI, y el negocio no ve la seguridad de TI como parte de su propia disciplina.

3 Definido
Existe conciencia sobre la seguridad y ésta es promovida por la gerencia. Los procedimientos de seguridad de TI están definidos y alineados con la política de seguridad de TI. Las responsabilidades de la seguridad de TI están asignadas y entendidas, pero no continuamente implementadas. Existe un plan de seguridad de TI y existen soluciones de seguridad motivadas por un análisis de riesgo. Los reportes no contienen un enfoque claro de negocio. Se realizan pruebas de seguridad adecuadas (por ejemplo, pruebas contra intrusos). Existe entrenamiento en seguridad para TI y para el negocio, pero se programa y se comunica de manera informal.

4 Administrado y Medible
Las responsabilidades sobre la seguridad de TI son asignadas, administradas e implementadas de forma clara. Regularmente se lleva a cabo un análisis de impacto y de riesgos de seguridad. Las políticas y prácticas de seguridad se complementan con referencias de seguridad específicas. El contacto con métodos para promover la conciencia de la seguridad es obligatorio. La identificación, autenticación y autorización de los usuarios está estandarizada. La certificación en seguridad es buscada por parte del personal que es responsable de la auditoría y la administración de la seguridad. Las pruebas de seguridad se hacen utilizando procesos estándares y formales que llevan a mejorar los niveles de seguridad. Los procesos de seguridad de TI están coordinados con la función de seguridad de toda la organización. Los reportes de seguridad están ligados con los objetivos del negocio. El entrenamiento sobre seguridad se imparte tanto para TI como para el negocio. El entrenamiento sobre seguridad de TI se planea y se administra de manera que responda a las necesidades del negocio y a los perfiles de riesgo de seguridad. Los KGIs y KPIs ya están definidos pero no se miden aún.

5 Optimizado
La seguridad en TI es una responsabilidad conjunta del negocio y de la gerencia de TI y está integrada con los objetivos de seguridad del negocio en la corporación. Los requerimientos de seguridad de TI están definidos de forma clara, optimizados e incluidos en un plan de seguridad aprobado. Los usuarios y los clientes se responsabilizan cada vez más de definir requerimientos de seguridad, y las funciones de seguridad están integradas con las aplicaciones en la fase de diseño. Los incidentes de seguridad son atendidos de con procedimientos formales de respuesta soportados por herramientas automatizadas. Se llevan a cabo valoraciones de seguridad de forma periódica para evaluar la efectividad de la implementación del plan de seguridad. La información sobre amenazas y vulnerabilidades se recolecta y analiza de manera sistemática. Se recolectan e implementan de forma oportuna controles adecuados para mitigar riesgos. Se llevan a cabo pruebas de seguridad, análisis de causa-efecto e identificación pro-activa riesgos para la mejora continua de procesos. Los procesos de seguridad y la tecnología están integrados a lo largo de toda la organización. Los KGIs y KPIs para administración de seguridad son recopilados y comunicados. La gerencia utiliza los KGIs y KPIs para ajustar el plan de seguridad en un proceso de mejora continua

Criterio 15: Gestión de incidentes

Asegurar los eventos de seguridad de la información y debilidades asociadas a los sistemas de información que son comunicados de una manera de manera que permite acciones correctivas oportunas que deban tomarse.

Subcriterio 15b. Escalada de incidentes

Procedimientos de mesa de servicio de incidentes están establecidos, así que los incidentes que no pueden resolverse inmediatamente son escalados apropiadamente de acuerdo a los límites definidos en el SLA y si es apropiada las soluciones se proporcionan. Propiedad de incidentes y seguimiento del ciclo de vida se mantienen con la mesa de servicio de incidentes basados en el usuario, sin importar a qué grupo de TI está trabajando en actividades de resolución.

Fortalezas

Se identificaron algunas posibles incidencias en el sistema PREP.
Para PREP el Ingeniero de Soporte funge como una mesa de ayuda para solventar las incidencias presentadas.
Existen acciones a tomar en cuanto a las incidencias.

Áreas de mejora

Definir un proceso de Gestión de Incidencias.
Establecer procedimientos para reportar incidentes significativos para la gestión de las aplicaciones.
Asegurar que los registros de incidentes se actualizan para mostrar la fecha y hora y la asignación de personal de TI para cada consulta.
Garantizar que los miembros del personal están involucrados en el tratamiento de consultas e incidencias y que los registros de solicitud de incidente se actualizan a lo largo del ciclo de vida.

No existente	Inicial / Ad Hoc	Repetible pero Intuitivo	Definido	Administrado y Medible	Optimizado
		X			

Interpretación del Modelo de Madurez

DS8 Administrar la Mesa de Servicio y los Incidentes.

0 No Existente
No hay soporte para resolver problemas y preguntas de los usuarios. Hay una completa falta de procesos para la administración de incidentes. La organización no reconoce que hay un problema que atender.

1 Inicial / Ad Hoc
La gerencia reconoce que requiere un proceso soportado por herramientas y personal para responder a las consultas de los usuarios y administrar la resolución de incidentes. Sin embargo, se trata de un proceso no estandarizado y sólo se brinda soporte reactivo. La gerencia no monitorea las consultas de los usuarios, los incidentes o las tendencias. No existe un proceso de escalamiento para garantizar que los problemas se resuelvan.

2 Repetible pero Intuitivo
Hay conciencia organizacional de la necesidad de una función de mesa de servicio y de un proceso de administración de incidentes. Existe ayuda disponible de manera informal a través de una red de individuos expertos. Estos individuos tienen a su disposición algunas herramientas comunes para ayudar en la resolución de incidentes. No hay entrenamiento formal y la comunicación obre procedimientos estándar y la responsabilidad es delegada al individuo.

3 Definido
Se reconoce y se acepta la necesidad de contar con una función de mesa de servicio y un proceso para la administración de incidentes. Los procedimientos se estandarizan y documentan, pero se lleva acabo entrenamiento informal. Se deja la responsabilidad al individuo de conseguir entrenamiento y de seguir los estándares. Se desarrollan guías de usuario y preguntas frecuentes (FAQs), pero los individuos deben encontrarlas y puede ser que no las sigan. Las consultas y los incidentes se rastrean de forma manual y se monitorean de forma individual, pero no existe un sistema formal de reporte. No se mide la respuesta oportuna a las consultas e incidentes y los incidentes pueden quedar sin resolución. Los usuarios han recibido indicaciones claras de dónde y cómo reportar problemas e incidentes.

4 Administrado y Medible
En todos los niveles de la organización hay un total entendimiento de los beneficios de un proceso de administración de incidentes y la función de mesa de servicio se ha establecido en las unidades organizacionales apropiadas. Las herramientas y técnicas están automatizadas con una base de conocimientos centralizada. El personal de la mesa de servicio interactúa muy de cerca con el personal de administración de problemas. Las responsabilidades son claras y se monitorea su efectividad. Los procedimientos para comunicar, escalar y resolver incidentes han sido establecidos y comunicados. El personal de la mesa de servicio está entrenado y los procesos se mejoran a través del uso de software para tareas específicas. La gerencia ha desarrollado los KPIs y KGIs para el desempeño de la mesa de servicio.

5 Optimizado
El proceso de administración de incidentes y la función de mesa de servicio están bien organizados y establecidos y se llevan a cabo con un enfoque de servicio al cliente ya que son expertos, enfocados al cliente y útiles. Los KPIs y KGIs son medidos y reportados sistemáticamente. Una amplia y extensa cantidad de preguntas frecuentes son parte integral de la base de conocimientos. Existen a disposición del usuario, herramientas para llevar a cabo autodiagnósticos y para resolver incidentes. La asesoría es consistente y los incidentes se resuelven de forma rápida dentro de un proceso estructurado de escalamiento. La gerencia utiliza una herramienta integrada para obtener estadísticas de desempeño del proceso de administración de incidentes y de la función de mesa de servicio. Los procesos han sido afinados al nivel de las mejores prácticas de la industria, con base en los resultados del análisis de los KPIs yKGIs, de la mejora continua y de benchmarking con otras organizaciones.

Criterio 16: Monitoreo **Evite las infracciones de cualquier ley, las obligaciones legales, reglamentarias o contractuales, y de cualquier requisito de seguridad. Asegurar el cumplimiento de los sistemas y la adherencia de las personas a las políticas relacionadas con seguridad de la información de la organización, estándares y procedimientos.**					
Subcriterio 16a. Pruebas de seguridad, vigilancia y monitoreo La implementación de seguridad TI es probada y monitoreada de una manera proactiva. La seguridad TI debería ser acreditada de manera oportuna para asegurar que se mantiene la línea de base de seguridad de información aprobada de la empresa.					
Fortalezas Se realiza un inventario de todos los dispositivos de la red. Se lleva un control. **Áreas de mejora** Realizar un documento que defina el proceso del inventario de dispositivos de res, servicios y aplicaciones**.** Establecer líneas base de seguridad para todas las TI utilizada por la organización.					
No existente	**Inicial / Ad Hoc**	**Repetible pero Intuitivo**	**Definido**	**Administrado y Medible**	**Optimizado**
		X			

Interpretación del Modelo de Madurez

DS5 Garantizar la Seguridad de los Sistemas

0 No Existente
La organización no reconoce la necesidad de la seguridad para TI. Las responsabilidades y la rendición de cuentas no están asignadas para garantizar la seguridad. Las medidas para soportar la administrar la seguridad de TI no están implementadas. No hay reportes de seguridad de TI ni un proceso de respuesta para resolver brechas de seguridad de TI. Hay una total falta de procesos reconocibles de administración de seguridad de sistemas.

1 Inicial / Ad Hoc
La organización reconoce la necesidad de seguridad para TI. La conciencia de la necesidad de seguridad depende principalmente del individuo. La seguridad de TI se lleva a cabo de forma reactiva. No se mide la seguridad de TI. Las brechas de seguridad de TI ocasionan respuestas con acusaciones personales, debido a que las responsabilidades no son claras. Las respuestas a las brechas de seguridad de TI son impredecibles.

2 Repetible pero Intuitivo
Las responsabilidades y la rendición de cuentas sobre la seguridad, están asignadas a un coordinador de seguridad de TI, pero la autoridad gerencial del coordinador es limitada. La conciencia sobre la necesidad de la seguridad esta fraccionada y limitada. Aunque los sistemas producen información relevante respecto a la seguridad, ésta no se analiza. Los servicios de terceros pueden no cumplir con los requerimientos específicos de seguridad de la empresa. Las políticas de seguridad se han estado desarrollando, pero las herramientas y las habilidades son inadecuadas. Los reportes de la seguridad de TI son incompletos, engañosos o no aplicables. El entrenamiento sobre seguridad está disponible pero depende principalmente de la iniciativa del individuo. La seguridad de TI es vista primordialmente como responsabilidad y disciplina de TI, y el negocio no ve la seguridad de TI como parte de su propia disciplina.

3 Definido
Existe conciencia sobre la seguridad y ésta es promovida por la gerencia. Los procedimientos de seguridad de TI están definidos y alineados con la política de seguridad de TI. Las responsabilidades de la seguridad de TI están asignadas y entendidas, pero no continuamente implementadas. Existe un plan de seguridad de TI y existen soluciones de seguridad motivadas por un análisis de riesgo. Los reportes no contienen un enfoque claro de negocio. Se realizan pruebas de seguridad adecuadas (por ejemplo, pruebas contra intrusos). Existe entrenamiento en seguridad para TI y para el negocio, pero se programa y se comunica de manera informal.

4 Administrado y Medible
Las responsabilidades sobre la seguridad de TI son asignadas, administradas e implementadas de forma clara. Regularmente se lleva a cabo un análisis de impacto y de riesgos de seguridad. Las políticas y prácticas de seguridad se complementan con referencias de seguridad específicas. El contacto con métodos para promover la conciencia de la seguridad es obligatorio. La identificación, autenticación y autorización de los usuarios está estandarizada. La certificación en seguridad es buscada por parte del personal que es responsable de la auditoría y la administración de la seguridad. Las pruebas de seguridad se hacen utilizando procesos estándares y formales que llevan a mejorar los niveles de seguridad. Los procesos de seguridad de TI están coordinados con la función de seguridad de toda la organización. Los reportes de seguridad están ligados con los objetivos del negocio. El entrenamiento sobre seguridad se imparte tanto para TI como para el negocio. El entrenamiento sobre seguridad de TI se planea y se administra de manera que responda a las necesidades del negocio y a los perfiles de riesgo de seguridad. Los KGIs y KPIs ya están definidos pero no se miden aún.

5 Optimizado
La seguridad en TI es una responsabilidad conjunta del negocio y de la gerencia de TI y está integrada con los objetivos de seguridad del negocio en la corporación. Los requerimientos de seguridad de TI están definidos de forma clara, optimizados e incluidos en un plan de seguridad aprobado. Los usuarios y los clientes se responsabilizan cada vez más de definir requerimientos de seguridad, y las funciones de seguridad están integradas con las aplicaciones en la fase de diseño. Los incidentes de seguridad son atendidos de con procedimientos formales de respuesta soportados por herramientas automatizadas. Se llevan a cabo valoraciones de seguridad de forma periódica para evaluar la efectividad de la implementación del plan de seguridad. La información sobre amenazas y vulnerabilidades se recolecta y analiza de manera sistemática. Se recolectan e implementan de forma oportuna controles adecuados para mitigar riesgos. Se llevan a cabo pruebas de seguridad, análisis de causa-efecto e identificación pro-activa riesgos para la mejora continua de procesos. Los procesos de seguridad y la tecnología están integrados a lo largo de toda la organización. Los KGIs y KPIs para administración de seguridad son recopilados y comunicados. La gerencia utiliza los KGIs y KPIs para ajustar el plan de seguridad en un proceso de mejora continua

Criterio 16: Monitoreo

Evite las infracciones de cualquier ley, las obligaciones legales, reglamentarias o contractuales, y de cualquier requisito de seguridad. Asegurar el cumplimiento de los sistemas y la adherencia de las personas a las políticas relacionadas con seguridad de la información de la organización, estándares y procedimientos.

Subcriterio 16b. Monitoreo del framework de control interno

El ambiente de control TI y el control del framework son continuamente monitoreados, comparados y mejorados para conocer los objetivos organizacionales y adherirse a las políticas de seguridad de la información, estándares y procedimientos.

Fortalezas

Los riesgos en cuanto a control interno son considerados aunque de manera informal.

Áreas de mejora

Realizar e implementar un proceso formal para el control interno y gestión de riesgos.

Para la documentación, tomar en cuenta los estándares de gobierno de la organización para el control interno y gestión de riesgos (por ejemplo, los minutos, las políticas corporativas, entrevista con el Director).

Establecer políticas y procedimientos para normas internas y la gestión de riesgos (por ejemplo, COSO Internal Control—Integrated Framework, COSO Enterprise Risk Management—Integrated Framework, COBIT).

Implementes un enfoque de mejora continua para monitoreo del control interno**.**

No existente	Inicial / Ad Hoc	Repetible pero Intuitivo	Definido	Administrado y Medible	Optimizado
	X				

Interpretación del Modelo de Madurez
ME2 Monitorear y Evaluar el Control Interno
0 No Existente La organización carece de procedimientos para monitorear la efectividad de los controles internos. Los métodos de reporte de control interno gerenciales no existen. Existe una falta generalizada de conciencia sobre la seguridad operativa y el aseguramiento del control interno de TI. La gerencia y los empleados no tienen conciencia general sobre el control interno. **1 Inicial / Ad Hoc** La gerencia reconoce la necesidad de administrar y asegurar el control de TI de forma regular. La experiencia individual para evaluar la suficiencia del control interno se aplica de forma ad hoc. La gerencia de TI no ha asignado de manera formal las responsabilidades para monitorear la efectividad de los controles internos. Las evaluaciones de control interno de TI se realizan como parte de las auditorías financieras tradicionales, con metodologías y habilidades que no reflejan las necesidades de la función de los servicios de información. **2 Repetible pero Intuitivo** La organización utiliza reportes de control informales para comenzar iniciativas de acción correctiva. La evaluación del control interno depende de las habilidades de individuos clave. La organización tiene una mayor conciencia sobre el monitoreo de los controles internos. La gerencia de servicios de información realiza monitoreo periódico sobre la efectividad de lo que considera controles internos críticos. Se están empezando a usar metodologías y herramientas para monitorear los controles internos, aunque no se basan en un plan. Los factores de riesgo específicos del ambiente de TI se identifican con base en las habilidades de individuos. **3 Definido** La gerencia apoya y ha institucionalizado el monitoreo del control interno. Se han desarrollado políticas y procedimientos para evaluar y reportar las actividades de monitoreo del control interno. Se ha definido un programa de educación y entrenamiento para el monitoreo del control interno. Se ha definido también un proceso para auto-evaluaciones y revisiones de aseguramiento del control interno, con roles definidos para los responsables de la administración del negocio y de TI. Se usan herramientas, aunque no necesariamente están integradas en todos los procesos. Las políticas de evaluación de riesgos de los procesos de TI se utilizan dentro de los marcos de trabajo desarrollados de manera específica para la función de TI. Se han definido políticas para el manejo y mitigación de riesgos específicos de procesos. **4 Administrado y Medible** La gerencia tiene implantado un marco de trabajo para el monitoreo del control interno de TI. La organización ha establecido niveles de tolerancia para el proceso de monitoreo del control interno. Se han implantado herramientas para estandarizar evaluaciones y para detectar de forma automática las excepciones de control. Se ha establecido una función formal para el control interno de TI, con profesionales especializados y certificados que utilizan un marco de trabajo de control formal avalado por la alta dirección. Un equipo calificado de TI participa de forma rutinaria en las evaluaciones de control interno. Se ha establecido una base de datos de métricas para información histórica sobre el monitoreo del control interno. Se realizan revisiones entre pares para verificar el monitoreo del control interno. **5 Optimizado** La gerencia tiene implantado un marco de trabajo para el monitoreo del control interno de TI. La organización ha establecido niveles de tolerancia para el proceso de monitoreo del control interno. Se han implantado herramientas para estandarizar evaluaciones y para detectar de forma automática las excepciones de control. Se ha establecido una función formal para el control interno de TI, con profesionales especializados y certificados que utilizan un marco de trabajo de control formal avalado por la alta dirección. Un equipo calificado de TI participa de forma rutinaria en las evaluaciones de control interno. Se ha establecido una base de datos de métricas para información histórica sobre el monitoreo del control interno. Se realizan revisiones entre pares para verificar el monitoreo del control interno.

Criterio 16: Monitoreo

Evite las infracciones de cualquier ley, las obligaciones legales, reglamentarias o contractuales, y de cualquier requisito de seguridad. Asegurar el cumplimiento de los sistemas y la adherencia de las personas a las políticas relacionadas con seguridad de la información de la organización, estándares y procedimientos.

Subcriterio 16c. Control interno de terceras partes

El estado de los controles internos de los proveedores de servicios externos se evalúa. Los procedimientos están en un lugar seguro para cumplir con los requisitos legales y regulatorios y obligaciones contractuales.

Fortalezas

Se lleva un control interno de acceso al SITE mediante huella digital.

Áreas de mejora

Elaborar un documento formal de bitácora de control de acceso interno.

Establecer un proceso para garantizar que las revisiones se realizan periódicamente para acceder a los controles internos de todas las terceras partes y que las cuestiones de incumplimiento se comunican.

Establecer políticas y procedimientos para investigar excepciones, y obtener garantías de que las medidas correctivas apropiadas se han implementado.

No existente	Inicial / Ad Hoc	Repetible pero Intuitivo	Definido	Administrado y Medible	Optimizado
	X				

Interpretación del Modelo de Madurez

ME2 Monitorear y Evaluar el Control Interno

0 No Existente
La organización carece de procedimientos para monitorear la efectividad de los controles internos. Los métodos de reporte de control interno gerenciales no existen. Existe una falta generalizada de conciencia sobre la seguridad operativa y el aseguramiento del control interno de TI. La gerencia y los empleados no tienen conciencia general sobre el control interno.

1 Inicial / Ad Hoc
La gerencia reconoce la necesidad de administrar y asegurar el control de TI de forma regular. La experiencia individual para evaluar la suficiencia del control interno se aplica de forma ad hoc. La gerencia de TI no ha asignado de manera formal las responsabilidades para monitorear la efectividad de los controles internos. Las evaluaciones de control interno de TI se realizan como parte de las auditorías financieras tradicionales, con metodologías y habilidades que no reflejan las necesidades de la función de los servicios de información.

2 Repetible pero Intuitivo
La organización utiliza reportes de control informales para comenzar iniciativas de acción correctiva. La evaluación del control interno depende de las habilidades de individuos clave. La organización tiene una mayor conciencia sobre el monitoreo de los controles internos. La gerencia de servicios de información realiza monitoreo periódico sobre la efectividad de lo que considera controles internos críticos. Se están empezando a usar metodologías y herramientas para monitorear los controles internos, aunque no se basan en un plan. Los factores de riesgo específicos del ambiente de TI se identifican con base en las habilidades de individuos.

3 Definido
La gerencia apoya y ha institucionalizado el monitoreo del control interno. Se han desarrollado políticas y procedimientos para evaluar y reportar las actividades de monitoreo del control interno. Se ha definido un programa de educación y entrenamiento para el monitoreo del control interno. Se ha definido también un proceso para auto-evaluaciones y revisiones de aseguramiento del control interno, con roles definidos para los responsables de la administración del negocio y de TI. Se usan herramientas, aunque no necesariamente están integradas en todos los procesos. Las políticas de evaluación de riesgos de los procesos de TI se utilizan dentro de los marcos de trabajo desarrollados de manera específica para la función de TI. Se han definido políticas para el manejo y mitigación de riesgos específicos de procesos.

4 Administrado y Medible
La gerencia tiene implantado un marco de trabajo para el monitoreo del control interno de TI. La organización ha establecido niveles de tolerancia para el proceso de monitoreo del control interno. Se han implantado herramientas para estandarizar evaluaciones y para detectar de forma automática las excepciones de control. Se ha establecido una función formal para el control interno de TI, con profesionales especializados y certificados que utilizan un marco de trabajo de control formal avalado por la alta dirección. Un equipo calificado de TI participa de forma rutinaria en las evaluaciones de control interno. Se ha establecido una base de datos de métricas para información histórica sobre el monitoreo del control interno. Se realizan revisiones entre pares para verificar el monitoreo del control interno.

5 Optimizado
La gerencia tiene implantado un marco de trabajo para el monitoreo del control interno de TI. La organización ha establecido niveles de tolerancia para el proceso de monitoreo del control interno. Se han implantado herramientas para estandarizar evaluaciones y para detectar de forma automática las excepciones de control. Se ha establecido una función formal para el control interno de TI, con profesionales especializados y certificados que utilizan un marco de trabajo de control formal avalado por la alta dirección. Un equipo calificado de TI participa de forma rutinaria en las evaluaciones de control interno. Se ha establecido una base de datos de métricas para información histórica sobre el monitoreo del control interno. Se realizan revisiones entre pares para verificar el monitoreo del control interno.

Criterio 16: Monitoreo **Evite las infracciones de cualquier ley, las obligaciones legales, reglamentarias o contractuales, y de cualquier requisito de seguridad. Asegurar el cumplimiento de los sistemas y la adherencia de las personas a las políticas relacionadas con seguridad de la información de la organización, estándares y procedimientos.**
Subcriterio 16d. La evaluación del cumplimiento con los requerimientos externos Las políticas TI, estándares, procedimientos y cumplan.
Fortalezas No se observó evidencia durante la auditoría. **Áreas de mejora** Establecer un documento formal de políticas, normas y procedimientos de la organización para hacer frente ante cualquier incumplimiento identificado. Dicha documentación deberá ser actualizada periódicamente.

No existente	Inicial / Ad Hoc	Repetible pero Intuitivo	Definido	Administrado y Medible	Optimizado
X					

Interpretación del Modelo de Madurez

ME3 Garantizar el Cumplimiento con Requerimientos Externos

0 No Existente
Existe poca conciencia respecto a los requerimientos externos que afectan a TI, sin procesos referentes al cumplimiento de requisitos regulatorios, legales y contractuales.
1 Inicial / Ad Hoc
Existe conciencia de los requisitos de cumplimiento regulatorio, contractual y legal que tienen impacto en la organización. Se siguen procesos informales para mantener el cumplimiento, pero solo si la necesidad surge en nuevos proyectos o como respuesta a auditorías o revisiones.
2 Repetible pero Intuitivo
Existe el entendimiento de la necesidad de cumplir con los requerimientos externos y la necesidad se comunica. En los casos en que el cumplimiento se ha convertido en un requerimiento recurrente, como en los requerimientos financieros o en la legislación de privacidad, se han desarrollado procedimientos individuales de cumplimiento y se siguen año a año. No existe, sin embargo, un enfoque estándar. Hay mucha confianza en el conocimiento y responsabilidad de los individuos, y los errores son posibles. Se brinda entrenamiento informal respecto a los requerimientos externos y a los temas de cumplimiento.
3 Definido
Se han desarrollado, documentado y comunicado políticas, procedimientos y procesos, para garantizar el cumplimiento de los reglamentos y de las obligaciones contractuales y legales, pero algunas quizá no se sigan y algunas quizá estén desactualizadas o sean poco prácticas de implementar. Se realiza poco monitoreo y existen requisitos de cumplimiento que no han sido resueltos. Se brinda entrenamiento sobre requisitos legales y regulatorios externos que afectan a la organización y se instruye respecto a los procesos de cumplimiento definidos. Existen contratos pro forma y procesos legales estándar para minimizar los riesgos asociados con las obligaciones contractuales.
4 Administrado y Medible
Existe un entendimiento completo de los eventos y de la exposición a requerimientos externos, y la necesidad de asegurar el cumplimiento a todos los niveles. Existe un esquema formal de entrenamiento que asegura que todo el equipo esté consciente de sus obligaciones de cumplimiento. Las responsabilidades son claras y se entiende el empoderamiento de los procesos. El proceso incluye una revisión del entorno para identificar requerimientos externos y cambios recurrentes. Existe un mecanismo implantado para monitorear el no cumplimiento de los requisitos externos, reforzar las prácticas internas e implementar acciones correctivas. Los eventos de no cumplimiento se analizan de forma estándar en busca de las causas raíz, con el objetivo de identificar soluciones sostenibles. Buenas prácticas internas estandarizadas se usan para necesidades específicas tales como reglamentos vigentes y contratos recurrentes de servicio.
5 Optimizado
Existe un proceso bien organizado, eficiente e implantado para cumplir con los requerimientos externos, basado en una sola función central que brinda orientación y coordinación a toda la organización. Hay un amplio conocimiento de los requerimientos externos aplicables, incluyendo sus tendencias futuras y cambios anticipados, así como la necesidad de nuevas soluciones. La organización participa en discusiones externas con grupos regulatorios y de la industria para entender e influenciar los requerimientos externos que la puedan afectar. Se han desarrollado mejores prácticas que aseguran el cumplimiento de los requisitos externos, y esto ocasiona que haya muy pocos casos de excepciones de cumplimiento. Existe un sistema central de rastreo para toda la organización, que permite a la gerencia documentar el flujo de trabajo, medir y mejorar la calidad y efectividad del proceso de monitoreo del cumplimiento. Un proceso externo de auto-evaluación de requerimientos existe y se ha refinado hasta alcanzar el nivel de buena práctica. El estilo y la cultura administrativa de la organización referente al cumplimiento es suficientemente fuerte, y se elaboran los procesos suficientemente bien para que el entrenamiento se limite al nuevo personal y siempre que ocurra un cambio significativo.

Criterio 16: Monitoreo

Evite las infracciones de cualquier ley, las obligaciones legales, reglamentarias o contractuales, y de cualquier requisito de seguridad. Asegurar el cumplimiento de los sistemas y la adherencia de las personas a las políticas relacionadas con seguridad de la información de la organización, estándares y procedimientos.

Subcriterio 16e. Aseguramiento de la independencia

El aseguramiento independiente (externo e interno) se obtiene de conformidad de las TI con las leyes y regulaciones; las políticas de la organización, estándares y procedimientos; prácticas generalmente aceptadas y el rendimiento eficiente y eficaz de las TI.

Fortalezas

No se observó evidencia durante la auditoría.

Áreas de mejora

Establecer un comité de auditoría interno para evaluar la importancia de los riesgos.

Evaluar la forma en que los riesgos se identifican, evalúan y gestionan; auditorías de seguridad y comisión TI y rigurosamente el seguimiento del cierre de recomendaciones posteriores.

No existente	Inicial / Ad Hoc	Repetible pero Intuitivo	Definido	Administrado y Medible	Optimizado
X					

Interpretación del Modelo de Madurez
ME4 Proporcionar Gobierno de TI
0 No Existente Existe una carencia completa de cualquier proceso reconocible de gobierno de TI. La organización ni siquiera ha reconocido que existe un problema a resolver; por lo tanto, no existe comunicación respecto al tema. **1 Inicial / Ad Hoc** Se reconoce que el tema del gobierno de TI existe y que debe ser resuelto. Existen enfoques ad hoc aplicados individualmente o caso por caso. El enfoque de la gerencia es reactivo y solamente existe una comunicación esporádica e inconsistente sobre los temas y los enfoques para resolverlos. La gerencia solo cuenta con una indicación aproximada de cómo TI contribuye al desempeño del negocio. La gerencia solo responde de forma reactiva a los incidentes que hayan causado pérdidas o vergüenza a la organización. **2 Repetible pero Intuitivo** Existe una conciencia sobre los temas de gobierno de TI. Las actividades y los indicadores de desempeño del gobierno de TI, los cuales incluyen procesos planeación, entrega y supervisión de TI, están en desarrollo. Los procesos de TI seleccionados se identifican para ser mejorados con base en decisiones individuales. La gerencia ha identificado mediciones básicas para el gobierno de TI, así como métodos de evaluación y técnicas; sin embargo, el proceso no ha sido adoptado a lo largo de la organización. La comunicación respecto a los estándares y responsabilidades de gobierno se deja a los individuos. Los individuos impulsan los procesos de gobierno en varios proyectos y procesos de TI. Los procesos, herramientas y métricas para medir el gobierno de TI están limitadas y pueden no usarse a toda su capacidad debido a la falta de experiencia en su funcionalidad. **3 Definido** La importancia y la necesidad de un gobierno de TI se reconocen por parte de la gerencia y se comunican a la organización. Un conjunto de indicadores base de gobierno de TI se elaboran donde se definen y documentan los vínculos entre las mediciones de resultados y los impulsores del desempeño. Los procedimientos se han estandarizado y documentado. La gerencia ha comunicado los procedimientos estandarizados y el entrenamiento está establecido. Se han identificado herramientas para apoyar a la supervisión del gobierno de TI. Se han definido tableros de control como parte de los Balanced Scorecard de TI. Sin embargo, se delega al individuo su entrenamiento, el seguimiento de los estándares y su aplicación. Puede ser que se monitoreen los procesos sin embargo la mayoría de desviaciones, se resuelven con iniciativa individual y es poco probable que se detecten por parte de la gerencia. **4 Administrado y Medible** Existe un entendimiento completo de los temas de gobierno a todos los niveles. Hay un entendimiento claro de quién es el cliente y se definen y supervisan las responsabilidades por medio de acuerdos de niveles de servicio. Las responsabilidades son claras y la propiedad de procesos está establecida. Los procesos de TI y el gobierno de TI están alineados e integrados con la estrategia corporativa de TI. La mejora de los procesos de TI se basa principalmente en un entendimiento cuantitativo y es posible monitorear y medir el cumplimiento con procedimientos y métricas de procesos. Todos los interesados en los procesos están conscientes de los riesgos, de la importancia de TI, y de las oportunidades que ésta puede ofrecer. La gerencia ha definido niveles de tolerancia bajo los cuales los procesos pueden operar. Existe un uso limitado, principalmente táctico, de la tecnología con base en técnicas maduras y herramientas estándar ya implantadas. El gobierno de TI ha sido integrado a los procesos de planeación estratégica y operativa, así como a los procesos de monitoreo. Los indicadores de desempeño de todas las actividades de gobierno de TI se registran y siguen, y esto lidera mejoras a nivel de toda la empresa. La rendición general de cuentas del desempeño de los procesos clave es clara, y la gerencia recibe recompensas con base en las mediciones clave de desempeño.

5 Optimizado
Existe un entendimiento avanzado y a fututo de los temas y soluciones del gobierno de TI. El entrenamiento y la comunicación se basan en conceptos y técnicas de vanguardia. Los procesos se han refinado hasta un nivel de mejor práctica de la industria, con base en los resultados de las mejoras continuas y en el modelo de madurez con respecto a otras organizaciones. La implantación de las políticas de TI ha resultado en una organización, personas y procesos que se adaptan rápidamente, y que dan soporte completo a los requisitos de gobierno de TI. Todos los problemas y desviaciones se analizan por medio de la técnica de causa raíz y se identifican e implementan medidas eficientes de forma rápida. TI se utiliza de forma amplia, integrada y optimizada para automatizar el flujo de trabajo y brindar herramientas para mejorar la calidad y efectividad. Los riesgos y los retornos de los procesos de TI están definidos, balanceados y comunicados en toda la empresa. Se aprovechan a los expertos externos y se usan evaluaciones por comparación para orientarse. El monitoreo, la auto-evaluación y la comunicación respecto a las expectativas de gobierno están en toda la organización y se dé un uso óptimo a la tecnología para apoyar las mediciones, el análisis, la comunicación y el entrenamiento. El Gobierno Corporativo y el gobierno de TI están vinculados de forma estratégica, aprovechando la tecnología y los recursos humanos y financieros para mejorar la ventaja competitiva de la empresa. Las actividades de gobierno de TI están integradas al proceso de Gobierno Corporativo.

Criterio 17: Gestión de la cuenta de usuario **Asegurar que los usuarios (internos, externa y temporalmente) solamente tengan acceso autorizado a los datos y funcionalidades y sus actividades dentro del ambiente TI son identificables únicamente.**					
Subcriterio 17a. Gestión de la identificación Todos los usuarios (internos, externos y temporales) y sus actividades en sistemas de TI (aplicaciones del negocio, ambiente TI, operaciones del sistema, desarrollo y mantenimiento) son identificados únicamente. Las identidades de los usuarios están disponibles vía mecanismos de autenticación. Los derechos de acceso de usuario son solicitados por la administración de usuarios, aprobado por los propietarios del sistema y ejecutado por la persona responsable de la seguridad. Las identidades de los usuarios y los derechos de acceso son mantenidos en un repositorio central. La implementación de las medidas de procedimiento y técnicas costo-efectividad está desplegada y mantenidas actualizadas para establecer la identificación del usuario, implementar la autenticación y hacer cumplir los derechos de acceso.					
Fortalezas Se utiliza el Active Directory como herramienta para la administración de usuarios. **Áreas de mejora** Determinar si las prácticas de seguridad requieren que los usuarios y los procesos del sistema deben ser únicamente de identificación y los sistemas se configuren para hacer cumplir la autenticación antes de conceder el acceso. Si se utilizan los roles predeterminados y con aprobación previa para conceder acceso, determinar si los papeles delinean claramente las responsabilidades sobre la base de privilegios mínimos y garantizar que el establecimiento y la modificación de los roles están aprobados por la administración responsable del proceso. Determinar si se utilizan mecanismos de control de acceso y autenticación de aprovisionamiento para el control de acceso lógico a través de todos los usuarios, los procesos del sistema y los recursos de TI, en la casa y gestionados de forma remota a los usuarios, procesos y sistemas.					
No existente	**Inicial / Ad Hoc**	**Repetible pero Intuitivo**	**Definido**	**Administrado y Medible**	**Optimizado**
		X			

Interpretación del Modelo de Madurez

DS5 Garantizar la Seguridad de los Sistemas

0 No Existente C

La organización no reconoce la necesidad de la seguridad para TI. Las responsabilidades y la rendición de cuentas no están asignadas para garantizar la seguridad. Las medidas para soportar la administrar la seguridad de TI no están implementadas. No hay reportes de seguridad de TI ni un proceso de respuesta para resolver brechas de seguridad de TI. Hay una total falta de procesos reconocibles de administración de seguridad de sistemas.

1 Inicial / Ad Hoc

La organización reconoce la necesidad de seguridad para TI. La conciencia de la necesidad de seguridad depende principalmente del individuo. La seguridad de TI se lleva a cabo de forma reactiva. No se mide la seguridad de TI. Las brechas de seguridad de TI ocasionan respuestas con acusaciones personales, debido a que las responsabilidades no son claras. Las respuestas a las brechas de seguridad de TI son impredecibles.

2 Repetible pero Intuitivo

Las responsabilidades y la rendición de cuentas sobre la seguridad, están asignadas a un coordinador de seguridad de TI, pero la autoridad gerencial del coordinador es limitada. La conciencia sobre la necesidad de la seguridad esta fraccionada y limitada. Aunque los sistemas producen información relevante respecto a la seguridad, ésta no se analiza. Los servicios de terceros pueden no cumplir con los requerimientos específicos de seguridad de la empresa. Las políticas de seguridad se han estado desarrollando, pero las herramientas y las habilidades son inadecuadas. Los reportes de la seguridad de TI son incompletos, engañosos o no aplicables. El entrenamiento sobre seguridad está disponible pero depende principalmente de la iniciativa del individuo. La seguridad de TI es vista primordialmente como responsabilidad y disciplina de TI, y el negocio no ve la seguridad de TI como parte de su propia disciplina.

3 Definido

Existe conciencia sobre la seguridad y ésta es promovida por la gerencia. Los procedimientos de seguridad de TI están definidos y alineados con la política de seguridad de TI. Las responsabilidades de la seguridad de TI están asignadas y entendidas, pero no continuamente implementadas. Existe un plan de seguridad de TI y existen soluciones de seguridad motivadas por un análisis de riesgo. Los reportes no contienen un enfoque claro de negocio. Se realizan pruebas de seguridad adecuadas (por ejemplo, pruebas contra intrusos). Existe entrenamiento en seguridad para TI y para el negocio, pero se programa y se comunica de manera informal.

4 Administrado y Medible

Las responsabilidades sobre la seguridad de TI son asignadas, administradas e implementadas de forma clara. Regularmente se lleva a cabo un análisis de impacto y de riesgos de seguridad. Las políticas y prácticas de seguridad se complementan con referencias de seguridad específicas. El contacto con métodos para promover la conciencia de la seguridad es obligatorio. La identificación, autenticación y autorización de los usuarios está estandarizada. La certificación en seguridad es buscada por parte del personal que es responsable de la auditoría y la administración de la seguridad. Las pruebas de seguridad se hacen utilizando procesos estándares y formales que llevan a mejorar los niveles de seguridad. Los procesos de seguridad de TI están coordinados con la función de seguridad de toda la organización. Los reportes de seguridad están ligados con los objetivos del negocio. El entrenamiento sobre seguridad se imparte tanto para TI como para el negocio. El entrenamiento sobre seguridad de TI se planea y se administra de manera que responda a las necesidades del negocio y a los perfiles de riesgo de seguridad. Los KGIs y KPIs ya están definidos pero no se miden aún.

5 Optimizado
La seguridad en TI es una responsabilidad conjunta del negocio y de la gerencia de TI y está integrada con los objetivos de seguridad del negocio en la corporación. Los requerimientos de seguridad de TI están definidos de forma clara, optimizados e incluidos en un plan de seguridad aprobado. Los usuarios y los clientes se responsabilizan cada vez más de definir requerimientos de seguridad, y las funciones de seguridad están integradas con las aplicaciones en la fase de diseño. Los incidentes de seguridad son atendidos de con procedimientos formales de respuesta soportados por herramientas automatizadas. Se llevan a cabo valoraciones de seguridad de forma periódica para evaluar la efectividad de la implementación del plan de seguridad. La información sobre amenazas y vulnerabilidades se recolecta y analiza de manera sistemática. Se recolectan e implementan de forma oportuna controles adecuados para mitigar riesgos. Se llevan a cabo pruebas de seguridad, análisis de causa-efecto e identificación pro-activa riesgos para la mejora continua de procesos. Los procesos de seguridad y la tecnología están integrados a lo largo de toda la organización. Los KGIs y KPIs para administración de seguridad son recopilados y comunicados. La gerencia utiliza los KGIs y KPIs
para ajustar el plan de seguridad en un proceso de mejora continua

Criterio 17: Gestión de la cuenta de usuario

Asegurar que los usuarios (internos, externa y temporalmente) solamente tengan acceso autorizado a los datos y funcionalidades y sus actividades dentro del ambiente TI son identificables únicamente.

Subcriterio 17b. Gestión de la cuenta de usuario

Solicitud, establecimiento, emisión, suspensión, modificación y clausura de las cuentas del usuario y los privilegios del usuario relacionado. Un procedimiento de autorización indicando los datos o propietario del sistema conceder los privilegios de acceso es incluido. Este procedimiento debería aplicar para todos los usuarios, incluyendo administradores (usuarios privilegiados) y usuarios internos y externos, para casos normales y de emergencia. Los derechos y obligaciones relativas al acceso para los sistemas de la empresa y la información esta contractualmente organizado para todos los tipos de usuarios. Revisar la gestión regular de todas las cuentas y privilegios relacionados se realizan.

Fortalezas

Se le otorga directamente la cuenta al usuario aunque no se establece formalmente.
Se realiza mantenimiento de las cuentas de usuario en el Active Directory.

Áreas de mejora

Determinar y documentar procedimientos para evaluar periódicamente el sistema y acceso a las aplicaciones.
Determinar si existen procedimientos de control de acceso para controlar y gestionar de sistemas y aplicaciones de los derechos y privilegios de acuerdo a las políticas de seguridad de la organización y los requisitos de cumplimiento y regulatorios.
Determinar si los sistemas, aplicaciones y datos han sido clasificados por niveles de importancia y el riesgo, y si los propietarios del proceso se han identificado y asignado.
Determinar si aprovisionamiento de usuario políticas, normas y procedimientos se extienden a todos los usuarios y procesos del sistema, incluidos los vendedores, proveedores de servicios y socios comerciales

No existente	Inicial / Ad Hoc	Repetible pero Intuitivo	Definido	Administrado y Medible	Optimizado
		X			

Interpretación del Modelo de Madurez
DS5 Garantizar la Seguridad de los Sistemas
0 No Existente La organización no reconoce la necesidad de la seguridad para TI. Las responsabilidades y la rendición de cuentas no están asignadas para garantizar la seguridad. Las medidas para soportar la administrar la seguridad de TI no están implementadas. No hay reportes de seguridad de TI ni un proceso de respuesta para resolver brechas de seguridad de TI. Hay una total falta de procesos reconocibles de administración de seguridad de sistemas. **1 Inicial / Ad Hoc** La organización reconoce la necesidad de seguridad para TI. La conciencia de la necesidad de seguridad depende principalmente del individuo. La seguridad de TI se lleva a cabo de forma reactiva. No se mide la seguridad de TI. Las brechas de seguridad de TI ocasionan respuestas con acusaciones personales, debido a que las responsabilidades no son claras. Las respuestas a las brechas de seguridad de TI son impredecibles. **2 Repetible pero Intuitivo** Las responsabilidades y la rendición de cuentas sobre la seguridad, están asignadas a un coordinador de seguridad de TI, pero la autoridad gerencial del coordinador es limitada. La conciencia sobre la necesidad de la seguridad esta fraccionada y limitada. Aunque los sistemas producen información relevante respecto a la seguridad, ésta no se analiza. Los servicios de terceros pueden no cumplir con los requerimientos específicos de seguridad de la empresa. Las políticas de seguridad se han estado desarrollando, pero las herramientas y las habilidades son inadecuadas. Los reportes de la seguridad de TI son incompletos, engañosos o no aplicables. El entrenamiento sobre seguridad está disponible pero depende principalmente de la iniciativa del individuo. La seguridad de TI es vista primordialmente como responsabilidad y disciplina de TI, y el negocio no ve la seguridad de TI como parte de su propia disciplina. **3 Definido** Existe conciencia sobre la seguridad y ésta es promovida por la gerencia. Los procedimientos de seguridad de TI están definidos y alineados con la política de seguridad de TI. Las responsabilidades de la seguridad de TI están asignadas y entendidas, pero no continuamente implementadas. Existe un plan de seguridad de TI y existen soluciones de seguridad motivadas por un análisis de riesgo. Los reportes no contienen un enfoque claro de negocio. Se realizan pruebas de seguridad adecuadas (por ejemplo, pruebas contra intrusos). Existe entrenamiento en seguridad para TI y para el negocio, pero se programa y se comunica de manera informal. **4 Administrado y Medible** Las responsabilidades sobre la seguridad de TI son asignadas, administradas e implementadas de forma clara. Regularmente se lleva a cabo un análisis de impacto y de riesgos de seguridad. Las políticas y prácticas de seguridad se complementan con referencias de seguridad específicas. El contacto con métodos para promover la conciencia de la seguridad es obligatorio. La identificación, autenticación y autorización de los usuarios está estandarizada. La certificación en seguridad es buscada por parte del personal que es responsable de la auditoría y la administración de la seguridad. Las pruebas de seguridad se hacen utilizando procesos estándares y formales que llevan a mejorar los niveles de seguridad. Los procesos de seguridad de TI están coordinados con la función de seguridad de toda la organización. Los reportes de seguridad están ligados con los objetivos del negocio. El entrenamiento sobre seguridad se imparte tanto para TI como para el negocio. El entrenamiento sobre seguridad de TI se planea y se administra de manera que responda a las necesidades del negocio y a los perfiles de riesgo de seguridad. Los KGIs y KPIs ya están definidos pero no se miden aún. **5 Optimizado** La seguridad en TI es una responsabilidad conjunta del negocio y de la gerencia de TI y está integrada con los objetivos de seguridad del negocio en la corporación. Los requerimientos de seguridad de TI están definidos de forma clara, optimizados e incluidos en un plan de seguridad aprobado. Los usuarios y los clientes se responsabilizan cada vez más de definir requerimientos de seguridad, y las funciones de seguridad están integradas con las aplicaciones en la fase de diseño. Los incidentes de seguridad son atendidos de con procedimientos formales de respuesta soportados por herramientas automatizadas. Se llevan a cabo valoraciones de seguridad de forma periódica para evaluar la efectividad de la implementación del plan de seguridad. La información sobre amenazas y vulnerabilidades se recolecta y analiza de manera sistemática. Se recolectan e implementan de forma oportuna controles adecuados para mitigar riesgos. Se llevan a cabo pruebas de seguridad, análisis de causa-efecto e identificación pro-activa riesgos para la mejora continua de procesos. Los procesos de seguridad y la tecnología están integrados a lo largo de toda la organización. Los KGIs y KPIs para administración de seguridad son recopilados y comunicados. La gerencia utiliza los KGIs y KPIs para ajustar el plan de seguridad en un proceso de mejora continua

Criterio 18: Definir un plan de seguridad de la información
Las técnicas y procedimientos administrativos relacionados (ej. firewalls, aplicaciones de seguridad, segmentación de la red, detección de intrusos, ruta o medio de confianza, encriptación) son usados para garantizar el almacenamiento de datos y transporte dentro de la infraestructura técnica de la empresa, fluye desde y para la red y los dispositivos móviles (ej. smart phones, usb sticks). Las técnicas aplicadas están de acuerdo con la clasificación de los datos.

Subcriterio 18 a. Disponibilidad y protección de los recursos de infraestructura
El control interno, medidas de seguridad y auditabilidad son implementados durante la configuración, integración y mantenimiento del hardware y software infraestructural para proteger los recursos y asegurar la integridad y disponibilidad. Las responsabilidades para el uso de los componentes de la infraestructura están claramente definidos y entendidos por aquellos que desarrollan e integrar componentes de la infraestructura. Su uso es monitoreado y evaluado.

Fortalezas
Se tiene un control interno con medidas de seguridad.
Cuentan con un outsourcing para proteger los recursos, asegurar la integridad y disponiblidad
Se tienen identificado responsables para la disponibilidad y protección de los recursos de infraestructura.
Se hacen respaldos de la información.

Áreas de mejora

Garantizar que los datos de la infraestructura y el software están respaldados antes de la instalación y/mantenimiento de las tareas.
Documentar los registros de respaldo para confirmar que los datos de la infraestructura y el software están correctamente respaldados.
Los miebros del equipo que la aplicación está probada antes de la instalación en un ambiente de pruebas similar al de producción.
Mejorar las especificaciones de prueba y procedimientos para confirmar qué pruebas incluye de funcionalidad, seguridad, disponibilidad e integración.
Inspeccionar la configuración del software para confirmar qué aspectos claves han sido ubicados, incluyendo la modificación de passwords por defecto, configuración inicial de parámetros de la aplicación relacionados con la seguridad.

No existente	Inicial / Ad Hoc	Repetible pero Intuitivo	Definido	Administrado y Medible	Optimizado
			X		

Interpretación del Modelo de Madurez
AI3 Adquirir y Mantener Infraestructura Tecnológica
0 No Existente No se reconoce la administración de la infraestructura de tecnología como un asunto importante al cual deba ser resuelto. **1 Inicial / Ad Hoc** Se realizan cambios a la infraestructura para cada nueva aplicación, sin ningún plan en conjunto. Aunque se tiene la percepción de que la infraestructura de TI es importante, no existe un enfoque general consistente. La actividad de mantenimiento reacciona a necesidades de corto plazo. El ambiente de producción es el ambiente de prueba. **2 Repetible pero Intuitivo** No hay consistencia entre enfoques tácticos al adquirir y dar mantenimiento a la infraestructura de TI. La adquisición y mantenimiento de la infraestructura de TI no se basa en una estrategia definida y no considera las necesidades de las aplicaciones del negocio que se deben respaldar. Se tiene la noción de que la infraestructura de TI es importante, que se apoya en algunas prácticas formales. Algunos mantenimientos se programan, pero no se programa ni se coordina en su totalidad. Para algunos ambientes, existe un ambiente de prueba por separado. **3 Definido** Existe un claro, definido y generalmente entendido proceso para adquirir y dar mantenimiento a la infraestructura TI. El proceso respalda las necesidades de las aplicaciones críticas del negocio y concuerda con la estrategia de negocio de TI, pero no se aplica en forma consistente. Se planea, programa y coordina el mantenimiento. Existen ambientes separados para prueba y producción. **4 Administrado y Medible** Se desarrolla el proceso de adquisición y mantenimiento de la infraestructura de tecnología a tal punto que funciona bien para la mayoría de las situaciones, se le da un seguimiento consistente y un enfoque hacia la reutilización. La infraestructura de TI soporta adecuadamente las aplicaciones del negocio. El proceso está bien organizado y es preventivo. Tanto el costo como el tiempo de realización para alcanzar el nivel esperado de escalamiento, flexibilidad e integración se han optimizado parcialmente. **5 Optimizado** El proceso de adquisición y mantenimiento de la infraestructura de tecnología es preventivo y está estrechamente en línea con las aplicaciones críticas del negocio y con la arquitectura de la tecnología. Se siguen buenas prácticas respecto a las soluciones de tecnología, y la organización tiene conciencia de las últimas plataformas desarrolladas y herramientas de administración. Se reducen costos al racionalizar y estandarizar los componentes de la infraestructura y con el uso de la automatización. Con un alto nivel de conciencia se pueden identificar los medios óptimos para mejorar el desempeño en forma preventiva, incluyendo el considerar la opción de contratar servicios externos. La infraestructura de TI se entiende como el apoyo clave para impulsar el uso de TI.

Criterio 18: Definir un plan de seguridad de la información **Las técnicas y procedimientos administrativos relacionados (ej. firewalls, aplicaciones de seguridad, segmentación de la red, detección de intrusos, ruta o medio de confianza, encriptación) son usados para garantizar el almacenamiento de datos y transporte dentro de la infraestructura técnica de la empresa, fluye desde y para la red y los dispositivos móviles (ej. smart phones, usb sticks). Las técnicas aplicadas están de acuerdo con la clasificación de los datos.**					
Subcriterio 18b. Mantenimiento de la infraestructura Un plan y estrategia para el mantenimiento de la infraestructura y aseguran que los cambio están controlados en línea con el procedimiento de gestión de cambio de la organización. Las revisiones periódicas contra las necesidades del negocio, gestión de parches, modernización de las estrategias, riesgos, evaluación de vulnerabilidades y requisitos de seguridad.					
Fortalezas Se lleva a cabo un programa de mantenimiento. Se monitorean las vulnerabilidades, se manejan enlaces dedicados VPN. **Áreas de mejora** Confirmar con los miembros clave del equipo que el mantenimiento del proceso de software del sistema instalado utiliza el mismo proceso que actualizaciones de la aplicación. Inspeccionar el mantenimiento del sistema planeado e identificar desviaciones del proceso normal de actualizaciones de la aplicación y / o excepciones a los procedimientos y directrices de proveedores. Actualizar la documentación del software del sistema. Inspeccionar la documentación pertinente e identificar las áreas donde es incompleta o fuera de fecha. Identificar todas las desviaciones y / o excepciones. Gestionar la cantidad de mantenimiento, la vulnerabilidad de la infraestructura no compatible, y los riesgos futuros y vulnerabilidades de seguridad son revisados de manera regular. Documentar los registros de seguimiento de mantenimiento y herramientas de análisis para asegurar que los resultados de estas revisiones son comunicadas a la UTSIT.					
No existente	**Inicial / Ad Hoc**	**Repetible pero Intuitivo**	**Definido**	**Administrado y Medible**	**Optimizado**
		X			

Interpretación del Modelo de Madurez
AI3 Adquirir y Mantener Infraestructura Tecnológica
0 No Existente No se reconoce la administración de la infraestructura de tecnología como un asunto importante al cual deba ser resuelto. **1 Inicial / Ad Hoc** Se realizan cambios a la infraestructura para cada nueva aplicación, sin ningún plan en conjunto. Aunque se tiene la percepción de que la infraestructura de TI es importante, no existe un enfoque general consistente. La actividad de mantenimiento reacciona a necesidades de corto plazo. El ambiente de producción es el ambiente de prueba. **2 Repetible pero Intuitivo** No hay consistencia entre enfoques tácticos al adquirir y dar mantenimiento a la infraestructura de TI. La adquisición y mantenimiento de la infraestructura de TI no se basa en una estrategia definida y no considera las necesidades de las aplicaciones del negocio que se deben respaldar. Se tiene la noción de que la infraestructura de TI es importante, que se apoya en algunas prácticas formales. Algunos mantenimientos se programan, pero no se programa ni se coordina en su totalidad. Para algunos ambientes, existe un ambiente de prueba por separado. **3 Definido** Existe un claro, definido y generalmente entendido proceso para adquirir y dar mantenimiento a la infraestructura TI. El proceso respalda las necesidades de las aplicaciones críticas del negocio y concuerda con la estrategia de negocio de TI, pero no se aplica en forma consistente. Se planea, programa y coordina el mantenimiento. Existen ambientes separados para prueba y producción. **4 Administrado y Medible** Se desarrolla el proceso de adquisición y mantenimiento de la infraestructura de tecnología a tal punto que funciona bien para la mayoría de las situaciones, se le da un seguimiento consistente y un enfoque hacia la reutilización. La infraestructura de TI soporta adecuadamente las aplicaciones del negocio. El proceso está bien organizado y es preventivo. Tanto el costo como el tiempo de realización para alcanzar el nivel esperado de escalamiento, flexibilidad e integración se han optimizado parcialmente. **5 Optimizado** El proceso de adquisición y mantenimiento de la infraestructura de tecnología es preventivo y está estrechamente en línea con las aplicaciones críticas del negocio y con la arquitectura de la tecnología. Se siguen buenas prácticas respecto a las soluciones de tecnología, y la organización tiene conciencia de las últimas plataformas desarrolladas y herramientas de administración. Se reducen costos al racionalizar y estandarizar los componentes de la infraestructura y con el uso de la automatización. Con un alto nivel de conciencia se pueden identificar los medios óptimos para mejorar el desempeño en forma preventiva, incluyendo el considerar la opción de contratar servicios externos. La infraestructura de TI se entiende como el apoyo clave para impulsar el uso de TI.

Criterio 18: Definir un plan de seguridad de la información
Las técnicas y procedimientos administrativos relacionados (ej. firewalls, aplicaciones de seguridad, segmentación de la red, detección de intrusos, ruta o medio de confianza, encriptación) son usados para garantizar el almacenamiento de datos y transporte dentro de la infraestructura técnica de la empresa, fluye desde y para la red y los dispositivos móviles (ej. smart phones, usb sticks). Las técnicas aplicadas están de acuerdo con la clasificación de los datos.

Subcriterio 18c. Administración de claves criptográficas
Los procedimientos y las políticas están en su lugar para organizar la generación, cambio, revocación, destrucción, distribución, certificación, almacenamiento, entrada, uso y archivo de claves criptográfica está en un lugar para asegurar que la protección de claves contra modificaciones y divulgación no autorizada.

Fortalezas
Se tiene contratado un outsourcing para la seguridad.
Cuentan con enlaces dedicados VPN.
Los sistemas internos no estan mapeados al internet.

Áreas de mejora
Poner en marcha la clasificación de la información y ha asociado controles de protección de la información que dan cuenta de las necesidades de la organización para el intercambio de información o la restricción y los impactos organizacionales asociados a tales necesidades.
Definir los procedimientos para asegurar que el etiquetado de la información y la manipulación se realicen de acuerdo con el esquema de clasificación de la información de IEEG.

No existente	Inicial / Ad Hoc	Repetible pero Intuitivo	Definido	Administrado y Medible	Optimizado
		X			

Interpretación del Modelo de Madurez
DS5 Garantizar la Seguridad de los Sistemas
0 No Existente La organización no reconoce la necesidad de la seguridad para TI. Las responsabilidades y la rendición de cuentas no están asignadas para garantizar la seguridad. Las medidas para soportar la administrar la seguridad de TI no están implementadas. No hay reportes de seguridad de TI ni un proceso de respuesta para resolver brechas de seguridad de TI. Hay una total falta de procesos reconocibles de administración de seguridad de sistemas. **1 Inicial / Ad Hoc** La organización reconoce la necesidad de seguridad para TI. La conciencia de la necesidad de seguridad depende principalmente del individuo. La seguridad de TI se lleva a cabo de forma reactiva. No se mide la seguridad de TI. Las brechas de seguridad de TI ocasionan respuestas con acusaciones personales, debido a que las responsabilidades no son claras. Las respuestas a las brechas de seguridad de TI son impredecibles. **2 Repetible pero Intuitivo** Las responsabilidades y la rendición de cuentas sobre la seguridad, están asignadas a un coordinador de seguridad de TI, pero la autoridad gerencial del coordinador es limitada. La conciencia sobre la necesidad de la seguridad esta fraccionada y limitada. Aunque los sistemas producen información relevante respecto a la seguridad, ésta no se analiza. Los servicios de terceros pueden no cumplir con los requerimientos específicos de seguridad de la empresa. Las políticas de seguridad se han estado desarrollando, pero las herramientas y las habilidades son inadecuadas. Los reportes de la seguridad de TI son incompletos, engañosos o no aplicables. La entrenamiento sobre seguridad está disponible pero depende principalmente de la iniciativa del individuo. La seguridad de TI es vista primordialmente como responsabilidad y disciplina de TI, y el negocio no ve la seguridad de TI como parte de su propia disciplina. **3 Definido** Existe conciencia sobre la seguridad y ésta es promovida por la gerencia. Los procedimientos de seguridad de TI están definidos y alineados con la política de seguridad de TI. Las responsabilidades de la seguridad de TI están asignadas y entendidas, pero no continuamente implementadas. Existe un plan de seguridad de TI y existen soluciones de seguridad motivadas por un análisis de riesgo. Los reportes no contienen un enfoque claro de negocio. Se realizan pruebas de seguridad adecuadas (por ejemplo, pruebas contra intrusos). Existe entrenamiento en seguridad para TI y para el negocio, pero se programa y se comunica de manera informal. **4 Administrado y Medible** Las responsabilidades sobre la seguridad de TI son asignadas, administradas e implementadas de forma clara. Regularmente se lleva a cabo un análisis de impacto y de riesgos de seguridad. Las políticas y prácticas de seguridad se complementan con referencias de seguridad específicas. El contacto con métodos para promover la conciencia de la seguridad es obligatorio. La identificación, autenticación y autorización de los usuarios está estandarizada. La certificación en seguridad es buscada por parte del personal que es responsable de la auditoría y la administración de la seguridad. Las pruebas de seguridad se hacen utilizando procesos estándares y formales que llevan a mejorar los niveles de seguridad. Los procesos de seguridad de TI están coordinados con la función de seguridad de toda la organización. Los reportes de seguridad están ligados con los objetivos del negocio. La entrenamiento sobre seguridad se imparte tanto para TI como para el negocio. La entrenamiento sobre seguridad de TI se planea y se administra de manera que responda a las necesidades del negocio y a los perfiles de riesgo de seguridad. Los KGIs y KPIs ya están definidos pero no se miden aún. **5 Optimizado** La seguridad en TI es una responsabilidad conjunta del negocio y de la gerencia de TI y está integrada con los objetivos de seguridad del negocio en la corporación. Los requerimientos de seguridad de TI están definidos de forma clara, optimizados e incluidos en un plan de seguridad aprobado. Los usuarios y los clientes se responsabilizan cada vez más de definir requerimientos de seguridad, y las funciones de seguridad están integradas con las aplicaciones en la fase de diseño. Los incidentes de seguridad son atendidos de con procedimientos formales de respuesta soportados por herramientas automatizadas. Se llevan a cabo valoraciones de seguridad de forma periódica para evaluar la efectividad de la implementación del plan de seguridad. La información sobre amenazas y vulnerabilidades se recolecta y analiza de manera sistemática. Se recolectan e implementan de forma oportuna controles adecuados para mitigar riesgos. Se llevan a cabo pruebas de seguridad, análisis de causa-efecto e identificación pro-activa riesgos para la mejora continua de procesos. Los procesos de seguridad y la tecnología están integrados a lo largo de toda la organización. Los KGIs y KPIs para administración de seguridad son recopilados y comunicados. La gerencia utiliza los KGIs y KPIs para ajustar el plan de seguridad en un proceso de mejora continua

Criterio 18: Definir un plan de seguridad de la información
Las técnicas y procedimientos administrativos relacionados (ej. firewalls, aplicaciones de seguridad, segmentación de la red, detección de intrusos, ruta o medio de confianza, encriptación) son usados para garantizar el almacenamiento de datos y transporte dentro de la infraestructura técnica de la empresa, fluye desde y para la red y los dispositivos móviles (ej. smart phones, usb sticks). Las técnicas aplicadas están de acuerdo con la clasificación de los datos.

Subcriterio 18d. Seguridad de la red
Las técnicas y procedimientos de gestión relacionados (ej. firewalls, aplicaciones de seguridad, segmentación de red, detección de instrucción) son usadas para autorizar los accesos autorizados y flujos de control de la información a partir de las redes. Las mejores prácticas disponibles en esta área (ej. GovCert, ISO/IEC, ITSec) están consideradas.

Fortalezas
Se tienen contratado un outsourcing para seguridad de la red.
Se cuentan con personal certificado en seguridad.
Se tiene una politica de seguridad.
Se monitorea el trafico, y se restringe el acceso de acuerdo a las funciones.

Áreas de mejora

Documentar los procedimientos y directrices para la administración de todos los componentes críticos de red (por ejemplo, los routers de núcleo, DMZ, interruptores VPN).
Actualizar los cambios en la documentación para realizar un seguimiento en el historial del documento.

No existente	Inicial / Ad Hoc	Repetible pero Intuitivo	Definido	Administrado y Medible	Optimizado
			X		

Interpretación del Modelo de Madurez
DS5 Garantizar la Seguridad de los Sistemas
0 No Existente La organización no reconoce la necesidad de la seguridad para TI. Las responsabilidades y la rendición de cuentas no están asignadas para garantizar la seguridad. Las medidas para soportar la administrar la seguridad de TI no están implementadas. No hay reportes de seguridad de TI ni un proceso de respuesta para resolver brechas de seguridad de TI. Hay una total falta de procesos reconocibles de administración de seguridad de sistemas. **1 Inicial / Ad Hoc** La organización reconoce la necesidad de seguridad para TI. La conciencia de la necesidad de seguridad depende principalmente del individuo. La seguridad de TI se lleva a cabo de forma reactiva. No se mide la seguridad de TI. Las brechas de seguridad de TI ocasionan respuestas con acusaciones personales, debido a que las responsabilidades no son claras. Las respuestas a las brechas de seguridad de TI son impredecibles. **2 Repetible pero Intuitivo** Las responsabilidades y la rendición de cuentas sobre la seguridad, están asignadas a un coordinador de seguridad de TI, pero la autoridad gerencial del coordinador es limitada. La conciencia sobre la necesidad de la seguridad esta fraccionada y limitada. Aunque los sistemas producen información relevante respecto a la seguridad, ésta no se analiza. Los servicios de terceros pueden no cumplir con los requerimientos específicos de seguridad de la empresa. Las políticas de seguridad se han estado desarrollando, pero las herramientas y las habilidades son inadecuadas. Los reportes de la seguridad de TI son incompletos, engañosos o no aplicables. La entrenamiento sobre seguridad está disponible pero depende principalmente de la iniciativa del individuo. La seguridad de TI es vista primordialmente como responsabilidad y disciplina de TI, y el negocio no ve la seguridad de TI como parte de su propia disciplina. **3 Definido** Existe conciencia sobre la seguridad y ésta es promovida por la gerencia. Los procedimientos de seguridad de TI están definidos y alineados con la política de seguridad de TI. Las responsabilidades de la seguridad de TI están asignadas y entendidas, pero no continuamente implementadas. Existe un plan de seguridad de TI y existen soluciones de seguridad motivadas por un análisis de riesgo. Los reportes no contienen un enfoque claro de negocio. Se realizan pruebas de seguridad adecuadas (por ejemplo, pruebas contra intrusos). Existe entrenamiento en seguridad para TI y para el negocio, pero se programa y se comunica de manera informal. **4 Administrado y Medible** Las responsabilidades sobre la seguridad de TI son asignadas, administradas e implementadas de forma clara. Regularmente se lleva a cabo un análisis de impacto y de riesgos de seguridad. Las políticas y prácticas de seguridad se complementan con referencias de seguridad específicas. El contacto con métodos para promover la conciencia de la seguridad es obligatorio. La identificación, autenticación y autorización de los usuarios está estandarizada. La certificación en seguridad es buscada por parte del personal que es responsable de la auditoría y la administración de la seguridad. Las pruebas de seguridad se hacen utilizando procesos estándares y formales que llevan a mejorar los niveles de seguridad. Los procesos de seguridad de TI están coordinados con la función de seguridad de toda la organización. Los reportes de seguridad están ligados con los objetivos del negocio. La entrenamiento sobre seguridad se imparte tanto para TI como para el negocio. La entrenamiento sobre seguridad de TI se planea y se administra de manera que responda a las necesidades del negocio y a los perfiles de riesgo de seguridad. Los KGIs y KPIs ya están definidos pero no se miden aún. **5 Optimizado** La seguridad en TI es una responsabilidad conjunta del negocio y de la gerencia de TI y está integrada con los objetivos de seguridad del negocio en la corporación. Los requerimientos de seguridad de TI están definidos de forma clara, optimizados e incluidos en un plan de seguridad aprobado. Los usuarios y los clientes se responsabilizan cada vez más de definir requerimientos de seguridad, y las funciones de seguridad están integradas con las aplicaciones en la fase de diseño. Los incidentes de seguridad son atendidos de con procedimientos formales de respuesta soportados por herramientas automatizadas. Se llevan a cabo valoraciones de seguridad de forma periódica para evaluar la efectividad de la implementación del plan de seguridad. La información sobre amenazas y vulnerabilidades se recolecta y analiza de manera sistemática. Se recolectan e implementan de forma oportuna controles adecuados para mitigar riesgos. Se llevan a cabo pruebas de seguridad, análisis de causa-efecto e identificación pro-activa riesgos para la mejora continua de procesos. Los procesos de seguridad y la tecnología están integrados a lo largo de toda la organización. Los KGIs y KPIs para administración de seguridad son recopilados y comunicados. La gerencia utiliza los KGIs y KPIs para ajustar el plan de seguridad en un proceso de mejora continua

Criterio 18: Definir un plan de seguridad de la información
Las técnicas y procedimientos administrativos relacionados (ej. firewalls, aplicaciones de seguridad, segmentación de la red, detección de intrusos, ruta o medio de confianza, encriptación) son usados para garantizar el almacenamiento de datos y transporte dentro de la infraestructura técnica de la empresa, fluye desde y para la red y los dispositivos móviles (ej. smart phones, usb sticks). Las técnicas aplicadas están de acuerdo con la clasificación de los datos.

Subcriterio 18e. El intercambio de datos confidenciales
Los datos de las transacciones sensibles sólo se intercambian a través de una ruta de acceso de confianza o medios con controles, para proporcionar autenticidad del contenido, la prueba de la presentación, la prueba de la recepción y el no repudio de origen.

Fortalezas
Todos los datos son confidenciales, no se manejan aplicaciones por internet, su usan los enlaces dedicados.
Se ejecutan pocas transmisiones de información a otras organizaciones.

Áreas de mejora

Mejorar la seguridad de las transmisiones de datos fuera de la organización con cifrado de formato antes de la transmisión.
Clasificar los datos corporativos según el nivel de exposición y el esquema de clasificación (por ejemplo, confidencial y sensible).
Controlar el procesamiento de los datos sensibles a través de controles de aplicación que validen la transacción antes de la transmisión.

No existente	Inicial / Ad Hoc	Repetible pero Intuitivo	Definido	Administrado y Medible	Optimizado
		X			

Interpretación del Modelo de Madurez
DS5 Garantizar la Seguridad de los Sistemas
0 No Existente La organización no reconoce la necesidad de la seguridad para TI. Las responsabilidades y la rendición de cuentas no están asignadas para garantizar la seguridad. Las medidas para soportar la administrar la seguridad de TI no están implementadas. No hay reportes de seguridad de TI ni un proceso de respuesta para resolver brechas de seguridad de TI. Hay una total falta de procesos reconocibles de administración de seguridad de sistemas. **1 Inicial / Ad Hoc** La organización reconoce la necesidad de seguridad para TI. La conciencia de la necesidad de seguridad depende principalmente del individuo. La seguridad de TI se lleva a cabo de forma reactiva. No se mide la seguridad de TI. Las brechas de seguridad de TI ocasionan respuestas con acusaciones personales, debido a que las responsabilidades no son claras. Las respuestas a las brechas de seguridad de TI son impredecibles. **2 Repetible pero Intuitivo** Las responsabilidades y la rendición de cuentas sobre la seguridad, están asignadas a un coordinador de seguridad de TI, pero la autoridad gerencial del coordinador es limitada. La conciencia sobre la necesidad de la seguridad esta fraccionada y limitada. Aunque los sistemas producen información relevante respecto a la seguridad, ésta no se analiza. Los servicios de terceros pueden no cumplir con los requerimientos específicos de seguridad de la empresa. Las políticas de seguridad se han estado desarrollando, pero las herramientas y las habilidades son inadecuadas. Los reportes de la seguridad de TI son incompletos, engañosos o no aplicables. La entrenamiento sobre seguridad está disponible pero depende principalmente de la iniciativa del individuo. La seguridad de TI es vista primordialmente como responsabilidad y disciplina de TI, y el negocio no ve la seguridad de TI como parte de su propia disciplina. **3 Definido** Existe conciencia sobre la seguridad y ésta es promovida por la gerencia. Los procedimientos de seguridad de TI están definidos y alineados con la política de seguridad de TI. Las responsabilidades de la seguridad de TI están asignadas y entendidas, pero no continuamente implementadas. Existe un plan de seguridad de TI y existen soluciones de seguridad motivadas por un análisis de riesgo. Los reportes no contienen un enfoque claro de negocio. Se realizan pruebas de seguridad adecuadas (por ejemplo, pruebas contra intrusos). Existe entrenamiento en seguridad para TI y para el negocio, pero se programa y se comunica de manera informal. **4 Administrado y Medible** Las responsabilidades sobre la seguridad de TI son asignadas, administradas e implementadas de forma clara. Regularmente se lleva a cabo un análisis de impacto y de riesgos de seguridad. Las políticas y prácticas de seguridad se complementan con referencias de seguridad específicas. El contacto con métodos para promover la conciencia de la seguridad es obligatorio. La identificación, autenticación y autorización de los usuarios está estandarizada. La certificación en seguridad es buscada por parte del personal que es responsable de la auditoría y la administración de la seguridad. Las pruebas de seguridad se hacen utilizando procesos estándares y formales que llevan a mejorar los niveles de seguridad. Los procesos de seguridad de TI están coordinados con la función de seguridad de toda la organización. Los reportes de seguridad están ligados con los objetivos del negocio. La entrenamiento sobre seguridad se imparte tanto para TI como para el negocio. La entrenamiento sobre seguridad de TI se planea y se administra de manera que responda a las necesidades del negocio y a los perfiles de riesgo de seguridad. Los KGIs y KPIs ya están definidos pero no se miden aún. **5 Optimizado** La seguridad en TI es una responsabilidad conjunta del negocio y de la gerencia de TI y está integrada con los objetivos de seguridad del negocio en la corporación. Los requerimientos de seguridad de TI están definidos de forma clara, optimizados e incluidos en un plan de seguridad aprobado. Los usuarios y los clientes se responsabilizan cada vez más de definir requerimientos de seguridad, y las funciones de seguridad están integradas con las aplicaciones en la fase de diseño. Los incidentes de seguridad son atendidos de con procedimientos formales de respuesta soportados por herramientas automatizadas. Se llevan a cabo valoraciones de seguridad de forma periódica para evaluar la efectividad de la implementación del plan de seguridad. La información sobre amenazas y vulnerabilidades se recolecta y analiza de manera sistemática. Se recolectan e implementan de forma oportuna controles adecuados para mitigar riesgos. Se llevan a cabo pruebas de seguridad, análisis de causa-efecto e identificación pro-activa riesgos para la mejora continua de procesos. Los procesos de seguridad y la tecnología están integrados a lo largo de toda la organización. Los KGIs y KPIs para administración de seguridad son recopilados y comunicados. La gerencia utiliza los KGIs y KPIs para ajustar el plan de seguridad en un proceso de mejora continua

Criterio 19: Gestión de ataques malware **Las mediciones de prevención, detección y corrección, están en su lugar (especialmente los parches de seguridad al día y control de virus) a través de la organización para los sistemas de protección de la información y la tecnología del malware (ej. virus, gusanos, spyware, spam).**					
Subcriterio 19a. Prevención de software malicioso, detección y corrección Las mediciones de prevención, detección y corrección, están en su lugar (especialmente los parches de seguridad al día y control de virus) a través de la organización para los sistemas de protección de la información y la tecnología del malware (ej. virus, gusanos, spyware, spam).					
Fortalezas Se cuenta con software Kaspersky para la detección de virus, gusanos, spyware, spam. Se tiene una práctica de prevención de software malintencionado. Se tienen 154 licencias para su control. Se filtra el correo electrocnico **Áreas de mejora** Gestionar sobre las nuevas amenazas potenciales es revisada y evaluada periódicamente y, en caso necesario, actualizar manualmente los archivos de definición de virus. Revisar el proceso de filtrado para determinar la eficacia de funcionamiento.					
No existente	**Inicial / Ad Hoc**	**Repetible pero Intuitivo**	**Definido**	**Administrado y Medible**	**Optimizado**
				X	

Interpretación del Modelo de Madurez
DS5 Garantizar la Seguridad de los Sistemas
0 No Existente La organización no reconoce la necesidad de la seguridad para TI. Las responsabilidades y la rendición de cuentas no están asignadas para garantizar la seguridad. Las medidas para soportar la administrar la seguridad de TI no están implementadas. No hay reportes de seguridad de TI ni un proceso de respuesta para resolver brechas de seguridad de TI. Hay una total falta de procesos reconocibles de administración de seguridad de sistemas. **1 Inicial / Ad Hoc** La organización reconoce la necesidad de seguridad para TI. La conciencia de la necesidad de seguridad depende principalmente del individuo. La seguridad de TI se lleva a cabo de forma reactiva. No se mide la seguridad de TI. Las brechas de seguridad de TI ocasionan respuestas con acusaciones personales, debido a que las responsabilidades no son claras. Las respuestas a las brechas de seguridad de TI son impredecibles. **2 Repetible pero Intuitivo** Las responsabilidades y la rendición de cuentas sobre la seguridad, están asignadas a un coordinador de seguridad de TI, pero la autoridad gerencial del coordinador es limitada. La conciencia sobre la necesidad de la seguridad esta fraccionada y limitada. Aunque los sistemas producen información relevante respecto a la seguridad, ésta no se analiza. Los servicios de terceros pueden no cumplir con los requerimientos específicos de seguridad de la empresa. Las políticas de seguridad se han estado desarrollando, pero las herramientas y las habilidades son inadecuadas. Los reportes de la seguridad de TI son incompletos, engañosos o no aplicables. La entrenamiento sobre seguridad está disponible pero depende principalmente de la iniciativa del individuo. La seguridad de TI es vista primordialmente como responsabilidad y disciplina de TI, y el negocio no ve la seguridad de TI como parte de su propia disciplina. **3 Definido** Existe conciencia sobre la seguridad y ésta es promovida por la gerencia. Los procedimientos de seguridad de TI están definidos y alineados con la política de seguridad de TI. Las responsabilidades de la seguridad de TI están asignadas y entendidas, pero no continuamente implementadas. Existe un plan de seguridad de TI y existen soluciones de seguridad motivadas por un análisis de riesgo. Los reportes no contienen un enfoque claro de negocio. Se realizan pruebas de seguridad adecuadas (por ejemplo, pruebas contra intrusos). Existe entrenamiento en seguridad para TI y para el negocio, pero se programa y se comunica de manera informal. **4 Administrado y Medible** Las responsabilidades sobre la seguridad de TI son asignadas, administradas e implementadas de forma clara. Regularmente se lleva a cabo un análisis de impacto y de riesgos de seguridad. Las políticas y prácticas de seguridad se complementan con referencias de seguridad específicas. El contacto con métodos para promover la conciencia de la seguridad es obligatorio. La identificación, autenticación y autorización de los usuarios está estandarizada. La certificación en seguridad es buscada por parte del personal que es responsable de la auditoría y la administración de la seguridad. Las pruebas de seguridad se hacen utilizando procesos estándares y formales que llevan a mejorar los niveles de seguridad. Los procesos de seguridad de TI están coordinados con la función de seguridad de toda la organización. Los reportes de seguridad están ligados con los objetivos del negocio. La entrenamiento sobre seguridad se imparte tanto para TI como para el negocio. La entrenamiento sobre seguridad de TI se planea y se administra de manera que responda a las necesidades del negocio y a los perfiles de riesgo de seguridad. Los KGIs y KPIs ya están definidos pero no se miden aún. **5 Optimizado** La seguridad en TI es una responsabilidad conjunta del negocio y de la gerencia de TI y está integrada con los objetivos de seguridad del negocio en la corporación. Los requerimientos de seguridad de TI están definidos de forma clara, optimizados e incluidos en un plan de seguridad aprobado. Los usuarios y los clientes se responsabilizan cada vez más de definir requerimientos de seguridad, y las funciones de seguridad están integradas con las aplicaciones en la fase de diseño. Los incidentes de seguridad son atendidos de con procedimientos formales de respuesta soportados por herramientas automatizadas. Se llevan a cabo valoraciones de seguridad de forma periódica para evaluar la efectividad de la implementación del plan de seguridad. La información sobre amenazas y vulnerabilidades se recolecta y analiza de manera sistemática. Se recolectan e implementan de forma oportuna controles adecuados para mitigar riesgos. Se llevan a cabo pruebas de seguridad, análisis de causa-efecto e identificación pro-activa riesgos para la mejora continua de procesos. Los procesos de seguridad y la tecnología están integrados a lo largo de toda la organización. Los KGIs y KPIs para administración de seguridad son recopilados y comunicados. La gerencia utiliza los KGIs y KPIs para ajustar el plan de seguridad en un proceso de mejora continua

Criterio 20: Proteger los componentes de la infraestructura **La tecnología se endurece, la tecnología relacionada con la seguridad se hace resistente a la manipulación, y la documentación de seguridad no se da a conocer de forma innecesaria.**					
Subcriterio 20a. Protección de la tecnología de seguridad La tecnología se hace resistente a la manipulación, y la documentación de seguridad no se da a conocer de forma innecesaria.					
Fortalezas Cuentan con prácticas para la protección de la tecnología. En caso de violación a la seguridad, el sistema manda avisos automoticos al respondables via celular. Se cuentan con un dispositivo biometrico para al acceso controlado al site. Se cuantan con claves de usuarios para acceso a algunas aplicaciones. **Áreas de mejora** Documentar las políticas y procedimientos para hacer frente a las consecuencias de violación de la seguridad (en concreto para hacer frente a los controles de la gestión de configuración, acceso a las aplicaciones, seguridad de datos y requisitos de seguridad física). Inspeccionar los registros de control de la concesión y aprobación de acceso y registro de intentos fallidos, autorización de acceso a los archivos y / o datos sensibles, y acceso a las instalaciones. Confirmar que las características de diseño de seguridad facilitan reglas de contraseña (por ejemplo, longitud máxima, personajes, de caducidad, de reutilización). Verificar que el acceso es autorizado y debidamente aprobado. Inspeccionar los informes de seguridad generados a partir de las herramientas del sistema					
No existente	**Inicial / Ad Hoc**	**Repetible pero Intuitivo**	**Definido**	**Administrado y Medible**	**Optimizado**
				X	

Interpretación del Modelo de Madurez
DS5 Garantizar la Seguridad de los Sistemas
0 No Existente La organización no reconoce la necesidad de la seguridad para TI. Las responsabilidades y la rendición de cuentas no están asignadas para garantizar la seguridad. Las medidas para soportar la administrar la seguridad de TI no están implementadas. No hay reportes de seguridad de TI ni un proceso de respuesta para resolver brechas de seguridad de TI. Hay una total falta de procesos reconocibles de administración de seguridad de sistemas. **1 Inicial / Ad Hoc** La organización reconoce la necesidad de seguridad para TI. La conciencia de la necesidad de seguridad depende principalmente del individuo. La seguridad de TI se lleva a cabo de forma reactiva. No se mide la seguridad de TI. Las brechas de seguridad de TI ocasionan respuestas con acusaciones personales, debido a que las responsabilidades no son claras. Las respuestas a las brechas de seguridad de TI son impredecibles. **2 Repetible pero Intuitivo** Las responsabilidades y la rendición de cuentas sobre la seguridad, están asignadas a un coordinador de seguridad de TI, pero la autoridad gerencial del coordinador es limitada. La conciencia sobre la necesidad de la seguridad esta fraccionada y limitada. Aunque los sistemas producen información relevante respecto a la seguridad, ésta no se analiza. Los servicios de terceros pueden no cumplir con los requerimientos específicos de seguridad de la empresa. Las políticas de seguridad se han estado desarrollando, pero las herramientas y las habilidades son inadecuadas. Los reportes de la seguridad de TI son incompletos, engañosos o no aplicables. La entrenamiento sobre seguridad está disponible pero depende principalmente de la iniciativa del individuo. La seguridad de TI es vista primordialmente como responsabilidad y disciplina de TI, y el negocio no ve la seguridad de TI como parte de su propia disciplina. **3 Definido** Existe conciencia sobre la seguridad y ésta es promovida por la gerencia. Los procedimientos de seguridad de TI están definidos y alineados con la política de seguridad de TI. Las responsabilidades de la seguridad de TI están asignadas y entendidas, pero no continuamente implementadas. Existe un plan de seguridad de TI y existen soluciones de seguridad motivadas por un análisis de riesgo. Los reportes no contienen un enfoque claro de negocio. Se realizan pruebas de seguridad adecuadas (por ejemplo, pruebas contra intrusos). Existe entrenamiento en seguridad para TI y para el negocio, pero se programa y se comunica de manera informal. **4 Administrado y Medible** Las responsabilidades sobre la seguridad de TI son asignadas, administradas e implementadas de forma clara. Regularmente se lleva a cabo un análisis de impacto y de riesgos de seguridad. Las políticas y prácticas de seguridad se complementan con referencias de seguridad específicas. El contacto con métodos para promover la conciencia de la seguridad es obligatorio. La identificación, autenticación y autorización de los usuarios está estandarizada. La certificación en seguridad es buscada por parte del personal que es responsable de la auditoría y la administración de la seguridad. Las pruebas de seguridad se hacen utilizando procesos estándares y formales que llevan a mejorar los niveles de seguridad. Los procesos de seguridad de TI están coordinados con la función de seguridad de toda la organización. Los reportes de seguridad están ligados con los objetivos del negocio. La entrenamiento sobre seguridad se imparte tanto para TI como para el negocio. La entrenamiento sobre seguridad de TI se planea y se administra de manera que responda a las necesidades del negocio y a los perfiles de riesgo de seguridad. Los KGIs y KPIs ya están definidos pero no se miden aún. **5 Optimizado** La seguridad en TI es una responsabilidad conjunta del negocio y de la gerencia de TI y está integrada con los objetivos de seguridad del negocio en la corporación. Los requerimientos de seguridad de TI están definidos de forma clara, optimizados e incluidos en un plan de seguridad aprobado. Los usuarios y los clientes se responsabilizan cada vez más de definir requerimientos de seguridad, y las funciones de seguridad están integradas con las aplicaciones en la fase de diseño. Los incidentes de seguridad son atendidos de con procedimientos formales de respuesta soportados por herramientas automatizadas. Se llevan a cabo valoraciones de seguridad de forma periódica para evaluar la efectividad de la implementación del plan de seguridad. La información sobre amenazas y vulnerabilidades se recolecta y analiza de manera sistemática. Se recolectan e implementan de forma oportuna controles adecuados para mitigar riesgos. Se llevan a cabo pruebas de seguridad, análisis de causa-efecto e identificación pro-activa riesgos para la mejora continua de procesos. Los procesos de seguridad y la tecnología están integrados a lo largo de toda la organización. Los KGIs y KPIs para administración de seguridad son recopilados y comunicados. La gerencia utiliza los KGIs y KPIs para ajustar el plan de seguridad en un proceso de mejora continua

Criterio 21: Seguridad Física **Las medidas de seguridad física son definidas e implementadas en línea con el negocio y los requisitos de clasificación para instalaciones seguras (ej. edificios, fuente de alimentación) y los activos físicos y de información. La seguridad física debe ser capaz de prevenir de manera eficaz, la detección y mitigación de los riesgos relacionados con los desastres y accidentes (por ejemplo, la naturaleza humana, vandalismo, terrorismo).**					
Subcriterio 21a. Medición de la seguridad física Las mediciones de seguridad están definidas e implementadas en línea con los requisitos del negocio para asegurar la ubicación y activos físicos. Las mediciones de seguridad debe ser capaz de prevenir eficazmente, detectar y mitigar los riegos relacionados al robo, temperatura, fuego, humo, agua, vibración, terror, vandalismo, cortes de energía, químicos o explosivos.					
Fortalezas Se cuenta con un área segura para el site. Tiene un acceso con dispositivo biometrico. Se cuentan con protocolos básicos en caso de siniestro natural. Cuentan con un respaldo de al menos 21 minutos. Tienen el cableado identificado de agua, electricidad, alcantarillado y red. Se tiene señaletica para el SITE y otras áreas relevantes. **Áreas de mejora** Documentar un proceso para el registro, control, gestión, elaboración de informes y resolución de incidentes de seguridad física, en línea con el proceso general de gestión de incidentes de TI. Vigilar sitios particularmente sensibles se comprueban con frecuencia (incluyendo fines de semana y días festivos) por personal de seguridad.					
No existente	**Inicial / Ad Hoc**	**Repetible pero Intuitivo**	**Definido**	**Administrado y Medible**	**Optimizado**
				X	

Interpretación del Modelo de Madurez
DS12 Administración del Ambiente Físico
0 No Existente No hay conciencia sobre la necesidad de proteger las instalaciones o la inversión en recursos de cómputo. Los factores ambientales tales como protección contra fuego, polvo, tierra y exceso de calor y humedad no se controlan ni se monitorean. **1 Inicial / Ad Hoc** La organización reconoce la necesidad de contar con un ambiente físico que proteja los recursos y el personal contra peligros naturales y causados por el hombre. La administración de instalaciones y de equipo depende de las habilidades de individuos clave. El personal se puede mover dentro de las instalaciones sin restricción. La gerencia no monitorea los controles ambientales de las instalaciones o el movimiento del personal. **2 Repetible pero Intuitivo** Los controles ambientales se implementan y monitorean por parte del personal de operaciones. La seguridad física es un proceso informal, realizado por un pequeño grupo de empleados con alto nivel de preocupación por asegurar las instalaciones físicas. Los procedimientos de mantenimiento de instalaciones no están bien documentados y dependen de las buenas prácticas de unos cuantos individuos. Las metas de seguridad física no se basan en estándares formales y la gerencia no se asegura de que se cumplan los objetivos de seguridad. **3 Definido** Se entiende y acepta a lo largo de toda la organización la necesidad de mantener un ambiente de cómputo controlado. Los controles ambientales, el mantenimiento preventivo y la seguridad física cuentan con presupuesto autorizado y rastreado por la gerencia. Se aplican restricciones de acceso, permitiendo el ingreso a las instalaciones de cómputo sólo al personal aprobado. Los visitantes se registran y acompañan dependiendo del individuo. Las instalaciones físicas mantienen un perfil bajo y no son reconocibles de manera fácil. Las autoridades civiles monitorean al cumplimiento con los reglamentos de salud y seguridad. Los riesgos se aseguran con el mínimo esfuerzo para optimizar los costos del seguro. **4 Administrado y Medible** Se establecen criterios formales y estandarizados para definir los términos de un acuerdo, incluyendo alcance del trabajo, servicios/entregables a suministrar, suposiciones, cronograma, costos, acuerdos de facturación y responsabilidades. Se asignan las responsabilidades para la administración del contrato y del proveedor. Las aptitudes, capacidades y riesgos del proveedor son verificadas de forma continua. Los requerimientos del servicio están definidos y alineados con los objetivos del negocio. Existe un proceso para comparar el desempeño contra los términos contractuales, lo cual proporciona información para evaluar los servicios actuales y futuros del tercero. Se utilizan modelos de fijación de precios de transferencia en el proceso de adquisición. Todas las partes involucradas tienen conocimiento de las expectativas del servicio, de los costos y de las etapas. Se acordaron los KPIs y KGIs para la supervisión del servicio. **5 Optimizado** Hay un plan acordado a largo plazo para las instalaciones requeridas para soportar el ambiente cómputo de la organización. Los estándares están definidos para todas las instalaciones, incluyendo la selección del centro de cómputo, construcción, vigilancia, seguridad personal, sistemas eléctricos y mecánicos, protección contra factores ambientales (por ejemplo, fuego, rayos, inundaciones, etc.). Se clasifican y se hacen inventarios de todas las instalaciones de acuerdo con el proceso continuo de administración de riesgos de la organización. El acceso es monitoreado continuamente y controlado estrictamente con base en las necesidades del trabajo, los visitantes son acompañados en todo momento. El ambiente se monitorea y controla por medio de equipo especializado y las salas de equipo funcionan sin operadores humanos. Los KPIs y KGIs se miden regularmente. Los programas de mantenimiento preventivo fomentan un estricto apego a los horarios y se aplican pruebas regulares a los equipos sensibles. Las estrategias de instalaciones y de estándares están alineadas con las metas de disponibilidad de los servicios de TI y están integradas con la administración de crisis y con la planeación de continuidad del negocio. La gerencia revisa y optimiza las instalaciones utilizando los KPIs y KGIs de manera continua, capitalizando oportunidades para mejorar la contribución al negocio.

Criterio 21: Seguridad Física

Las medidas de seguridad física son definidas e implementadas en línea con el negocio y los requisitos de clasificación para instalaciones seguras (ej. edificios, fuente de alimentación) y los activos físicos y de información. La seguridad física debe ser capaz de prevenir de manera eficaz, la detección y mitigación de los riesgos relacionados con los desastres y accidentes (por ejemplo, la naturaleza humana, vandalismo, terrorismo).

Subcriterio 21b. Acceso físico

Los procedimientos están definidos e implementados para conceder, limitar y revocar el acceso a los locales, edificios y áreas de acuerdo a las necesidades del negocio, incluyendo las emergencias. El acceso a las instalaciones, edificios y áreas que pueden ser justificadas, autorizadas, logueadas y monitoreadas. Esto se aplica a todas las personas que entran en el local, incluido el personal, el personal temporal, clientes, proveedores, visitantes o cualquier otro tercero.

Fortalezas

Se cuenta con vigilancia externa desde le primer acceso al IEEG.
Se tiene un acceso restringido para el acceso a los servidores.
El acceso al site esta restringido por un sistema biometrico.

Áreas de mejora

Documentar procedimientos para garantizar que los perfiles de acceso siguen siendo actuales.
Verifique que el acceso a los sitios de TI (salas de servidores, edificios, áreas o zonas) se basa en la función y las responsabilidades del trabajo.
Incorporar una política a todo el personal para mostrar en todo momento una identificación visible y evita la emisión de tarjetas de identidad o insignias sin la debida autorización.
Exigir a los visitantes a ser escoltados en todo momento por un miembro del grupo de operaciones de TI, mientras este en el lugar, los individuos que no llevan identificación apropiada son señalados por el personal de seguridad.
Entrenar al personal de seguridad para algun siniestro y guardar los registros de capacitación.

No existente	Inicial / Ad Hoc	Repetible pero Intuitivo	Definido	Administrado y Medible	Optimizado
			X		

Interpretación del Modelo de Madurez
DS12 Administración del Ambiente Físico
0 No Existente No hay conciencia sobre la necesidad de proteger las instalaciones o la inversión en recursos de cómputo. Los factores ambientales tales como protección contra fuego, polvo, tierra y exceso de calor y humedad no se controlan ni se monitorean. **1 Inicial / Ad Hoc** La organización reconoce la necesidad de contar con un ambiente físico que proteja los recursos y el personal contra peligros naturales y causados por el hombre. La administración de instalaciones y de equipo depende de las habilidades de individuos clave. El personal se puede mover dentro de las instalaciones sin restricción. La gerencia no monitorea los controles ambientales de las instalaciones o el movimiento del personal. **2 Repetible pero Intuitivo** Los controles ambientales se implementan y monitorean por parte del personal de operaciones. La seguridad física es un proceso informal, realizado por un pequeño grupo de empleados con alto nivel de preocupación por asegurar las instalaciones físicas. Los procedimientos de mantenimiento de instalaciones no están bien documentados y dependen de las buenas prácticas de unos cuantos individuos. Las metas de seguridad física no se basan en estándares formales y la gerencia no se asegura de que se cumplan los objetivos de seguridad. **3 Definido** Se entiende y acepta a lo largo de toda la organización la necesidad de mantener un ambiente de cómputo controlado. Los controles ambientales, el mantenimiento preventivo y la seguridad física cuentan con presupuesto autorizado y rastreado por la gerencia. Se aplican restricciones de acceso, permitiendo el ingreso a las instalaciones de cómputo sólo al personal aprobado. Los visitantes se registran y acompañan dependiendo del individuo. Las instalaciones físicas mantienen un perfil bajo y no son reconocibles de manera fácil. Las autoridades civiles monitorean al cumplimiento con los reglamentos de salud y seguridad. Los riesgos se aseguran con el mínimo esfuerzo para optimizar los costos del seguro. **4 Administrado y Medible** Se establecen criterios formales y estandarizados para definir los términos de un acuerdo, incluyendo alcance del trabajo, servicios/entregables a suministrar, suposiciones, cronograma, costos, acuerdos de facturación y responsabilidades. Se asignan las responsabilidades para la administración del contrato y del proveedor. Las aptitudes, capacidades y riesgos del proveedor son verificadas de forma continua. Los requerimientos del servicio están definidos y alineados con los objetivos del negocio. Existe un proceso para comparar el desempeño contra los términos contractuales, lo cual proporciona información para evaluar los servicios actuales y futuros del tercero. Se utilizan modelos de fijación de precios de transferencia en el proceso de adquisición. Todas las partes involucradas tienen conocimiento de las expectativas del servicio, de los costos y de las etapas. Se acordaron los KPIs y KGIs para la supervisión del servicio. **5 Optimizado** Hay un plan acordado a largo plazo para las instalaciones requeridas para soportar el ambiente cómputo de la organización. Los estándares están definidos para todas las instalaciones, incluyendo la selección del centro de cómputo, construcción, vigilancia, seguridad personal, sistemas eléctricos y mecánicos, protección contra factores ambientales (por ejemplo, fuego, rayos, inundaciones, etc.). Se clasifican y se hacen inventarios de todas las instalaciones de acuerdo con el proceso continuo de administración de riesgos de la organización. El acceso es monitoreado continuamente y controlado estrictamente con base en las necesidades del trabajo, los visitantes son acompañados en todo momento. El ambiente se monitorea y controla por medio de equipo especializado y las salas de equipo funcionan sin operadores humanos. Los KPIs y KGIs se miden regularmente. Los programas de mantenimiento preventivo fomentan un estricto apego a los horarios y se aplican pruebas regulares a los equipos sensibles. Las estrategias de instalaciones y de estándares están alineadas con las metas de disponibilidad de los servicios de TI y están integradas con la administración de crisis y con la planeación de continuidad del negocio. La gerencia revisa y optimiza las instalaciones utilizando los KPIs y KGIs de manera continua, capitalizando oportunidades para mejorar la contribución al negocio.

Control de versiones

Versión	Preparado por	Revisado por	Fecha
1.0	Ana Jimenez Mayra Uscanga	Carlos Carballo	17-May-2015
1.1	Carlos Carballo	Ana Jimenez Mayra Uscanga	18-May-2015
1.2	Ana Jimenez Mayra Uscanga	Carlos Carballo	18-May-2015

Aprobaciones

En la siguiente lista están incluidos los responsables del proyecto por parte del Instituto Electoral del Estado de Guanajuato (IEEG) a través de la Unidad Técnica de Sistemas de Información y Telecomunicaciones (UTSIT), los cuales dan fe de lo descrito en las páginas anteriores y que con su firma aprueban los resultados de auditoría en madurez TI.

Number	Fecha	Firma
Ing. Erick Carrillo Werring	18-May-2015	
Ing. Concepción Vázquez López	18-May-2015	
Lic. Evaristo Gama Guerrero	18-May-2015	

Nota: Cualquier cambio al entregable posterior a la fecha en que se firma la aprobación de este documento, tendrá que ser considerado a través de un proceso de “Cambio de requerimientos” definido por la Universidad de Guanajuato.